



Cours: Sécurité Informatique et Techniques Cryptographiques

Année Académique 2024-2025

Option: GI

M.MANGA JOSEPH



PLAN DU COURS

Première partie : Sécurité informatique

Introduction

Chapitre 1: Généralités sur la sécurité informatique

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

Chapitre 3 : Système de protection informatique

Chapitre 4 : Administration d'accès aux données informatiques

Deuxième partie : Techniques Cryptographiques

Chapitre 1 : Introduction et historique

Chapitre 2 : Cryptographie symétrique

Chapitre 3 : Cryptographie asymétrique

Chapitre 4 : cryptographie quantique

TD : Fiche d'exercices de cours

TP: détection de faille de sécurité, mise en place d'une protection informatique

Première partie : Sécurité Informatique

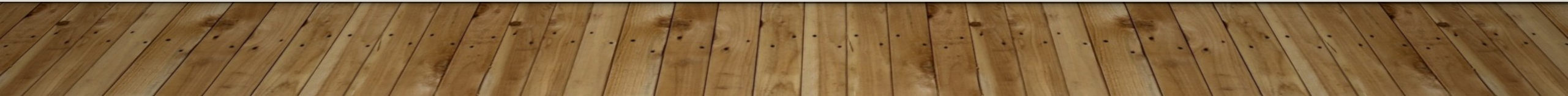
3

Introduction

L'univers des systèmes d'information composé de réseaux et de systèmes informatiques prend un rôle et une place chaque jour plus important dans les entreprises.

Cependant, l'actualité présentée par les médias nous démontre que le système d'information est vulnérable et qu'il peut subir des piratages, des attaques (virus, hackers...), des pertes de données, des sinistres. Il est donc indispensable pour les entreprises de savoir définir et de garantir la sécurité de ses ressources informatiques.

La sécurité des systèmes est un moyen de protéger dans un sens large le système d'information ou de minimiser les risques encourus par l'entreprise dans l'usage de l'outil informatique.



Première partie : Sécurité Informatique

4

Introduction

Les nécessités de sécuriser son système d'information

Certains facteurs peuvent apparaître de l'ordre de l'évidence comme la nécessité de protéger une partie opérationnelle de l'entreprise. Toutefois, l'ensemble des menaces n'est pourtant pas toujours bien identifié.

Par contre, d'autres sont souvent méconnues comme les obligations et responsabilités légales des dirigeants d'entreprise dans l'exploitation et la maîtrise de leur système d'information.

Ces exigences impliquent la mise en place d'une protection des systèmes sous la forme d'une politique de sécurité avec :

- l'élaboration de règles et procédures,
- la définition des actions à entreprendre et des personnes responsables,
- la détermination du périmètre concerné.

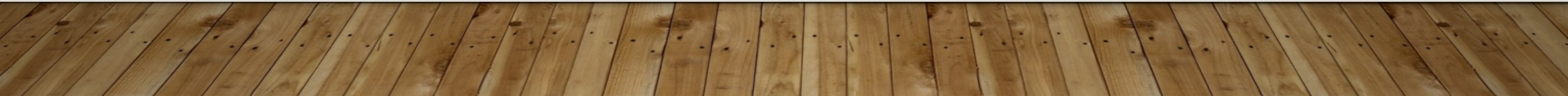


Première partie : Sécurité Informatique

5

Introduction

Ce périmètre comprend à la fois les données aussi bien sous forme électronique que papier (fichiers, messages...), les transactions dans les réseaux, les applications logicielles et bases de données. Il ne faut pas oublier l'aspect continuité des services du traitement de l'information et les plans de reprise d'activité après sinistre.



Première partie : Sécurité Informatique

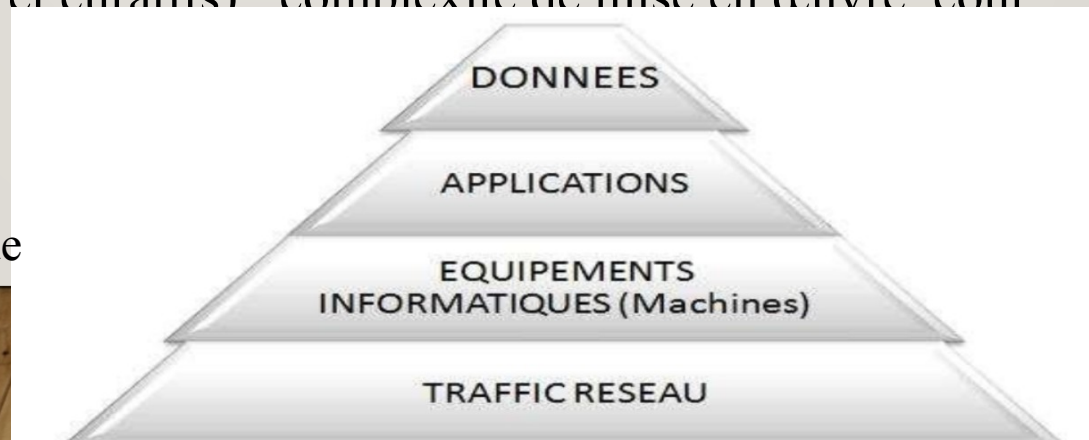
6

Introduction

La sécurité informatique s'intéresse à la protection contre les risques liés à l'informatique ; elle doit prendre en compte :

- ↳ les éléments à protéger : matériels, données, utilisateurs ;
- ↳ leur vulnérabilité ;
- ↳ leur sensibilité : quantité de travail impliqué, confidentialité...
- ↳ les menaces qui pèsent sur eux
- ↳ les moyens d'y faire face (préventifs et curatifs) : complexité de mise en œuvre, coût

Figure: Niveaux de la sécurité informatique

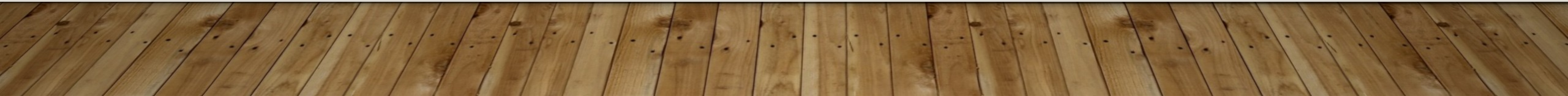


Première partie : Sécurité Informatique

7 Chapitre 1:Généralités sur la sécurité informatique

1.1 Définition

La sécurité informatique c'est l'ensemble des moyens mis en œuvre pour réduire la vulnérabilité d'un système contre les menaces accidentelles ou intentionnelles. L'objectif de la sécurité informatique est d'assurer que les ressources matérielles et/ou logicielles d'un parc informatique sont uniquement utilisées dans le cadre prévu et par des personnes autorisées.



Première partie : Sécurité Informatique

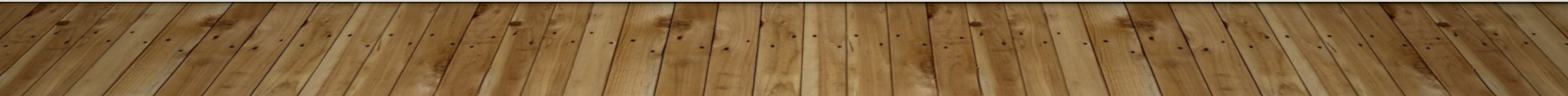
8 Chapitre 1:Généralités sur la sécurité informatique

1.1 Définition

Il convient d'identifier les exigences fondamentales en sécurité informatique, qui caractérisent ce à quoi s'attendent les utilisateurs de systèmes informatiques au regard de la sécurité :

↳ **La confidentialité** - Seules les personnes habilitées doivent avoir accès aux données. Toute interception ne doit pas être en mesure d'aboutir, les données doivent être cryptées, seuls les acteurs de la transaction possèdent la clé de compréhension.

↳ **L'intégrité** - Il faut garantir à chaque instant que les données qui circulent sont bien celles que l'on croit, qu'il n'y a pas eu d'altération (volontaire ou non) au cours de la communication. L'intégrité des données doit valider l'intégralité des données, leur précision, l'authenticité et la validité.



Première partie : Sécurité Informatique

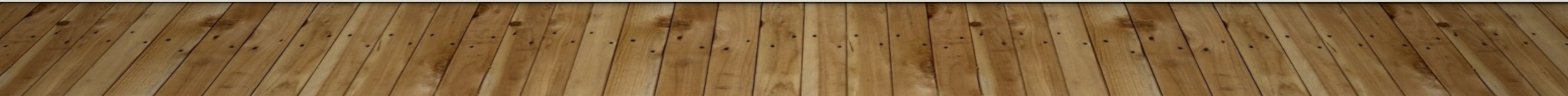
9 Chapitre 1:Généralités sur la sécurité informatique

1.1 Définition

↻ **La disponibilité** - Il faut s'assurer du bon fonctionnement du système, de l'accès à un service et aux ressources à n'importe quel moment. La disponibilité d'un équipement se mesure en divisant la durée durant laquelle cet équipement est opérationnel par la durée durant laquelle il aurait dû être opérationnel.

↻ **La non-répudiation** - Une transaction ne peut être niée par aucun des correspondants. La non-répudiation de l'origine et de la réception des données prouve que les données ont bien été reçues. Cela se fait par le biais de certificats numériques grâce à une clé privée.

↻ **L'authentification** - Elle limite l'accès aux personnes autorisées. Il faut s'assurer de l'identité d'un utilisateur avant l'échange de données.



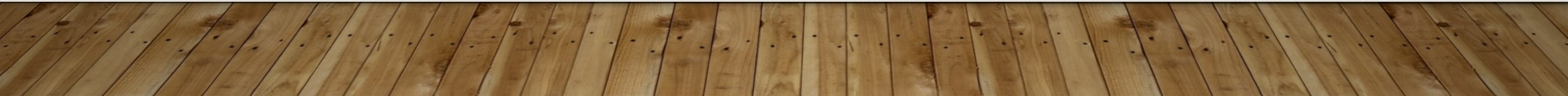
Première partie : Sécurité Informatique

10 Chapitre 1: Généralités sur la sécurité informatique

1.1 Définition

En sécurité informatique, on mesure la sécurité d'un système entier à la sécurité du maillon le plus faible.

Ainsi, si tout un système est sécurisé techniquement mais que le facteur humain, souvent mis en cause, est défaillant, c'est toute la sécurité du système qui est remise en cause.

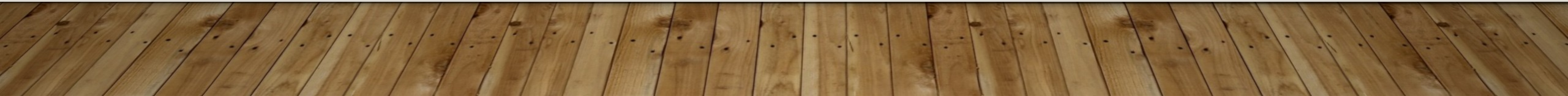


Première partie : Sécurité Informatique

11 Chapitre 1:Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

Les coûts d'un problème informatique peuvent être élevés et ceux de la sécurité le sont aussi. Il est nécessaire de réaliser une analyse de risque en prenant soin d'identifier les problèmes potentiels avec les solutions avec les coûts associés. L'ensemble des solutions retenues doit être organisé sous forme d'une politique de sécurité cohérente, fonction du niveau de tolérance au risque. On obtient ainsi la liste de ce qui doit être protégé. Il faut cependant prendre conscience que les principaux risques restent : câble arraché, coupure secteur, crash disque, mauvais profil utilisateur ...



Première partie : Sécurité Informatique

12 Chapitre 1: Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

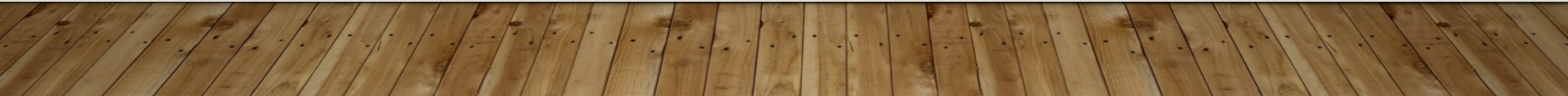
Voici quelques éléments pouvant servir de base à une étude de risque :

↳ Quelle est la valeur des équipements, des logiciels et surtout des informations ?

↳ Quel est le coût et le délai de remplacement ?

↳ Faire une analyse de vulnérabilité des informations contenues sur les ordinateurs en réseau (programmes d'analyse des paquets, logs...).

↳ Quel serait l'impact sur la clientèle d'une information publique concernant des intrusions sur les ordinateurs de la société ?



Première partie : Sécurité Informatique

13

Chapitre 1:Généralités sur la sécurité informatique

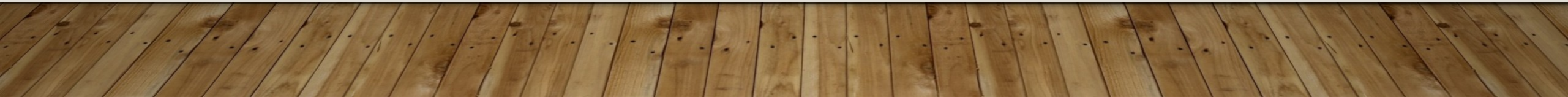
1.2 Etudes des risques liés à la sécurité informatique

Définition

L'actif: C'est la partie d'un bien qui compose le patrimoine et présentant de la valeur pour l'entreprise. Il peut représenter : les équipements, les matériels, les logiciels, les brevets, les processus et activités métier...

La vulnérabilité est une faille dans les actifs, les contrôles de sécurité technique ou les procédures d'exploitation ou d'administration utilisées dans l'entreprise. Elle consiste, en général, en une faiblesse dans la protection du système, sous la forme d'une menace qui peut être exploitée pour intervenir sur l'ensemble du système ou d'un intrus qui s'attaque aux actifs.

Une menace est quelqu'un ou quelque chose qui peut exploiter une vulnérabilité pour obtenir, modifier ou empêcher l'accès à un actif ou encore le compromettre. Elle existe en corrélation avec des vulnérabilités. Il peut y avoir aussi plusieurs menaces pour chaque vulnérabilité. La connaissance des différents types de menaces peut aider dans la détermination de leur dangerosité et des contrôles adaptés permettant de réduire leur impact potentiel.



Première partie : Sécurité Informatique

14 Chapitre 1: Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

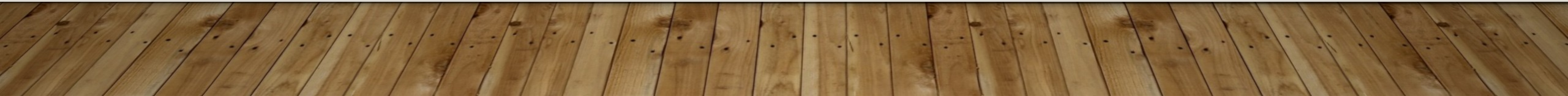
Définition

La menace est une source effective d'incidents pouvant entraîner des effets indésirables et graves sur un actif ou un ensemble d'actifs, l'entreprise par elle-même.

- origine ou source,
- type,
- motivation, action.

Elles peuvent être :

- délibérées (vol, fraude, virus, hacking, incendie, attentat, sabotage, interception, divulgation ou altération de données...),
- naturelles ou environnementales (tremblement de terre, éruption volcanique, inondation, coupure de courant, incendie...),
- accidentelles (erreurs d'utilisation, omissions...),
- dues à des pannes techniques : mauvais fonctionnement d'un équipement, d'un logiciel.



Première partie : Sécurité Informatique

15 Chapitre 1: Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

Définition

Le risque est la possibilité qu'une chose critique apparaisse. Son évaluation permet d'établir des actions pour réduire et maintenir la menace à un niveau raisonnable et acceptable.

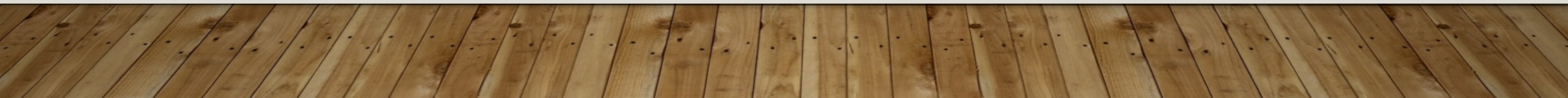
Les risques peuvent être qualifiés selon leurs origines (externes ou internes).

❑ Les risques externes :

- Les attaques non ciblées. Toute entreprise est concernée par l'agression de virus ou d'attaques globales sur le réseau (déni de service).
- Les attaques ciblées. Les risques physiques (vol ou destruction de matériel) ou logiques (accès d'intrus)

❑ Les risques internes :

- Ils sont plus difficiles à appréhender car ils concernent des ressources internes à l'entreprise.



Première partie : Sécurité Informatique

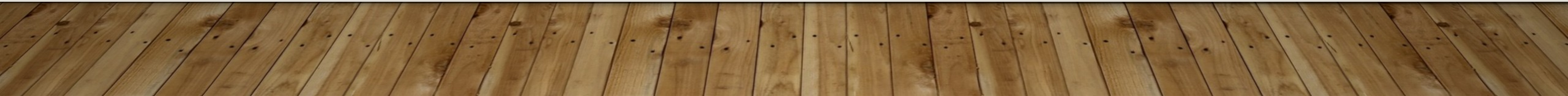
16 Chapitre 1: Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

Définition

Il existe des facteurs aggravants de risque liés au métier de l'entreprise :

- Les postes nomades : ordinateurs portables, assistants numériques de poche, téléphones évolués portables (Smart phones).
- Des infrastructures, services et applications mal protégés.
- Un plan de sauvegarde ou de secours informatique inexistant ou non opérationnel.



Première partie : Sécurité Informatique

17 Chapitre 1: Généralités sur la sécurité informatique

1.2 Etudes des risques liés à la sécurité informatique

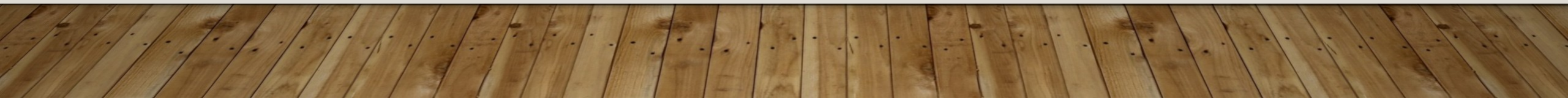
Définition

L'impact d'un risque

Il peut être exprimé par les conséquences ou les préjudices affectant un actif : atteinte à l'intégrité, perte de disponibilité, atteinte à l'image de marque, perte de chiffre d'affaires.

Les impacts peuvent être évalués selon les critères suivants :

- financier (frais de remise en état ou de restauration, pertes d'exploitation...),
- juridique et légal,
- réputation et image de l'entreprise (par rapport à l'extérieur et au personnel),
- expertise et savoir faire reconnus de l'entreprise.

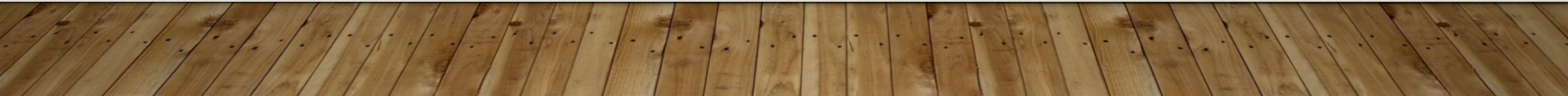


Première partie : Sécurité Informatique

18 Chapitre 1:Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

En sécurité informatique, il existe deux grands types des risques à savoir : les risques humains et les risques matériels.



Première partie : Sécurité Informatique

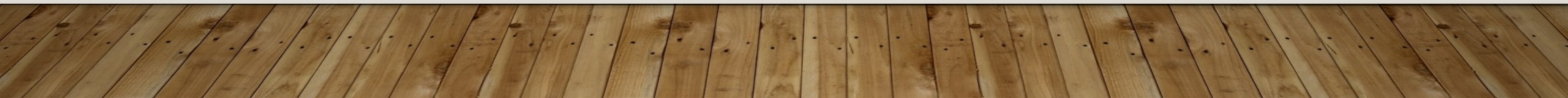
19 Chapitre 1: Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

1.2.1.1 Risques humains

Ce sont les plus importants, même s'ils sont le plus souvent ignorés ou minimisés. Ils concernent les utilisateurs mais également les informaticiens eux-mêmes. On peut citer :

- ↳ La maladresse – commettre des erreurs ou exécuter de traitement non souhaité, ou effacer involontairement des données ou des programmes ; etc.
- ↳ L'inconscience et l'ignorance – introduire des programmes malveillants sans le savoir (par exemple lors de la réception du courrier). Des nombreux utilisateurs d'outils informatiques sont encore inconscients ou ignorants des risques qu'ils font courir aux systèmes qu'ils utilisent. Réaliser des manipulations inconsidérées (autant avec des logiciels qu'avec du matériel) ;



Première partie : Sécurité Informatique

20 Chapitre 1:Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

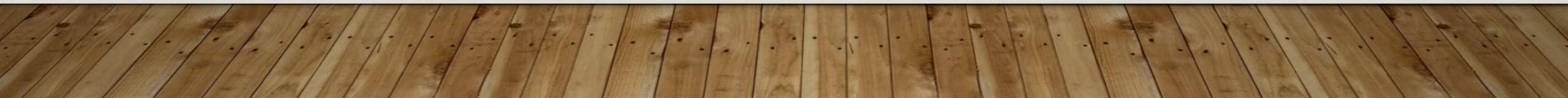
1.2.1.1 Risques humains

↻ La malveillance – ces dernières années, il est impossible d'ignorer les différents problèmes de virus et des vers. Certains utilisateurs peuvent volontairement mettre en péril le système d'informations, en y introduisant en connaissance de cause de virus ou en introduisant volontairement des mauvaises informations dans une base des données. On parle même de la « cybercriminalité » ;

↻ L'ingénierie sociale – une méthode pour obtenir d'une personne des informations confidentielles, que l'on n'est pas normalement autorisé à obtenir, en vue de les exploiter à d'autres fins. Elle consiste à :

--Se faire passer pour quelqu'un que l'on n'est pas (en général un administrateur réseau) ;

--Demander des informations personnelles (nom de connexion, mot de passe, données confidentielles, etc.) en intervenant un quelconque prétexte (problème dans le réseau, modification de celui-ci, etc.) ;



Première partie : Sécurité Informatique

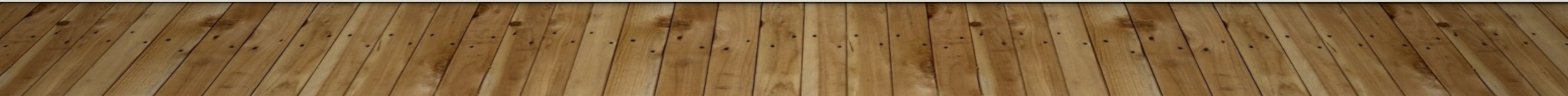
21 Chapitre 1: Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

1.2.1.1 Risques humains

Elle peut se faire soit au moyen d'une simple communication téléphonique ; soit par mail, soit en se déplaçant directement sur place.

↳ L'espionnage – surtout industriel, emploie les mêmes moyens, ainsi que bien d'autres, pour obtenir des informations sur des activités concurrentes, procédés de fabrication, projets en cours, futurs produits, politique de prix, clients et prospects, etc.



Première partie : Sécurité Informatique

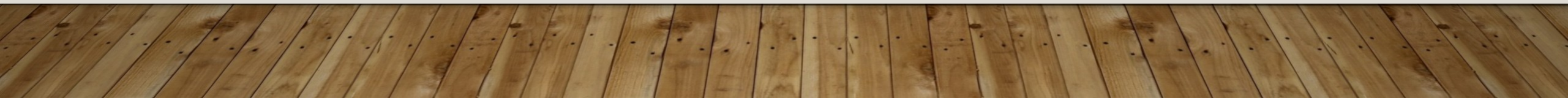
22 Chapitre 1: Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

1.2.1.2 Risques Matériels

Ils sont liés aux défauts et pannes inévitables que connaissent tous les systèmes matériels et logiciels. Ces incidents sont plus ou moins fréquents selon les soins apportés lors de la fabrication et de l'application des procédures de tests effectués avant que les ordinateurs et les programmes ne soient mis en service. Certaines de ces pannes ont des causes indirectes, voire très indirectes, donc difficiles à prévoir. On peut citer :

↳ **Les incidents liés au matériel** – la plupart des composants électroniques modernes produits en grandes séries, peuvent comporter des défauts de fabrication. Ils finissent un jour ou l'autre par tomber en panne. Certains de ces pannes sont assez difficiles à déceler car intermittentes ou rares. Parfois, elles relèvent d'une erreur de conception.



Première partie : Sécurité Informatique

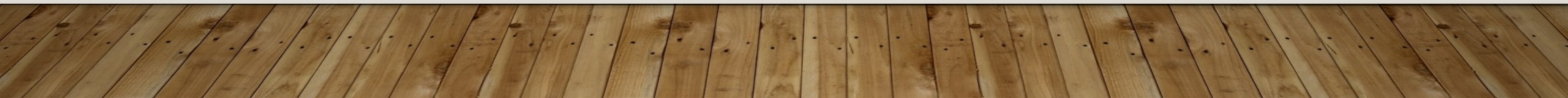
23 Chapitre 1: Généralités sur la sécurité informatique

1.2.1 Typologie des risques informatiques

1.2.1.2 Risques Matériels

↳ **Les incidents liés au logiciel** – ce sont les plus fréquents. Les systèmes d'exploitation et les programmes sont de plus en plus complexes car ils font de plus en plus de choses. Ils nécessitent l'effort conjoint de dizaines, de centaines, voire de milliers de développeurs. Ces derniers peuvent faire des erreurs de manière individuelle ou collective que les meilleures méthodes de travail et les meilleurs outils de contrôle ou de test ne peuvent pas éliminer en totalité.

↳ **Les incidents liés à l'environnement** – les machines électroniques les réseaux de communication sont sensibles aux variations de températures ou de l'humidité ainsi qu'aux champs électromagnétiques. Dès lors, il est possible qu'un ordinateur tombe en panne de manière définitive ou intermittente à cause des conditions climatiques inhabituelles ou par l'influence d'installations électriques notamment industrielles.



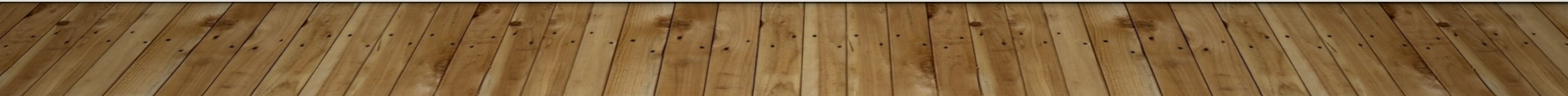
Première partie : Sécurité Informatique

24 Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

La gestion des risques informatiques est un ensemble d'opérations de gérer et de diriger les différentes incidences liées à la manipulation de l'outil informatique. La gestion des risques consiste en trois actions majeures :

- ↳ Etudier les risques potentiels (identifier/mettre au jour ces risques) ;
- ↳ Imposer des règles de sécurité adéquates pour réduire ces risques ;
- ↳ Formation des utilisateurs.



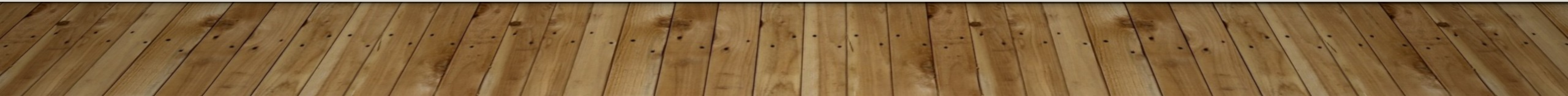
Première partie : Sécurité Informatique

25 Chapitre 1: Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

Un risque est généralement caractérisé par :

- sa source ou son origine : employé malveillant, intrus, programmes illégaux...
- une menace : divulgation d'information confidentielle, coupure d'électricité...
- la probabilité d'occurrence ou potentialité : durée et lieu, probabilité d'occurrence,
- la vulnérabilité ayant permis ce risque : erreur de conception, erreur humaine, manque de suivi des événements suspects...
- l'impact, conséquence ou préjudice : indisponibilité du service, perte de marché ou d'image pour l'entreprise...
- les mesures de sécurité ou protections ou contremesures pour s'en protéger,
- les contrôles d'accès, la politique de sécurité, la sensibilisation du personnel...



Première partie : Sécurité Informatique

26 Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

La démarche idéale consiste à en :

- choisir la méthode d'évaluation adaptée au contexte de l'entreprise,
- définir les critères d'identification des risques.

Pour avoir une idée plus précise sur la méthode à utiliser, il est utile de se référer aux méthodologies les plus connues d'analyse et d'évaluation de risques :

- MEHARI (MEthodologie Harmonisée d'Analyse de RISques)
- EBIOS (Expression des Besoins et Identification des Objectifs de Sécurité)
- OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Évaluation)

Pour MEHARI, une version française existe en téléchargement gratuit sur le site du CLUSIF (Club de la Sécurité de l'Information Français) <https://www.clusif.asso.fr/fr/production/mehari/>

Première partie : Sécurité Informatique

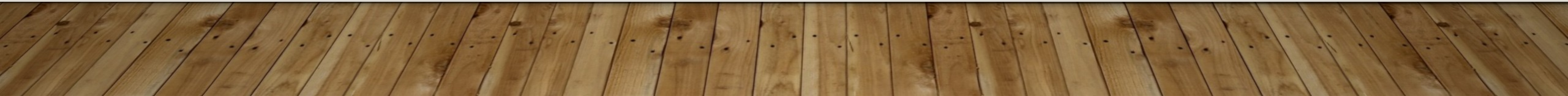
27 Chapitre 1: Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

1.2.2.1 Méthodes d'analyse des risques

Elle est définie par les actions suivantes :

- Identification des actifs (une première bonne pratique est de connaître la liste des matériels et logiciels) utilisés par les services informatiques.
- Identification des menaces et leurs impacts possibles sur la confidentialité, la disponibilité et l'intégrité de ces actifs.
- Pour chacune des menaces possibles, identification des vulnérabilités.
- Détermination de la probabilité d'occurrence des menaces et des niveaux de vulnérabilité qui pourraient impacter les services.



Première partie : Sécurité Informatique

28 Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

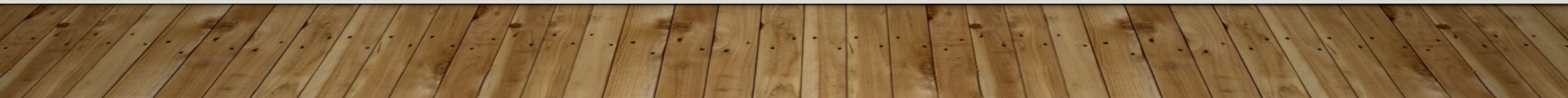
1.2.2.2 L'évaluation du risques

Des informations méthodologiques sur le principe d'évaluation peuvent être trouvées dans la norme ISO 13335, (chapitre La sécurité dans l'entreprise Les systèmes et Le plan de secours informatique)

Le processus d'évaluation consiste à effectuer l'analyse et l'interprétation du risque et comprend trois activités de base :

- Détermination de la méthodologie et le périmètre d'évaluation.
- Collecte et analyse des données.
- Interprétation des résultats d'analyse de risques.

À partir de ces éléments, les personnels responsables de l'infrastructure informés du contexte établissent les protections à mettre en place.



Première partie : Sécurité Informatique

29 Chapitre 1: Généralités sur la sécurité informatique

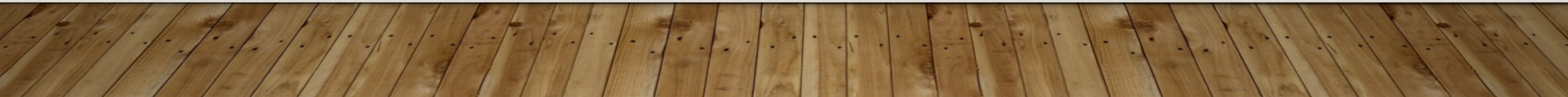
1.2.2 Gestion des risques informatiques

1.2.2.2 L'évaluation du risques

Établissement de la valeur des actifs

Cette démarche comprend l'inventaire des actifs concernés susceptibles d'être affectés par les menaces (les matériels, les logiciels et support associés, les licences...).

- Les matériels : serveurs, stations de travail, ordinateurs personnels, imprimantes, unités de stockage, lignes de communication, routeurs, parefeu, passerelles de réseau...
- Les logiciels : systèmes d'exploitation, programmes applicatifs et de diagnostic, les logiciels de pare feu, les outils logiciels...
- Les données : stockées en ligne ou archivées, les sauvegardes, les bases de données, les journaux d'erreurs et les rapports de supervision, en transit sur les supports de communication, toutes celles qui sont en cours de traitement à tout instant dans l'entreprise.
- Les programmes et procédures.



Première partie : Sécurité Informatique

30

Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

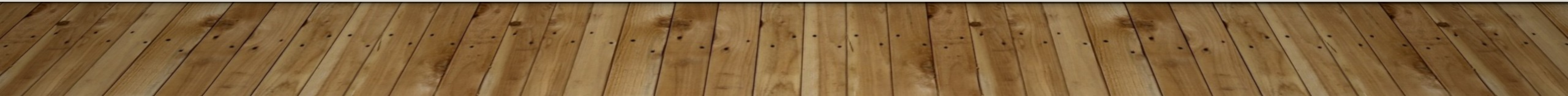
1.2.2.2 L'évaluation du risques

- Les supports d'installation de logiciels, les supports magnétiques...

Basé sur cette liste, cet inventaire va enregistrer un minimum d'éléments pour chaque actif. Cela peut être :

- le propriétaire de l'information,
- son emplacement physique ou logique,
- un numéro d'identification.

L'estimation du coût d'un actif consiste en sa valeur intrinsèque, les impacts à court terme et les conséquences à long terme de sa vulnérabilité.



Première partie : Sécurité Informatique

31 Chapitre 1:Généralités sur la sécurité informatique

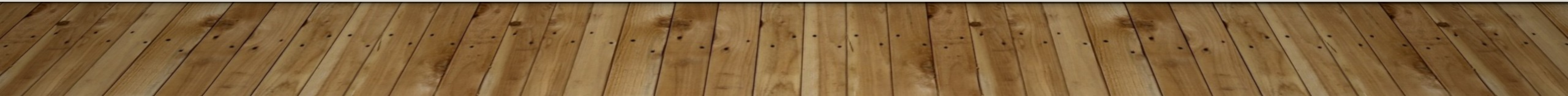
1.2.2 Gestion des risques informatiques

1.2.2.2 L'évaluation du risques

Identification des menaces

Une menace est une entité ou un évènement qui perturbe le système d'information. Elle inclut les erreurs volontaires ou involontaires, les fraudes, les actions possibles des employés mécontents, les incendies et autres causes naturelles, les hackers, les programmes néfastes ou virus.

Une fois l'inventaire des actifs requérant une protection effectué, il est nécessaire d'identifier les menaces en lien avec chacun d'eux et les risques de perte (d'information, financière...). Ce qui permettra l'élaboration de protections adaptées.



Première partie : Sécurité Informatique

32 Chapitre 1: Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

1.2.2.2 L'évaluation du risques

Identification et évaluation des impacts

Après avoir identifié les actifs et les menaces, l'impact de l'attaque est évalué et des mesures appropriées de protection de sécurité doivent être mises en place, sous les formes suivantes :

- identification des vulnérabilités du système, des protections mises en place,
- analyse des probabilités d'occurrence de menaces qui pourraient exploiter ces vulnérabilités,
- évaluation des conséquences possibles pour chaque menace,
- sélection des outils ou mécanismes de sécurité adéquats.

Cette évaluation estime le degré de perte pour les actifs. Plus les conséquences d'une menace sont graves, plus le risque pour le système d'information ou l'entreprise est important. Les impacts peuvent être estimés selon le contexte et les pertes possibles. Les conséquences peuvent être directes (financières) ou indirectes (perte de confiance).

Première partie : Sécurité Informatique

33 Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

1.2.2.2 L'évaluation du risques

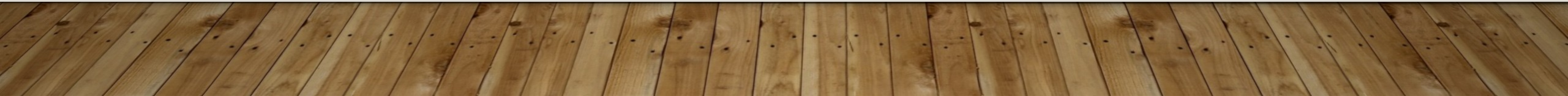
Analyse des vulnérabilités

Une vulnérabilité est une faiblesse de procédures de sécurité, de contrôles techniques ou physiques. Il peut s'agir de même une absence de protection qui peuvent être exploités par une menace.

Les interrelations entre vulnérabilités, menaces et actifs sont déterminantes pour l'analyse de risques.

Analyse des protections

Une protection consiste en toute action, procédure, outil qui limite la vulnérabilité d'un système par rapport à une menace.



Première partie : Sécurité Informatique

34 Chapitre 1:Généralités sur la sécurité informatique

1.2.2 Gestion des risques informatiques

1.2.2.2 L'évaluation du risques

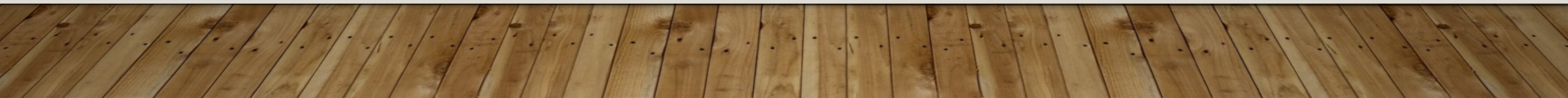
Évaluation de probabilité de survenance

Cette probabilité, appelée aussi probabilité d'occurrence, est une estimation de la possibilité de l'apparition d'une menace ou d'un évènement grave pouvant mettre en péril un système d'information. Dans l'estimation, outre les possibilités d'incendies ou d'inondation, l'historique du système et l'expérience des personnels peuvent donner une indication valable.

En général, plus la probabilité d'une menace est grande, plus son risque est important.

Les résultats des analyses de risque et mise en place des protections

L'interprétation des résultats des analyses de risques peut amener à sécuriser en priorité certains éléments du système d'information jugés critiques. Naturellement, la suppression des vulnérabilités de l'ensemble du système d'information est toujours l'objectif essentiel.



Première partie : Sécurité Informatique

35

Chapitre 1: Généralités sur la sécurité informatique

1.3. Les vulnérabilités

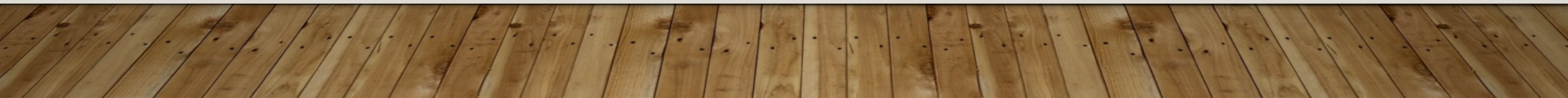
Pour le domaine de la sécurité informatique, Il existe trois familles de vulnérabilités :

Vulnérabilités liées aux domaines physiques:

- manque de redondance et de ressource au niveau équipement,
- accès aux salles informatiques non sécurisé,
- absence ou mauvaise stratégie de sauvegarde des données.

Vulnérabilités liées aux domaines organisationnels

- Manque de :ressources humaines et de personnels qualifiés, communications.
- Absence de :contrôles périodiques, documents de procédures adaptés à l'entreprise, moyens adaptés aux risques encourus.
- Trop grande complexité fonctionnelle.



Première partie : Sécurité Informatique

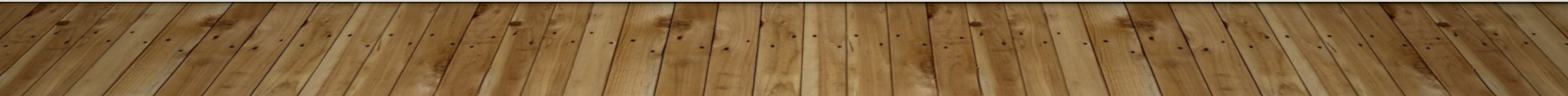
36

Chapitre 1:Généralités sur la sécurité informatique

1.3. Les vulnérabilités

Vulnérabilités liées aux domaines technologiques

- failles nombreuses dans les services et applicatifs Web et les bases de données,
- pas de mises à jour des systèmes d'exploitation et des correctifs,
- pas de contrôle suffisant sur les logiciels malveillants,
- récurrence des failles et absence de supervision des événements,
- réseaux complexes, non protégés,
- mauvaise utilisation de la messagerie.



Première partie : Sécurité Informatique

37

Chapitre 1:Généralités sur la sécurité informatique

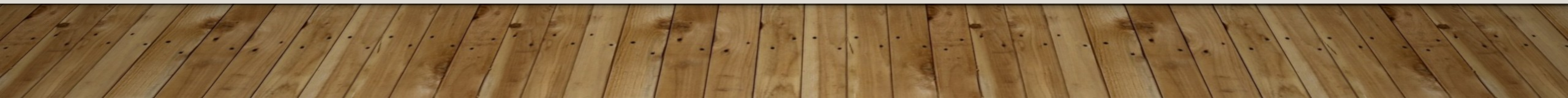
1.4. Les menaces

Les systèmes d'information sont vulnérables par rapport à plusieurs menaces susceptibles de leur infliger différents types de dommages et des pertes significatives.

L'importance des dégâts peut s'échelonner de la simple altération de données à la destruction complète de centres de données informatiques.

La valeur réelle des pertes relatives au manque de sécurité n'est pas toujours possible à estimer car beaucoup d'entre elles ne sont jamais découvertes, d'autres peuvent être délibérément ignorées pour éviter de montrer une mauvaise image de l'entreprise.

Les effets des différentes menaces varient considérablement suivant les conséquences affectant l'entreprise, certaines affectent la confidentialité ou l'intégrité des données, d'autres agissent sur la disponibilité des systèmes.



Première partie : Sécurité Informatique

38

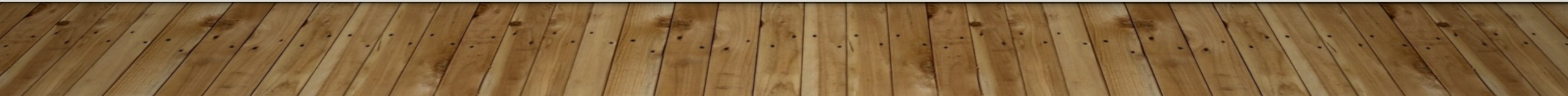
Chapitre 1:Généralités sur la sécurité informatique

1.3. Les menaces

Les menaces les plus communes sont représentées cidessous :

Erreurs et omissions

Ce sont des menaces importantes pour l'intégrité des données et des systèmes. Ces erreurs ont souvent une origine humaine. En effet, même les programmes les plus sophistiqués ne peuvent pas tout détecter. N'importe quelle personne intervenant sur le système d'information (utilisateur, administrateur système, développeur...) contribue directement ou indirectement à ces dangers mettant en péril la sécurité des systèmes. Souvent l'erreur concerne une menace (erreur d'entrée de données, erreur de programmation...) ou encore crée elle-même la vulnérabilité.



Première partie : Sécurité Informatique

39

Chapitre 1: Généralités sur la sécurité informatique

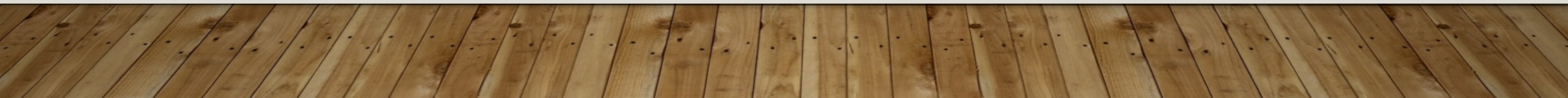
1.3. Les menaces

Fraude et vol

Les fraudes ou vols peuvent être commis par l'intérieur ou l'extérieur de l'entreprise. Par expérience, il s'avère, la plupart du temps, que la menace vient de l'intérieur (des utilisateurs ayant des accès privilégiés aux systèmes). En effet, par défaut, ce sont les utilisateurs familiers de l'entreprise qui sont dans la meilleure position pour commettre des forfaits.

Sabotage causé par des employés

Ce sont les personnels les plus familiarisés avec les systèmes et les applications. Ils peuvent donc perpétrer des dommages, sabotages... Ce qui implique la nécessité de gérer et de contrôler de façon rigoureuse les comptes des utilisateurs, surtout de ceux qui ont des accès privilégiés aux systèmes.



Première partie : Sécurité Informatique

40

Chapitre 1:Généralités sur la sécurité informatique

1.3. Les menaces

Les Hackers

Le terme hacker ou encore cracker fait référence à la personne qui s'introduit dans les systèmes d'information sans autorisation pour, dans le pire des cas, provoquer des dégradations dans les données ou les applications. Ses actions peuvent s'effectuer à partir de l'intérieur (dans le cas où il a pu obtenir un accès sur le réseau) ou de l'extérieur de l'entreprise. Toutefois, il n'est pas toujours facile de détecter sa présence sur les systèmes ni de connaître ce qu'il a provoqué comme dégâts.

L'espionnage industriel ou commercial

C'est le fait de récupérer des données confidentielles de l'entreprise dans le cas de concurrence économique ou industrielle. Cette menace n'implique pas, en général, d'altération des données internes. Par contre, elle peut avoir un impact important sur les actifs sensibles de l'entreprise (données clients, brevets industriels...). La menace vise spécifiquement les ordinateurs ou appareils portables particulièrement sensibles au vol car ils peuvent contenir des informations confidentielles. Des précautions d'utilisation et de protection devront être prises.

Première partie : Sécurité Informatique

41

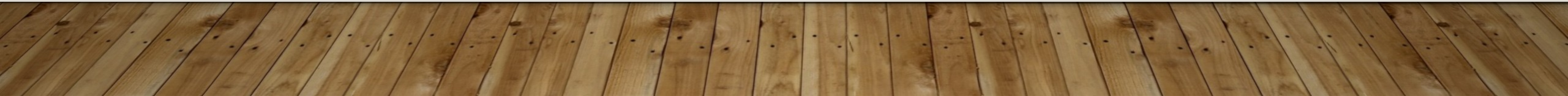
Chapitre 1:Généralités sur la sécurité informatique

1.3. Les menaces

Les programmes malveillants

Ils font référence aux virus, chevaux de Troie, bombes logiques et autres logiciels indésirables. Souvent, leur point d'entrée se situe au niveau des ordinateurs personnels mal protégés lors de leur connexion sur Internet. Leurs effets peuvent s'étendre à tout le réseau de l'entreprise en contaminant d'autres matériels.

Il est possible de se protéger de la plupart des risques liés à ces menaces. Aussi, dans les premières phases de mise en place de la sécurité du système d'information, un état des lieux, sous forme de diagnostic, va être nécessaire pour préparer une meilleure protection en détectant les vulnérabilités.



Première partie : Sécurité Informatique

42

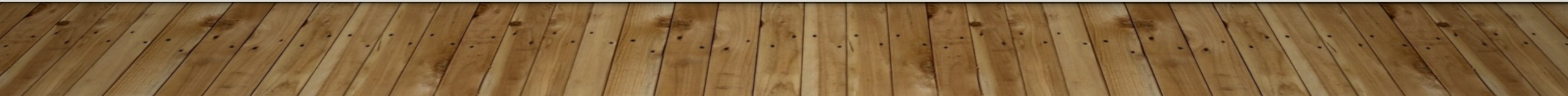
Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

La politique de sécurité a pour objectif de définir la protection des systèmes d'information de l'entreprise.

Elle comprend un ensemble de bases définissant une stratégie, des directives, des procédures, des codes de conduite, des règles organisationnelles et techniques. Elle implique une mise en œuvre d'une sécurité adaptée aux usages, économiquement viable et conforme à la législation.

Cette politique est formalisée dans l'entreprise sous forme d'un document. Il doit comporter un recueil de pratiques qui régissent la manière de gérer, de protéger et de transmettre les informations critiques ou sensibles appartenant à l'organisation. La documentation sur la norme ISO 27001 et sa suite est l'ouvrage de référence d'aide à la réalisation de ce référentiel.



Première partie : Sécurité Informatique

43

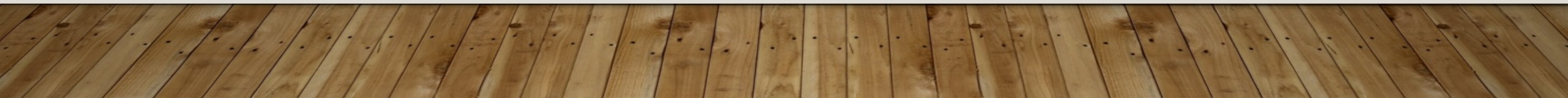
Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

Parmi les domaines abordés, il est possible de trouver les thèmes sur :

- l'organisation et les structures de l'entreprise impliquées dans la gestion de la sécurité,
- les éléments fondateurs d'une culture de sécurité,
- le maintien de la cohérence dans les solutions techniques mises en œuvre,
- les moyens mis en œuvre et les méthodes de pilotage.

L'objectif central de la sécurité informatique est de garder ou de sauvegarder la pérennité de l'entreprise. C'est pour cela que la politique de sécurité mise en œuvre doit s'inspirer des besoins réels qui ont été définis à partir des évaluations des actifs, des menaces et des vulnérabilités. Elle impose une complémentarité entre les procédures, les outils mis en œuvre et les personnes impliquées.

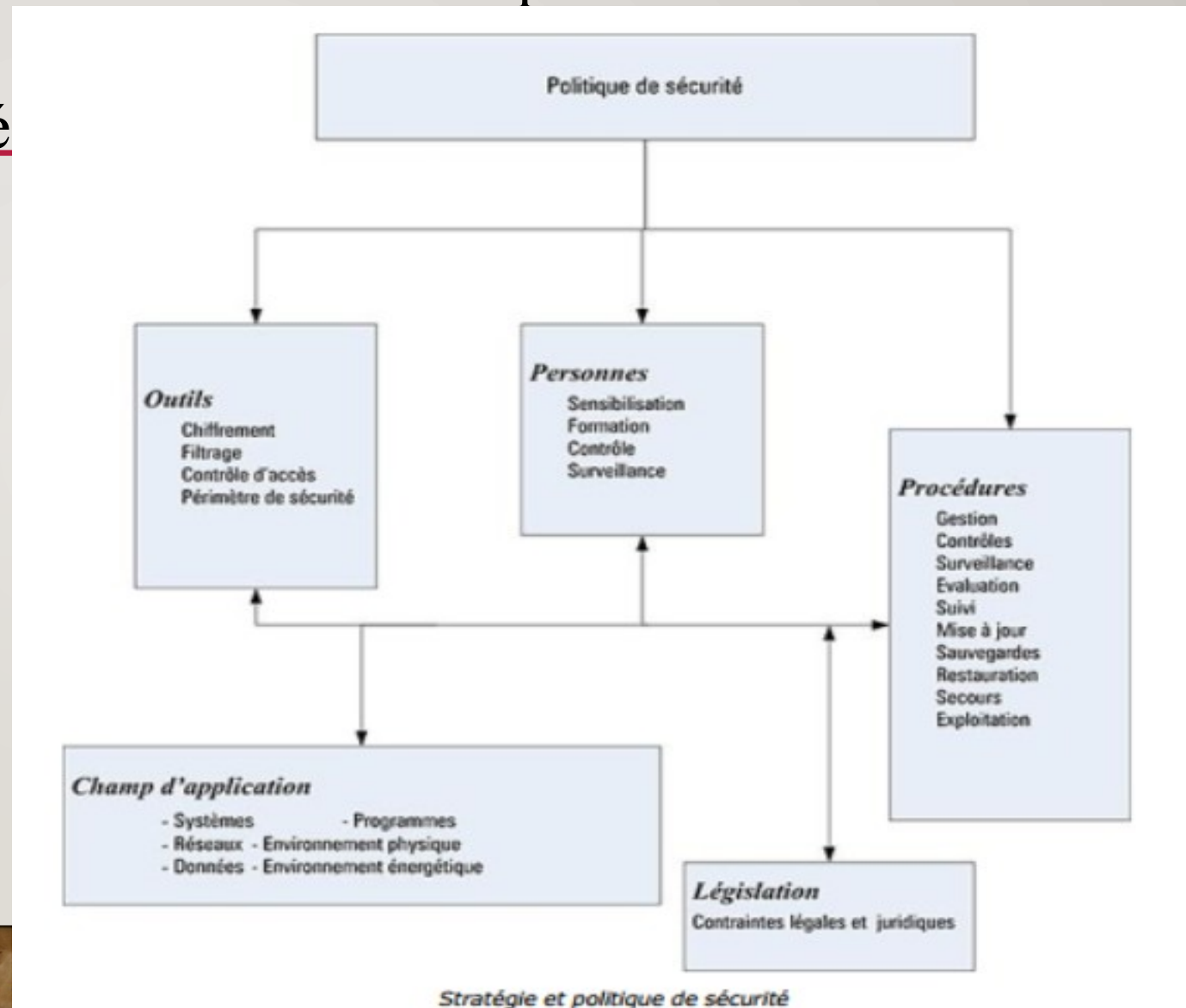


Première partie : Sécurité Informatique

44

Chapitre 1: Généralités sur la sécurité informatique

1.4. La politique de sécurité



Première partie : Sécurité Informatique

45

Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.1 Les principes

Le rôle principal de sécurité informatique consiste en trois démarches principales :

- Définir le périmètre de la vulnérabilité lié à l'usage des technologies de l'information et de la communication.
- Offrir un niveau de protection adapté aux risques encourus par l'entreprise.
- Mettre en œuvre et valider l'organisation, les mesures, les outils et les procédures de sécurité.

La première étape consiste à connaître le périmètre lié à la sécurité, c'est-à-dire la zone qui correspond aux services (authentification, contrôles d'accès physiques et logiques, disponibilité, intégrité et confidentialité) utilisés sur le réseau d'entreprise (postes clients, réseaux LAN et WAN), sur les serveurs, avec les points d'accès externes (serveurs distants, accès VPN...).

À chaque sous-ensemble du périmètre correspond un niveau de sécurité différent selon les menaces possibles ou en fonction de la valeur des informations à protéger.

Première partie : Sécurité Informatique

46

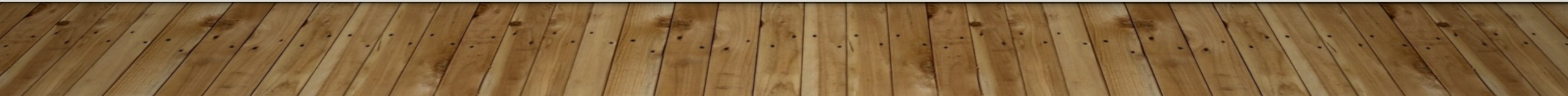
Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.1 Les principes

Les principes de base de cette sécurité imposent de :

- Définir et d'implémenter une stratégie de sécurité adaptée au contexte ou au métier de l'entreprise.
- Appliquer les dernières mises à jour et corrections pour les systèmes d'exploitation, les logiciels applicatifs, principalement pour ceux qui sont établis en protection (antivirus...).
- Utiliser les recommandations des éditeurs en ce qui concerne la gestion des mots de passe des comptes privilégiés.



Première partie : Sécurité Informatique

47

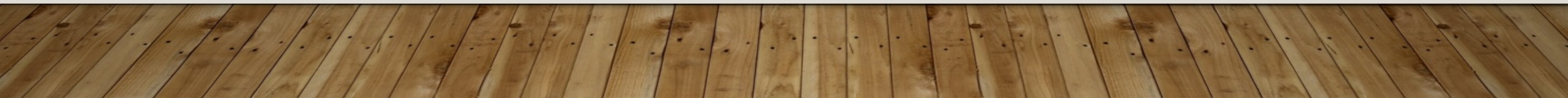
Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.1 Les principes

Pour bâtir une politique de sécurité adaptée au métier de l'entreprise, il est nécessaire de préparer les étapes suivantes :

- Identifier les actifs à protéger :
- Matériels.
- Les données sensibles de l'entreprise.
- Les services et applications : applications métier internes et externes pouvant communiquer avec le monde extérieur (fournisseurs, clients, site de commerce électronique) ou en interne.
- Découvrir les réseaux de communication. Cela consiste à découvrir les interactions entre les différents matériels et logiciels, d'identifier les applications communiquant avec l'extérieur.



Première partie : Sécurité Informatique

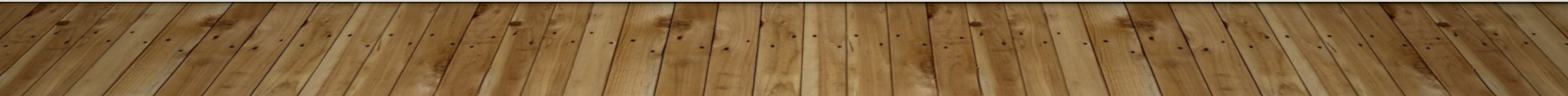
48

Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.2 L'élaboration du document

Après avoir évalué les besoins globaux en sécurité, le document présentant la politique peut être conçu selon le bon sens pratique. Une façon simple est d'utiliser une approche hiérarchique pour définir le périmètre global, ensuite le décomposer en différents composants.



Première partie : Sécurité Informatique

49

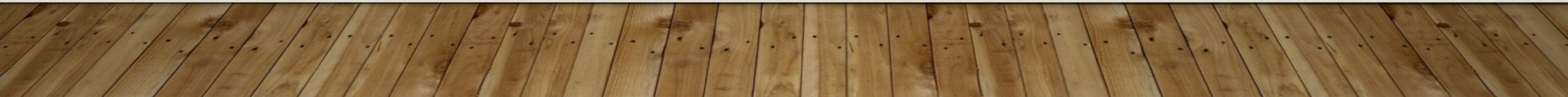
Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.2 L'élaboration du document

La politique de sécurité doit être rigoureuse, mais doit rester flexible. Elle peut tenter de répondre aux premières questions suivantes :

- Quel est le niveau de sensibilité ou d'importance des données de l'entreprise ?
- Quels sont les objectifs principaux et le périmètre ?
- Quels systèmes d'information sont à protéger ?
- Quelles sont les mesures minimales à définir pour leur protection ?
- Quelles sont les personnes responsables de la sécurité des données (accès logiques, privilèges d'administration...) et les ressources matérielles et logicielles mises à disposition ?
- Quels sont les droits et devoirs des utilisateurs ou des administrateurs ?



Première partie : Sécurité Informatique

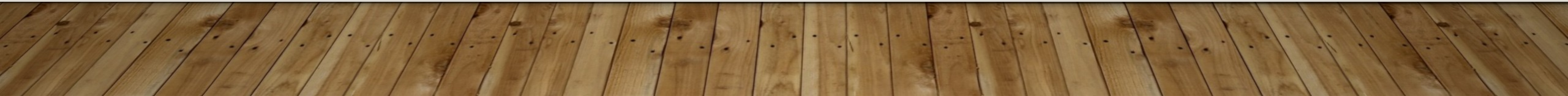
50

Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.2 L'élaboration du document

L'objectif de ce document est de considérer spécifiquement les vulnérabilités d'ordre technique et les solutions simples et efficaces à mettre en place. L'aspect humain interviendra obligatoirement car les rôles de l'administrateur et des personnels d'exploitation y sont traités.



Première partie : Sécurité Informatique

51

Chapitre 1:Généralités sur la sécurité informatique

1.4. La politique de sécurité

1.4.3 Les outils

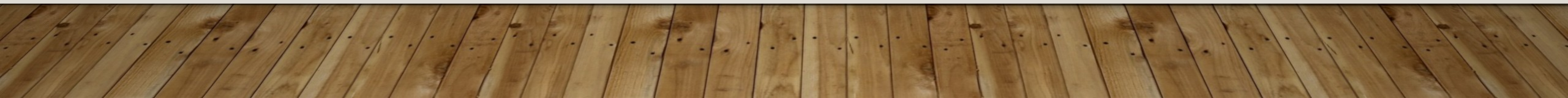
Tout projet de mise en place de la politique de sécurité dans l'entreprise requiert une documentation adaptée sous forme de guides de bonnes pratiques, de procédures.

Les documents des normes peuvent être acquis, les guides et procédures doivent être rédigés par les personnes en charge de la sécurité des systèmes.

Les procédures consistent à décrire les étapes détaillées qui doivent être suivies par les utilisateurs, les responsables systèmes et toutes les personnes qui doivent accomplir une tâche particulière.

Chaque document doit être rédigé et adapté selon le personnel concerné et sa fonction dans l'entreprise.

L'objectif final des documents est d'assister les utilisateurs, les responsables systèmes et toutes les personnes impliquées dans la gestion des systèmes d'information dans l'optique de la politique de sécurité définie.

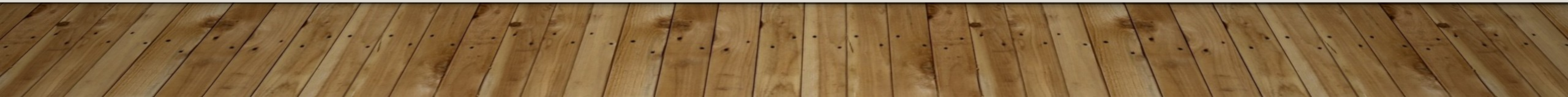


Première partie : Sécurité Informatique

52

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

En entreprise, c'est le réseau local qui est connecté à Internet. Il est donc indispensable de contrôler les communications entre le réseau interne et l'extérieur. De plus une formation du personnel est indispensable (règles de sécurité, déontologie, attention aux participations aux forums qui sont archivées ...). Les problèmes de sécurité qu'on peut rencontrer sur un réseau d'entreprise ou sur l'Internet relèvent d'abord de la responsabilité des victimes avant d'être imputables aux hackers. Les menaces qui ont sensiblement augmenté au cours de ces dernières années, nous indique la dernière étude du Computer Security Institute, un institut professionnel de San Francisco qui réalise chaque année un sondage auprès des entreprises en collaboration avec le FBI. Dans cette étude, plus de 40 % des sociétés interrogées ont déclaré que des intrus s'étaient introduits dans leurs systèmes depuis l'Internet, 38 % des sociétés ont détecté des attaques de type "dénier de service", et 94 % ont été infectées par un virus en 2014

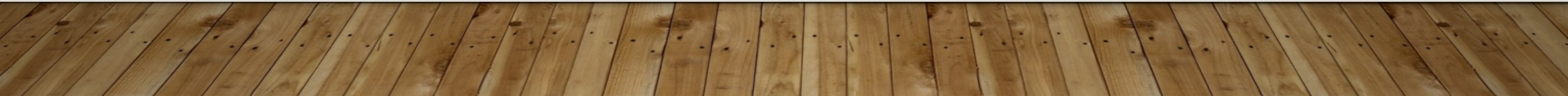


Première partie : Sécurité Informatique

53

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

D'autre part, votre sécurité peut dépendre d'autres entreprises dont vous pensez, parfois à tort, qu'elles ont assuré leur propre sécurité. Alors que le gouvernement et les forces de l'ordre cherchent à interpellier les intrus, les sociétés ne se préoccupent trop souvent que de relancer leurs réseaux après une attaque : « Le secteur privé ne cherche pas à savoir qui est responsable, tout ce qui intéresse les entreprises, c'est que l'attaque cesse ».



Première partie : Sécurité Informatique

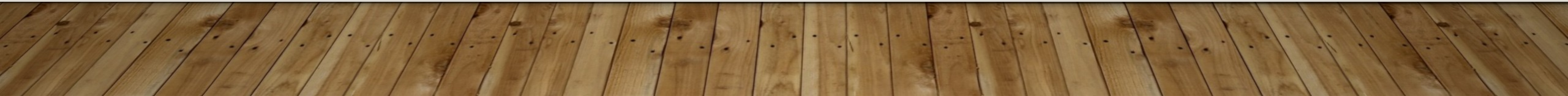
54

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

Lors de la connexion à un système informatique, celui-ci demande la plupart du temps, un identifiant (login ou username) et un mot de passe (password) pour y accéder. Ce couple identifiant/mot de passe forme ainsi la clé permettant d'obtenir un accès au système.

Si l'identifiant est généralement automatiquement attribué par le système ou son administrateur, le choix du mot de passe est souvent laissé libre à l'utilisateur. Ainsi, la plupart des utilisateurs, estimant qu'ils n'ont rien de vraiment secret à protéger, se contentent d'utiliser un mot de passe facile à retenir (par exemple leur identifiant, le prénom de leur conjoint ou leur date de naissance).



Première partie : Sécurité Informatique

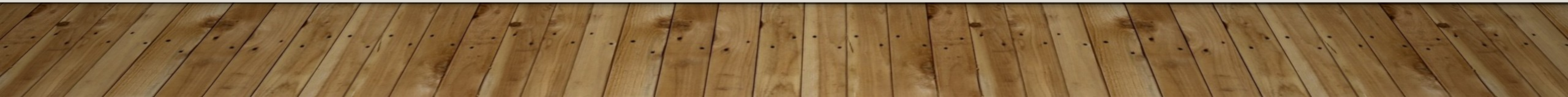
55

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

Or, si les données sur le compte de l'utilisateur n'ont pas un caractère stratégique, l'accès au compte de l'utilisateur peut constituer une porte ouverte vers le système tout entier. En effet, dès qu'un pirate obtient un accès à un compte d'une machine, il lui est possible d'élargir son champ d'action en obtenant la liste des utilisateurs autorisés à se connecter à la machine. À l'aide d'outils de génération de mots de passe, le pirate peut essayer un grand nombre de mots de passe générés aléatoirement ou à l'aide d'un dictionnaire (éventuellement une combinaison des deux). S'il trouve par hasard le mot de passe de l'administrateur, il obtient alors toutes les permissions sur la machine !

De plus, à partir d'une machine du réseau, le pirate peut éventuellement obtenir un accès sur le réseau local, ce qui signifie qu'il peut dresser une cartographie des autres serveurs côtoyant celui auquel il a obtenu un accès.



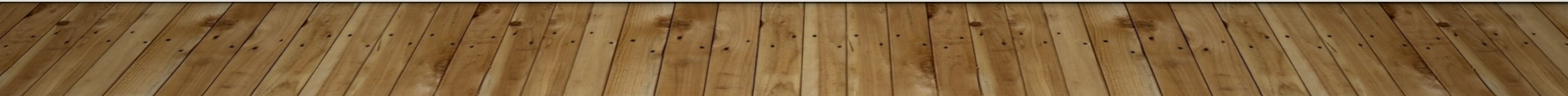
Première partie : Sécurité Informatique

56

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

Les mots de passe des utilisateurs représentent donc la première défense contre les attaques envers un système, c'est la raison pour laquelle il est nécessaire de définir une politique en matière de mots de passe afin d'imposer aux utilisateurs le choix d'un mot de passe suffisamment sécurisé.



Première partie : Sécurité Informatique

57

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

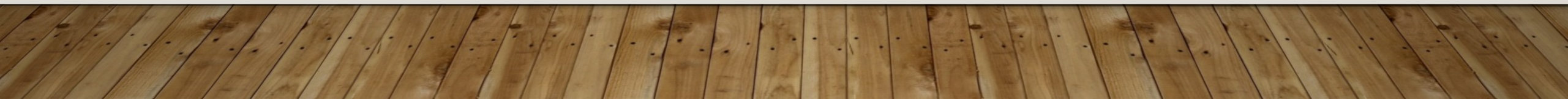
La plupart des systèmes sont configurés de manière à bloquer temporairement le compte d'un utilisateur après un certain nombre de tentatives de connexion infructueuses.

Ainsi, un pirate peut difficilement s'infiltrer sur un système de cette façon.

En contrepartie, un pirate peut se servir de ce mécanisme d'autodéfense pour bloquer l'ensemble des comptes utilisateurs afin de provoquer un déni de service.

Sur la plupart des systèmes les mots de passe sont stockés de manière chiffrée (cryptée) dans un fichier ou une base de données.

Néanmoins, lorsqu'un pirate obtient un accès au système et obtient ce fichier, il lui est possible de tenter de casser le mot de passe d'un utilisateur en particulier ou bien de l'ensemble des comptes utilisateurs.



Première partie : Sécurité Informatique

58

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

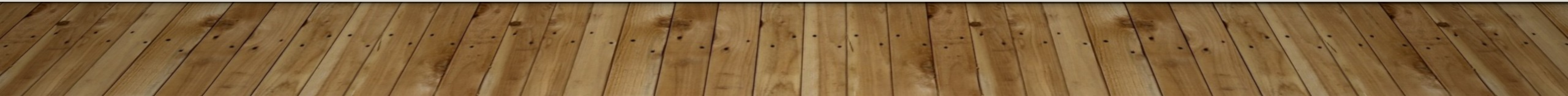
2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Attaque par force brute

On appelle ainsi attaque par force brute (brute force cracking, ou parfois attaque exhaustive) le cassage d'un mot de passe en testant tous les mots de passe possibles.

Il existe un grand nombre d'outils, pour chaque système d'exploitation, permettant de réaliser ce genre d'opération. Ces outils servent aux administrateurs système à éprouver la solidité des mots de passe de leurs utilisateurs mais leur usage est détourné par les pirates informatiques pour s'introduire dans les systèmes informatiques.



Première partie : Sécurité Informatique

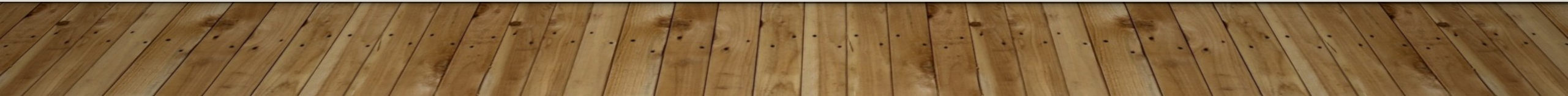
59

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

L'attaque par force brute de mots de passe avait perdu de son intérêt, notamment face à des outils de cryptage de plus en plus perfectionnés. Depuis 2007, ces attaques redeviennent techniquement possibles pour les pirates grâce à la puissance de calculs des...cartes vidéo. En effet, les puces utilisées dans ces éléments de l'ordinateur sont optimisées pour les calculs mathématiques. Un programme a même été mis en vente par l'éditeur russe ElcomSoft. Il permet non seulement d'utiliser la puissance de la carte vidéo de l'ordinateur mais aussi de distribuer les calculs sur plusieurs centaines/milliers d'ordinateurs de part le monde. Cette technique rend possible le cassage de certains cryptages dans des temps acceptables.



Première partie : Sécurité Informatique

60

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

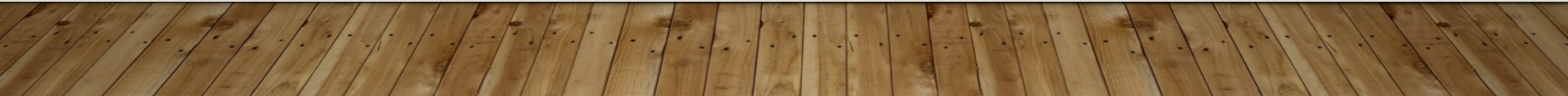
2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Attaque par dictionnaire

Les outils d'attaque par force brute peuvent demander des heures, voire des jours, de calcul même avec des machines équipées de processeurs puissants. Ainsi, une alternative consiste à effectuer une attaque par dictionnaire. En effet, la plupart du temps les utilisateurs choisissent des mots de passe ayant une signification réelle.

Avec ce type d'attaques, un tel mot de passe peut être craqué en quelques minutes.



Première partie : Sécurité Informatique

61

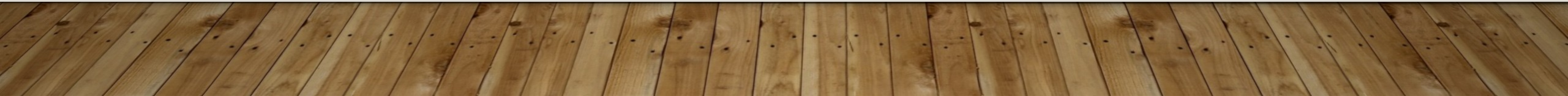
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Attaque hybride

Le dernier type d'attaques de ce type, appelées attaques hybrides, vise particulièrement les mots de passe constitués d'un mot traditionnel et suivi d'une lettre ou d'un chiffre (tel que « marechal6 »). Il s'agit d'une combinaison d'attaque par force brute et d'attaque par dictionnaire.



Première partie : Sécurité Informatique

62

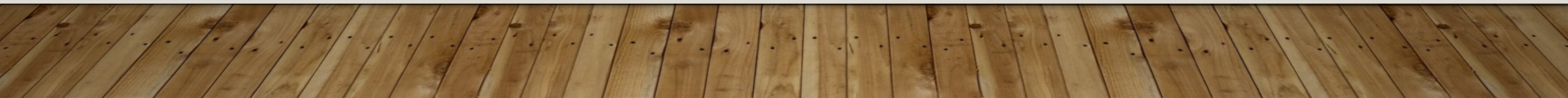
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Il existe enfin des moyens permettant au pirate d'obtenir les mots de passe des utilisateurs :

- Les keyloggers, sont des logiciels qui, lorsqu'ils sont installés sur le poste de l'utilisateur, permettent d'enregistrer les frappes de claviers saisies par l'utilisateur. Les systèmes d'exploitation récents possèdent des mémoires tampon protégées permettant de retenir temporairement le mot de passe et accessibles uniquement par le système.
- L'ingénierie sociale consiste à exploiter la naïveté des individus pour obtenir des informations. Un pirate peut ainsi obtenir le mot de passe d'un individu en se faisant passer pour un administrateur du réseau ou bien à l'inverse appeler l'équipe de support en demandant de réinitialiser le mot de passe en prétextant un caractère d'urgence.
- L'espionnage représente la plus vieille des méthodes. Il suffit en effet parfois à un pirate d'observer les papiers autour de l'écran de l'utilisateur ou sous le clavier afin d'obtenir le mot de passe. Par ailleurs, si le pirate fait partie de l'entourage de la victime, un simple coup d'œil par-dessus son épaule lors de la saisie du mot de passe peut lui permettre de le voir ou de le deviner.



Première partie : Sécurité Informatique

63

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

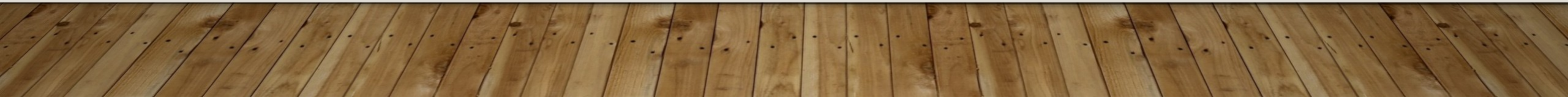
2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Choix des mots de passe

Il est aisément compréhensible que plus un mot de passe est long, plus il est difficile à casser. D'autre part, un mot de passe constitué uniquement de chiffres sera beaucoup plus simple à casser qu'un mot de passe contenant des lettres :

- Un mot de passe de quatre chiffres correspond à 10 000 possibilités (10^4). Si ce chiffre paraît élevé, un ordinateur doté d'une configuration modeste est capable de le casser en quelques minutes.
- On lui préférera un mot de passe de quatre lettres, pour lequel il existe 456 972 possibilités (26^4). Dans le même ordre d'idée, un mot de passe mêlant chiffres et lettres, voire également des majuscules et des caractères spéciaux sera encore plus difficile à casser.



Première partie : Sécurité Informatique

64

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Attention !

Mots de passe à éviter :

- votre identifiant ;
- votre nom, votre prénom ou celui d'un proche ;
- un mot du dictionnaire ;
- un mot à l'envers (les outils de cassage de mots de passe prennent en compte cette possibilité) ;
- un mot suivi d'un chiffre, de l'année en cours ou d'une année de naissance (par exemple « password1999 »).

Première partie : Sécurité Informatique

65

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

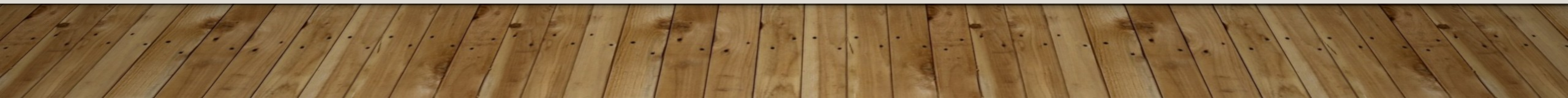
2.2 Attaques de mots de passe

☐ Politique en matière de mots de passe

L'accès au compte d'un seul employé d'une entreprise peut compromettre la sécurité globale de toute l'organisation. Ainsi, toute entreprise souhaitant garantir un niveau de sécurité optimal se doit de mettre en place une réelle politique de sécurité en matière de mots de passe.

Il s'agit notamment d'imposer aux employés le choix d'un mot de passe conforme à certaines exigences, par exemple :

- une longueur de mot de passe minimale ;
- la présence de caractères particuliers ;
- un changement de casse (minuscule et majuscule).



Première partie : Sécurité Informatique

66

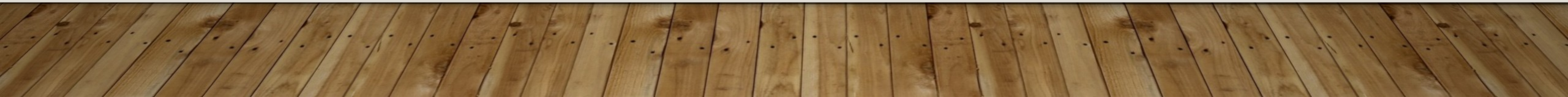
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

Par ailleurs, il est possible de renforcer cette politique de sécurité en imposant une durée d'expiration des mots de passe, afin d'obliger les utilisateurs à modifier régulièrement leur mot de passe. Cela complique ainsi la tâche des pirates essayant de casser des mots de passe sur la durée. Par ailleurs il s'agit d'un excellent moyen de limiter la durée de vie des mots de passe ayant été cassés.

Enfin, il est recommandé aux administrateurs système d'utiliser des logiciels de cassage de mots de passe en interne sur les mots de passe de leurs utilisateurs afin d'en éprouver la solidité. Ceci doit néanmoins se faire dans le cadre de la politique de sécurité et être écrit noir sur blanc, afin d'avoir l'approbation de la direction et des utilisateurs.



Première partie : Sécurité Informatique

67

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.2 Attaques de mots de passe

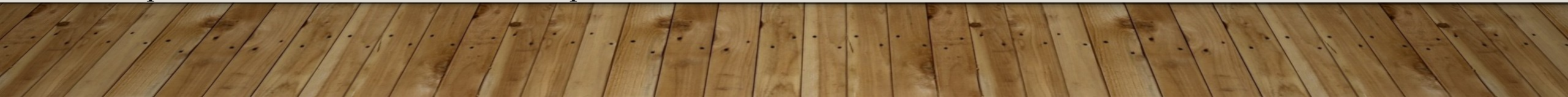
☐ Mots de passe multiples

Il n'est pas sain d'avoir un seul mot de passe, au même titre qu'il ne serait pas sain d'avoir comme code de carte bancaire le même code que pour son téléphone portable et que le digicode en bas de l'immeuble.

Il est donc conseillé de posséder plusieurs mots de passe par catégorie d'usage, en fonction de la confidentialité du secret qu'il protège.

Le code d'une carte bancaire devra ainsi être utilisé uniquement pour cet usage. Par contre, le code PIN d'un téléphone portable peut correspondre à celui du cadenas d'une valise.

De la même façon, lors de l'inscription à un service en ligne demandant une adresse électronique, il est fortement déconseillé de choisir le même mot de passe que celui permettant d'accéder à cette messagerie car un administrateur peu scrupuleux, pourrait sans aucun problème avoir un œil sur votre vie privée !



Première partie : Sécurité Informatique

68

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

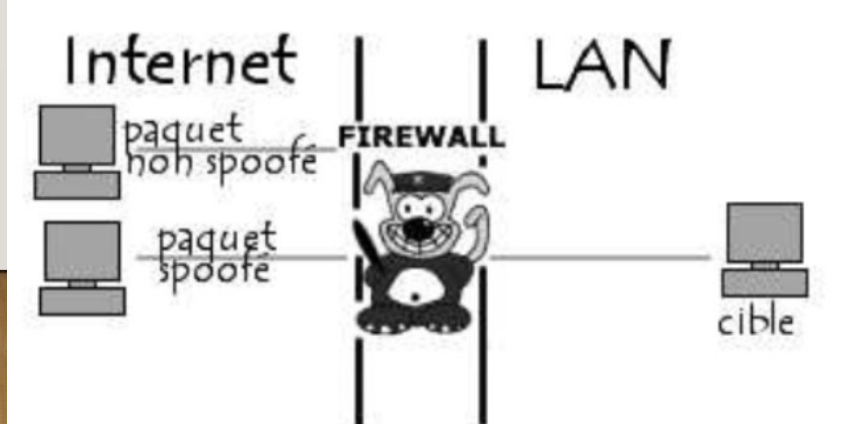
2.3 Usurpation d'adresse IP

L'usurpation d'adresse IP (également appelé mystification ou spoofing IP) est une technique consistant à remplacer l'adresse IP de l'expéditeur d'un paquet IP par l'adresse IP d'une autre machine.

Cette technique permet ainsi à un pirate d'envoyer des paquets anonymement. Il ne s'agit pas pour autant d'un changement d'adresse IP, mais d'une mascarade de l'adresse IP au niveau des paquets émis.

La technique de l'usurpation d'adresse IP peut permettre à un pirate de faire passer des paquets sur un réseau sans que ceux-ci ne soient interceptés par le système de filtrage de paquets (pare-feu).

En effet, un système pare-feu (firewall) fonctionne la plupart du temps grâce à des règles de filtrage indiquant les adresses IP autorisées à communiquer avec les machines internes au réseau.



Première partie : Sécurité Informatique

69

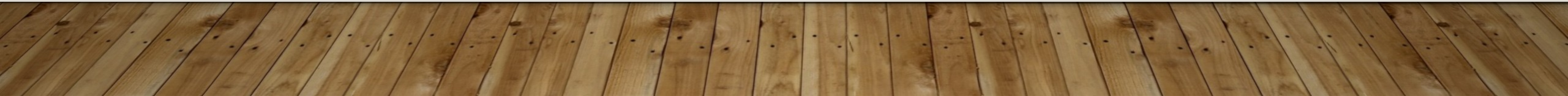
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

Ainsi, un paquet spoofé avec l'adresse IP d'une machine interne semblera provenir du réseau interne et sera relayé à la machine cible, tandis qu'un paquet contenant une adresse IP externe sera automatiquement rejeté par le pare-feu.

Cependant, le protocole TCP (protocole assurant principalement le transport fiable de données sur Internet) repose sur des liens d'authentification et d'approbation entre les machines d'un réseau, ce qui signifie que pour accepter le paquet, le destinataire doit auparavant accuser réception auprès de l'émetteur, ce dernier devant à nouveau accuser réception de l'accusé de réception



Première partie : Sécurité Informatique

70

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

Modification de l'en-tête TCP

Sur Internet, les informations circulent grâce au protocole IP, qui assure l'encapsulation des données dans des structures appelées paquet (ou plus exactement datagramme IP). Voici la structure d'un datagramme :

Version	Longueur d'en-tête	Type de service	Longueur totale	
Identification			Drapeau	Décalage fragment
Durée de vie		Protocole	Somme de contrôle en-tête	
Adresse IP source				
Adresse IP destination				
Données				

Première partie : Sécurité Informatique

71

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

Usurper une adresse IP revient à modifier le champ source afin de simuler un datagramme provenant d'une autre adresse IP. Toutefois, sur Internet, les paquets sont généralement transportés par le protocole TCP, qui assure une transmission dite « fiable ». Avant d'accepter un paquet, une machine doit auparavant en accuser réception auprès de la machine émettrice, et attendre que cette dernière confirme la bonne réception de l'accusé.

Liens d'approbation

Le protocole TCP est un des principaux protocoles de la couche transport du modèle TCP/IP. Il permet, au niveau des applications, de gérer les données en provenance (ou à destination) de la couche inférieure du modèle (c'est-à-dire le protocole IP).

Version	Longueur d'en-tête	Type de service	Longueur totale	
Identification			Drapeau	Décalage fragment
Durée de vie		Protocole	Somme de contrôle en-tête	
Adresse IP source				
Adresse IP destination				
Données				

Première partie : Sécurité Informatique

72

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

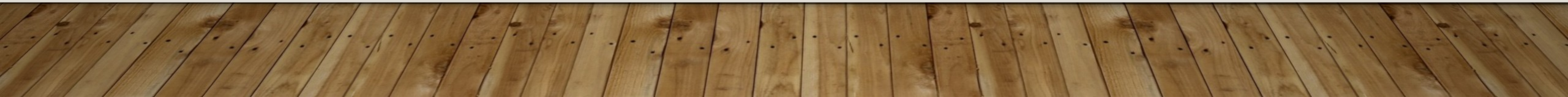
Le protocole TCP permet d'assurer le transfert des données de façon fiable, bien qu'il utilise le protocole IP (qui n'intègre aucun contrôle de livraison de datagramme) grâce à un système d'accusés de réception (ACK) permettant au client et au serveur de s'assurer de la bonne réception mutuelle des données.

Les datagrammes IP encapsulent des paquets TCP (appelés segments), la structure est présentée sur le schéma page suivante.

Lors de l'émission d'un segment, un numéro d'ordre (appelé aussi numéro de séquence) est associé, et un échange de segments contenant des champs particuliers (appelés drapeaux ou flags) permet de synchroniser le client et le serveur.

Ce dialogue (appelé poignée de mains en trois temps) permet d'initier la communication. Les trois temps sont les suivants :

► Dans un premier temps, la machine émettrice (le client) transmet un segment dont le drapeau SYN est à 1 (pour signaler qu'il s'agit d'un segment de synchronisation), avec un numéro d'ordre N , que l'on appelle numéro d'ordre initial du client.



Première partie : Sécurité Informatique

73

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

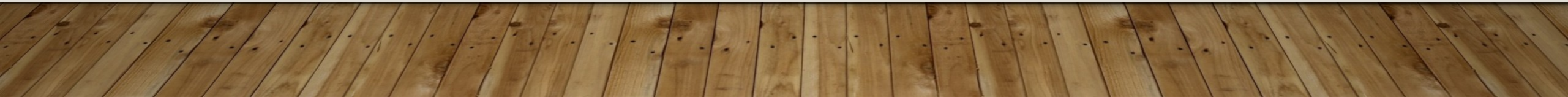
2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

► Dans un second temps la machine réceptrice (le serveur) reçoit le segment initial provenant du client, puis lui envoie un accusé de réception, c'est-à-dire un segment dont le drapeau ACK est non nul (accusé de réception) et le drapeau SYN est à 1 (car il s'agit là encore d'une synchronisation). Ce segment contient un numéro de séquence égal au numéro d'ordre initial du client. Le champ le plus important de ce segment est le champ accusé de réception (ACK) qui contient le numéro d'ordre initial du client, incrémenté de 1.

► Enfin, le client transmet au serveur un accusé de réception, c'est-à-dire un segment dont le drapeau ACK est non nul, et dont le drapeau SYN est à zéro (il ne s'agit plus d'un segment de synchronisation). Son numéro d'ordre est incrémenté et le numéro d'accusé de réception représente le numéro de séquence initial du serveur incrémenté de 1.

La machine spoofée va répondre avec un paquet TCP dont le drapeau RST (reset) est non nul, ce qui mettra fin à la connexion.



74

2.3 Usurpation d'adresse IP

,

Première partie : Sécurité Informatique

75

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

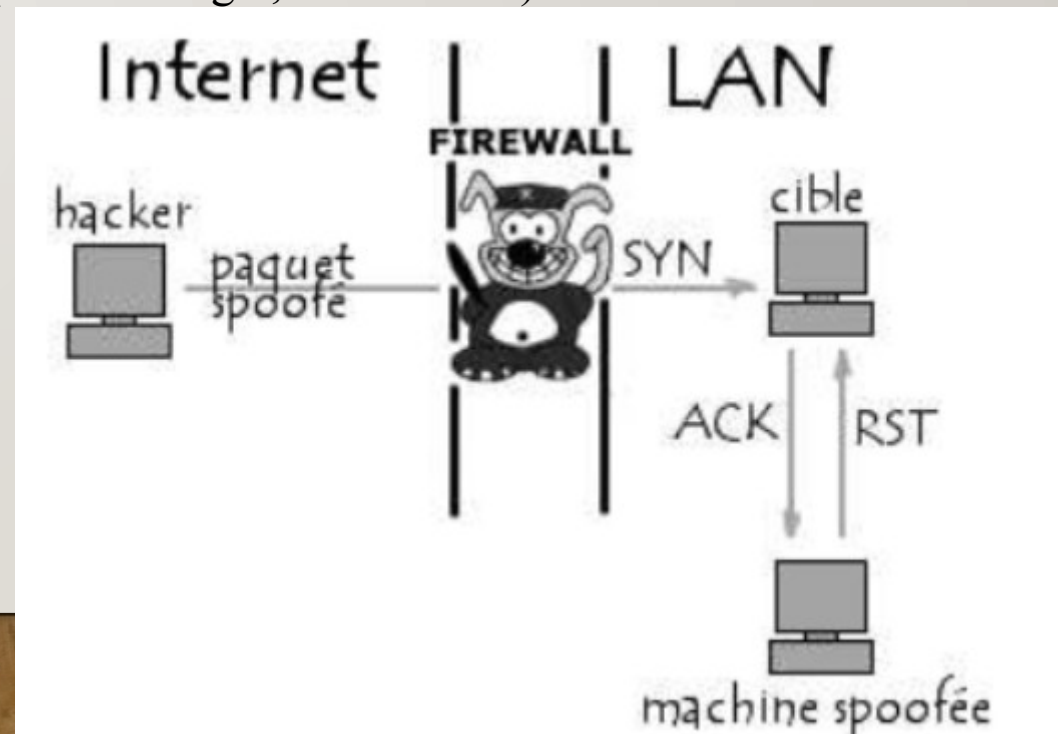
2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP

Annihilation de la machine spoofée

Dans le cadre d'une attaque par usurpation d'adresse IP, l'attaquant n'a aucune information en retour car les réponses de la machine cible vont vers une autre machine du réseau (on parle alors d'attaque à l'aveugle, blind attack).

De plus, la machine « spoofée » prive le hacker de toute tentative de connexion, car elle envoie systématiquement un drapeau RST à la machine cible. Le travail du pirate consiste alors à invalider la machine spoofée en la rendant injoignable pendant toute la durée de l'attaque.



Première partie : Sécurité Informatique

76

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

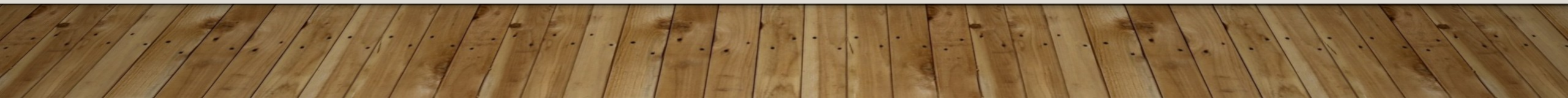
2.3 Usurpation d'adresse IP

Prédiction des numéros de séquence

Lorsque la machine spoofée est invalidée, la machine cible attend un paquet contenant l'accusé de réception et le bon numéro de séquence. Tout le travail du pirate consiste alors à « deviner » le numéro de séquence à renvoyer au serveur afin que la relation de confiance soit établie.

Pour cela, les pirates utilisent généralement le source routing, c'est-à-dire qu'ils utilisent le champ option de l'en-tête IP afin d'indiquer une route de retour spécifique pour le paquet. Ainsi, grâce au sniffing, le pirate sera à même de lire le contenu des trames de retour...

Ainsi, en connaissant le dernier numéro de séquence émis, le pirate établit des statistiques concernant son incrémentation et envoie des accusés de réception jusqu'à obtenir le bon numéro de séquence.



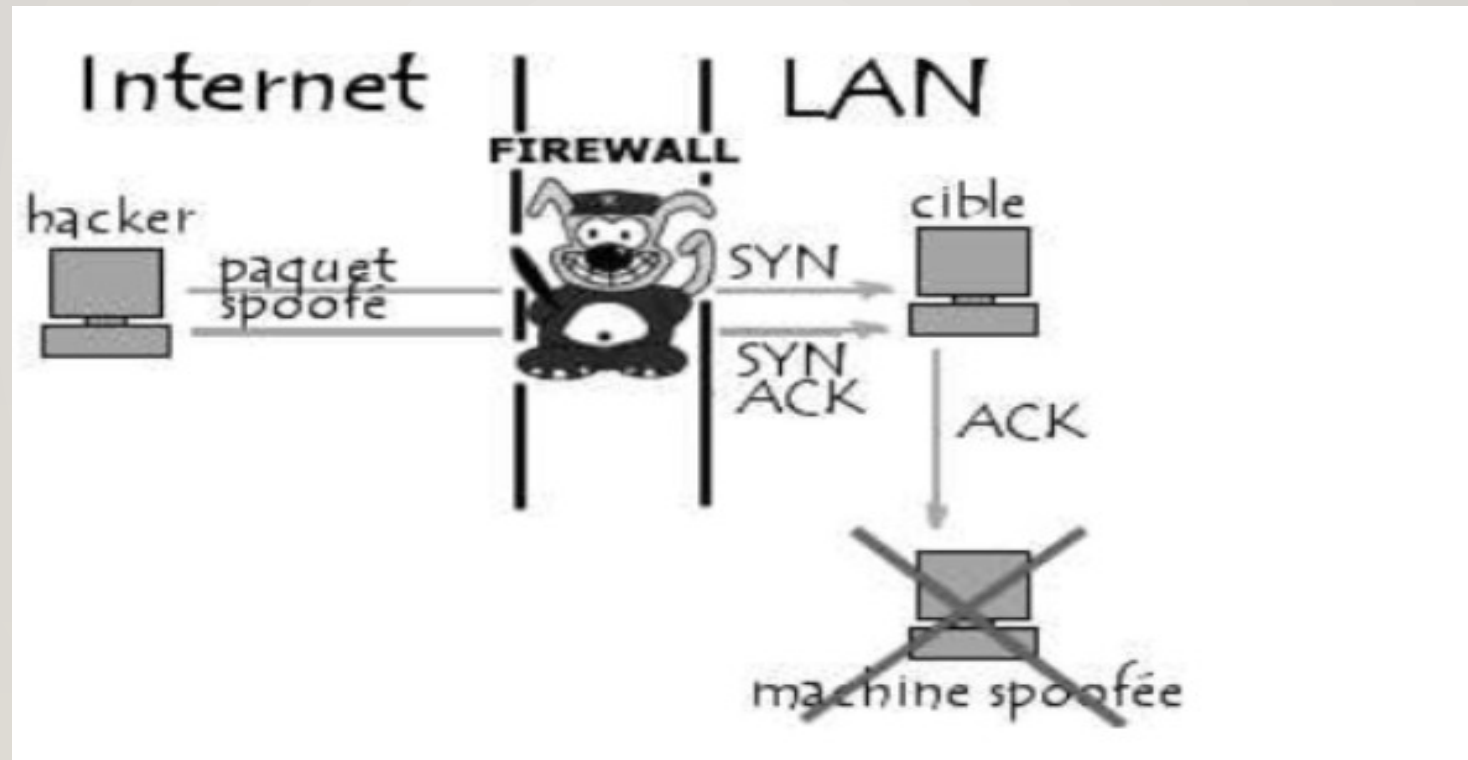
Première partie : Sécurité Informatique

77

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.3 Usurpation d'adresse IP



Première partie : Sécurité Informatique

78

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

Une attaque par déni de service (DoS, Denial of Service) est un type d'attaque visant à rendre indisponible pendant un temps indéterminé . les services ou ressources d'une organisation. Il s'agit la plupart du temps d'attaques à l'encontre des serveurs d'une entreprise, afin qu'ils ne puissent être utilisés et consultés.

Les attaques par déni de service sont un fléau pouvant toucher tout serveur d'entreprise ou tout particulier relié à Internet. Le but d'une telle attaque n'est pas de récupérer ou d'altérer des données, mais

De nuire à la réputation de sociétés ayant une présence sur Internet et éventuellement de nuire à leur fonctionnement si leur activité repose sur un système d'information. D'un point de vue technique, ces attaques ne sont pas très compliquées, mais ne sont pas moins efficaces contre tout type de machine possédant un système d'exploitation Windows (95, 98, NT, 2000, XP, etc.), Linux (Debian, Mandrake, RedHat, Suse, etc.), Unix commercial (HP-UX, AIX, IRIX, Solaris, etc.) ou tout autre système. La plupart des attaques par déni de service exploitent des failles liées à l'implémentation d'un protocole du modèle TCP/IP.

Première partie : Sécurité Informatique

79

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

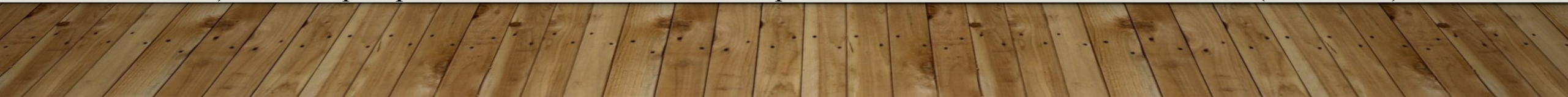
2.1.3 Attaque par déni de service

On distingue habituellement deux types de dénis de service :

- Les dénis de service par saturation, consistant à submerger une machine de requêtes, afin qu'elle ne soit plus capable de répondre aux requêtes réelles.
- Les dénis de service par exploitation de vulnérabilités, consistant à exploiter une faille du système distant afin de le rendre inutilisable.

Le principe de ces attaques consiste à envoyer des paquets IP ou des données de taille ou de constitution inhabituelle, afin de provoquer une saturation ou un état instable des machines victimes et de les empêcher ainsi d'assurer les services réseau qu'elles proposent.

Lorsqu'un déni de service est provoqué par plusieurs machines, on parle alors de déni de service distribué (DDoS, Distributed Denial of Service). Les attaques par déni de service distribué les plus connues sont Tribal Flood Network (notée TFN) et Trinoo.



Première partie : Sécurité Informatique

80

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

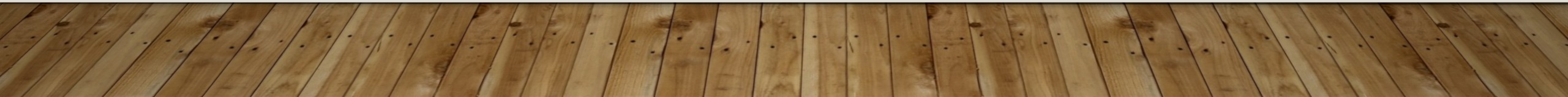
2.1.3 Attaque par déni de service

Attaque par réflexion

La technique dite attaque par réflexion (smurf) est une attaque par déni de service basée sur l'utilisation de serveurs de diffusion (broadcast) pour paralyser un réseau. Un serveur broadcast est un serveur capable de dupliquer un message et de l'envoyer à toutes les machines présentes sur le même réseau.

Le scénario d'une telle attaque est le suivant :

► La machine attaquante envoie une requête ping (ping est un outil exploitant le protocole ICMP, permettant de tester les connexions sur un réseau en envoyant un paquet et en attendant la réponse) à un ou plusieurs serveurs de diffusion en falsifiant l'adresse IP source (adresse à laquelle le serveur doit théoriquement répondre) et en fournissant l'adresse IP d'une machine cible.



Première partie : Sécurité Informatique

81

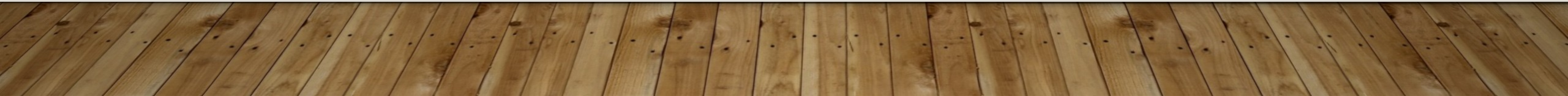
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

- Le serveur de diffusion répercute la requête sur l'ensemble du réseau.
- Toutes les machines du réseau envoient une réponse au serveur de diffusion.
- Le serveur broadcast redirige les réponses vers la machine cible.

Ainsi, lorsque la machine attaquante adresse une requête à plusieurs serveurs de diffusion situés sur des réseaux différents, l'ensemble des réponses des ordinateurs des différents réseaux vont être routées sur la machine cible.



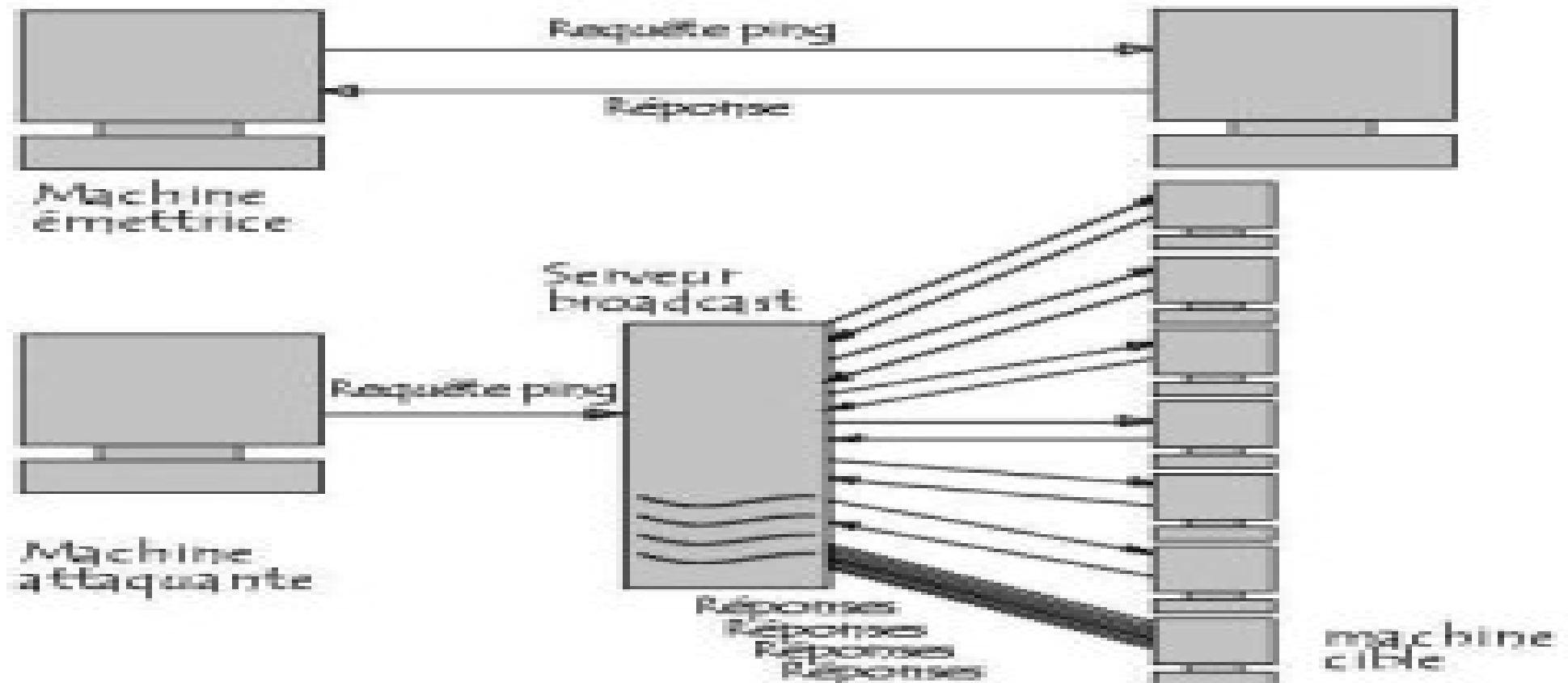
Première partie : Sécurité Informatique

82

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service



Première partie : Sécurité Informatique

83

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

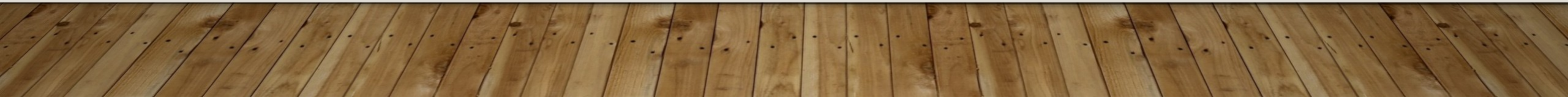
2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

De cette façon l'essentiel du travail de l'attaquant consiste à trouver une liste de serveurs de diffusion et à falsifier l'adresse de réponse afin de les diriger vers la machine cible.

Attaque par amplification

L'attaque par amplification est une variante de l'attaque par réflexion. Ces attaques n'utilisent pas une adresse de broadcast mais des mécanismes réseau plus complexes (les adresses de broadcast sont très surveillées par les pare-feu, et un réseau bien configuré ne permet plus d'exploiter ce genre de procédé). L'actualité récente (2015) a mis en avant une attaque très efficace qui consiste à utiliser des serveurs dont la réponse à une requête renvoie bien plus de données que la requête originale. C'est par exemple le cas des serveurs NTP (Network Time Protocol). Ces derniers sont chargés de donner l'heure sur le réseau (indispensable pour de nombreuses tâches des systèmes). Chaque serveur peut fournir une liste des ordinateurs qui sont connectés à lui.



Première partie : Sécurité Informatique

84

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

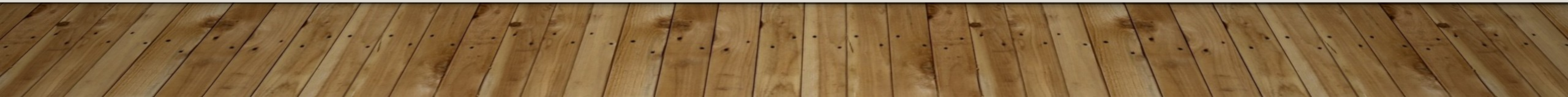
2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

Il suffit pour cela d'envoyer une commande. En forgeant une demande avec une adresse d'origine falsifiée, on peut très facilement générer un gros volume de données (environ 200 fois la taille du paquet original). En multipliant ces demandes et en faisant envoyer la réponse à la victime de l'attaque, on génère un flux très important. Ce type d'amplification a déjà été utilisé sur les protocoles DNS et SMTP avec des taux d'amplification allant jusqu'à 650 fois le flux original.

□ Parade

Lorsque les pirates informatiques utilisent en plus un botnet de taille importante, il devient très difficile d'échapper à de tels volumes de données, même pour des sites ou des services Internet connus. Comme souvent, la seule parade qui existe est la mise à jour des serveurs... lorsque les protocoles ont été corrigés. La multiplication des objets connectés risque de rendre ce genre d'attaques encore plus efficaces.



Première partie : Sécurité Informatique

85

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

Attaque du ping de la mort

L'attaque du ping de la mort (ping of death) est une des plus anciennes attaques de déni de service.

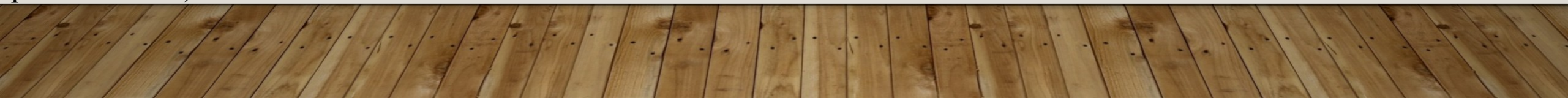
Le principe du ping de la mort consiste tout simplement à créer un datagramme IP dont la taille totale excède la taille maximum autorisée (65 536 octets). Un tel paquet envoyé à un système possédant une pile TCP/IP vulnérable, provoquera un plantage.

Plus aucun système récent n'est vulnérable à ce type d'attaque.

Attaque SYN

L'attaque SYN (appelée également TCP/SYN Flooding) est une attaque réseau par saturation (déni de service) exploitant le mécanisme de poignée de mains en trois temps (Three-ways handshake) du protocole TCP.

Le mécanisme de poignée de main en trois temps est la manière selon laquelle toute connexion « fiable » à Internet (utilisant le protocole TCP) s'effectue.



Première partie : Sécurité Informatique

86

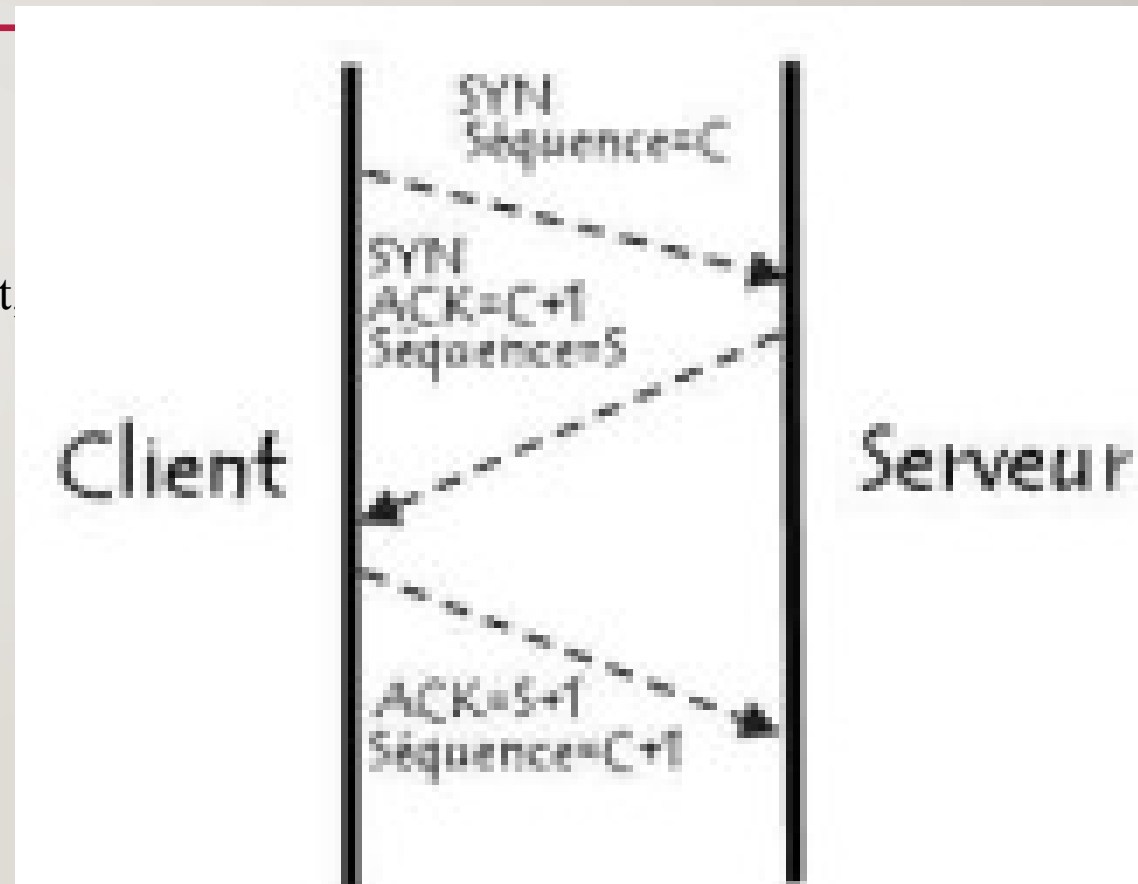
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

Lorsqu'un client établit une connexion à un serveur, le client envoie une requête SYN, le serveur répond alors par un paquet SYN/ACK et enfin le client valide la connexion par un paquet ACK (acknowledgement qui signifie accord ou remerciement).

Une connexion TCP ne peut s'établir que lorsque ces trois étapes ont été franchies. L'attaque SYN consiste à envoyer un grand nombre de requêtes SYN à un hôte avec une adresse IP source inexistante ou invalide. Ainsi, il est impossible que la machine cible reçoive un paquet ACK.



Première partie : Sécurité Informatique

87

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

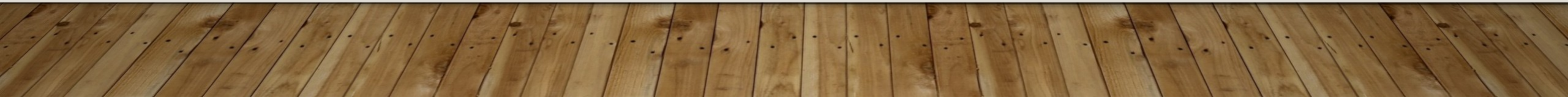
2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

Les machines vulnérables aux attaques SYN mettent en file d'attente, dans une structure de données en mémoire, les connexions ainsi ouvertes, et attendent de recevoir un paquet ACK. Il existe un mécanisme d'expiration permettant de rejeter les paquets au bout d'un certain délai. Néanmoins, avec un nombre de paquets SYN très important, si les ressources utilisées par la machine cible pour stocker les requêtes en attente sont épuisées, elle risque d'entrer dans un état instable pouvant conduire à un plantage ou un redémarrage.

Parades

Pour se protéger des attaques par déni de service, il est nécessaire de mener une veille active sur les nouvelles attaques et vulnérabilités et de récupérer sur Internet des correctifs logiciels (patches) conçus par les éditeurs de logiciels ou certains groupes spécialisés



Première partie : Sécurité Informatique

88

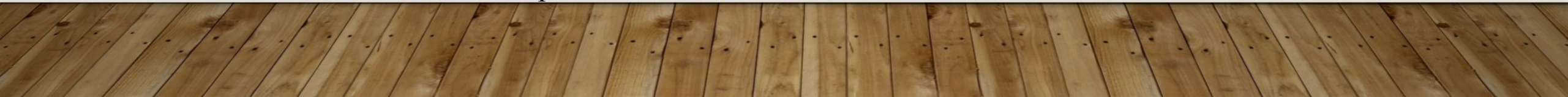
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.3 Attaque par déni de service

. Le logiciel Personal software inspector de Secunia (www.secunia.com) vous permettra de scanner votre ordinateur à la recherche des applications installées et de vérifier qu'il n'existe pas de mise à jour corrigeant une vulnérabilité. Cette application est d'autant plus précieuse que ce processus est automatisé. Pour les mises à jour des systèmes Windows, vous devrez utiliser les panneaux Windows Update intégré ou vous rendre sur le site windowsupdate.microsoft.com. Les attaques DDOS sont, elles, beaucoup plus redoutables. En effet, la multiplicité des sources rend le filtrage très complexe. Certains routeurs haut de gamme permettent de rediriger ces attaques vers une voie réseau sans issue (blackhole) et de réduire l'impact du déni de service. Malheureusement, les DDoS peuvent prendre la forme de requêtes tout à fait valides (ex. : des requêtes SQL aléatoires sur une base de données) et devenir complètement impossible à arrêter.

L'évolution du nombre d'attaque est toujours à la hausse. Selon le rapport de Prolexic.com, les attaques ont augmenté de 88 % entre le troisième trimestre 2012 et la même période en 2011.



Première partie : Sécurité Informatique

89

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

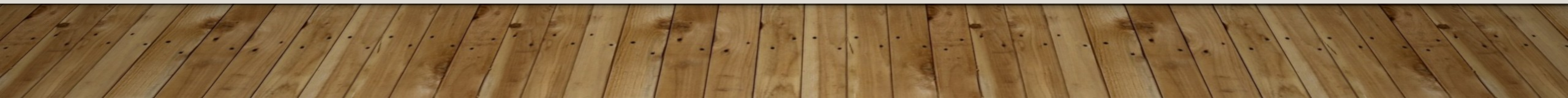
2.1.4 Attaque man in the middle

Une attaque man in the middle (littéralement « attaque de l'homme au milieu » ou « attaque de l'intercepteur »), parfois notée MITM, est un scénario d'attaque dans lequel un pirate écoute une communication entre deux interlocuteurs et falsifie les échanges afin de se faire passer pour l'une des parties. La plupart des attaques de type man in the middle consistent à écouter le réseau à l'aide d'outils d'écoute du réseau.

Attaque par rejeu

Les attaques par rejeu (replay attaque) sont des attaques de type man in the middle consistant à intercepter des paquets de données et à les rejouer, c'est-à-dire les retransmettre tels quel (sans aucun déchiffrement) au serveur destinataire.

Ainsi, selon le contexte, le pirate peut bénéficier des droits de l'utilisateur. Imaginons un scénario dans lequel un client transmet un nom d'utilisateur et un mot de passe chiffrés à un serveur afin de s'authentifier..



Première partie : Sécurité Informatique

90

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

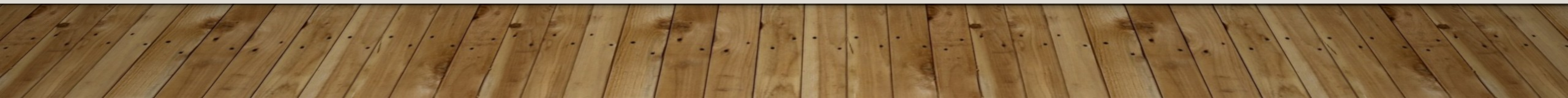
2.1.4 Attaque man in the middle

Si un pirate intercepte la communication (grâce à un logiciel d'écoute) et rejoue la séquence, il obtiendra alors les mêmes droits que l'utilisateur. Si le système permet de modifier le mot de passe, il pourra même en mettre un autre, privant ainsi l'utilisateur de son accès.

Attaque du protocole ARP

Une des attaques man in the middle les plus célèbres consiste à exploiter une faiblesse du protocole ARP (Address Resolution Protocol) dont l'objectif est de permettre de retrouver l'adresse IP d'une machine connaissant l'adresse physique (adresse MAC) de sa carte réseau.

L'objectif de l'attaque consiste à s'interposer entre deux machines du réseau et de transmettre à chacune un paquet ARP falsifié indiquant que l'adresse ARP (adresse MAC) de l'autre machine a changé, l'adresse ARP fournie étant celle de l'attaquant.



Première partie : Sécurité Informatique

91

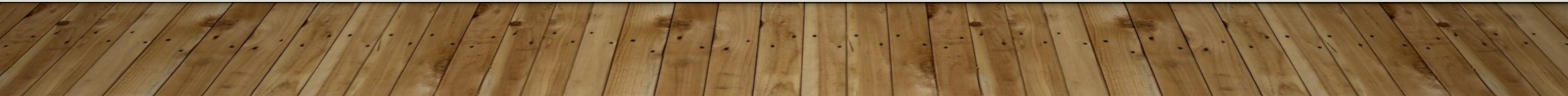
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.4 Attaque man in the middle

Les deux machines cibles vont ainsi mettre à jour leur table dynamique appelée cache ARP. On parle ainsi d'ARP cache poisoning (parfois ARP spoofing ou ARP redirect) pour désigner ce type d'attaque.

De cette manière, à chaque fois qu'une des deux machines souhaitera communiquer avec la machine distante, les paquets seront envoyés à l'attaquant, qui les transmettra de manière transparente à la machine destinatrice.



Première partie : Sécurité Informatique

92

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

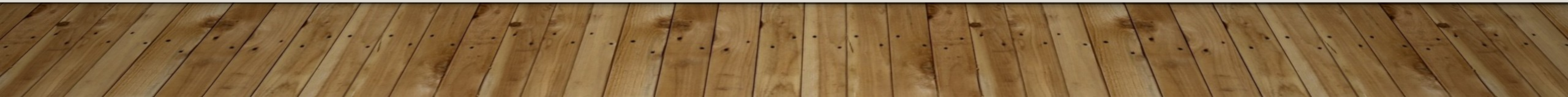
2.1 Présentation des failles sur l'internet

2.1.5 Attaque par débordement de tampon

Les attaques par débordement de tampon (buffer overflow, parfois également appelées dépassement de tampon) ont pour principe l'exécution de code arbitraire par un programme en lui envoyant plus de données qu'il n'est censé en recevoir.

En effet, les programmes acceptant des données en entrée, passées en paramètre, les stockent temporairement dans une zone de la mémoire appelée tampon (buffer). Or, certaines fonctions de lecture, telles que les fonctions strcpy() du langage C, ne gèrent pas ce type de débordement et provoquent un plantage de l'application pouvant aboutir à l'exécution du code arbitraire et ainsi donner un accès au système.

La mise en œuvre de ce type d'attaque est très compliquée car elle demande une connaissance fine de l'architecture des programmes et des processeurs. Néanmoins, il existe de nombreux exploits capables d'automatiser ce type d'attaque et la rendant à la portée de quasinéophytes.



Première partie : Sécurité Informatique

93

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.5 Attaque par débordement de tampon

Principe de fonctionnement

Le principe de fonctionnement d'un débordement de tampon est fortement lié à l'architecture du processeur sur lequel l'application vulnérable est exécutée.

Les données saisies dans une application sont stockées en mémoire vive dans une zone appelée tampon. Un programme correctement conçu doit prévoir une taille maximale pour les données en entrées et vérifier que les données saisies ne dépassent pas cette valeur.

Les instructions et les données d'un programme en cours d'exécution sont provisoirement stockées en mémoire de manière contiguë dans une zone appelée pile (stack). Les données situées après le tampon contiennent ainsi une adresse de retour (appelée pointeur d'instruction) permettant au programme de continuer son exécution. Si la taille des données est supérieure à la taille du tampon, l'adresse de retour est alors écrasée et le programme lira une adresse mémoire invalide provoquant une faute de segmentation (segmentation fault) de l'application.

Première partie : Sécurité Informatique

94

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

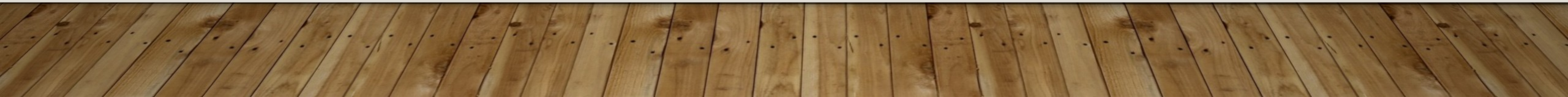
2.1 Présentation des failles sur l'internet

2.1.5 Attaque par débordement de tampon

Un pirate ayant de bonnes connaissances techniques peut s'assurer que l'adresse mémoire écrasée correspond à une adresse réelle, par exemple située dans le tampon lui-même. Ainsi, en écrivant des instructions dans le tampon (code arbitraire), il lui est simple de l'exécuter. Il est ainsi possible d'inclure dans le tampon des instructions ouvrant un interpréteur de commande (shell) et permettant au pirate de prendre la main sur le système. Ce code arbitraire permettant d'exécuter l'interpréteur de commande est appelé shellcode.

Shellcode

Les shellcodes¹ sont des chaînes de caractères qu'un pirate tente d'injecter dans la mémoire d'un ordinateur lors d'un dépassement de tampon mémoire. Ils ont pour objectif de lancer un shell (command.com sous Windows, sh sous Linux) et de lui envoyer ensuite des commandes pour prendre le contrôle d'un ordinateur. L'écriture de shellcode est réservée à des programmeurs connaissant parfaitement le langage machine et est dépendante des jeux d'instructions contenus dans le processeur de l'ordinateur.



Première partie : Sécurité Informatique

95

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.5 Attaque par débordement de tampon

Parades

Pour se protéger de ce type d'attaques, il est nécessaire de développer des applications à l'aide de langages de programmation évolués assurant une gestion fine de la mémoire allouée ou bien à l'aide de langages de bas niveau en utilisant des bibliothèques de fonctions sécurisées (par exemple les fonctions `strncpy()`). Des bulletins d'alerte sont régulièrement publiés, annonçant la vulnérabilité de certaines applications à des attaques par débordement de tampon. À la suite de ces bulletins d'alerte, les éditeurs des logiciels touchés par la vulnérabilité publient généralement des correctifs (patches) permettant de corriger la faille. Tout administrateur système et réseau se doit de se tenir informé des alertes de sécurité et d'appliquer le plus rapidement possible les correctifs. Les processeurs et les systèmes d'exploitation comportent des modules de protection qui rendent plus difficile l'exploitation des débordements de tampon mémoire. Deux mécanismes sont à l'œuvre : DEP (Data Execution Prevention) et ASLR (Address Space Layout Randomization)

Première partie : Sécurité Informatique

96

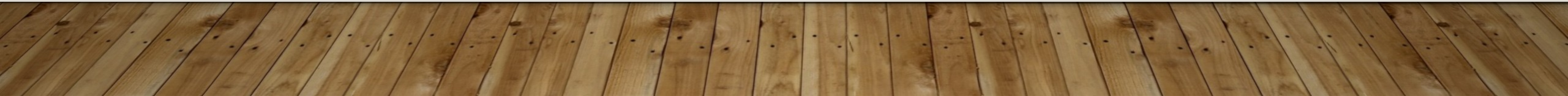
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.5 Attaque par débordement de tampon

DEP interdit l'exécution d'un code dépassant la mémoire allouée à un programme. ASLR permet de rendre aléatoire l'attribution de plage de mémoire à des applications.

Ainsi, un programme très courant ne prendra pas les mêmes adresses mémoire d'un ordinateur à un autre, ce qui rend plus complexe l'exploitation d'une faille par un programme malveillant.



Première partie : Sécurité Informatique

97

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

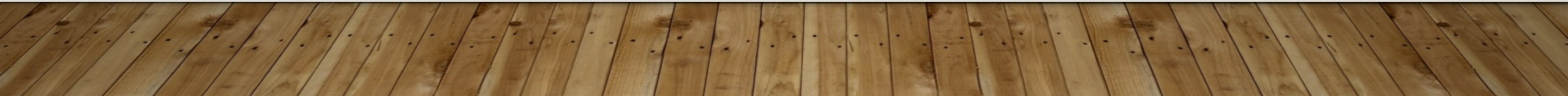
2.1 Présentation des failles sur l'internet

2.1.6 Attaques APT

Attaques APT (Advanced Persistent Threat)

Ce type d'attaques est une attaque très ciblée (sur un individu ou une entreprise, une organisation). Il concerne des dirigeants de société, des personnes influentes (diplomates, hommes politiques) ou possédant des informations stratégiques. Les APT combinent de nombreuses techniques et n'ont pas forcément un but lucratif.

On peut notamment citer les enregistreurs de clavier (keylogger). Ce type d'attaques est qualifié de persistant car, dans la plupart des cas, l'objectif des pirates est de recueillir des informations sur le long terme. Les systèmes sont donc infiltrés de manière très discrète et des portes dérobées sont laissées pour des infiltrations ultérieures. Les APT peuvent aussi utiliser des portes dérobées introduites volontairement dans certains matériels réseau (routeur/switch...).



Première partie : Sécurité Informatique

98

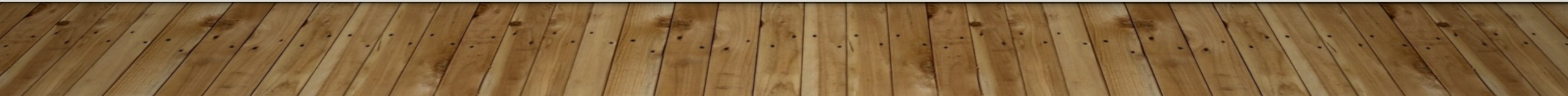
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.6 Attaques APT

☐ Les parades

Les attaques APT sont par définition très difficiles à identifier. Des outils de type « honeypot » (ordinateur volontairement vulnérable) permettent de détecter les intrusions. Les pare-feu de nouvelles générations peuvent aussi aider à diagnostiquer ce type d'attaques.



Première partie : Sécurité Informatique

99

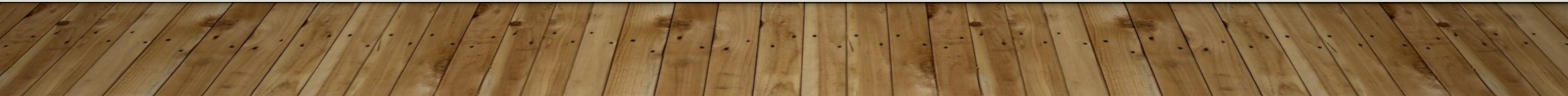
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Attaque par ingénierie sociale

L'ingénierie sociale apparaît comme outil dans la panoplie des hackers. Elle lui permet parfois de pallier à l'absence de faille et d'extirper des informations de l'utilisateur d'un ordinateur sans que ce dernier n'ait conscience d'ouvrir son PC à une personne non désirée.

Outre la récupération de post-it sur l'écran, la lecture de listing dans les poubelles d'une entreprise, l'usurpation d'identité au téléphone, l'ingénierie sociale est un « sport » qui tend à se développer grâce à l'explosion des réseaux sociaux et à la généralisation de la VoIP.



Première partie : Sécurité Informatique

100

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Attaque par ingénierie sociale

Réseaux sociaux

Du rang de simple outil, l'ingénierie sociale est devenue, grâce à ces réseaux et aux blogs personnels, un véritable vecteur d'attaque. Pour s'en convaincre, le mieux est d'évoquer une affaire qui a secoué la campagne électorale américaine de 2008. En effet, la colistière du candidat John McCain, Sarah Palin a été victime du piratage de son compte e-mail hébergé chez Yahoo!. Les hackers ne se sont pas attaqués aux serveurs d'un des géants du Web, ni à la machine de Mme Palin. Ils ont tout simplement utilisé le système de récupération de mot de passe de Yahoo! mail. Ce système permet de réinitialiser son mot de passe en indiquant des données personnelles : la ville de naissance de sa mère, le nom de son chien... des données relativement difficiles à trouver quand il s'agit du compte d'un simple quidam mais très simples à récupérer dans le cas d'une personne très connue. Le mot de passe réinitialisé a été envoyé à une adresse email contrôlée par un pirate et il a eu alors accès au compte de celle qui aurait pu devenir la vice-présidente des États-Unis...

Première partie : Sécurité Informatique

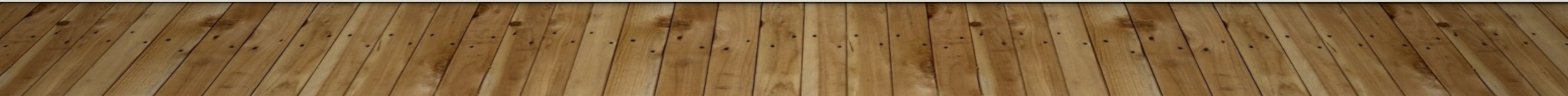
101

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Attaque par ingénierie sociale

Les réseaux sociaux et leur capacité à collecter des données personnelles sont donc un paradis pour les pirates : ils peuvent connaître le nom des salariés d'une entreprise, le nom de leurs amis, leur degré d'intimité, leurs coordonnées... des données qui leur permettront de trouver des mots de passe ou de se faire passer pour eux



Première partie : Sécurité Informatique

102

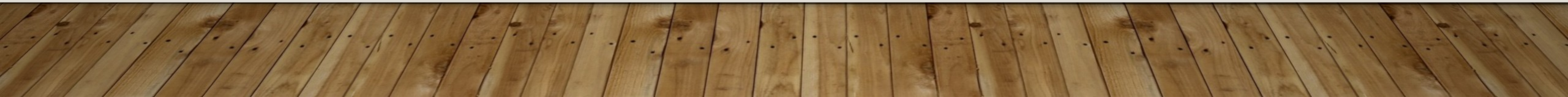
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Attaque par ingénierie sociale

Attaque par watering hole

Cette technique d'attaque repose à la fois sur l'exploitation de failles informatiques et l'utilisation de social engineering. Elle consiste à déterminer les services en ligne et les sites web utilisés par une entreprise (ou par leurs salariés) pour ensuite s'y introduire. L'attaque a donc lieu en deux temps : dans un premier temps, le pirate va devoir s'introduire dans l'un des sites ou services utilisé par l'entreprise. Il peut par exemple insérer un contenu web malveillant sur un site web qui ne sera visible que pour les internautes provenant de l'entreprise visée (en ciblant les adresses IP pour qui ce contenu doit apparaître). Une fois le fichier malveillant téléchargé, le pirate pourra alors s'attaquer aux infrastructures de la véritable cible ou récupérer les informations renvoyées par son programme.



Première partie : Sécurité Informatique

103

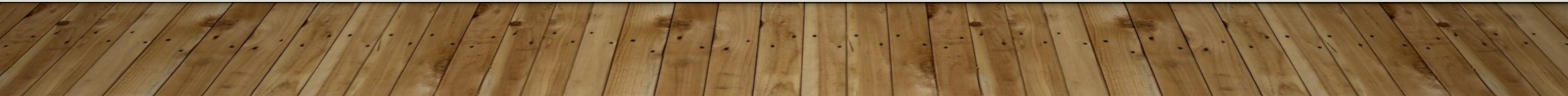
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Attaque par ingénierie sociale

☐ Les parades

Se soustraire à ce type d'attaque est compliqué car on ne maîtrise pas la sécurité de la première cible. En revanche, comme il ne peut s'agir que d'une attaque réseau, les systèmes de protection (IDS, système de détection d'intrusion) peuvent analyser les données envoyées et empêcher l'arrivée de fichiers malveillants. La mise à jour des composants du navigateur web, son placement dans une sandbox ou la protection par des applications de sécurité peuvent réduire les possibilités d'attaque.



Première partie : Sécurité Informatique

104

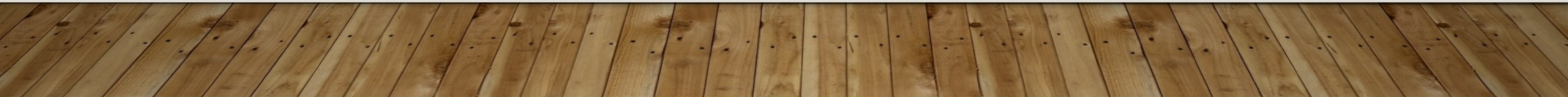
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Les logiciels malveillants

Un logiciel malveillant ou maliciel, aussi dénommé logiciel nuisible ou programme malveillant ou pourriel (« malware » en anglais), est un programme développé dans le but de nuire à un système informatique, sans le consentement de l'utilisateur dont l'ordinateur est infecté. De nos jours, le terme « virus » est souvent employé, à tort, pour désigner toutes sortes de logiciels malveillants. En effet, les maliciels englobent les virus, les vers, les chevaux de Troie, ainsi que d'autres menaces. La catégorie des virus informatiques, qui a longtemps été la plus répandue, a cédé sa place aux chevaux de Troie en 2005. Les logiciels malveillants peuvent être classés en fonction des trois mécanismes suivants :

↳ le mécanisme de propagation (par exemple, un ver se propage sur un réseau informatique en exploitant une faille applicative ou humaine) ;



Première partie : Sécurité Informatique

105

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

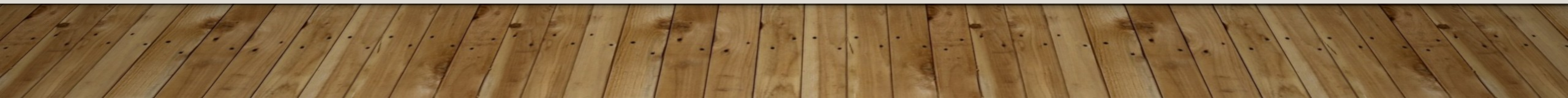
2.1.7 Les logiciels malveillants

↳ le mécanisme de déclenchement (par exemple, la bombe logique comme la bombe logique surnommée vendredi 13 se déclenche lorsqu'un événement survient) ;

↳ la charge utile (par exemple, le virus Tchernobyl tente de supprimer des parties importantes du BIOS, ce qui bloque le démarrage de l'ordinateur infecté).

La classification n'est pas parfaite, et la différence entre les classes n'est pas toujours évidente. Cependant, c'est aujourd'hui la classification standard la plus couramment adoptée dans les milieux internationaux de la sécurité informatique.

Dans une publication, J. Rutkowska propose une taxonomie qui distingue les logiciels malveillants suivant leur mode de corruption du noyau du système d'exploitation : ne touche pas au noyau (applications, micrologiciel), corruption d'éléments fixes (code), corruption d'éléments dynamiques (données) et au-dessus du noyau (hyperviseurs).



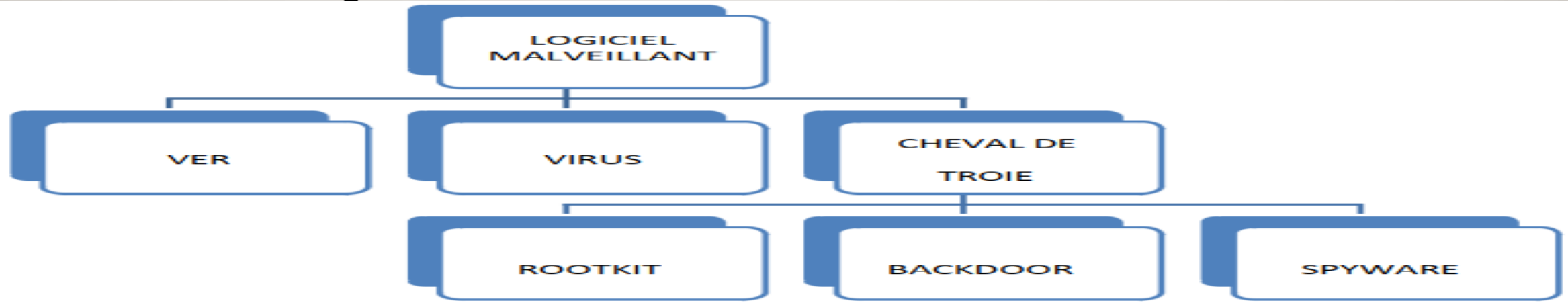
Première partie : Sécurité Informatique

106

Chapitre 2 : Faible la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.7 Les logiciels malveillants



Les programmes malveillants ont été développés pour de nombreux systèmes d'exploitation et applications. Pourtant, certains d'entre eux n'ont jamais été concernés. En effet, les auteurs de virus privilégient les systèmes d'exploitation largement utilisés ; les systèmes comportant des vulnérabilités ; et ceux pour lesquels une documentation détaillée est disponible (puisqu'elle inclut des descriptions des services et des règles en vigueur pour écrire des programmes compatibles). Le volume de logiciels malveillants destinés à Windows et Linux est à peu près proportionnel à leurs parts de marché respectives.

Première partie : Sécurité Informatique

107

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

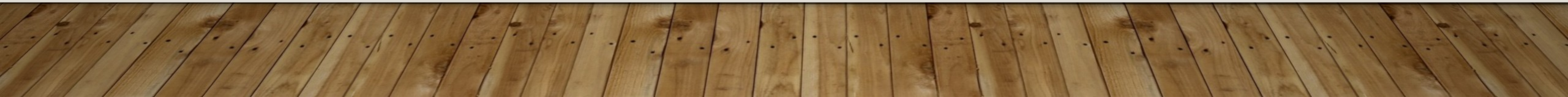
2.1.8 Les virus informatiques

Un virus informatique est un automate auto répliatif à la base non malveillant, mais aujourd'hui souvent additionné de code malveillant (donc classifié comme logiciel malveillant) conçu pour se propager à d'autres ordinateurs en s'insérant dans des logiciels légitimes, appelés « hôtes ». Il peut perturber plus ou moins gravement le fonctionnement de l'ordinateur infecté.

Il peut se répandre par tout moyen d'échange de données numériques comme les réseaux informatiques et le CD-ROM, les clefs USB, les disques durs, etc.

Tout comme le virus biologique, le virus informatique poursuit 3 objectifs :

- ↳ se dissimuler le plus longtemps possible aux yeux de l'utilisateur infecté ;
- ↳ Il contamine tout ce qui est à sa portée ;
- ↳ Il tente de se répandre, sans se cantonner au support sur lequel il se trouve.



Première partie : Sécurité Informatique

108

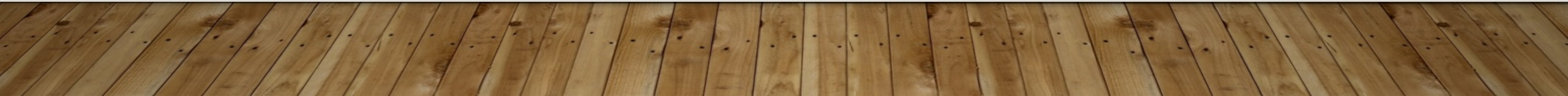
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

Sur Internet, les virus peuvent contaminer une machine de plusieurs manières :

- ↳ Téléchargement de logiciel puis exécution de celui-ci sans précautions ;
- ↳ Ouverture sans précautions de documents contenant des macros ;
- ↳ Pièce jointe de courrier électronique (exécutable, script type vbs...) ;
- ↳ Ouverture d'un courrier au format HTML contenant du javascript exploitant une faille de sécurité du logiciel de courrier;
- ↳ Exploitation d'un bug du logiciel de courrier (effectuer souvent les mises à jour).



Première partie : Sécurité Informatique

109

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

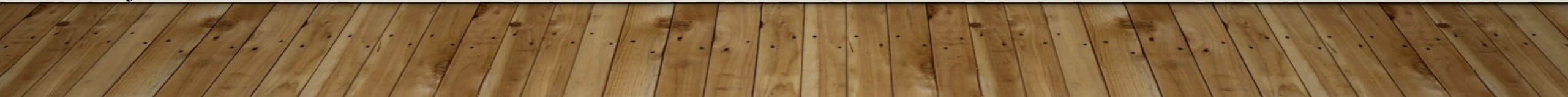
2.1.8 Les virus informatiques

L'appellation « virus informatique » provient d'une analogie avec le virus biologique puisqu'il présente des similitudes dans sa manière de se propager en utilisant les facultés de reproduction de la cellule hôte. On attribue le terme à l'informaticien et spécialiste en biologie moléculaire Leonard Adleman. Les virus informatiques ne doivent pas être confondus avec les vers informatiques, qui sont des programmes capables de se propager et de se dupliquer par leurs propres moyens sans contaminer de programme hôte. Au sens large, on utilise souvent et abusivement le mot virus pour désigner toute forme de logiciel malveillant.

Voici les quelques virus les plus célèbres du monde informatique :

--Cabir est considéré comme le tout premier virus informatique proof of concept recensé se propageant par la téléphonie mobile grâce à la technologie Bluetooth et du système d'exploitation Symbian OS.

--MyDoom.A est un virus informatique qui se propage par les courriels et le service P2P de Kazaa. Les premières infections ont eu lieu le 26 janvier 2004.



Première partie : Sécurité Informatique

110

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

- Psybot est un virus informatique découvert en janvier 2009. Il est considéré comme étant le seul virus informatique ayant la capacité d'infecter les routeurs et modem haut-débit.
- Le virus Tchernobyl ou CIH est connu pour avoir été un des plus destructeurs. Il détruisait l'ensemble des informations du système attaqué et parfois il rendait la machine quasiment inutilisable. Il a sévi de 1998 à 2002.
- Le ver Conficker exploite une faille du Windows Server Service utilisé par Windows 2000, Windows XP, Windows Vista, Windows 7, Windows Server 2003 et Windows Server 2008.
- Cryptolocker est un logiciel malveillant dont la présence sur le web a augmenté de 700 % entre 2012 et 2014. Selon les calculs du FBI en juin 2014, il a causé pour 27 millions de dollars de pertes aux utilisateurs. Sous couvert d'une mise à jour Adobe Flash, le logiciel malveillant chiffre les fichiers des victimes et exige un paiement (pouvant aller de 100 dollars à 400 dollars) pour les décrypter2.

Première partie : Sécurité Informatique

111

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--Zeus Bot est responsable d'environ 4 millions d'infections rien qu'aux États-Unis. Il a provoqué pour 70 millions de dollars de pertes pour les entreprises et consommateurs américains avant d'être démantelé par le FBI début 2014. Il exploite les vulnérabilités présentes dans Adobe Reader et Adobe Flash pour infecter les machines

Première partie : Sécurité Informatique

112

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

CARACTERISTIQUES DES VIRUS

--le **chiffrement** - à chaque réplique, le virus est chiffré (afin de dissimuler les instructions qui, si elles s'y trouvaient en clair, révéleraient la présence de ce virus ou pourraient indiquer la présence de code suspect) ;

--le **polymorphisme** - le virus est chiffré et la routine de déchiffrement est capable de changer certaines de ses instructions au fil des répliques afin de rendre plus difficile la détection par l'antivirus ;

--le **métamorphisme** - contrairement au chiffrement simple et au polymorphisme, où le corps du virus ne change pas et est simplement chiffré, le métamorphisme permet au virus de modifier sa structure même et les instructions qui le composent ;

--la **furtivité** - le virus « trompe » le système d'exploitation (et par conséquent les logiciels antivirus) sur l'état des fichiers infectés. Des rootkits permettent de créer de tels virus. Par exemple, l'exploitation d'une faille de sécurité au niveau des répertoires permet de masquer l'existence de certains fichiers exécutables ainsi que les processus qui leur sont associés.

Première partie : Sécurité Informatique

113

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

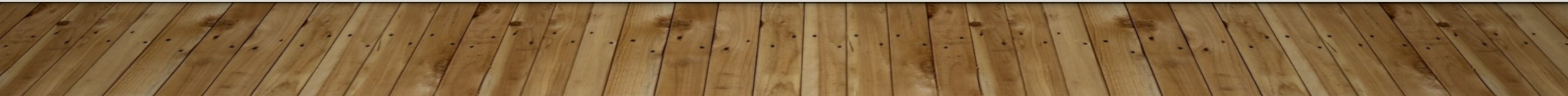
2.1.8 Les virus informatiques

CLASSIFICATION DES VIRUS

Il n'existe pas de classification stricte des virus. Cependant on peut en retenir 4 grandes classifications :

- ↳ Classification selon le format visé (exécutable ou documents) ;
- ↳ Classification selon leur comportement (rapide, lent, résident, polymorphe...)
- ↳ Classification selon l'organe visé (boot sector, driver...) ;
- ↳ Classification selon le langage utilisé (virus assembleur, macrovirus, virus interprété...).

C'est grâce à cette classification que nous pouvons maintenant en mesure de distinguer les différents types de virus qui existent :



Première partie : Sécurité Informatique

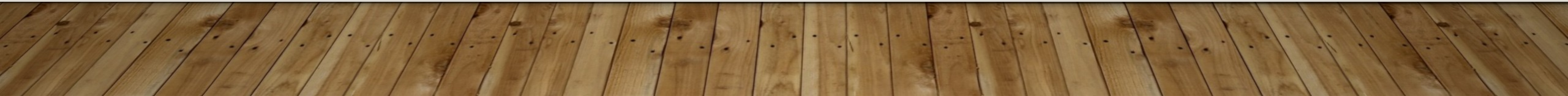
114

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Le virus classique** - est un morceau de programme, souvent écrit en assembleur, qui s'intègre dans un programme normal (le Cheval de Troie), le plus souvent à la fin, mais cela peut varier. Chaque fois que l'utilisateur exécute ce programme « infecté », il active le virus qui en profite pour aller s'intégrer dans d'autres programmes exécutables. De plus, lorsqu'il contient une charge utile, il peut, après un certain temps (qui peut être très long) ou un événement particulier, exécuter une action prédéterminée. Cette action peut aller d'un simple message anodin à la détérioration de certaines fonctions du système d'exploitation ou la détérioration de certains fichiers ou même la destruction complète de toutes les données de l'ordinateur. On parle dans ce cas de « bombe logique » et de « charge utile ».



Première partie : Sécurité Informatique

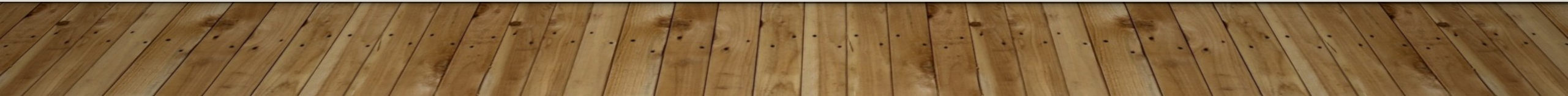
115

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Un virus de boot** - s'installe dans un des secteurs de boot d'un périphérique de démarrage, disque dur (le secteur de boot principal, le « Master boot record », ou celui d'une partition), disquette, ou autre. Il remplace un chargeur d'amorçage (ou programme de démarrage ou « bootloader ») existant (en copiant l'original ailleurs) ou en crée un (sur un disque où il n'y en avait pas) mais ne modifie pas un programme comme un virus normal ; quand il remplace un programme de démarrage existant, il agit un peu comme un virus « prepender » (qui s'insère au début), mais le fait d'infecter aussi un périphérique vierge de tout logiciel de démarrage le distingue du virus classique, qui ne s'attaque jamais à « rien ».



Première partie : Sécurité Informatique

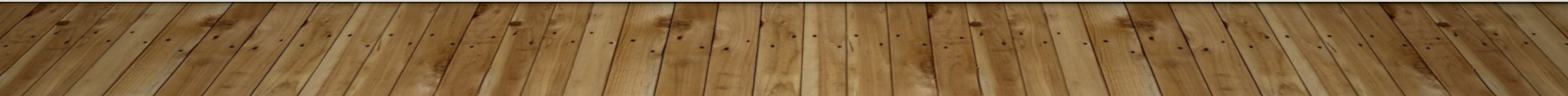
116

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les macro virus** - qui s'attaquent aux macros de logiciels de la suite Microsoft Office (Word, Excel, etc.) grâce au VBA de Microsoft. Par exemple, en s'intégrant dans le modèle normal.dot de Word, un virus peut être activé à chaque fois que l'utilisateur lance ce programme.



Première partie : Sécurité Informatique

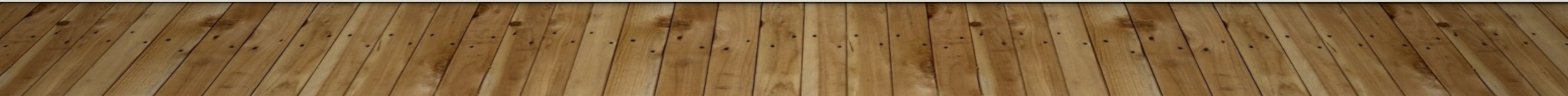
117

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus-vers** - apparus aux environs de l'année 2003, ayant connu un développement fulgurant dans les années qui suivirent, sont des virus classiques car ils ont un programme hôte. Mais s'apparentent aux vers (en anglais « worm ») car : Leur mode de propagation est lié au réseau, comme des vers, en général via l'exploitation de failles de sécurité. Comme des vers, leur action se veut discrète, et non destructrice pour les utilisateurs de la machine infectée. Comme des vers, ils poursuivent des buts à visée large, tels que l'attaque par saturation des ressources ou attaque DoS (Denial of Service) d'un serveur par des milliers de machines infectées se connectant simultanément.



Première partie : Sécurité Informatique

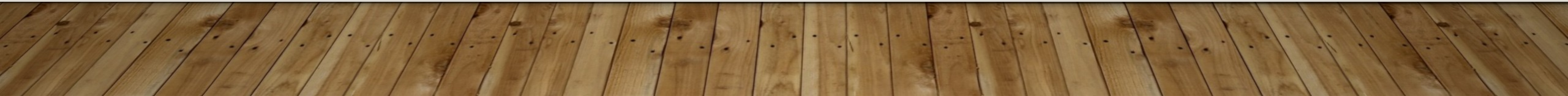
118

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus de type batch** - apparu à l'époque où MS-DOS était le système d'exploitation en vogue, sont des virus « primitifs ». Bien que capables de se reproduire et d'infecter d'autres fichiers batch, ils sont lents et ont un pouvoir infectant très faible. Certains programmeurs ont été jusqu'à créer des virus batch cryptés et polymorphes, ce qui peut être qualifié de « prouesse technique » tant le langage batch est simple et primitif.



Première partie : Sécurité Informatique

119

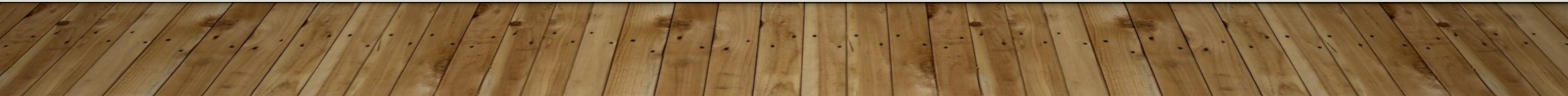
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus résidents** - Ils se placent en mémoire RAM et contaminent les fichiers au fur et à mesure de leurs exécutions. Ils peuvent par exemple prendre la forme de fichier pilote de Windows (.vxd). Ils sont alors chargés dès le démarrage du système, avant le chargement de l'antivirus.

--**Les virus lents** - A la différence d'un virus rapide qui infecte les fichiers dès qu'ils sont manipulés par le système, les virus lents n'infectent les fichiers qu'en cas de modification, ce qui rend leur détection plus subtile.



Première partie : Sécurité Informatique

120

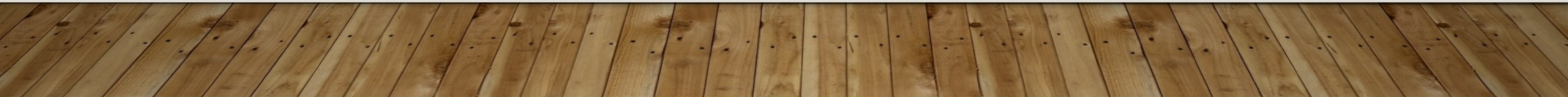
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus furtifs** - Un virus furtif est un virus qui, lorsqu'il est actif, dissimule les modifications apportées aux fichiers ou aux secteurs de boot. En règle générale, ce phénomène est rendu possible par le virus qui observe les appels aux fonctions de lecture des fichiers et falsifie les résultats renvoyés par ces fonctions. Cette méthode permet au virus de ne pas être détecté par les utilitaires anti-virus qui recherchent des modifications éventuelles apportées aux fichiers. Néanmoins, pour que cela soit possible, le virus doit être actif en mémoire résidente, ce qui est détectable par les anti-virus.

--**Les virus polymorphes** - Un virus polymorphe est un virus qui produit des copies variées de lui-même, mais qui restent opérationnelles. Ces stratégies ont été employées dans l'espoir que les utilitaires anti-virus ne puissent pas détecter toutes les variantes du virus.



Première partie : Sécurité Informatique

121

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

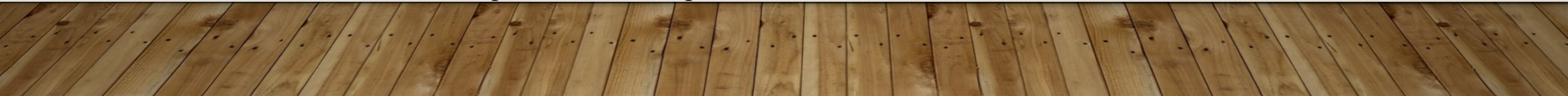
2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus « cavité »** - Les virus cavités sont des virus qui écrasent une partie du fichier hôte qui est constitué d'une constante (en général, des 0) sans augmenter la taille du fichier et tout en préservant sa fonctionnalité.

Les virus compagnons - Un virus compagnon est un virus qui, au lieu de modifier un fichier existant, crée un nouveau programme qui est exécuté à l'insu de l'utilisateur au lieu du programme voulu. Le programme original est ensuite exécuté de telle sorte que tout apparaît normal à l'utilisateur. Sur un PC, ceci est généralement accompli en créant un nouveau fichier .COM portant le même nom que le fichier .EXE. Les anti-virus qui ne cherchent que les modifications apportées aux fichiers existants (vérificateurs d'intégrité) ne détecteront pas ce type de virus.

--**Les virus blindés** - Un virus blindé est un virus qui utilise des astuces spéciales pour que son dépistage, son désassemblage et la compréhension de son code soient plus durs. Ils utilisent certaines ruses techniques pour mieux résister au désassemblage et à la détection et rendre leur fonctionnement quasiment incompréhensible.



Première partie : Sécurité Informatique

122

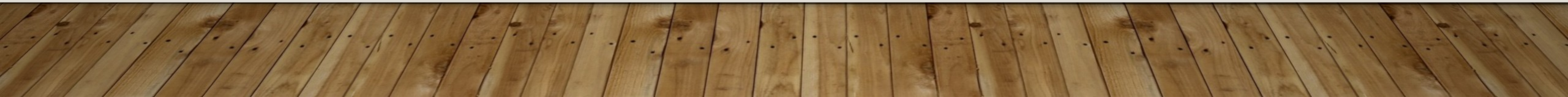
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les virus souterrains** - Les virus souterrains sont des virus qui appellent directement les vecteurs d'interruption du DOS et du BIOS, contournant ainsi tout programme de contrôle qui pourrait être chargé et avoir intercepté ces mêmes vecteurs dans le but de détecter l'activité d'un virus. Certains anti-virus utilisent cette même technique pour contourner un virus inconnu ou non détecté.

--**Les virus compte-gouttes** - Un virus compte-gouttes est un programme conçu pour installer un virus sur le système visé. Le code du virus est en règle générale contenu dans ce programme de telle manière qu'il ne sera pas détecté par un anti-virus qui, dans d'autres circonstances, détecte ce virus (le compte-gouttes n'est pas infecté par ce virus). Bien qu'assez rare, ce type de virus a été signalé à plusieurs reprises. Un compte-gouttes est en fait un cheval de Troie dont le but est d'installer le virus. Un compte-gouttes qui installe le virus seulement en mémoire (donc sans infecter de fichiers sur le disque) est parfois appelé un injecteur.



Première partie : Sécurité Informatique

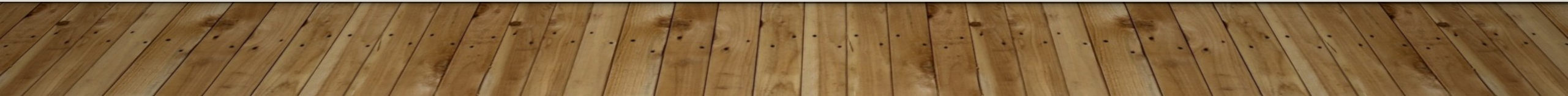
123

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

--**Les bombes ANSI** - Une bombe ANSI est une séquence de caractères, généralement incluse dans un fichier texte, qui reprogramme certaines fonctions du clavier d'ordinateurs ayant une console ANSI (écran + clavier). On peut ainsi reprogrammer la touche Enter d'un clavier pour qu'elle exécute l'instruction format c : suivi de la fonction Enter. Néanmoins, cette possibilité ne constitue pas une grande menace. En effet, il est rare pour un logiciel moderne d'exiger un ordinateur tournant sur une console ANSI. De même, peu de gens utilisent des logiciels qui envoient simplement la sortie sur le terminal, donc une bombe ANSI dans un email ne reprogrammerait pas votre clavier.



Première partie : Sécurité Informatique

124

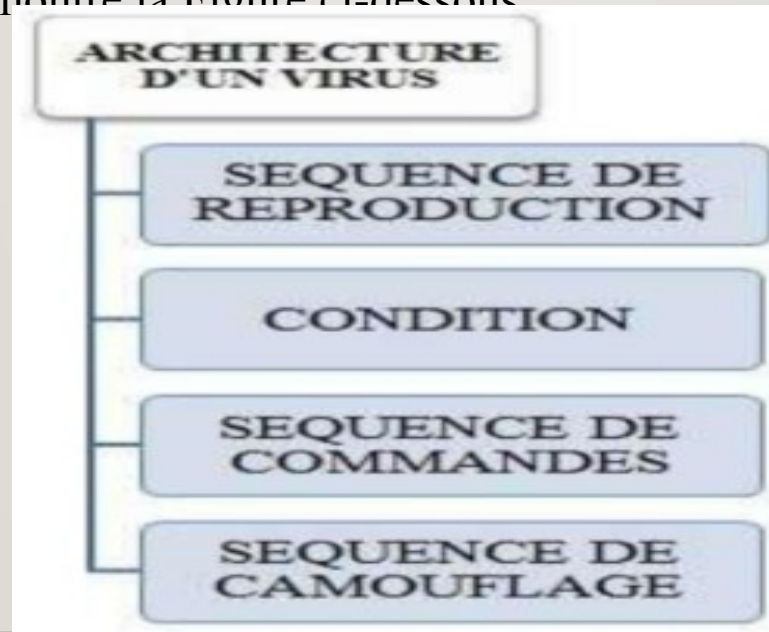
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

ARCHITECTURE D'UN VIRUS

Un virus se compose de 3 fonctionnalités principales et d'une quatrième optionnelle (mais de plus en plus présente dans les virus afin d'en améliorer l'efficacité), comme le montre la Figure ci-dessous :



Première partie : Sécurité Informatique

125

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

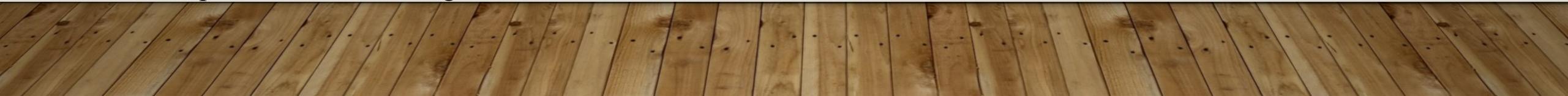
2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

↳ **Séquence de reproduction** - C'est l'objectif premier du virus. Elle inclut une fonctionnalité de recherche, qui permet de rechercher des fichiers à infecter. Elle permet aussi au virus de vérifier d'abord que le fichier n'est pas déjà infecté, pour ne l'infecter que le cas échéant. En effet, un virus ne doit pas se reproduire deux fois dans un fichier, car son comportement serait alors faussé.

↳ **Condition** - Il s'agit tout simplement de la partie qui va cordonner le lancement de l'action qu'est censé accomplir le virus. En effet, le virus a toujours un objectif précis. C'est la séquence de commande (ou de destruction) qui est chargée de cette action. Elle est déclenchée lorsque la condition est satisfaite. Cette dernière peut-être de diverses forme (une date, une action particulière de l'utilisateur, une réaction spécifique de l'ordinateur...). Les développeurs de virus font preuve de toujours plus d'imagination pour trouver des conditions de déclenchement de plus en plus originales et spécifiques.

Cette condition peut aussi être à l'origine du bon fonctionnement ou non du virus.



Première partie : Sécurité Informatique

126

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

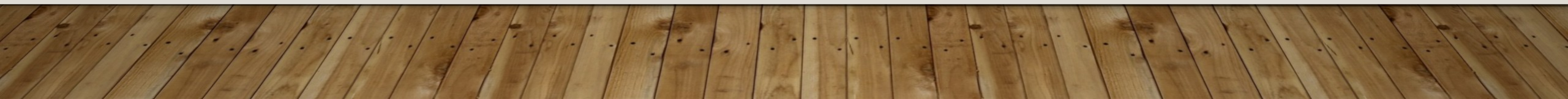
2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

↳ **Séquence de commandes** - Comme nous venons de le dire, c'est elle qui effectue l'action du virus. Cela peut être détruire des fichiers, formater une partition...

↳ **Séquence de camouflage** - Malgré leur petite taille, les virus peuvent être vite repérés (pour certains). Les développeurs de virus ont donc élaboré plusieurs techniques pour cacher le virus. Il existe plusieurs techniques. Nous les aborderons en parlant des virus polymorphes et furtifs par la suite.

Il s'avère qu'en dépit de leur finalité, tous les virus fonctionnent selon un modèle unifié qui les décrit tous: le modèle de virus générique. Eric Filiol et Jean-Paul Fizaine estiment que le virus est une sorte de machine de Turing se décomposant en sous autres machines de Turing connectées entre elles dont chacune représente un élément fonctionnel.



Première partie : Sécurité Informatique

127

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

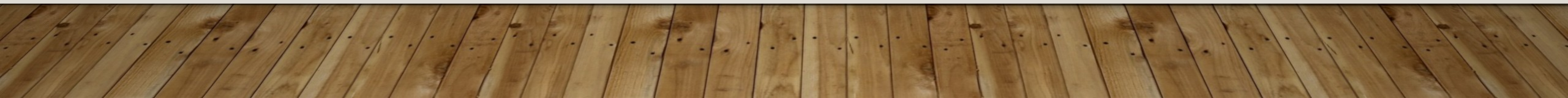
Un virus V est un quadruplet :

$$VPr = (\mathbf{Rech}, \mathbf{Inf}, \mathbf{Cf}, \mathbf{Tr}).$$

Rech c'est l'ensemble des fonctions de recherche de cibles; **Inf** est l'ensemble des fonctions d'infection tel que :

$$\mathbf{Inf} = \{\mathbf{E}, \mathbf{R}, \mathbf{A}, \mathbf{T}\}$$

Où E, R, A, T sont des ensembles de machines de Turing tels que E la classe des fonctions par écrasement, R la classe des fonctions par recouvrement, A la classe des fonctions par accompagnement, T est la classe des fonctions par entrelacement. Tandis que Cf est l'ensemble des fonctions des charges finales et Tr l'ensemble des fonctions de transfert d'exécution.



Première partie : Sécurité Informatique

128

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

MODE DE CONTAMINATION D'UN VIRUS

Le virus informatique utilise de même 4 modes de contamination pour se propager dans les systèmes informatiques :

➤ **Contamination par recouvrement** - le virus écrase les premières instructions du fichier par ses propres instructions. L'avantage est que la taille du fichier n'est pas modifiée. Cependant, il n'est plus utilisable par la suite, le début de ses instructions ayant été supprimé.

➤ **Contamination par ajout** - le virus s'exécute avant le code original du fichier infecté, mais repasse la main à ce dernier à la suite de son exécution. Dans ce cas, la taille du fichier est modifiée.

➤ **Contamination par entrelacement** - il s'agit ici d'insérer du code entre les blocs valides du programme. Elle est plus difficile à mettre en place, mais est moins facilement détectée.

➤ **Contamination par accompagnement** - ici, il s'agit tout simplement de surcharger les fichiers infectés en les rendant plus lourd lors de leurs exécutions.

Première partie : Sécurité Informatique

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

129 2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

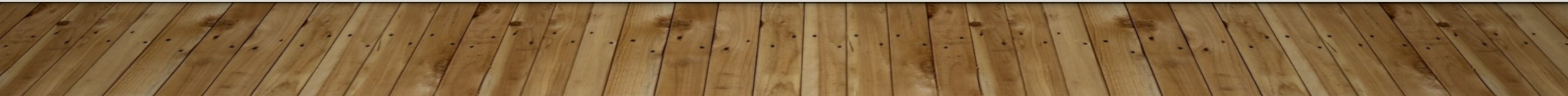
CYCLE DE VIE D'UN VIRUS

Les virus informatiques suivent un cycle de vie, qui recense 7 grandes étapes :

↳ **Création** : c'est la période durant laquelle un programmeur développe un virus aussi féroce que possible (dans la majeure partie des cas). La programmation se fait généralement en code assembleur ou Visual Basic, ou encore parfois en C ou C++.

↳ **Gestation** : C'est le temps pendant lequel le virus s'introduit dans le système qu'il souhaite infecter. Il y reste en sommeil.

↳ **Reproduction (infection)**: comme nous l'avons dit, le virus doit se reproduire. Un virus correctement conçu se reproduira un nombre important de fois avant de s'activer. C'est là le meilleur moyen de s'assurer de la pérennité d'un virus.



Première partie : Sécurité Informatique

130

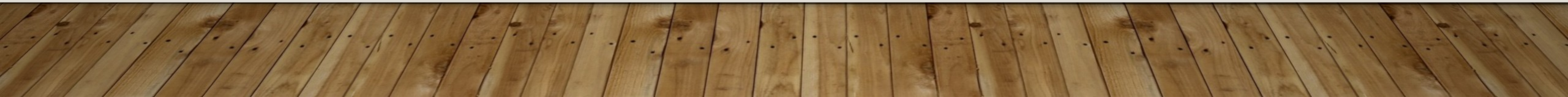
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

□ **Activation** : Les virus possédant une routine de destruction (portions de code destinées à causer des dégâts sur l'hôte) ne s'activent que lorsque certaines conditions sont réunies. Certains s'activent à une date précise (fixée par le développeur), d'autres possèdent un système de compte à rebours interne. L'activation peut aussi avoir lieu à distance, par le développeur. Même les virus ne possédant pas de telles routines et ne nécessitant pas de procédure d'activation spécifique peuvent causer des dommages aux systèmes en s'appropriant petit à petit l'ensemble des ressources.

--Découverte : C'est le moment où l'utilisateur s'aperçoit que son système a des comportements étranges et soupçonne la présence de virus. Ou alors, les anti-virus performants découvrent certains virus avant qu'ils aient eu le temps de faire des ravages.



Première partie : Sécurité Informatique

131

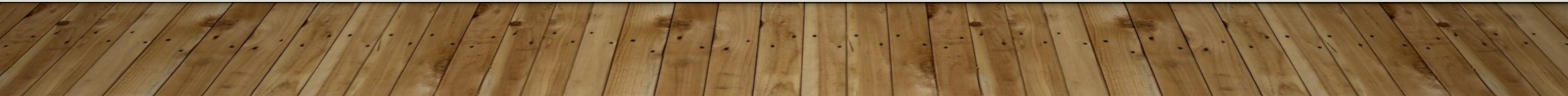
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les virus informatiques

-- Assimilation : Une fois la découverte faite, les développeurs de logiciels anti-virus mettent à jour leur base de données vira le (nous reviendrons sur cette notion) afin que les utilisateurs puissent détecter la présence de virus sur leur ordinateur. Ils développent également le correctif (ou antidote) permettant d'éradiquer le virus (si cela est possible).

-- Elimination : C'est la mort du virus. Tout au moins, c'est la mort de l'exemplaire du virus sur un poste utilisateur. C'est le moment où l'anti-virus ayant découvert le virus propose à l'utilisateur de le supprimer. Même si de nombreux virus connus depuis des années ne sont pas complètement annihilés, ils ont cessé de constituer une menace sérieuse car ils sont découverts très rapidement. Dans les faits, rares sont les virus ayant complètement disparu.



Première partie : Sécurité Informatique

132

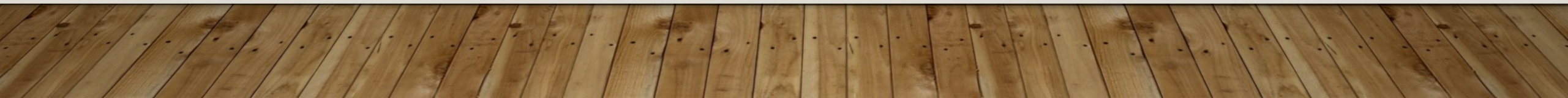
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Les vers informatiques

Un ver informatique est un logiciel malveillant qui se reproduit sur plusieurs ordinateurs en utilisant un réseau informatique comme Internet. Il a la capacité de se dupliquer une fois qu'il a été exécuté. Contrairement au virus, le ver se propage sans avoir besoin de se lier à d'autres programmes exécutables. Le ver appartient à la famille des programmes malveillants ou nuisibles, « les malware ».

Le concept de ver vient des programmes autoreproducteurs qui eux-mêmes sont issus d'idées des logiciens John von Neumann et W. V. Quine. Un virus, contrairement à un virus informatique, n'a pas besoin d'un programme hôte pour se reproduire. Il exploite les différentes ressources de l'ordinateur qui l'héberge pour assurer sa reproduction. Il faut noter également que les données qui sont corrompues ou détruites par un ver informatique sont généralement irrécupérables.



Première partie : Sécurité Informatique

133

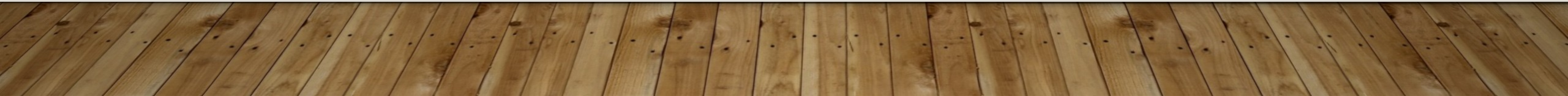
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

La plupart du temps, les vers n'ont d'autres utilités que la destruction (s'ils s'accompagnent d'une bombe logique), et la congestion du réseau. Malgré tout, le ver a parfois d'autres utilisations. Certaines entreprises les utilisent pour tester la sécurité de leur réseau intranet. L'objectif des vers n'est pas seulement de se reproduire mais habituellement, ils sont un objectif malfaisant, par exemple :

- Espionner l'ordinateur où il se trouve ;
- Offrir une porte dérobée à des pirates informatiques ;
- Détruire des données sur l'ordinateur où il se trouve ou y faire d'autres dégâts ;
- Envoyer de multiples requêtes vers un site Internet dans le but de le saturer (attaque par déni de service).



Première partie : Sécurité Informatique

134

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

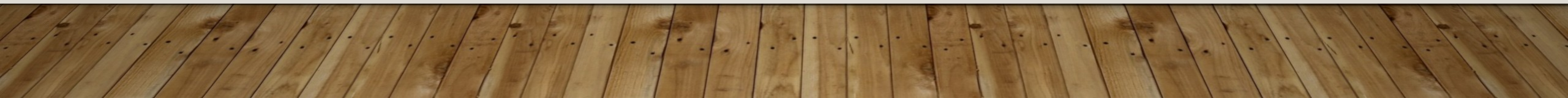
2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

Les conséquences des effets secondaires de l'activité d'un ver sur un ordinateur sont souvent :

- Ǻ Le ralentissement par saturation de la machine infectée ;
- Ǻ Le ralentissement par saturation du réseau utilisé par la machine infectée ;
- Ǻ Le plantage de services ou du système d'exploitation de la machine infectée.

En majorité, des vers écrits sous forme de scripts peuvent être intégrés dans un courriel ou sur une page HTML (chevaux de Troie). Ces vers sont activés par les actions de l'utilisateur qui croit accéder à des informations lui étant destinées. Un ver peut aussi être programmé en C, C++, Delphi, assembleur, ou dans un autre langage de programmation. La plupart du temps, les vers utilisent des failles de logiciels pour se propager.



Première partie : Sécurité Informatique

135

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

Voici les quelques exemples des vers sur Internet les plus célèbres :

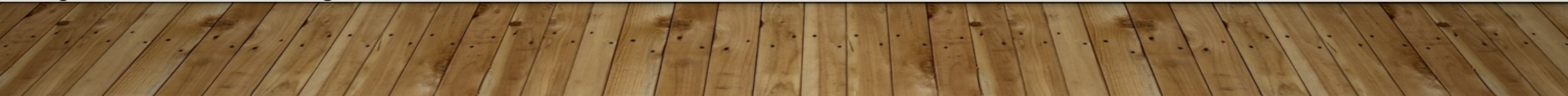
□ Félicitations vous venez d'être tiré au sort pour un séjour aux Etats-Unis.

ǃ Vous avez reçu un bonus sur votre carte Visa.

ǃ Vous êtes les 1.000.000 visiteurs ; Vous venez de gagner un smartphone.

ǃ Le ver informatique le plus populaire est le ver crée par Samy Kankar qui lui a donné son nom : le ver SAMY. Il a infecté plus d'un million d'utilisateur MySpace en seulement 20 heures. Voici ce qu'affichait le ver à l'écran des utilisateurs infectés : “mais par-dessus tout, Samy est mon héros”. Chaque personne visitant un profil infecté se faisait infecter à son tour.

ǃ Le ver Facebook qui se propage à travers Facebook Messenger, qui est un système de messagerie instantanée incorporé au réseau social Facebook. Une personne infectée va automatiquement envoyer un message à tous ses contacts avec un lien vers un site permettant de télécharger le ver.



Première partie : Sécurité Informatique

136

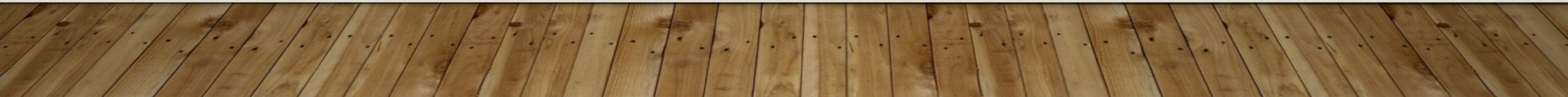
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

CARACTERISTIQUE D'UN VER INFORMATIQUE

- Ǻ Le ver est souvent transmis aux ordinateurs de différentes manières, telles que le courrier électronique, des programmes source obscurs, des sites de forum, des DVD et des CD de jeux piratés.
- Ǻ Le ver est conçu pour se copier d'un ordinateur à un autre automatiquement. Tout d'abord, il prend le contrôle des propriétés qui transmettent des fichiers ou des informations sur l'ordinateur. Cela peut entraîner un trafic réseau important en raison de l'effet domino, ce qui ralentit les réseaux des lieux de travail et l'ensemble de l'Internet.
- Ǻ Le ver est une sous-classe de virus et se propage généralement sans action de l'utilisateur et distribue des copies complètes de lui-même (éventuellement modifiées) de réseaux en réseaux.
- Ǻ Un ver peut consommer de la mémoire ou de la bande passante réseau, ce qui peut entraîner une panne d'ordinateur.



Première partie : Sécurité Informatique

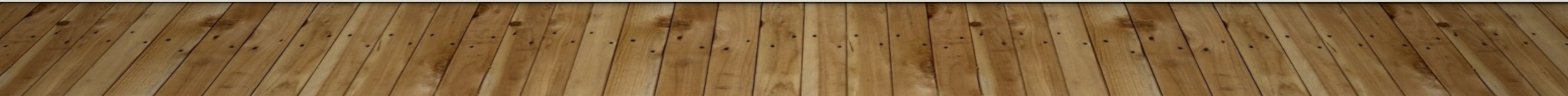
137

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

5 Comme les vers n'ont pas besoin d'un programme ou d'un fichier "support" pour se répandre, ils peuvent ouvrir un tunnel dans votre système et permettre à une autre personne de contrôler votre ordinateur à distance. Des exemples de vers récents incluent le ver Sasser et le ver Blaster.



Première partie : Sécurité Informatique

138

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

CLASSIFICATION D'UN INFORMATIQUE

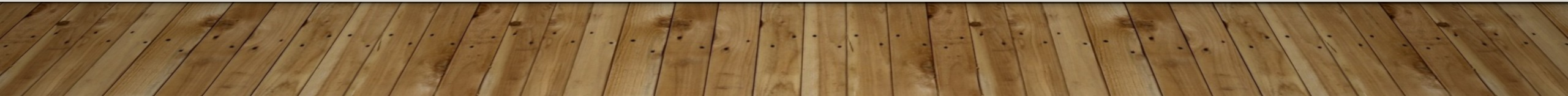
Il existe actuellement 4 Classes des vers informatiques :

ǂ Vers de réseau (Vers de réseaux de partage de fichiers) ;

☐ Vers de courrier électronique ;

☐ Vers de messagerie instantanée (Vers IRC : Internet Relay Chat);

ǂ Vers Internet ;



Première partie : Sécurité Informatique

139

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

ARCHITECTURE D'UN VER INFORMATIQUE

Il est composé de deux parties :

ǃ **Le vecteur** - c'est la partie principale du ver, qui s'occupe de la recherche de failles et est responsable de transmettre la seconde partie du ver.

ǃ **L'archive** - c'est la partie « morte » du ver, qui sera envoyée sur le système distant et l'infectera.

Cette archive peut exister sous deux formes distinctes :

ǃ **Sous forme de sources** - la reproduction est beaucoup plus aisée, car le nombre de machines potentiellement ciblées est beaucoup plus grand. L'inconvénient majeur de ce procédé est qu'un compilateur est nécessaire sur la machine à infecter. Les données nécessaires à l'infection sont plus volumineuses et une compression des sources sera parfois opérée préalablement.



Première partie : Sécurité Informatique

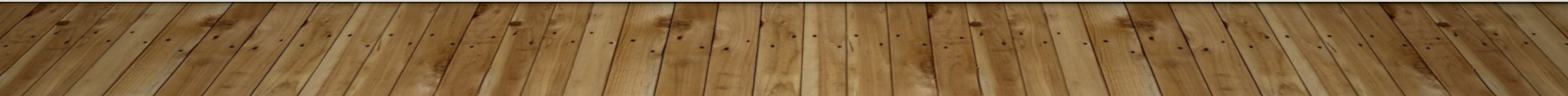
140

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

Ǐ **Sous forme binaire** - la reproduction de ce type de ver n'est possible que sur une architecture compatible avec les données binaires. Cependant, ce format ne nécessite pas de compilateur sur la machine hôte et est souvent plus compacte que la version source. Il est à remarquer qu'il existe des vers multiformes, c'est-à-dire utilisant une archive en sources ou binaire selon le système à infecter.



Première partie : Sécurité Informatique

141

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

MODE DE REPRODUCTION D'UN VER

Avant d'infecter un système, le ver doit procéder dans l'ordre à une série d'étapes. Ce n'est qu'à la suite de celles-ci qu'il pourra attaquer la machine cible. La succession d'étapes est la suivante (et ne concerne que la partie « vecteur » jusqu'à la phase d'invasion) :

ǃ **Initialisation** - ce sont les premières instructions du ver. Il peut s'agir de la création de fichiers temporaires, ou la compilation d'une partie de l'archive. A cet instant, le ver est toujours sur la machine mère.

ǃ **Recherche de l'hôte** - Cette étape procède à un scan d'IP. Ce scan peut être aléatoire ou incrémental (on passe en revue des séries d'adresses IP). Pour chacune d'entre elles, on teste si le système répond ou non ("up" ou "down").

ǃ **Identification de l'hôte** - une fois une victime potentielle détectée, le ver (la partie vecteur) va tester le système en place sur la machine distante. Il s'agira de vérifier si le système possède des failles pouvant être exploitées par le ver, s'il possède un compilateur approprié, Si ce n'est pas le cas, on retourne à l'étape précédente.

Première partie : Sécurité Informatique

142

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

ǫ **Attaque** - c'est ici que le ver exploite les vulnérabilités mises au jour dans la phase précédente. Le vecteur obtient alors un accès sur la machine cible.

ǫ **Invasion** - Le vecteur est maintenant présent sur la machine cible, mais n'est pas encore actif. Les instructions sont toujours données par la machine mère. Dès cet instant, le vecteur va rapatrier la partie archive sur le système à infecter. Deux techniques sont possibles :

→ Soit le vecteur est toujours accompagné de sa partie archive, auquel cas l'archive est présente sur la machine à tout moment, le vecteur uploadant son archive de machines en machines. Cette technique est un peu plus complexe à réaliser car le vecteur doit avoir été programmé pour transmettre cette archive.

→ Soit le vecteur doit rapatrier la partie archive. Ce rapatriement se fait à partir de la machine mère, ou depuis un serveur fixe (de type FTP) et unique pour toutes les machines (mais dans ce cas, l'attaque se terminera si le serveur tombe en panne).

Première partie : Sécurité Informatique

143

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

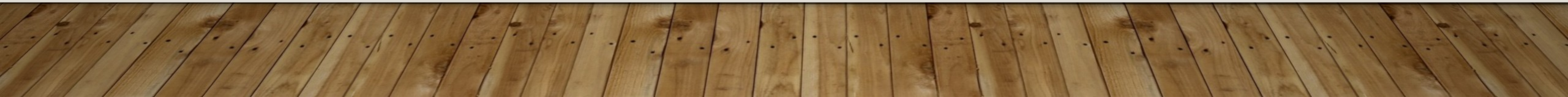
2.1.8 Les vers informatiques

C'est beaucoup plus facile à réaliser, mais également plus dangereux car l'utilisateur piraté pourra plus facilement tracer le ver. Si l'archive est sous forme de sources, le vecteur devra également procéder à la décompression et à la compilation de ces sources avant de passer à la phase suivante.

Ǿ Reproduction - ici aussi, deux possibilités existent pour permettre la reproduction du ver :

→ Soit on tue le ver présent sur la machine mère. Le ver se déplacera alors de stations en stations.

→ Soit on ne le tue pas et chacun des deux vers continue à se propager selon la méthode décrite ci-dessus. Ce choix provoque une étendue exponentielle du ver et est logiquement plus dangereuse que la précédente.



Première partie : Sécurité Informatique

144

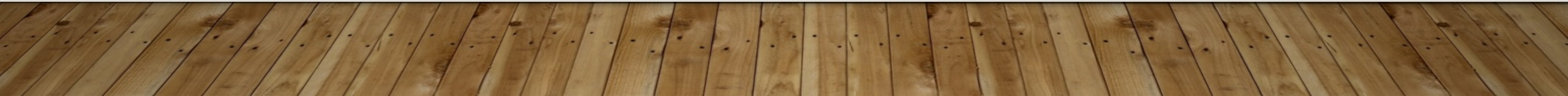
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.8 Les vers informatiques

Il faut également noter que des mesures simples permettent de limiter le risque d'attaque par un ver :

- Ǻ Analyse régulière de tous les fichiers suspects à l'aide d'un antivirus ;
- Ǻ Mises à jour régulières des logiciels installés pour s'assurer d'avoir les dernières versions ;
- Ǻ Évitement des sites Internet à risque (sites de hackers ou de téléchargement de matériel piraté par exemple) ;
- Ǻ Scannage des pièces jointes d'un email par un antivirus à jour.



Première partie : Sécurité Informatique

145

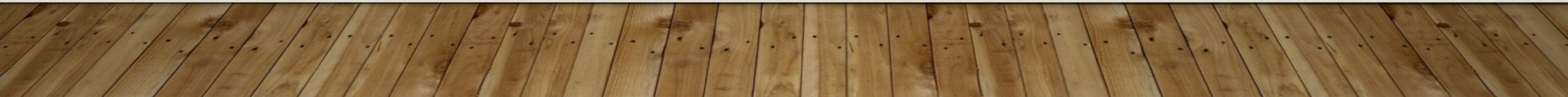
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

Un cheval de Troie (Trojan horse en anglais) est un type de logiciel malveillant, qui ne doit pas être confondu avec les virus ou autres parasites. Le cheval de Troie est un logiciel en apparence légitime, mais qui contient une fonctionnalité malveillante. Le rôle du cheval de Troie est de faire entrer ce parasite sur l'ordinateur et de l'installer à l'insu de l'utilisateur.

Un cheval de Troie informatique est un programme d'apparence inoffensive, mais qui en contient un autre, malveillant celui-là et qui est installé par l'utilisateur lui-même, ignorant qu'il fait pénétrer un intrus malveillant sur son ordinateur. C'est par analogie, que ce type de programme a été baptisé « cheval de Troie », en référence à la ruse qu'Ulysse utilisa pour contourner les défenses adverses. Le cheval de Troie prend l'apparence d'un logiciel existant, légitime et parfois même réputé, mais qui aura été modifié pour y dissimuler un parasite. La subtilité avec laquelle l'installation est faite est expliquée par Ken Thompson dans sa conférence Turing. Berné, l'utilisateur va télécharger et installer le programme, pensant avoir affaire à une version saine.



Première partie : Sécurité Informatique

146

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

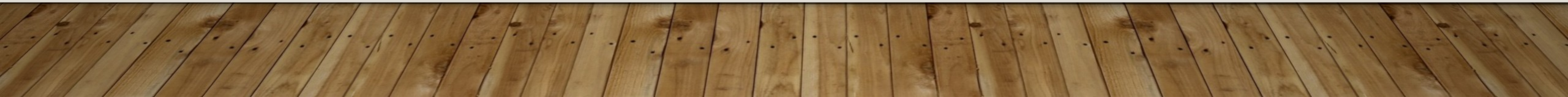
2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

En réalité, le logiciel véhicule un parasite qui va pouvoir s'exécuter sur son ordinateur. Les logiciels crackés peuvent être des chevaux de Troie qui vont allécher l'internaute qui cherche à obtenir gratuitement un logiciel normalement payant (Adobe Acrobat pro, Photoshop, Microsoft Office..). En 2014, une étude de l'Association of Internet Security Professionals centrée sur les dangers du live streaming illégal révèle qu'un ordinateur sur trois est infecté par un logiciel malveillant et que 73 % de ces infections proviennent d'un cheval de Troie.

Le cheval de Troie ne doit pas être confondu avec d'autres notions proches :

-**L'injecteur** (ou dropper, en anglais) - est quasiment identique au cheval, car il sert lui aussi de véhicule pour une malveillance. Mais l'injecteur est un programme spécialement fabriqué pour propager des parasites, alors que le cheval est une version modifiée d'un programme existant et légitime.



Première partie : Sécurité Informatique

147

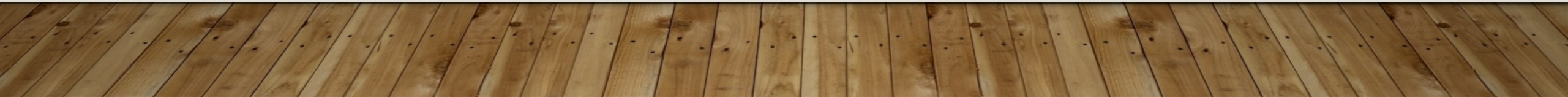
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

-**La porte dérobée (backdoor)** - est un programme qui va s'exécuter discrètement sur l'ordinateur où il est installé pour y créer une faille de sécurité. Le backdoor ouvre un ou plusieurs ports sur la machine, ce qui lui permet d'accéder à internet librement et de télécharger, à l'insu de l'utilisateur, un parasite. Le backdoor n'est donc pas un cheval de Troie : il ne véhicule pas le parasite en lui, il va simplement ouvrir l'accès et récupérer, via internet, le programme malveillant qui se trouve sur un serveur distant.

-**Le RAT (Remote administration tool)** - est un logiciel de prise de contrôle à distance d'un ordinateur. Un RAT peut être un outil légitime (par exemple pour le dépannage à distance), mais il peut aussi être utilisé par un pirate pour s'emparer d'une machine. Dans ce cas, l'introduction du RAT sur la machine à contrôler se fait à l'insu de l'utilisateur. Par exemple, par un cheval de Troie qui contient le RAT, mais le RAT n'est pas le cheval. Contrairement à ce qu'on lit parfois, le T de RAT ne signifie pas Trojan mais Tool (outil).



Première partie : Sécurité Informatique

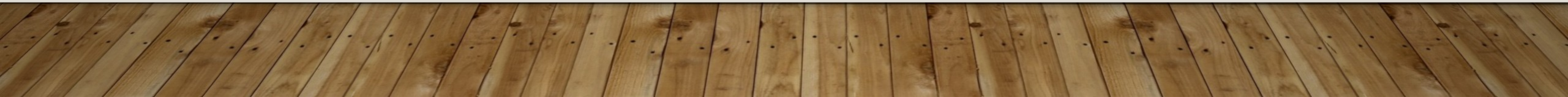
148

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

-**Les bombes de décompression** - ne transportent pas de parasite, mais elles peuvent être confondues avec les chevaux de Troie car la notion de conteneur entre aussi en jeu. Il s'agit d'un fichier compressé, par exemple un fichier zip, de taille raisonnable tant qu'il n'est pas ouvert. Mais lorsque l'utilisateur va tenter de la décompresser, elle va générer un fichier d'une taille gigantesque. Cette « explosion » entraîne le ralentissement ou le plantage de l'ordinateur, et sature le disque dur avec des données inutiles. Bien qu'il s'agisse de conteneurs malveillants, le fonctionnement des bombes de décompression n'a donc rien à voir avec celui des chevaux de Troie. En effet, elles ne transportent aucun parasite indépendant, elles saturent la machine de données aléatoires. « Le Trojan Stealer - plutôt spécialisé dans le vol de données et notamment les comptes en ligne (Mail, Réseaux sociaux ou encore bancaire).



Première partie : Sécurité Informatique

149

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

MANIFESTIONS D'UNE INFECTION PAR UN CHEVAL DE TROIE

- Activité anormale de la carte réseau ou du disque dur (des données sont chargées en l'absence d'activité de la part de l'utilisateur) ou du modem ;
- Réactions curieuses de la souris ;
- Ouvertures impromptues de programmes, du lecteur CD/DVD ;
- Plantages répétés ;
- Redémarrage répété du système ;
- Écran ou fenêtres avec des messages inhabituels ;
- Un comportement inhabituel dans le fonctionnement de l'ordinateur, tels que: changements d'économiseur d'écran de bureau, modification du rôle des boutons de la souris, modification du volume du lecteur audio ;

Première partie : Sécurité Informatique

150

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.9 Le cheval de troie

- Ouverture/Fermeture intempestive de fenêtres ;
- Les programmes commencent ou terminent leur exécution de manière inattendue ;
- Le navigateur accède tout seul à certains sites Internet ;
- Présence d'autres programmes qui n'ont pas été volontairement installés (y compris des logiciels malveillants) ;
- Vol de renseignements personnels : informations bancaires, mots de passe, codes de sécurité...
- Suppression, modification ou transfert de fichiers (téléchargement ou upload)
- Exécution ou arrêt de processus ;
- Arrêt ou redémarrage impromptus de l'ordinateur ;
- Surveillance des frappes (voir Enregistreur de frappe) ;
- Captures d'écran impromptues ;
- Espace libre du disque dur occupé par des fichiers inutiles.

Première partie : Sécurité Informatique

151

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

Un rootkit (Aussi appelé « outil de dissimulation d'activité », « maliciel furtif », « trousse administrateur pirate », parfois simplement « kit »), est un ensemble de techniques mises en œuvre par un ou plusieurs logiciels, dont le but est d'obtenir et de pérenniser un accès (généralement non autorisé) à un ordinateur de la manière la plus furtive possible, à la différence d'autres logiciels malveillants. Le terme peut désigner la technique de dissimulation ou plus généralement un ensemble particulier d'objets informatiques mettant en œuvre cette technique.

Pour l'« attaquant », l'utilité d'un « rootkit » est soit de mettre à disposition des ressources système (temps processeur, connexions réseaux, etc.) sur une, voire plusieurs machines, parfois en utilisant la « cible » comme intermédiaire pour une autre attaque ; soit d'espionner, d'accéder aux données stockées ou en transit sur la machine cible⁶. Ils sont généralement classés parmi les logiciels malveillants, mais pas toujours ; ils peuvent utiliser des « techniques virales » pour se transmettre (par exemple, en utilisant un virus ou un cheval de Troie). Il existe des outils de détection et des méthodes de protection pour les contrer mais elles ne sont pas totalement efficaces.

Première partie : Sécurité Informatique

152

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

TYPES DES ROOTKITS

Un rootkit peut intervenir à un ou plusieurs niveaux du système parmi les cinq suivants : micrologiciel, hyperviseur, noyau, bibliothèque ou applicatif :

--**Niveau micrologiciel / matériel** - Il est possible d'installer des rootkits directement au niveau du micrologiciel (ou firmware). De nombreux produits proposent désormais des mémoires flash qui peuvent être utilisées pour injecter durablement du code en détournant par exemple l'usage d'un module de persistance souvent implanté dans le BIOS de certains systèmes. C'est par exemple, « LoJack, d'Absolute Software »⁷ Un outil légitime qui utilise cette technique pouvant permet de suivre un ordinateur à l'insu de l'utilisateur pour retrouver un ordinateur portable en cas de vol. Ce code reste en place après un formatage du disque dur, voire après un flashage du BIOS si le module de persistance est présent et actif. Tout périphérique disposant d'un tel type de mémoire est donc potentiellement vulnérable.

Première partie : Sécurité Informatique

153

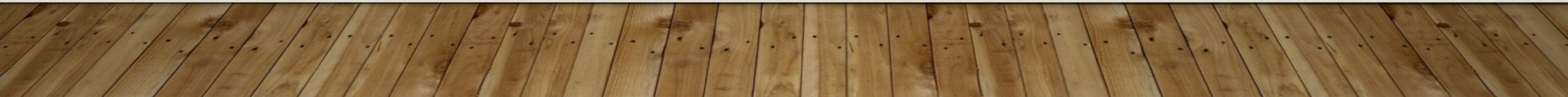
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

--**Niveau hyperviseur** - Ce type de rootkit se comporte comme un hyperviseur natif, après s'être installé et avoir modifié la séquence de démarrage, pour être lancé en tant qu'hyperviseur à l'initialisation de la machine infectée. Le système d'exploitation original devient alors un hôte (invité) du rootkit, lequel peut intercepter tout appel au matériel. Il devient quasiment impossible à détecter depuis le système original. Blue Pill est un autre exemple de rootkit utilisant cette technique.

--**Niveau noyau** - Certains rootkits s'implantent dans les couches du noyau du système d'exploitation : soit dans le noyau lui-même, soit dans des objets exécutés avec un niveau de privilèges équivalent à celui du noyau. Sous GNU/Linux, il s'agit souvent de modules pouvant être chargés par le noyau, et sous Windows de pilotes. Avec un tel niveau de privilèges, la détection et l'éradication du rootkit n'est souvent possible que de manière externe au système en redémarrant depuis un système sain, installé sur CD, sur une clé USB ou par réseau.



Première partie : Sécurité Informatique

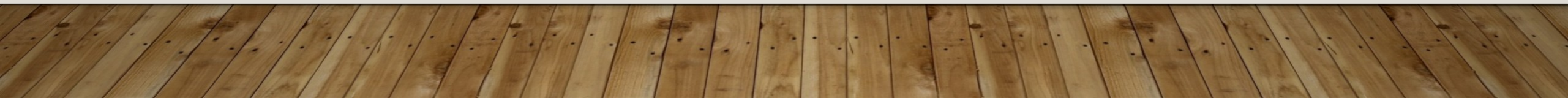
154

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

--**Niveau bibliothèque** - À ce niveau, le rootkit détourne l'utilisation de bibliothèques légitimes du système d'exploitation. Plusieurs techniques peuvent être utilisées. On peut patcher une bibliothèque, c'est-à-dire lui ajouter du code. On peut aussi détourner l'appel d'un objet par hooking, ce qui revient à appeler une « autre fonction » puis à revenir à la fonction initiale, pour que le détournement soit transparent du point de vue fonctionnel. Enfin, on peut remplacer des appels système par du code malveillant. Ce type de rootkit est assez fréquent, mais il est aussi le plus facile à contrer, notamment par un contrôle d'intégrité des fichiers essentiels, en surveillant leur empreinte grâce à une fonction de hachage ; par une détection de signature du programme malveillant ; ou par exemple, par un examen des hooks au moyen d'outils comme unhide sous GNU/Linux ou HijackThis sous Windows.



Première partie : Sécurité Informatique

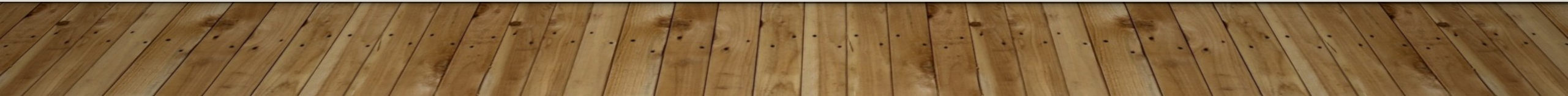
155

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

--**Niveau applicatif** - Un rootkit applicatif implante des programmes malveillants de type cheval de Troie, au niveau utilisateur. Ces programmes prennent la place de programmes légitimes par usurpation d'identité ou en modifiant le comportement, afin de prendre le contrôle des ressources accessibles par ces programmes. Par exemple, une application de traitement de texte peut être remplacée par une version malicieuse et donner accès aux fonctions permettant de lire et d'écrire un fichier dans une partie de l'arborescence.



Première partie : Sécurité Informatique

156

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

MODE OPERATOIRE D'UN ROOTKIT

1. Contamination - Le mode de contamination par un rootkit se fait en deux phases : *

--La première phase d'action d'un rootkit sert généralement à trouver un hôte vulnérable par balayage d'un ensemble d'adresses IP ou grâce à une base de données d'IP vulnérables.

--L'étape suivante consiste à chercher à obtenir un accès au système, sans forcément que celui-ci soit un accès privilégié (ou en mode administrateur). Il existe trois manières d'obtenir un accès au système, en suivant les techniques habituelles des programmes malveillants :

*Mettre en œuvre un exploit, c'est-à-dire profiter d'une vulnérabilité de sécurité connue ou non, à n'importe quel niveau du système (application, système d'exploitation, BIOS, etc.). Cette mise en œuvre peut être le fait d'un virus, mais elle résulte aussi, souvent, de botnets qui réalisent des scans de machines afin d'identifier et d'exploiter les failles utiles à l'attaque.

Première partie : Sécurité Informatique

157

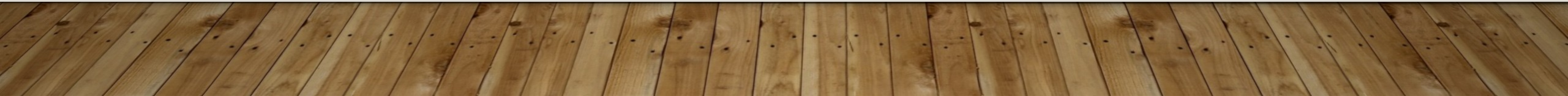
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

*Même s'il n'est pas un virus à proprement parler, un rootkit peut utiliser des techniques virales pour se transmettre, notamment via un cheval de Troie. Un virus peut avoir pour objet de répandre des rootkits sur les machines infectées. A contrario, un virus peut aussi utiliser les techniques utilisées par des rootkits pour parfaire sa dissimulation.

*Enfin, l'attaque par force brute permet d'accéder au système, en profitant de la faiblesse des mots de passe mis en œuvre par certains utilisateurs. À ces fins, il suffit de tester les mots de passe les plus courants.



Première partie : Sécurité Informatique

158

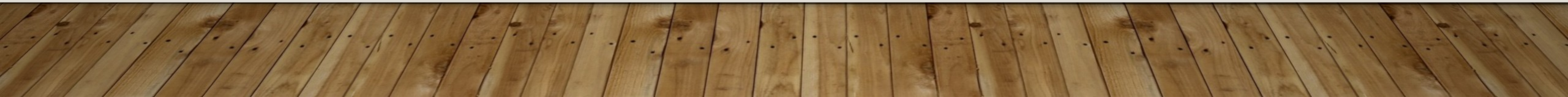
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

2. La modification du système - Une fois la contamination effectuée et l'accès obtenu, la phase suivante consiste à installer, au moyen de son script d'installation, les objets et outils nécessaires au rootkit; c'est-à-dire les objets (programmes, bibliothèques) permettant la mise en place de la charge utile du rootkit, s'ils n'ont pas pu être installés durant la phase de contamination, ainsi que les outils et les modifications nécessaires à la dissimulation.

L'opération consiste en l'ouverture de portes dérobées, afin de permettre le contrôle des machines (pc, serveurs, etc.), et, d'y installer la charge utile. Le tout, afin de pérenniser l'accès au système, ceci constitue une technique très fréquemment usitée.



Première partie : Sécurité Informatique

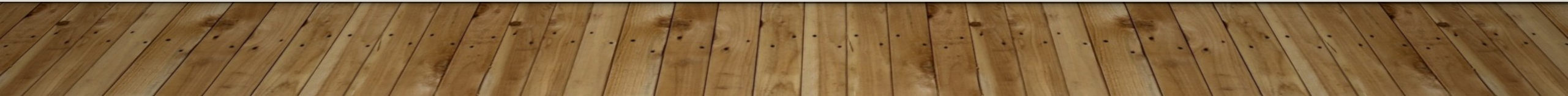
159

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

3. La Dissimulation - Le rootkit cherche à dissimuler son activité pour minimiser le risque qu'on le découvre, afin de profiter le plus longtemps possible de l'accès frauduleux, mais aussi pour rendre sa désinstallation difficile. Il va notamment dissimuler ses propres fichiers, les autres fichiers utilisés par l'attaquant, les processus qu'il exécute et les connexions qu'il va ouvrir. Cette faculté de dissimulation le différencie des virus, qui cherchent principalement à se répandre, bien que ces deux fonctions soient parfois jumelées pour une efficacité supérieure. Plusieurs méthodes de dissimulation peuvent être combinées.



Première partie : Sécurité Informatique

160

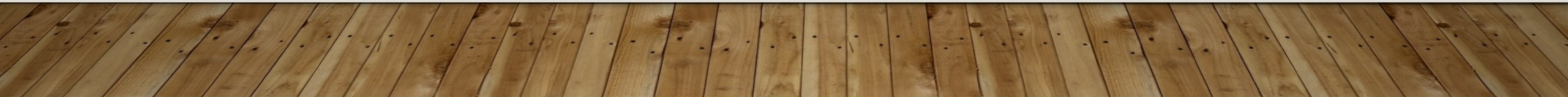
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

4. Maintien de l'accès - Un rootkit doit pouvoir être manipulé à distance par un attaquant. Celui-ci cherche donc souvent à maintenir un shell (ou « interpréteur de commandes ») disponible idéalement à n'importe quel moment (ou au moins durant l'installation du rootkit), en remplaçant des commandes comme ping ou xterm. Généralement, l'attaquant installe plusieurs de ces portes dérobées au cas où l'une viendrait à être découverte et supprimée.

5. La Mise en place de la charge utile - La charge utile est la partie active du rootkit (programme malveillant en général), dont le rôle est d'accomplir les tâches assignées. Cette charge utile permet d'avoir accès aux ressources de la machine infectée, et notamment le processeur, pour décrypter des mots de passe, pour effectuer des calculs distribués à des fins malveillantes ou pour mettre en œuvre (ou détourner l'usage légitime) des applications comme un serveur de messagerie afin d'envoyer des mails (pourriel ou spam) en quantité.



Première partie : Sécurité Informatique

161

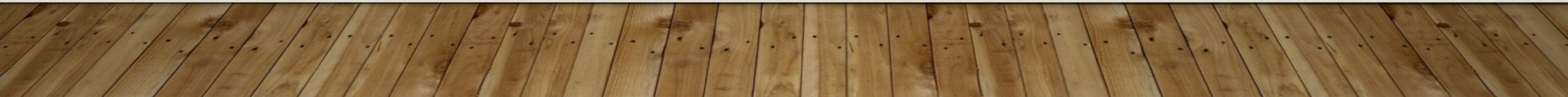
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.10 Les rootkits

Les ressources réseaux intéressent également les attaquants, la machine pouvant alors servir de base pour d'autres attaques (exploits) ou pour inspecter, sniffer l'activité réseau. La machine infectée peut aussi devenir le point de départ pour d'autres attaques, sur internet, ou sur l'intranet, comme un déni de service. La prise de contrôle de la machine offre la possibilité de constituer un réseau de type botnet (la machine infectée devenant alors une machine zombie, comme dans le cas du botnet Srizbi8), ou d'accéder à d'autres machines, par rebond.

6. Elévation du niveau de privilège - l'élévation de privilège est souvent nécessaire pour que le camouflage soit efficace : le rootkit peut utiliser certains exploits afin de parfaire sa dissimulation en opérant à un niveau de privilège très élevé, pour atteindre des bibliothèques du système, des éléments du noyau, pour désactiver les défenses du système, etc.



Première partie : Sécurité Informatique

162

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

Un cookie (ou témoin de connexion) est défini par le protocole de communication HTTP comme étant une suite d'informations envoyée par un serveur HTTP à un client HTTP, que ce dernier retourne lors de chaque interrogation du même serveur HTTP sous certaines conditions. Le cookie est l'équivalent d'un fichier texte de petite taille, stocké sur le terminal de l'internaute. Existant depuis les années 1990, ils permettent aux développeurs de sites web de conserver des données utilisateur afin de faciliter la navigation et de permettre certaines fonctionnalités. Les cookies ont toujours été plus ou moins controversés car elles contiennent des informations personnelles résiduelles pouvant potentiellement être exploitées par des tiers.

Ces informations censées être privées ne le sont pas vraiment, puisqu'elles sont accessibles à un certain point. Il est envoyé en tant qu'en-tête HTTP par le serveur web au navigateur web qui le renvoie inchangé à chaque fois qu'il accède au serveur. Un cookie peut être utilisé pour une authentification, une session (maintenance d'état), et pour stocker une information spécifique sur l'utilisateur, comme les préférences d'un site ou le contenu d'un panier d'achat électronique.

Le terme cookie est dérivé de magic cookie¹², un concept bien connu dans l'informatique d'UNIX, qui a inspiré l'idée et le nom des cookies de navigation. Quelques alternatives aux

Première partie : Sécurité Informatique

163

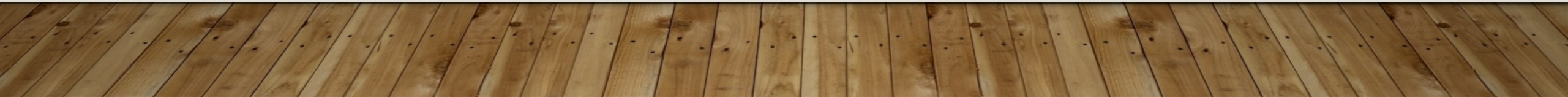
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

Le terme cookie est dérivé de magic cookie¹², un concept bien connu dans l'informatique d'UNIX, qui a inspiré l'idée et le nom des cookies de navigation. Quelques alternatives aux cookies existent, chacune a ses propres utilisations, avantages et inconvénients.

Étant généralement stockés sous forme de simples fichiers texte, les cookies ne sont pas exécutables. Ils ne sont ni des logiciels espions ni des virus, bien que des cookies provenant de certains sites soient détectés par plusieurs logiciels antivirus parce qu'ils peuvent permettre de suivre les utilisateurs ayant visité certains sites web. La plupart des navigateurs récents permettent aux utilisateurs de décider s'ils acceptent ou rejettent les cookies. Les utilisateurs peuvent aussi choisir la durée de stockage des cookies. Toutefois, le rejet complet des cookies rend certains sites inutilisables. Par exemple, les paniers d'achat de magasins ou les sites qui exigent une connexion à l'aide d'identifiants (utilisateur et mot de passe).



Première partie : Sécurité Informatique

164

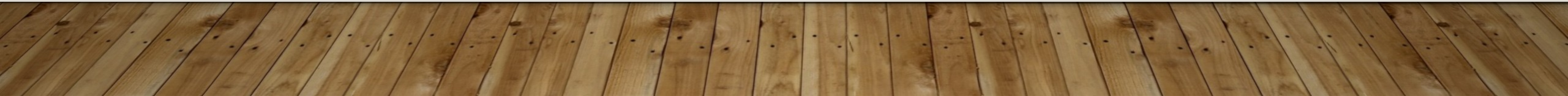
Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

UTILISATIONS DES COOKIES

--**Gestion des sessions** - Les cookies peuvent être utilisés pour maintenir les données relatives à l'utilisateur durant sa navigation, mais aussi à travers plusieurs visites. Les cookies ont été introduits pour donner un moyen d'implémenter les paniers d'achat électronique, un dispositif virtuel dans lequel l'utilisateur peut accumuler les articles qu'il veut acheter durant sa navigation sur le site. Le navigateur web renvoie alors cet identifiant de session à chaque requête suivante et les articles du panier sont enregistrés et associés avec ce même identifiant unique de session. Une utilisation fréquente des cookies est utile pour la connexion à un site à l'aide d'identifiants.



Première partie : Sécurité Informatique

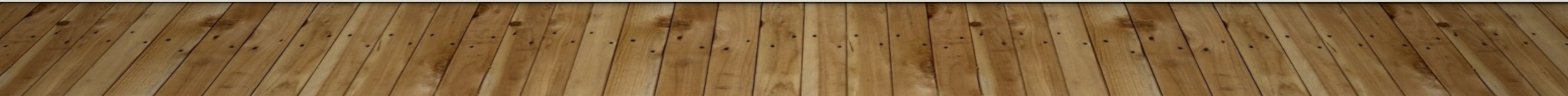
165

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

--**Personnalisation** - Les cookies peuvent être utilisés pour mémoriser l'information sur l'utilisateur d'un site, dans le but de lui montrer un contenu approprié dans le futur. Beaucoup de sites web utilisent les cookies pour la personnalisation basée sur les préférences des utilisateurs. Les utilisateurs sélectionnent leurs préférences dans un formulaire et envoient celles-ci au serveur. Le serveur encode les préférences dans un cookie et renvoie celui-ci au navigateur. Par la suite, à chaque fois que l'utilisateur accède à une page de ce site, le navigateur renvoie le cookie et donc la liste des préférences ; le serveur peut alors personnaliser la page d'après les préférences de l'utilisateur. Par exemple,. Le moteur de recherche Google permet à ses utilisateurs (même s'ils ne sont pas enregistrés) de choisir le nombre de résultats qu'ils veulent voir sur chaque page de résultats.



Première partie : Sécurité Informatique

166

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

--**Pistage** - Les cookies de pistage sont utilisés pour suivre les habitudes de navigation des utilisateurs d'internet. Cela peut être fait aussi en partie en utilisant l'adresse IP de l'ordinateur faisant une requête d'une page ou à l'aide de l'en-tête HTTP « référant » que le client envoie à chaque requête, mais les cookies permettent une plus grande précision. Cela peut être fait comme dans l'exemple suivant :

➤ Si l'utilisateur fait appel à une page d'un site, et que la requête ne contient pas de cookie, le serveur présume que c'est la première page visitée par l'utilisateur. Le serveur crée alors une chaîne aléatoire et l'envoie au navigateur en même temps que la page demandée.

➤ À partir de ce moment, le cookie sera automatiquement envoyé par le navigateur à chaque fois qu'une nouvelle page du site sera appelée. Le serveur enverra la page comme d'habitude, mais enregistrera aussi l'URL de la page appelée, la date, l'heure de la requête et le cookie dans un fichier de journalisation.

Première partie : Sécurité Informatique

167

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

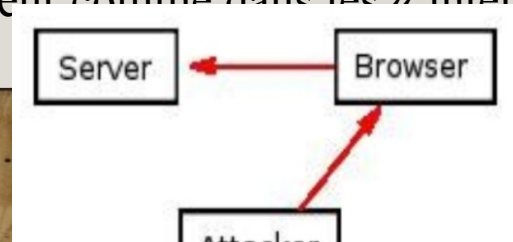
2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

INCONVENIENTS DES COOKIES

En plus des problèmes d'atteinte à la vie privée, les cookies ont aussi quelques inconvénients techniques. En particulier, ils n'identifient pas toujours exactement les utilisateurs, ils peuvent ralentir la performance des sites lorsqu'en grand nombre, ils peuvent être utilisés pour des attaques de sécurité et ils sont en oppositions avec le transfert représentatif d'état, style architectural du logiciel. On peut citer :

➤ **Identification imprécise** - Si plus d'un navigateur est utilisé sur un ordinateur, dans chacun d'eux, il y a toujours une unité de stockage séparée pour les cookies. Par conséquent les cookies n'identifient pas une personne, mais la combinaison d'un compte utilisateur, d'un ordinateur, et d'un navigateur web. Ainsi, n'importe qui peut utiliser ces comptes, les ordinateurs, ou les navigateurs qui ont la panoplie des cookies. De même, les cookies ne font pas la différence entre les multiples utilisateurs qui partagent le même compte d'utilisateur, l'ordinateur, et le navigateur comme dans les « internet cafés » ou tous lieux donnant accès libre à des ressources informatiques.



Première partie : Sécurité Informatique

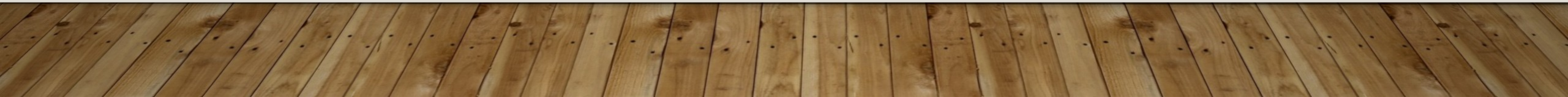
168

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

↳ **Vol de cookie** - Durant l'opération normale, les cookies sont renvoyés entre le serveur (ou un groupe de serveurs dans le même domaine) et le navigateur de l'ordinateur de l'utilisateur. Puisque les cookies peuvent contenir des informations sensibles (nom de l'utilisateur, un mot de passe utilisé pour une authentification, etc.), leurs valeurs ne devraient pas être accessibles aux autres ordinateurs. Le vol de cookie est un acte d'interception des cookies par un tiers non autorisé. Les cookies peuvent être volés via un renifleur de paquets dans une attaque appelée détournement de session. Le trafic sur le net peut être intercepté et lu par les ordinateurs autres que ceux qui envoient et qui reçoivent (particulièrement sur l'espace public Wi-Fi non-chiffré). Ce trafic inclut les cookies envoyés sur des sessions utilisant le protocole HTTP ordinaire. Quand le trafic réseau n'est pas chiffré, des utilisateurs malveillants peuvent ainsi lire les communications d'autres utilisateurs sur le réseau en utilisant des « renifleurs de paquets ».



Première partie : Sécurité Informatique

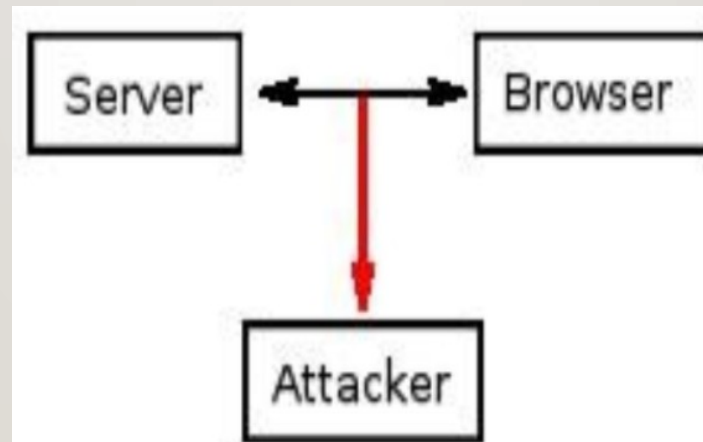
169

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

Ce problème peut être surmonté en chiffrant la connexion entre l'ordinateur de l'utilisateur et le serveur par l'emploi du protocole HTTPS. Un serveur peut spécifier un drapeau sécurisé tout en mettant en place un cookie ; le navigateur l'enverra seulement sur une ligne sécurisée, comme une connexion en SSL.



Première partie : Sécurité Informatique

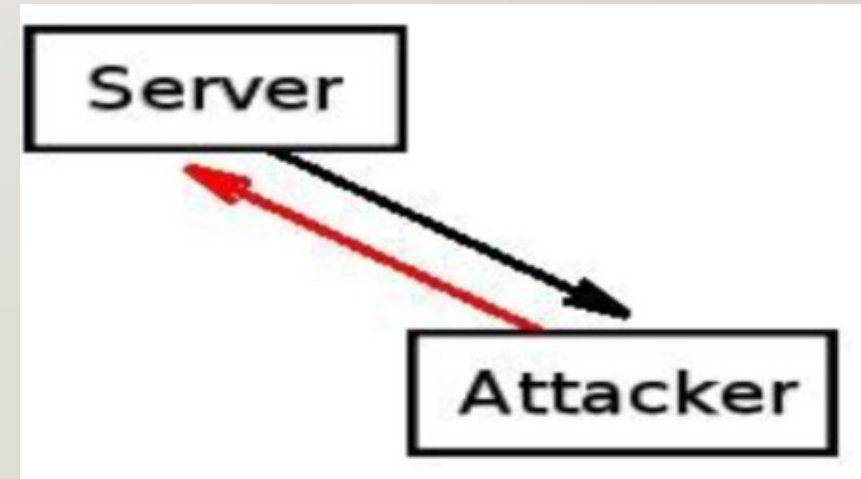
170

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

➤ **Modification de cookie** - Dès que les cookies ont besoin d'être stockés et renvoyés inchangés au serveur, un attaquant peut modifier la valeur des cookies avant leur renvoi au serveur. Par exemple, si un cookie contient la valeur totale que l'utilisateur doit payer pour les articles mis dans le panier du magasin, en changeant cette valeur le serveur est exposé au risque de faire payer moins l'attaquant que le prix de départ. Le procédé de modifier la valeur des cookies est appelé cookie poisoning et peut être utilisé après un vol de cookie pour rendre l'attaque persistante.



Première partie : Sécurité Informatique

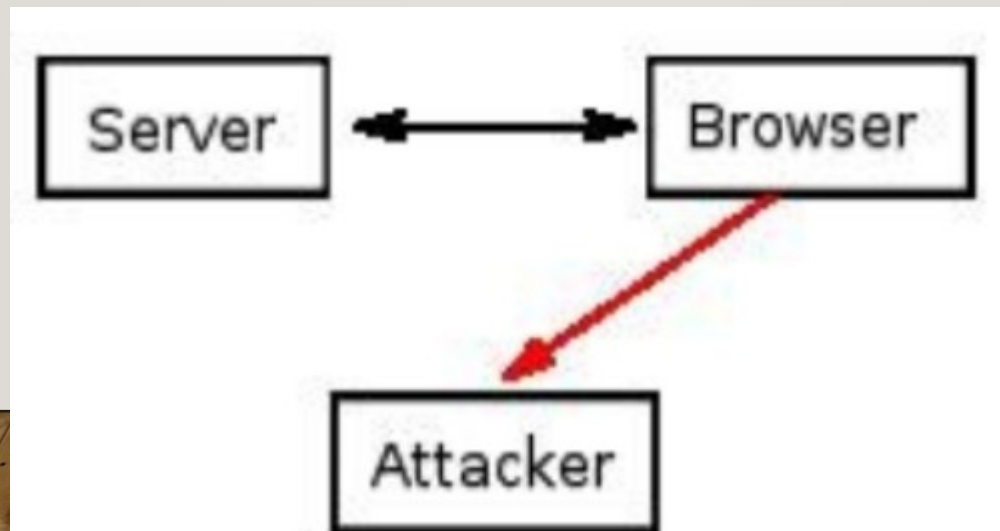
171

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

🔗 **Manipulation de cookie entre sites web** - Chaque site est supposé avoir ses propres cookies, donc un site ne devrait pas être capable de modifier ou créer des cookies associés à un autre site. Une faille de sécurité d'un navigateur web peut permettre à des sites malveillants d'enfreindre cette règle. L'exploitation d'une telle faille est couramment appelée cross-site cooking. Le but de telles attaques peut être le vol de l'identifiant de session. Les utilisateurs devraient utiliser les versions les plus récentes des navigateurs web dans lesquels ces vulnérabilités sont pratiquement éliminées.



Première partie : Sécurité Informatique

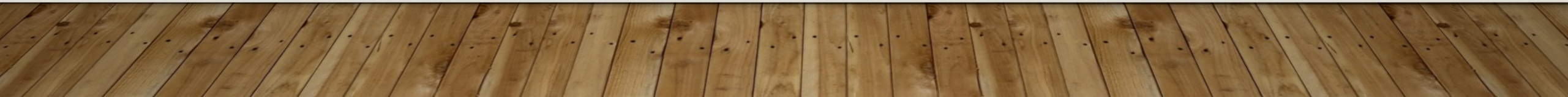
172

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

➤ **État contradictoire entre le client et le serveur** - L'utilisation des cookies peut générer une contradiction entre l'état du client et l'état stocké dans le cookie. Si l'utilisateur acquiert un cookie et clique sur le bouton « Retour » du navigateur, l'état du navigateur n'est généralement pas le même qu'avant cette acquisition. Par exemple, si le panier d'une boutique en ligne est réalisé en utilisant les cookies, le contenu du panier ne peut pas changer quand l'utilisateur revient dans l'historique du navigateur : si l'utilisateur presse sur un bouton pour ajouter un article dans son panier et clique sur le bouton « Retour », l'article reste dans celui-ci. Cela n'est peut-être pas l'intention de l'utilisateur, qui veut certainement annuler l'ajout de l'article. Cela peut mener à un manque de fiabilité, de la confusion, et des bugs. Les développeurs web doivent donc être conscients de ce problème et mettre en œuvre des mesures visant à gérer des situations comme celle-ci.



Première partie : Sécurité Informatique

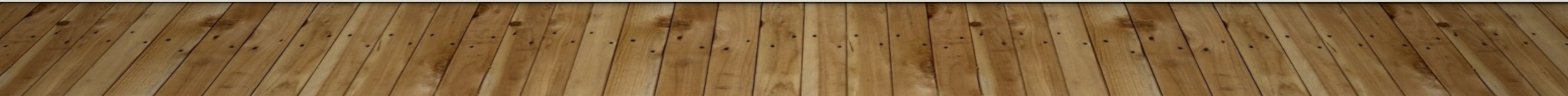
173

Chapitre 2 : Faille la sécurité sur internet et mode de piraterie

2.1 Présentation des failles sur l'internet

2.1.11 Les cookies

⚠Échéance de cookie - Les cookies permanents ont été critiqués par les experts de la sécurité de la vie privée pour ne pas être prévus pour expirer assez tôt, et de ce fait permettre aux sites web de suivre les utilisateurs et de construire au fur et à mesure leur profil. Cet aspect des cookies fait partie aussi du problème de détournement de session, parce qu'un cookie permanent volé peut être utilisé pour se faire passer pour un utilisateur pour une période de temps considérable.



Première partie : Sécurité Informatique

174

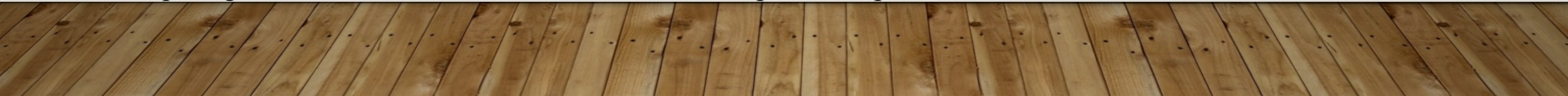
Chapitre 3 : Système de protection informatique

Introduction

Chaque ordinateur connecté à Internet (et d'une manière plus générale à n'importe quel réseau informatique) est susceptible d'être victime d'une attaque d'un pirate informatique. La méthodologie généralement employée consiste à scruter le réseau (en envoyant des paquets de données de manière aléatoire) à la recherche d'une machine connectée, puis à chercher une faille de sécurité afin de l'exploiter et d'accéder aux données s'y trouvant. Cette menace est d'autant plus grande que la machine est connectée en permanence à Internet pour plusieurs raisons :

- La machine cible est susceptible d'être connectée sans pour autant être surveillée.
- La machine cible est généralement connectée avec une plus large bande passante.
- La machine cible ne change pas (ou peu) d'adresse IP.

Ainsi, il est nécessaire, autant pour les réseaux d'entreprises que pour les internautes possédant une connexion de type câble ou ADSL, de se protéger des intrusions réseaux en installant un dispositif de protection.



Première partie : Sécurité Informatique

175

Chapitre 3 : Système de protection informatique

3.1 Antivirus

Principe de fonctionnement

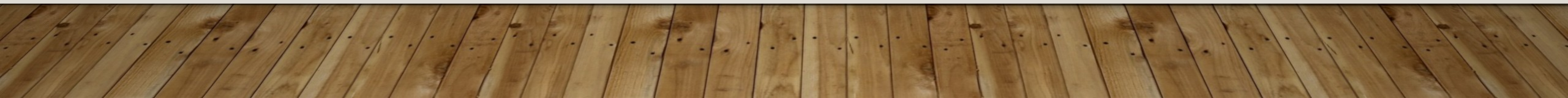
Un antivirus est un programme capable de détecter la présence de malware sur un ordinateur et, dans la mesure du possible, de désinfecter ce dernier. On parle ainsi d'éradication de virus pour désigner la procédure de nettoyage de l'ordinateur.

Détection des malwares

Les malwares sont des fichiers ou des portions de code embarquées dans des fichiers. Ces codes sont repérés suivant leur comportement, les fichiers qu'ils génèrent ou leur « hash ». L'ensemble constitue leur signature virale.

☐ **Recherche de signature virale**

Les antivirus s'appuient ainsi sur cette signature propre à chaque malware pour les détecter. Il s'agit de la méthode de recherche de signature (scanning), la plus ancienne méthode utilisée par les antivirus.



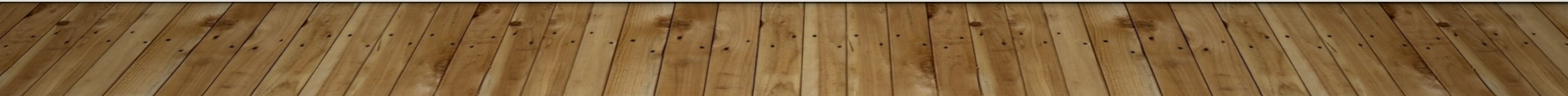
Première partie : Sécurité Informatique

176

Chapitre 3 : Système de protection informatique

3.1 Antivirus

Cette méthode n'est fiable que si l'antivirus possède une base virale à jour, c'est-à-dire comportant les signatures de tous les malwares connus. Toutefois, cette méthode ne permet pas la détection des malwares n'ayant pas encore été répertoriés par les éditeurs d'antivirus. Ceux-ci sont désormais dotés de capacités de camouflage, de manière à rendre leur signature difficile à détecter, voire indétectable : il s'agit de virus polymorphes.



Première partie : Sécurité Informatique

177

Chapitre 3 : Système de protection informatique

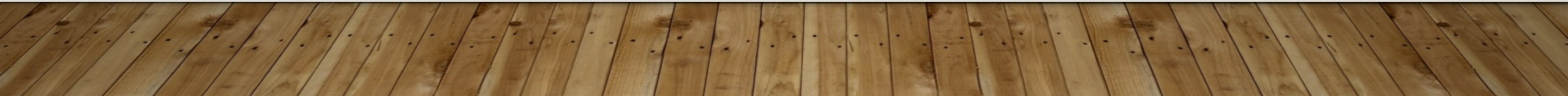
3.1 Antivirus

☐ **Contrôle d'intégrité**

Certains antivirus utilisent un contrôleur d'intégrité pour vérifier si les fichiers ont été modifiés. Ainsi le contrôleur d'intégrité construit une base de données contenant des informations sur les fichiers exécutables du système (date de modification, taille et éventuellement une somme de contrôle). Ainsi, lorsqu'un fichier exécutable change de caractéristiques, l'antivirus prévient l'utilisateur de la machine.

☐ **Identification des fichiers sains**

Certains antivirus utilisent aussi une base de données de signatures (hash) de fichiers sains. Ainsi, le moteur de l'antivirus n'est plus obligé de suivre les activités de programmes connues comme faisant parti du système ou d'une application courante. Comme la base de signature virale, ces signatures de fichiers sains sont mises à jour régulièrement par le programme antivirus.



Première partie : Sécurité Informatique

178

Chapitre 3 : Système de protection informatique

3.1 Antivirus

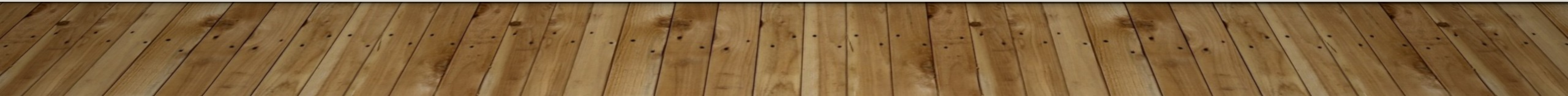
☐ **Analyse des comportements**

La méthode heuristique consiste à analyser le comportement des applications afin de détecter une activité proche de celle d'un malware connu. Ce type d'antivirus peut ainsi détecter des virus même lorsque la base antivirale n'a pas été mise à jour. En contrepartie, ils sont susceptibles de déclencher de fausses alertes.

☐ **Éradication**

Il existe plusieurs méthodes d'éradication :

- la suppression du code correspondant au virus dans le fichier infecté ;
- la suppression du fichier infecté ;
- la mise en quarantaine du fichier infecté, consistant à le déplacer dans un emplacement où il ne pourra pas être exécuté.



Première partie : Sécurité Informatique

179

Chapitre 3 : Système de protection informatique

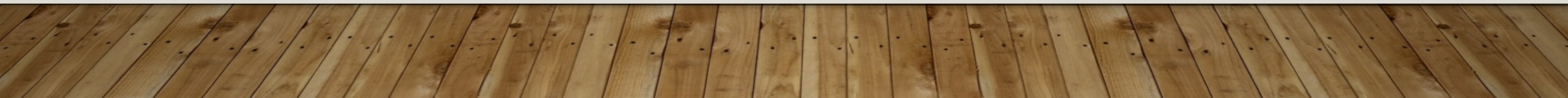
3.1 Antivirus

Antivirus mais pas seulement

Les logiciels antivirus ont amorcé leur mutation ces dernières années : en effet, face à une menace qui s'est diversifiée, les éditeurs ont inclus dans leurs solutions de nouveaux éléments.

Tout d'abord, au niveau de l'analyse des codes, au lieu d'envoyer à chaque ordinateur la totalité de la liste des signatures – ce qui est devenu difficile vu la quantité de données que cela impliquerait – celle-ci est mise sur des serveurs dispersés dans le monde. Chaque analyse renvoie la signature du fichier présent sur le disque dur vers ce nuage. Les programmes ayant un comportement suspect peuvent aussi être envoyés dans ce « nuage » pour y être analysés. Avec la liste de fichiers sains, l'ensemble a permis un véritable saut qualitatif en termes de rapidité et de pertinence des moteurs antiviraux.

Ainsi, aujourd'hui, les antivirus des grands éditeurs n'ont plus un impact important sur les performances de la machine.



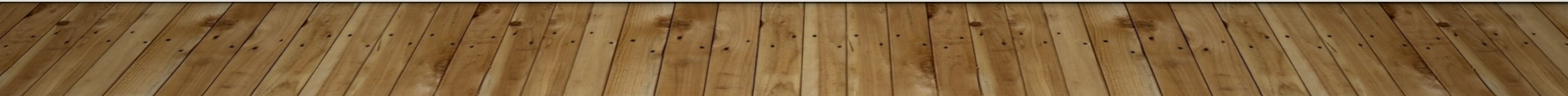
Première partie : Sécurité Informatique

180

Chapitre 3 : Système de protection informatique

3.1 Antivirus

Par ailleurs, la problématique des postes déjà infectés est mieux prise en compte qu'auparavant : des outils dédiés à la suppression des malwares actifs accompagnent les antivirus (souvent sous la forme d'un CD ou d'une clé USB s'exécutant au démarrage de la machine). Les éditeurs ajoutent aussi des modules pour sécuriser les communications sensibles (par exemple avec les établissements bancaires ou les cybermarchands), détecter les sites web contrefaits (phishing) ou encore lister les programmes contenant des vulnérabilités.



Première partie : Sécurité Informatique

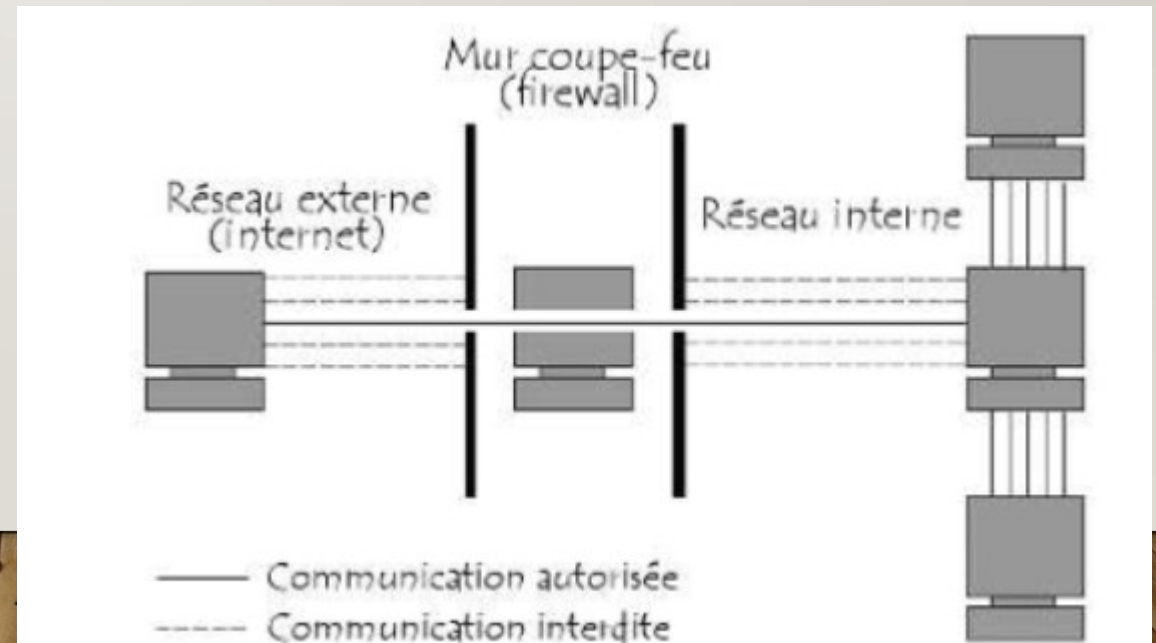
181

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Un pare-feu (appelé aussi coupe-feu, garde-barrière ou firewall), est un système permettant de protéger un ordinateur, ou un réseau d'ordinateurs, des intrusions provenant d'un réseau tiers (notamment Internet). Le pare-feu est un système permettant de filtrer les paquets de données échangés avec le réseau, il s'agit ainsi d'une passerelle filtrante comportant au minimum les interfaces réseau suivantes :

- une interface pour le réseau à protéger (réseau interne) ;
- une interface pour le réseau externe.



Première partie : Sécurité Informatique

182

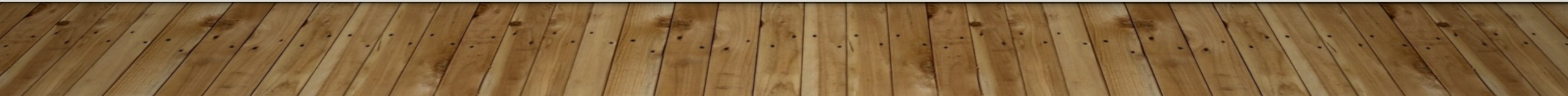
Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Le système pare-feu est un système logiciel, reposant parfois sur un matériel réseau dédié, constituant un intermédiaire entre le réseau local (ou la machine locale) et un ou plusieurs réseaux externes. Il est possible de mettre un système pare-feu sur n'importe quelle machine et avec n'importe quel système pourvu que :

- la machine soit suffisamment puissante pour traiter le trafic ;
- le système soit sécurisé ;
- aucun autre service que le service de filtrage de paquets ne fonctionne sur le serveur.

Dans le cas où le système pare-feu est fourni dans une boîte noire «clé en main », on utilise le terme d'appliance.



Première partie : Sécurité Informatique

183

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Principe de fonctionnement

Un système pare-feu contient un ensemble de règles prédéfinies permettant :

- d'autoriser la connexion (allow) ;
- de bloquer la connexion (deny) ;
- de rejeter la demande de connexion sans avertir l'émetteur(drop).

L'ensemble de ces règles permet de mettre en œuvre une méthode de filtrage dépendant de la politique de sécurité adoptée par l'entité. On distingue habituellement deux types de politiques de sécurité permettant :

- soit d'autoriser uniquement les communications ayant été explicitement autorisées : « Tout ce qui n'est pas explicitement autorisé est interdit » ;
- soit d'empêcher les échanges qui ont été explicitement interdits.

Première partie : Sécurité Informatique

184

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

La première méthode est sans nul doute la plus sûre, mais elle impose toutefois une définition précise et contraignante des besoins en communication.

☐ Filtrage simple de paquets

Un système pare-feu fonctionne sur le principe du filtrage simple de paquets (stateless packet filtering). Il analyse les en-têtes de chaque paquet de données (datagramme) échangé entre une machine du réseau interne et une machine extérieure.

Ainsi, les paquets de données échangés entre une machine du réseau extérieur et une machine du réseau interne transitent par le pare-feu et possèdent les en-têtes suivants, systématiquement analysés par le firewall :

- adresse IP de la machine émettrice ;
- adresse IP de la machine réceptrice ;
- type de paquet (TCP, UDP, etc.) ;
- numéro de port (rappel : un port est un numéro associé à un service ou une application réseau).

Première partie : Sécurité Informatique

185

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Les adresses IP contenues dans les paquets permettent d'identifier la machine émettrice et la machine cible, tandis que le type de paquet et le numéro de port donnent une indication sur le type de service utilisé.

Les ports reconnus (dont le numéro est compris entre 0 et 1 023) sont associés à des services courants (les ports 25 et 110 sont par exemple associés au courrier électronique, et le port 80 au Web). La plupart des dispositifs pare-feu sont au minimum configurés de manière à filtrer les communications selon le port utilisé. Il est généralement conseillé de bloquer tous les ports qui ne sont pas indispensables (selon la politique de sécurité retenue).

Le port 23 est par exemple souvent bloqué par défaut par les dispositifs pare-feu car il correspond au protocole telnet, permettant d'émuler un accès par terminal à une machine distante de manière à pouvoir exécuter des commandes à distance. Les données échangées par telnet ne sont pas chiffrées, ce qui signifie qu'un individu est susceptible d'écouter le réseau et de voler les éventuels mots de passe circulant en clair. Les administrateurs lui préfèrent généralement le protocole SSH, réputé sûr et fournissant les mêmes fonctionnalités que telnet.

Première partie : Sécurité Informatique

186

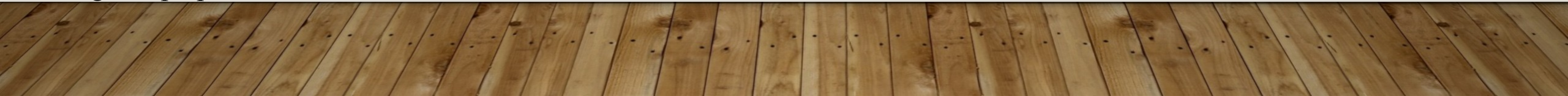
Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

□ Filtrage dynamique

Le filtrage simple de paquets ne s'attache qu'à examiner les paquets IP indépendamment les uns des autres, ce qui correspond au niveau 3 du modèle OSI. Or, la plupart des connexions reposent sur le protocole TCP, qui gère la notion de session, afin d'assurer le bon déroulement des échanges. D'autre part, de nombreux services (le FTP par exemple) initient une connexion sur un port statique, mais ouvrent dynamiquement (c'est-à-dire de manière aléatoire) un port afin d'établir une session entre la machine faisant office de serveur et la machine cliente.

Ainsi, il est impossible avec un filtrage simple de paquets de prévoir les ports à laisser passer ou à interdire. Pour y remédier, le système de filtrage dynamique de paquets est basé sur l'inspection des couches 3 et 4 du modèle OSI, permettant d'effectuer un suivi des transactions entre le client et le serveur. Le terme anglosaxon est stateful inspection ou stateful packet filtering, traduisez « filtrage de paquets avec état ».



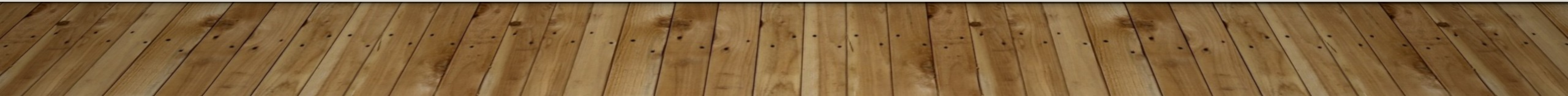
Première partie : Sécurité Informatique

187

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Un dispositif pare-feu de type stateful inspection est ainsi capable d'assurer un suivi des échanges, c'est-à-dire de tenir compte de l'état des anciens paquets pour appliquer les règles de filtrage. De cette manière, à partir du moment où une machine autorisée initie une connexion à une machine située de l'autre côté du pare-feu ; l'ensemble des paquets transitant dans le cadre de cette connexion seront implicitement acceptés par le pare-feu. Si le filtrage dynamique est plus performant que le filtrage de paquets basique, il ne protège pas pour autant de l'exploitation des failles applicatives, liées aux vulnérabilités des applications. Or, ces vulnérabilités représentent la part la plus importante des risques en termes de sécurité.



Première partie : Sécurité Informatique

188

Chapitre 3 : Système de protection informatique

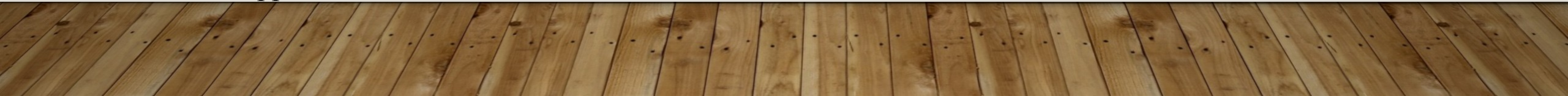
3.2 Système pare-feu (firewall)

□ Filtrage applicatif

Le filtrage applicatif permet de filtrer les communications application par application. Le filtrage applicatif opère donc au niveau 7 (couche application) du modèle OSI, contrairement au filtrage de paquets simple (niveau 4). Le filtrage applicatif suppose donc une connaissance des applications présentes sur le réseau, et notamment de la manière dont les données sont échangées (ports, etc.). Le filtrage applicatif permet, comme son nom l'indique, de filtrer les communications application par application.

Un firewall effectuant un filtrage applicatif est appelé généralement passerelle applicative (ou proxy), car il sert de relais entre deux réseaux en s'interposant et en effectuant une validation fine du contenu des paquets échangés.

Le proxy représente donc un intermédiaire entre les machines du réseau interne et le réseau externe, subissant les attaques à leur place. De plus, le filtrage applicatif permet la destruction des en-têtes précédant le message applicatif, ce qui permet de fournir un niveau de sécurité supplémentaire.



Première partie : Sécurité Informatique

189

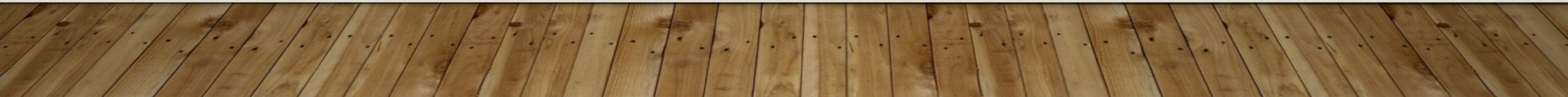
Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Il s'agit d'un dispositif performant, assurant une bonne protection du réseau, pour peu qu'il soit correctement administré. En contrepartie, une analyse fine des données applicatives requiert une grande puissance de calcul et se traduit donc souvent par un ralentissement des communications, chaque paquet devant être finement analysé.

Par ailleurs, le proxy doit nécessairement être en mesure d'interpréter une vaste gamme de protocoles et connaître les failles afférentes pour être efficace.

Enfin, un tel système peut potentiellement comporter une vulnérabilité dans la mesure où il interprète les requêtes qui transitent par son biais. Ainsi, il est recommandé de dissocier le pare-feu (dynamique ou non) du proxy, afin de limiter les risques de compromission.



Première partie : Sécurité Informatique

190

Chapitre 3 : Système de protection informatique

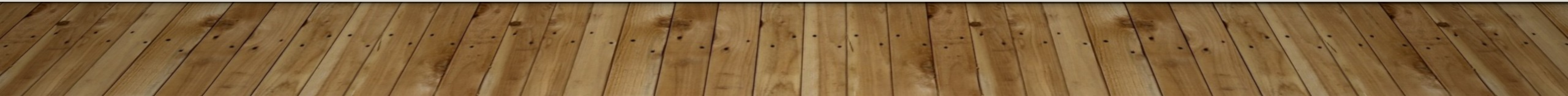
3.2 Système pare-feu (firewall)

Pare-feu personnel

Dans le cas où la zone protégée se limite à l'ordinateur sur lequel le firewall est installé on parle de firewall personnel (pare-feu personnel).

Ainsi, un firewall personnel permet de contrôler l'accès au réseau des applications installées sur la machine, et notamment empêcher les attaques du type cheval de Troie, c'est-à-dire des programmes nuisibles ouvrant une brèche dans le système afin de permettre une prise en main à distance de la machine par un pirate informatique.

Le firewall personnel permet en effet de repérer et d'empêcher l'ouverture non sollicitée de la part d'applications non autorisées à se connecter.



Première partie : Sécurité Informatique

191

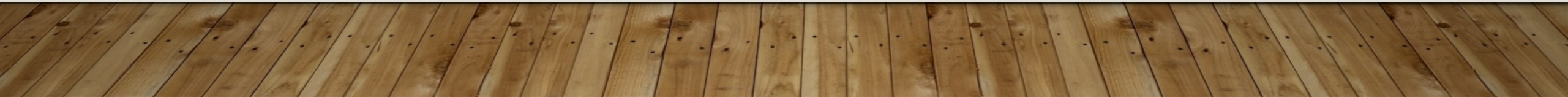
Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

CATEGORIES DE PARE-FEU

Il existe 3 modèles de firewalls. Chacun possède des avantages et désagréments. Il faudra donc préalablement analyser les besoins réels en termes de sécurité, ainsi que les coûts engendrés avant toute utilisation :

➤ **Les firewalls Bridge** - Ce format de mur de feu a l'apparence d'un simple câble réseau, sans machine spécifique. Il est invisible et indétectable pour un pirate, son adresse MAC ne circulant jamais sur le réseau. Placé sur le réseau, le pirate devra donc automatiquement passer par lui pour transmettre des requêtes. On trouvera notamment ce type de firewalls dans des Switch. Ces formats de pare-feu ont **pour avantages** : Ils sont relativement peu coûteux et transparent lors de leurs mises en place. Ils présentent comme **Inconvénients** : Pour les contourner, il suffit d'adapter l'attaque ; et ses fonctionnalités sont souvent restreintes.



Première partie : Sécurité Informatique

192

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

□ **Les firewalls hardware** - Ils sont souvent assimilés à des boîtes noires, l'accès à leur code étant difficile. Ce type de matériel propriétaire renferme d'ailleurs souvent un système de protection permettant d'authentifier le logiciel associé (par signature RSA par exemple), et ainsi rendre toute modification pratiquement impossible. Ils ont pour avantages : Ils sont facilement intégrables au réseau ; leur administration est souvent simplifiée et leur niveau de sécurité est assez élevé. Ils présentent comme Inconvénients : Ce type de firewall étant propriétaire, les mises à jour dépendent entièrement du constructeur et en raison de l'architecture hardware, peu de modifications sont autorisées.

✚ **Les firewalls logiciels** - Ces pare-feu existent autant sous forme commerciales que sous forme gratuites. Quelque soit leur origine, la sécurité pourra fortement varier. Un logiciel commercial pourra parfois mettre en avant sa facilité de mise en place et de configuration, mais ce sera souvent aux dépens de la sécurité. Au niveau des logiciels gratuits et/ou libres, ils seront souvent plus flexibles (c'est-à-dire plus fournis en options), mais nécessiteront la plupart du temps de bonnes connaissances en réseau afin de les configurer finement sans abaisser le niveau de sécurité.

Première partie : Sécurité Informatique

193

Chapitre 3 : Système de protection informatique

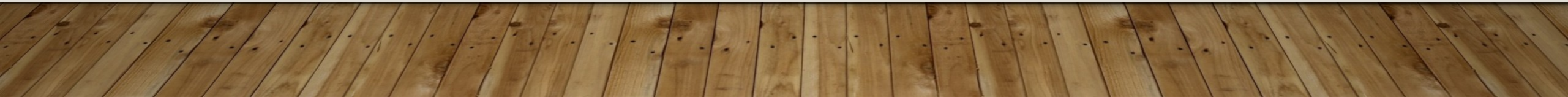
3.2 Système pare-feu (firewall)

Limites des systèmes pare-feu

Un système pare-feu n'offre bien évidemment pas une sécurité absolue, bien au contraire. Les firewalls n'offrent une protection que dans la mesure où l'ensemble des communications vers l'extérieur passe systématiquement par leur intermédiaire et qu'ils sont correctement configurés. Ainsi, les accès au réseau extérieur par contournement du firewall sont autant de failles de sécurité. C'est notamment le cas des connexions effectuées à partir du réseau interne à l'aide d'un modem ou de tout moyen de connexion échappant au contrôle du pare-feu.

De la même manière, l'introduction de supports de stockage provenant de l'extérieur sur des machines internes au réseau ou bien d'ordinateurs portables peut porter fortement préjudice à la politique de sécurité globale.

Enfin, afin de garantir un niveau de protection maximal, il est nécessaire d'administrer le pare-feu et notamment de surveiller son journal d'activité afin d'être en mesure de détecter les tentatives d'intrusion et les anomalies.



Première partie : Sécurité Informatique

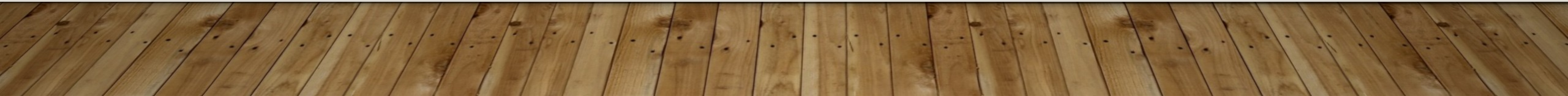
194

Chapitre 3 : Système de protection informatique

3.2 Système pare-feu (firewall)

Par ailleurs, il est recommandé d'effectuer une veille de sécurité (en s'abonnant aux alertes de sécurité des CERT par exemple) afin de modifier le paramétrage de son dispositif en fonction de la publication des alertes.

La mise en place d'un firewall doit donc se faire en accord avec une véritable politique de sécurité.



Première partie : Sécurité Informatique

195

Chapitre 3 : Système de protection informatique

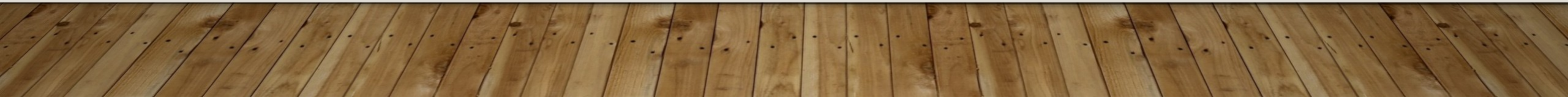
3.3 Zone démilitarisée (DMZ)

Les systèmes pare-feu (firewall) permettent de définir des règles d'accès entre deux réseaux. Néanmoins, dans la pratique, les entreprises ont généralement plusieurs sous-réseaux avec des politiques de sécurité différentes.

C'est la raison pour laquelle il est nécessaire de mettre en place des architectures de systèmes pare-feu permettant d'isoler les différents réseaux de l'entreprise : on parle ainsi de cloisonnement des réseaux (le terme isolation est parfois également utilisé).

Lorsque certaines machines du réseau interne ont besoin d'être accessibles de l'extérieur (serveur web, serveur de messagerie, serveur FTP public, etc.), il est souvent nécessaire de créer une nouvelle interface vers un réseau à part, accessible aussi bien du réseau interne que de l'extérieur, sans pour autant risquer de compromettre la sécurité de l'entreprise.

On parle ainsi de zone démilitarisée (notée DMZ, DeMilitarized Zone) pour désigner cette zone isolée hébergeant des applications mises à disposition du public. La DMZ fait ainsi office de « zone tampon » entre le réseau à protéger et le réseau hostile.



Première partie : Sécurité Informatique

196

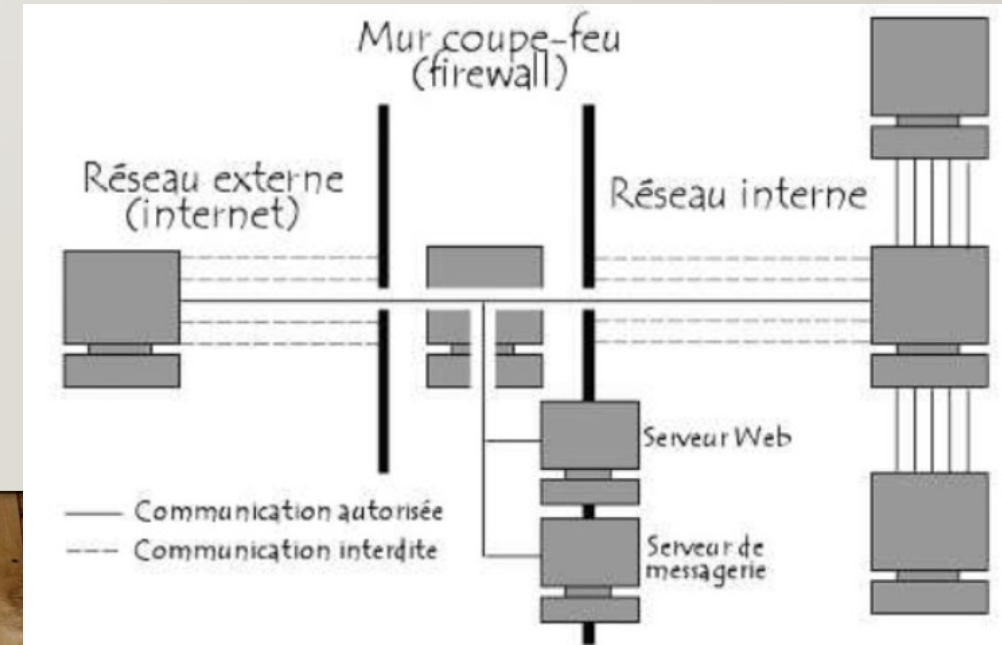
Chapitre 3 : Système de protection informatique

3.3 Zone démilitarisée (DMZ)

Les serveurs situés dans la DMZ sont appelés bastions en raison de leur position d'avant-poste dans le réseau de l'entreprise.

La politique de sécurité mise en œuvre sur la DMZ est généralement la suivante :

- Trafic du réseau externe vers la DMZ **autorisé**.
- Trafic du réseau externe vers le réseau interne **interdit**.
- Trafic du réseau interne vers la DMZ **autorisé**.
- Trafic du réseau interne vers le réseau externe **autorisé**.
- Trafic de la DMZ vers le réseau interne **interdit**.
- Trafic de la DMZ vers le réseau externe **interdit**



Première partie : Sécurité Informatique

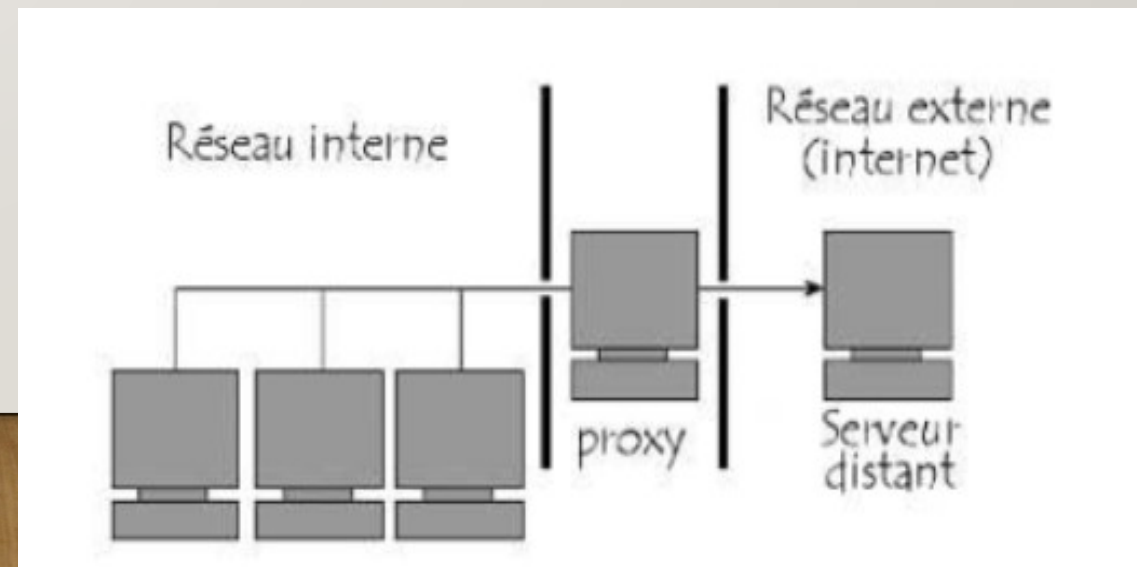
197

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

Un serveur proxy (traduction française de proxy server, appelé aussi serveur mandataire) est à l'origine une machine faisant fonction d'intermédiaire entre les ordinateurs d'un réseau local (utilisant parfois des protocoles autres que le protocole TCP/IP) et Internet.

La plupart du temps le serveur proxy est utilisé pour le Web, il s'agit alors d'un proxy HTTP. Toutefois il peut exister des serveurs proxy pour chaque protocole applicatif (FTP, etc.).



Première partie : Sécurité Informatique

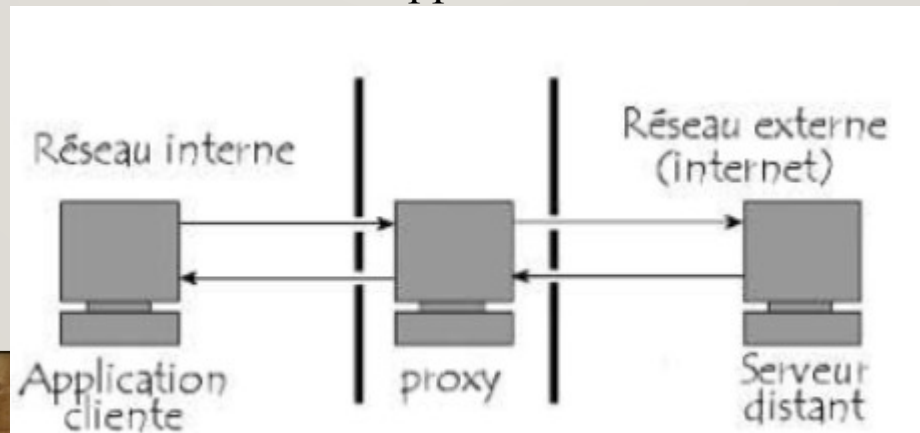
198

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

Principe de fonctionnement

Le principe de fonctionnement d'un serveur proxy est assez simple : il s'agit d'un serveur « mandaté » par une application pour effectuer une requête sur Internet à sa place. Ainsi, lorsqu'un utilisateur se connecte à l'aide d'une application cliente configurée pour utiliser un serveur proxy, celle-ci va se connecter en premier lieu au serveur proxy et lui donner sa requête. Le serveur proxy va alors se connecter au serveur que l'application cliente cherche à joindre et lui transmettre la requête. Le serveur va ensuite donner sa réponse au proxy, qui va à son tour la transmettre à l'application cliente.



Première partie : Sécurité Informatique

199

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

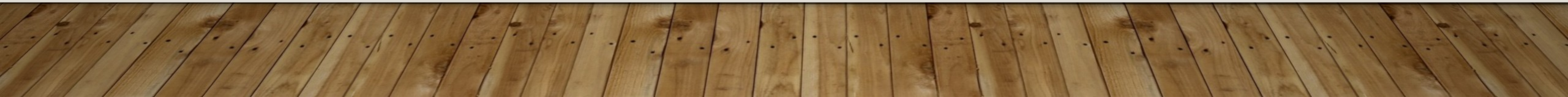
Fonctionnalités d'un serveur proxy

Avec l'utilisation de TCP/IP au sein des réseaux locaux, le rôle de relais du serveur proxy est directement assuré par les passerelles et les routeurs. Pour autant, les serveurs proxy sont toujours d'actualité grâce à un certain nombre d'autres fonctionnalités.

☐ Cache

La plupart des proxys assurent ainsi une fonction de cache (caching), c'est-à-dire la capacité à garder en mémoire (en « cache ») les pages les plus souvent visitées par les utilisateurs du réseau local afin de pouvoir les leur fournir le plus rapidement possible. En effet, en informatique, le terme de « cache » désigne un espace de stockage temporaire de données (le terme de « tampon » est également parfois utilisé).

Un serveur proxy ayant la possibilité de cacher (néologisme signifiant « mettre en mémoire cache ») les informations est généralement appelé serveur proxy-cache.



Première partie : Sécurité Informatique

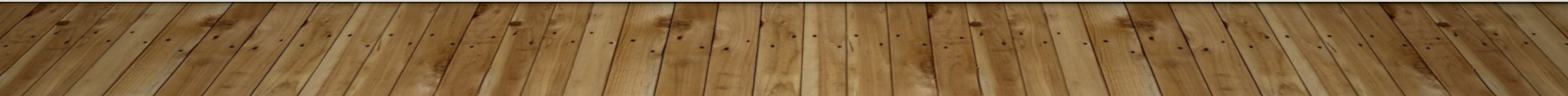
200

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

Cette fonctionnalité implémentée dans certains serveurs proxy permet d'une part de réduire l'utilisation de la bande passante vers Internet ainsi que de réduire le temps d'accès aux documents pour les utilisateurs.

Toutefois, pour mener à bien cette mission, il est nécessaire que le proxy compare régulièrement les données qu'il stocke en mémoire cache avec les données distantes afin de s'assurer que les données en cache sont toujours valides.



Première partie : Sécurité Informatique

201

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

☐ Filtrage

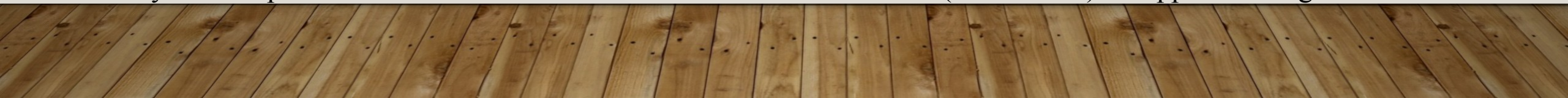
D'autre part, grâce à l'utilisation d'un proxy, il est possible d'assurer un suivi des connexions (logging ou tracking) via la constitution de journaux d'activité (logs) en enregistrant systématiquement les requêtes des utilisateurs lors de leurs demandes de connexion à Internet.

Il est ainsi possible de filtrer les connexions à Internet en analysant d'une part les requêtes des clients, d'autre part les réponses des serveurs.

Le filtrage basé sur l'adresse des ressources consultées est appelé filtrage d'URL.

Lorsque le filtrage est réalisé en comparant la requête du client à une liste de requêtes autorisées, on parle de liste blanche, lorsqu'il s'agit d'une liste de sites interdits on parle de liste noire.

Enfin l'analyse des réponses des serveurs conformément à une liste de critères (mots-clés...) est appelée filtrage de contenu.



Première partie : Sécurité Informatique

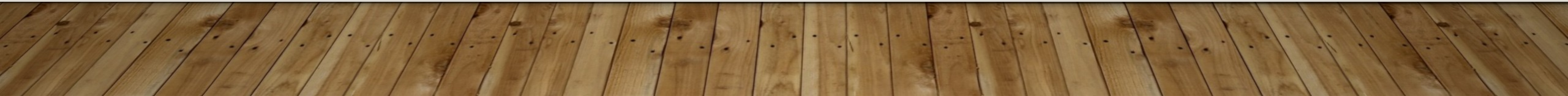
202

Chapitre 3 : Système de protection informatique

3.4 Serveurs mandataires(proxy)

☐ **Authentication**

Dans la mesure où le proxy est l'intermédiaire indispensable des utilisateurs du réseau interne pour accéder à des ressources externes, il est parfois possible de l'utiliser pour authentifier les utilisateurs, c'est-à-dire de leur demander de s'identifier à l'aide d'un nom d'utilisateur et d'un mot de passe par exemple. Il est ainsi aisé de donner l'accès aux ressources externes aux seules personnes autorisées à le faire et de pouvoir enregistrer dans les fichiers journaux des accès identifiés. Ce type de mécanisme lorsqu'il est mis en œuvre pose bien évidemment de nombreux problèmes relatifs aux libertés individuelles et aux droits des personnes.



Première partie : Sécurité Informatique

203

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

On appelle IDS (Intrusion Detection System) un mécanisme écoutant le trafic réseau de manière furtive afin de repérer des activités anormales ou suspectes et permettant ainsi d'avoir une action de prévention sur les risques d'intrusion.

Il existe deux grandes familles distinctes d'IDS :

- **Les N-IDS** (Network Based Intrusion Detection System) : ils assurent la sécurité au niveau du réseau.(snort, suricata, checkpoint)
- **Les H-IDS** (Host Based Intrusion Detection System) : ils assurent la sécurité au niveau des hôtes.(fail2ban,IceSword, Ossec,Tripwire,,)
- **les IDS hybrides**, qui utilisent les NIDS et HIDS pour avoir des alertes plus pertinentes(ossim, prelude,,)

Un N-IDS nécessite un matériel dédié et constitue un système capable de contrôler les paquets circulant sur un ou plusieurs liens réseau dans le but de découvrir si un acte malveillant ou anormal a lieu. Le N-IDS place une ou plusieurs cartes d'interface réseau du système dédié en mode promiscuité (promiscuous mode), elles sont alors en mode « furtif » afin qu'elles n'aient pas d'adresse IP. Elles n'ont pas non plus de pile de protocole attachée.

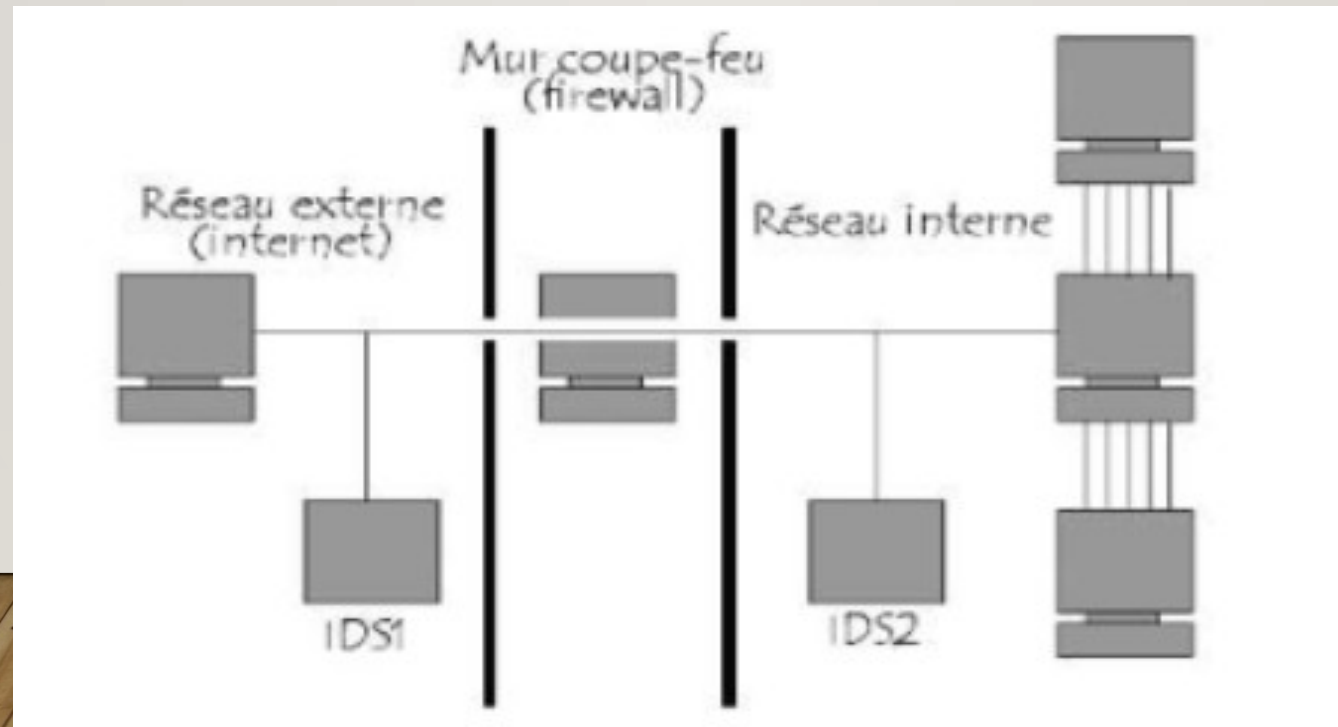
Première partie : Sécurité Informatique

204

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Il est fréquent de trouver plusieurs IDS sur les différentes parties du réseau et en particulier de placer une sonde à l'extérieur du réseau afin d'étudier les tentatives d'attaques ainsi qu'une sonde en interne pour analyser les requêtes ayant traversé le pare-feu ou bien menées depuis l'intérieur



Première partie : Sécurité Informatique

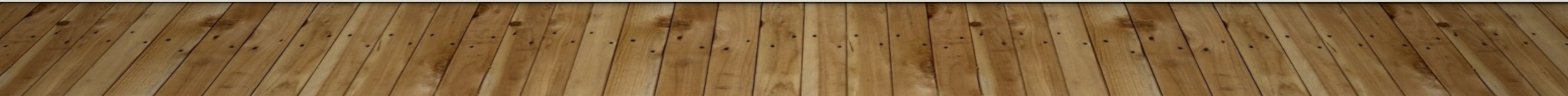
205

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Le H-IDS réside sur un hôte particulier et la gamme de ces logiciels couvre donc une grande partie des systèmes d'exploitation tels que Windows, Solaris, Linux, HP-UX, Aix, etc.

Le H-IDS se comporte comme un démon ou un service standard sur un système hôte. Traditionnellement, le H-IDS analyse des informations particulières dans les journaux de logs et aussi capture les paquets réseaux entrant/sortant de l'hôte pour y déceler des signaux d'intrusions (déni de services, backdoors, chevaux de Troie, tentatives d'accès non autorisés, exécution de codes malicieux, attaques par débordement de tampon, etc.).



Première partie : Sécurité Informatique

206

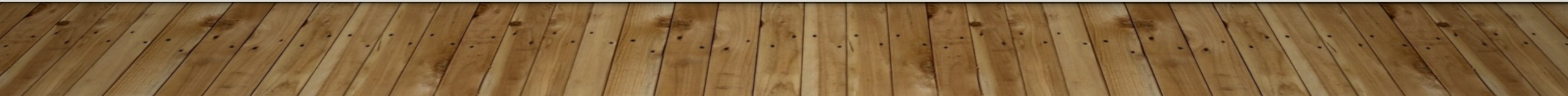
Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Techniques de détection

Le trafic réseau est généralement (en tout cas sur Internet) constitué de datagrammes IP. Un N-IDS est capable de capturer les paquets lorsqu'ils circulent sur les liaisons physiques sur lesquelles il est connecté. Un N-IDS consiste en une pile TCP/IP qui réassemble les datagrammes IP et les connexions TCP. Il peut appliquer les techniques suivantes pour reconnaître les intrusions :

► **Vérification de la pile protocolaire** : un nombre d'intrusions, tels que par exemple ping of death et TCP stealth scanning ont recours à des violations des protocoles IP, TCP, UDP, et ICMP dans le but d'attaquer une machine. Une simple vérification protocolaire peut mettre en évidence les paquets invalides et signaler ce type de techniques très usitées.



Première partie : Sécurité Informatique

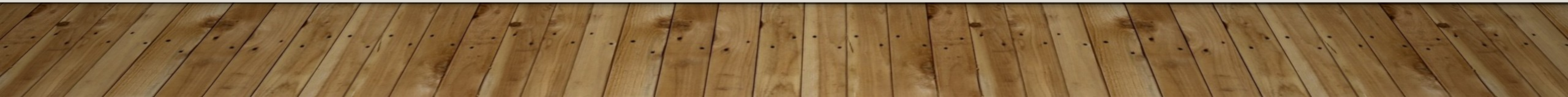
207

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

► **Vérification des protocoles applicatifs** : nombre d'intrusions utilisent des comportements protocolaires invalides, comme par exemple WinNuke, qui utilise des données NetBIOS invalides (ajout de données OOB data). Dans le but de détecter efficacement ce type d'intrusions, un N-IDS doit implémenter une grande variété de protocoles applicatifs tels que NetBIOS, TCP/IP...

Cette technique est rapide (il n'est pas nécessaire de chercher des séquences d'octets sur l'exhaustivité de la base de signatures), élimine en partie les fausses alertes et s'avère donc plus efficiente. Par exemple, grâce à l'analyse protocolaire le N-IDS distinguera un événement de type « Back Orifice PING » (dangerosité basse) d'un événement de type « Back Orifice COMPROMISE » (dangerosité haute).



Première partie : Sécurité Informatique

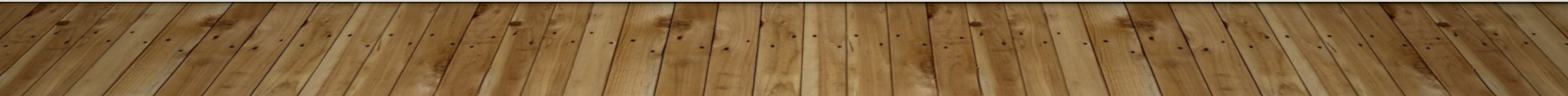
208

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

► **Reconnaissance des attaques par pattern matching** : cette technique de reconnaissance d'intrusions est la plus ancienne méthode d'analyse des N-IDS et elle est encore très courante.

Il s'agit de l'identification d'une intrusion par le seul examen d'un paquet et la reconnaissance dans une suite d'octets du paquet d'une séquence caractéristique d'une signature précise. Par exemple, la recherche de la chaîne de caractères « /cgi-bin/phf », qui indique une tentative d'exploit sur le script CGI appelé « phf ». Cette méthode est aussi utilisée en complément de filtres sur les adresses IP sources, destinations utilisées par les connexions, les ports sources et/ou destination. On peut tout aussi coupler cette méthode de reconnaissance afin de l'affiner avec la succession ou la combinaison de flags TCP.



Première partie : Sécurité Informatique

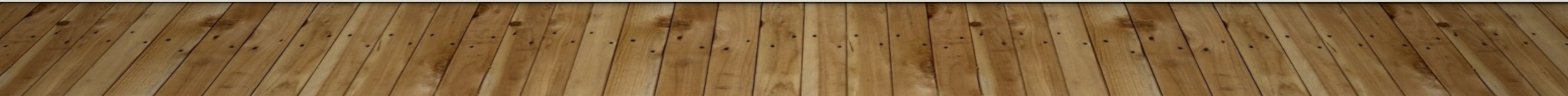
209

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Cette technique est répandue chez les N-IDS de type « Network Grep » basé sur la capture des paquets bruts sur le lien surveillé, et comparaison via un analyseur sémantique de type « expressions régulières » qui va tenter de faire correspondre les séquences de la base de signatures octet par octet avec le contenu du paquet capturé.

L'avantage principal de cette technique tient dans sa facilité de mise à jour et évidemment dans la quantité importante de signatures contenues dans la base du N-IDS. Cette technique entraîne néanmoins inévitablement un nombre important de fausses alertes ou faux positifs.



Première partie : Sécurité Informatique

210

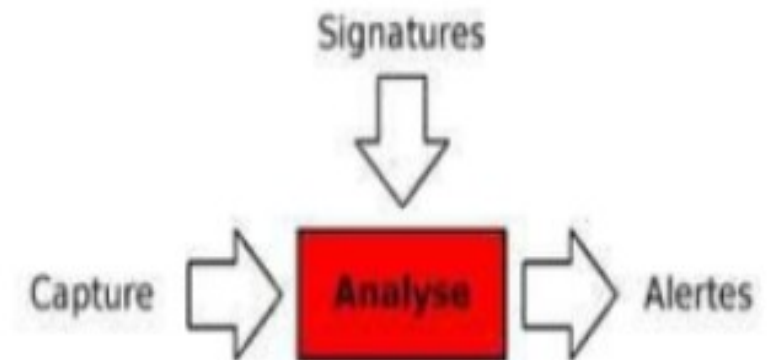
Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

LES NIDS (IDS réseau)

Un NIDS se découpe en trois grandes parties : la capture, les signatures et les alertes. Cependant à ces trois principales parties, s'ajoute de même 2 principales techniques :

--**La Capture** - La capture sert à la récupération de trafic réseau. En général cela se fait en temps réel, bien que certains NIDS permettent l'analyse de trafic capturé précédemment. La plupart des NIDS utilisent la bibliothèque standard de capture de paquets libpcap. La bibliothèque de capture de paquets Packet Capture Library est portée sur quasiment toutes les plates-formes, ce qui permet en général aux IDS réseau de suivre.



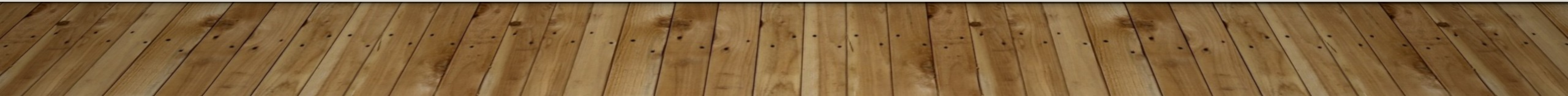
Première partie : Sécurité Informatique

211

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Le fonctionnement de la capture d'un NIDS est donc en général fortement lié à cette libpcap. Son mode de fonctionnement est de copier (sous Linux) tout paquet arrivant au niveau de la couche liaison de données du système d'exploitation. Une fois ce paquet copié, il lui est appliqué un filtre BPF (Berkeley Packet Filter), correspondant à l'affinage de ce que l'IDS cherche à récupérer comme information. Il se peut que certains paquets soient ignorés car sous une forte charge, le système d'exploitation ne les copiera pas. Le comportement de la libpcap est différent dans le monde BSD, puisqu'il lui attache le fichier périphérique « `/dev/bpf` », permettant ainsi aux NIDS de ne pas avoir besoin des droits super utilisateur pour capturer le trafic mais simplement de pouvoir lire sur ce fichier sur lequel les filtres sont directement compilés. Aussi, le trafic analysé n'est pas forcément égal à celui du trafic entrant, étant donné que la libpcap agit à une couche en dessous du pare-feu (qui agit au niveau réseau).



Première partie : Sécurité Informatique

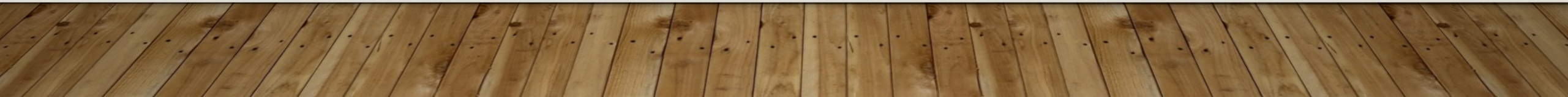
212

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

--Les Signatures - Les bibliothèques de signatures (approche par scénario) rendent la démarche d'analyse similaire à celle des anti-virus quand ceux-ci s'appuient sur des signatures d'attaques. Ainsi, le NIDS est efficace s'il connaît l'attaque, mais inefficace dans le cas contraire. Les outils commerciaux ou libres ont évolué pour proposer une personnalisation de la signature afin de faire face à des attaques dont on ne connaît qu'une partie des éléments. Les outils à base de signatures requièrent des mises à jour très régulières.

Les NIDS ont pour avantage d'être des systèmes temps réel et ont la possibilité de découvrir des attaques ciblant plusieurs machines à la fois. Leurs inconvénients sont le taux élevé de faux positifs qu'ils génèrent, le fait que les signatures aient toujours du retard sur les attaques de type « 0day » et qu'ils puissent être la cible d'une attaque.



Première partie : Sécurité Informatique

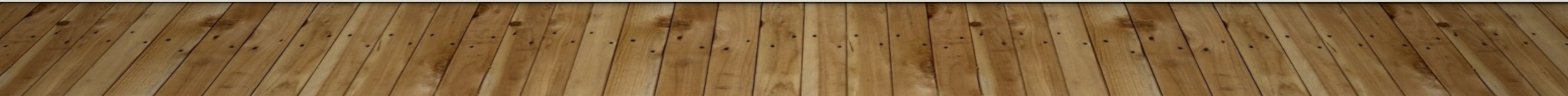
213

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

--**Les Alertes** - Les alertes sont généralement stockées dans les journaux du système.

Cependant il existe une norme qui permet d'en formaliser le contenu, afin de permettre à différents éléments de sécurité d'interopérer. Ce format s'appelle IDMEF (pour Intrusion Detection Message Exchange Format) décrit dans la RFC 4765. Le format IDMEF est popularisé par le projet Prelude, qui offre une infrastructure permettant aux IDS de ne pas avoir à s'occuper de l'envoi des alertes. Cela permet aux IDS de n'avoir qu'à décrire les informations qu'ils connaissent et « Prelude » se charge de les stocker pour permettre une visualisation humaine ultérieure.



Première partie : Sécurité Informatique

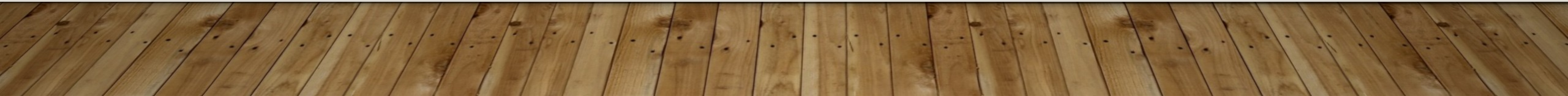
214

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

❗ **La recherche de motif (pattern matching)** - La recherche de motif est ce qui permet à un NIDS de trouver le plus rapidement possible les informations dans un paquet réseau.

□ **L'Analyse** - À partir des éléments donnés dans l'introduction, le moteur d'analyse met ces éléments de relation en employant plusieurs techniques : la défragmentation, la dissection protocolaire ou encore l'analyse comportementale :



Première partie : Sécurité Informatique

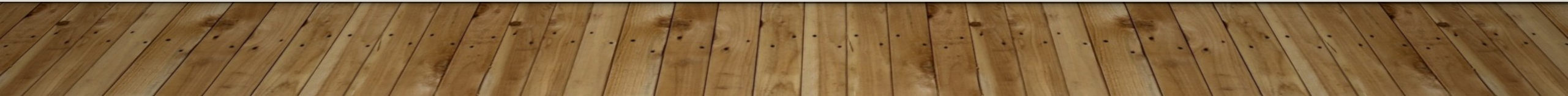
215

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

***La défragmentation** - Les paquets dépassant une certaine taille (qui en général est de 1 500 octets) sont fragmentés. La fragmentation de l'en-tête de la couche transport étant aussi possible, cela rendait les NIDS vulnérables aux attaques de Stick et de Snort car les paquets fragmentés n'étaient pas analysés. Les NIDS ont le devoir de défragmenter les paquets avant analyse, afin de ne pas manquer une attaque. Il s'agit d'une opération relativement complexe, étant donné que chaque hôte de destination ne défragmente pas de la même façon, selon le système d'exploitation sur lequel l'attaque est visée. Il s'agit encore d'une technique d'évasion utilisable aujourd'hui car les NIDS ne sont pas forcément configurés correctement pour gérer un cas précis.

***La dissection** - La dissection permet de comprendre un protocole donné, de le décoder pour l'analyser. Il s'agit de la partie la plus sensible des NIDS car c'est elle qui est le plus grand vecteur d'attaques



Première partie : Sécurité Informatique

216

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

LES HIDS (IDS machine)

Les HIDS, pour Host based IDS, signifiant "Système de détection d'intrusion machine« sont des IDS dédiés à un matériel ou système d'exploitation. Généralement, contrairement à un NIDS, le HIDS récupère les informations qui lui sont données par le matériel ou le système d'exploitation. Il y a pour cela plusieurs approches : signatures, comportement (statistiques) ou délimitation du périmètre avec un système d'ACL (Access Control List). Un HIDS se comporte comme un daemon ou un service standard sur un système hôte qui détecte une activité suspecte en s'appuyant sur une norme. Si les activités s'éloignent de la norme, une alerte est générée. La machine peut être surveillée sur plusieurs points :

- Ǻ Activité de la machine : nombre et listes de processus ainsi que d'utilisateurs, ressources consommées, ...
- Ǻ Activité de l'utilisateur : horaires et durée des connexions, commandes utilisées, messages envoyés, programmes activés, dépassement du périmètre défini...
- Ǻ Activité malicieuse d'un ver, virus ou cheval de Troie. □

Première partie : Sécurité Informatique

217

Chapitre 3 : Système de protection informatique

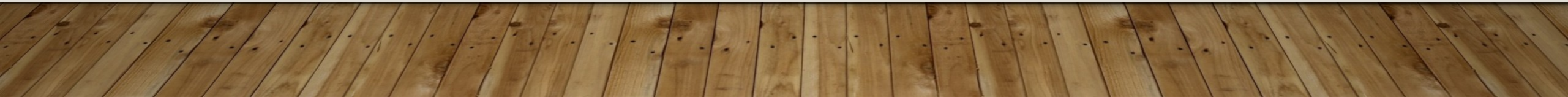
3.5 Systèmes de détection d'intrusions

Un autre type d'HIDS cherche les intrusions dans le « noyau » (kernel) du système, et les modifications qui y sont apportées.

Certains appellent cette technique « analyse protocolaire ». Très rapide, elle ne nécessite pas de recherche dans une base de signature. Exemples de contrôles pour Windows :

- EPROCESS (structure de données en mode noyau contenant des informations qui peuvent permettre de cacher un processus) ;
- Les processus fonctionnant en mode « noyau »
- Les fonctions logicielles système ou de gestion de périphérique présentes dans l'ordinateur.
- La SSDT (System Service Dispatch Table) table utilisée par Windows pour diriger des appels de système vers un traitement approprié : table d'adressage des interruptions ; etc.

Le HIDS a pour avantage de n'avoir que peu de faux positifs, permettant d'avoir des alertes pertinentes. Quant à ses inconvénients il faut configurer un HIDS par poste et il demande une configuration de chaque système.



Première partie : Sécurité Informatique

218

Chapitre 3 : Système de protection informatique

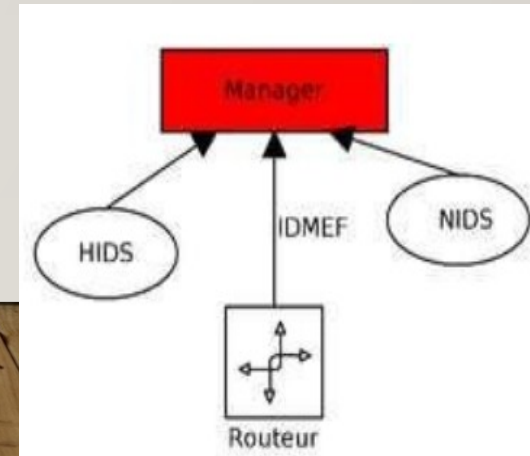
3.5 Systèmes de détection d'intrusions

LES IDS hybride

Les IDS hybrides sont basés sur une architecture distribuée, où chaque composant unifie son format d'envoi d'alerte (typiquement IDMEF : Intrusion Detection Message Exchange Format) permettant à des composants divers de communiquer et d'extraire des alertes plus pertinentes.

Les avantages des IDS hybrides sont multiples :

- ☐ Moins de faux positifs ;
- ☐ Meilleure corrélation ;
- ✂ Possibilité de réaction sur les analyseurs.



Première partie : Sécurité Informatique

219

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

TECHNIQUES D'ANALYSE DU TRAFIC DES IDS

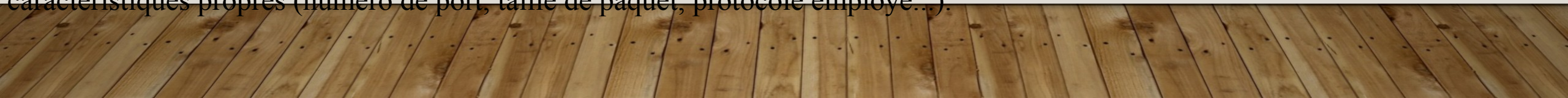
Il existe principalement deux techniques d'analyse du trafic, chacune ayant des avantages et des inconvénients :

➤ **L'analyse comportementale** (AIDS : Anomaly Intrusion Detection System) - à partir d'un comportement normal déterminé, l'IDS analyse le comportement des machines. Si un ordinateur se connecte en pleine nuit alors que personne n'est présent, cela pourrait lever une alerte pour l'IDS. Ainsi, dans ce type d'analyse, un profil est dressé et lorsque la machine liée s'éloigne du profil type, l'IDS réagit.

> **Avantage** : ce type d'analyse permet de détecter des attaques inconnues, elle ne nécessite pas de base de données.

> **Inconvénient** : cette détection est assez aléatoire, elle peut produire de fausses alertes relativement facilement.

➤ **L'analyse par scénario** (MIDS : Misuse Intrusion Detection System) - l'IDS utilise ici une base de données de signatures d'attaques. Ces signatures peuvent être assimilées à des déroulements d'attaques. En effet, chaque attaque possède des caractéristiques propres (numéro de port, taille de paquet, protocole employé...).



Première partie : Sécurité Informatique

220

Chapitre 3 : Système de protection informatique

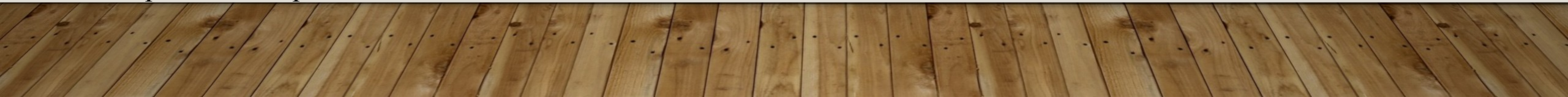
3.5 Systèmes de détection d'intrusions

Ces caractéristiques peuvent être collectées et placées dans une base de données qu'interrogera l'IDS. Ce type d'IDS utilise les fichiers journaux (log). Dès qu'il détectera des séquences suspectes (relatives à une signature de sa base de données), il déclenchera une alerte.

☞ **Avantage** : on peut gérer les attaques de façon très précise.

☞ **Inconvénient** : on doit maintenir une base de données à jour.

Avertissons que certains IDS analysent uniquement les fichiers systèmes (fichiers d'historique), et d'autres uniquement le trafic réseau. On les nomme respectivement HIDS pour "Host IDS" (protection des machines) et NIDS pour "Network IDS" (protection du réseau). Les IDS ne réagissent pas non plus de la même manière en présence d'une attaque. La plupart agissent passivement, c'est-à-dire qu'une fois l'attaque détectée, ils émettent simplement une alerte. D'autres, beaucoup moins répandus, tentent de contre-attaquer. On dit que ces derniers sont actifs.



Première partie : Sécurité Informatique

221

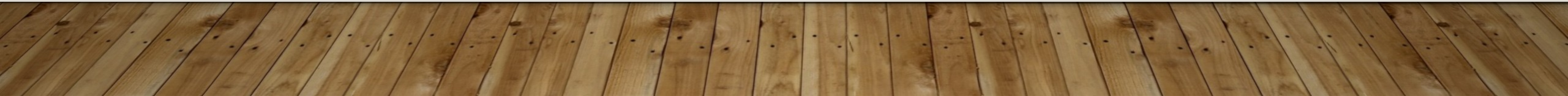
Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

LA CORRÉLATION DES IDS HYBRIDE

La corrélation est une connexion entre deux ou plusieurs éléments, dont un de ces éléments crée ou influence un autre. Elle se traduit plus généralement par la transformation d'une ou plusieurs alertes en attaque. Cela permet de faciliter la compréhension sur les attaques au lieu de s'éparpiller parmi les alertes. Idéalement, elle nécessite un IDS Hybride car plus il y a d'informations hétérogènes sur un événement, plus la corrélation se fait d'une façon pertinente.

Les formats ayant été normalisés (IDMEF), il ne reste plus qu'à faire des associations afin de détecter des alertes qui n'auraient jamais eu lieu sur un analyseur seul.



Première partie : Sécurité Informatique

222

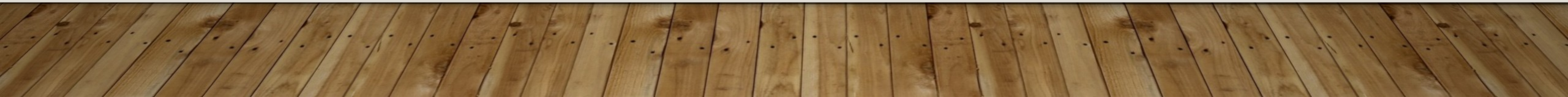
Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

Si l'on prend l'exemple d'une authentification échouée, cela génère une alerte de faible intensité. Mais s'il y a une série d'authentifications échouées avec des utilisateurs différents, on peut conclure à une attaque de force brute. La corrélation permet de générer de nouvelles alertes à partir de celles existantes. C'est une étape préalable à une contre-mesure efficace. Il y a diverses façons de faire de la corrélation. Cependant on peut définir deux catégories :

---**la corrélation passive** - correspondant à une génération d'alerte basée sur celles existantes. Nous pouvons prendre par exemple les scans de force brute ssh ;

---**la corrélation active** - qui va chercher les informations correspondant à des alertes émises. Par exemple, lorsqu'une personne se connecte en dehors des heures de travail, cela a une influence importante qui n'aurait pas été en temps normal d'activité



Première partie : Sécurité Informatique

223

Chapitre 3 : Système de protection informatique

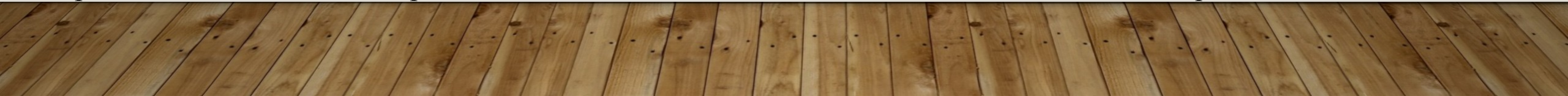
3.5 Systèmes de détection d'intrusions

L'HARMONISATION DES FORMATS

Le format IDMEF (Intrusion Detection Message Exchange Format) décrit une alerte de façon objet et exhaustive. Une alerte est le message qui est émis depuis un analyseur, qui est une sonde en langage IDMEF, vers un collecteur. Le but d>IDMEF est de proposer un standard permettant d'avoir une communication homogène quels que soient l'environnement ou les capacités d'un analyseur donné.

Ces alertes sont définies au format XML, offrant une possibilité de validation de chaque message. En général, les implémentations restent binaires, afin d'éviter les problèmes connus d'ajout d'information inutiles en dehors d'XML lorsque l'on envoie un message sur le réseau.

Le format IDMEF offre aussi un vocabulaire précis, qu'il est courant d'utiliser dans le domaine de la détection d'intrusions. Par exemple, une classification correspond au nom d'une alerte ; une influence à celui d'un niveau d'attaque.



Première partie : Sécurité Informatique

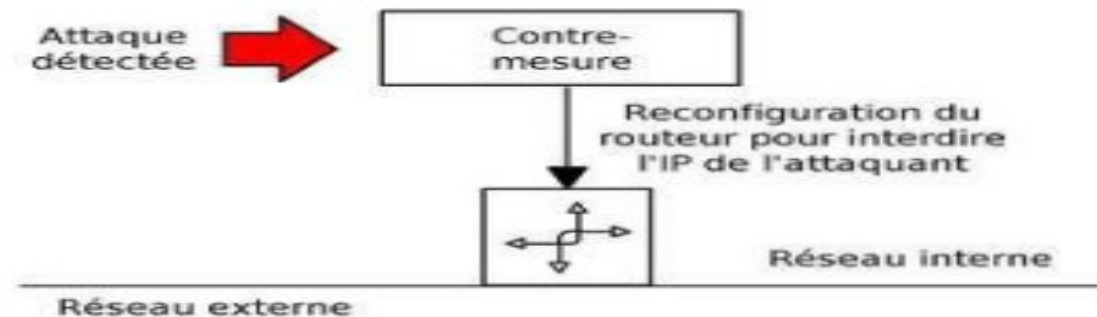
224

Chapitre 3 : Système de protection informatique

3.5 Systèmes de détection d'intrusions

LA CONTRE-MESURE DES IDS HYBRIDE

La contre-mesure est l'art de piloter les éléments réseau ou la machine cible, afin d'empêcher une attaque de se propager (Islanding) ou de perdurer. Il s'agit d'une procédure assez compliquée et souvent désactivée. Ce qui rend la contre-mesure difficile est la définition d'une attaque d'un point de vue formel. Il n'est pas possible de se baser sur des éléments qui génèrent des faux positifs. Et cela peut aussi engendrer un autre problème où l'attaquant se fait passer pour un client du réseau en générant des motifs d'attaque. Cela peut même bloquer le réseau interne si la contre-mesure est mal configurée. Un système de contre-mesure se configure en général avec une liste blanche, dans laquelle sont mises les IP du réseau interne.



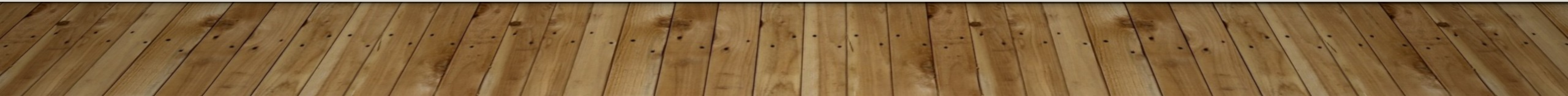
Première partie : Sécurité Informatique

225

Chapitre 4 : Administration d'accès aux données informatiques

Introduction

Dans ce chapitre, nous allons présenter d'une manière succincte les différentes techniques d'accès aux données dans un système informatique en général et dans un système d'exploitation en particulier. Étant donné que l'accès à un système exige une authentification, nous allons exposer les caractéristiques et la problématique d'un mot de passe.



Première partie : Sécurité Informatique

226

Chapitre 4 : Administration d'accès aux données informatiques

4.1 Modèle de LAMPSON

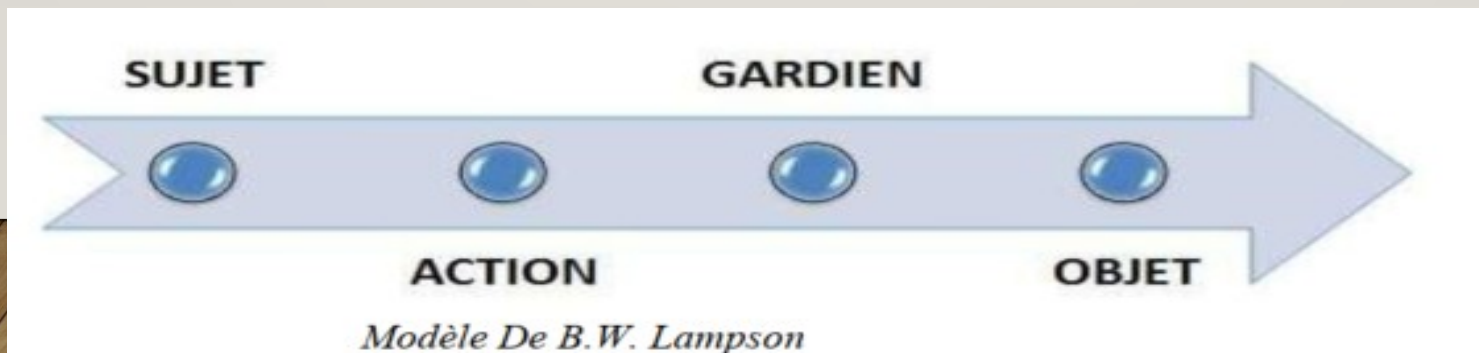
C'est en 2001 que Butler W. Lampson a présenté un modèle mettant en évidence les relations entre les différentes entités réelles d'un système d'accès aux données. Avant de voir un peu plus en détails les trois méthodes d'accès principales existantes, nous allons donc présenter son modèle. Lampson a défini les entités de son modèle en ceci :

✂ **Sujet** - Entité pouvant effectuer des actions (humain, processus, machine,. . .) ;

□ **Action** - Opération effectuée par le sujet afin d'accéder à l'objet ;

✂ **Gardien** - Entité contrôlant l'accès proprement dit.

□ **Objet** - Entité considérée comme ressource nécessitant un contrôle d'accès (fichier, répertoire, port,. . .) ;



Première partie : Sécurité Informatique

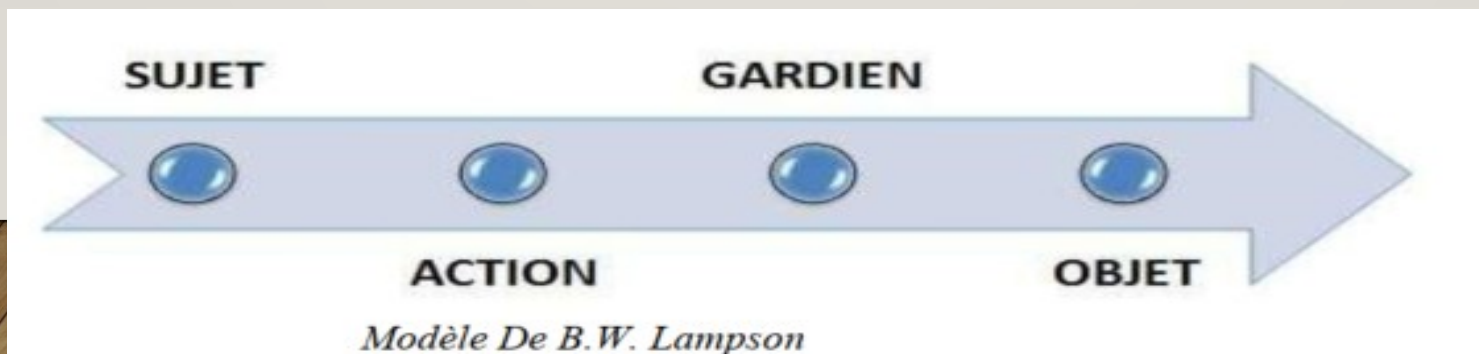
227

Chapitre 4 : Administration d'accès aux données informatiques

4.1 Modèle de LAMPSON

L'exemple ci-après illustre, en pratique, le modèle de Lampson:

SUJET	ACTION	GARDIEN	OBJET
Utilisateur	REQUETE	DBMS	BASE DE DONNEES
UTILISATEUR	AFFICHER UNE PAGE WEB	SERVEUR WEB	PAGE WEB
MACHINE	ENVOI DE PAQUET	FIREWALL	INTRANET
PROGRAMME	OUVRIR UN FICHIER	SECURITY MANAGEMENT JAVA	FICHIER



Première partie : Sécurité Informatique

228

Chapitre 4 : Administration d'accès aux données informatiques

4.1 Modèle de LAMPSON

Le modèle de Lampson est particulièrement adapté à la présentation pratique du protocole AAA (Authentification, Autorisation et Audit). En effet, par l'intermédiaire de son schéma, on représente facilement les endroits où ont lieu les différentes phases dudit protocole.

En revanche, la vérification de l'identité des parties communicantes est en réalité la base de tous les systèmes existants. Il fut complété au fil des années, mais reste historiquement la première modélisation de la sécurité d'un système. Le contrôle d'accès se fait en 4 étapes :

ǂ Identification : Qui êtes-vous ?

☐ Authentification : Prouvez-le !

☐ Autorisation : Avez-vous les droits requis ?

ǂ Accounting/Audit : Qu'avez-vous fait ?



Première partie : Sécurité Informatique

229

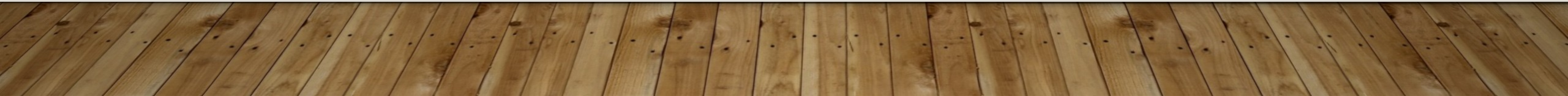
Chapitre 4 : Administration d'accès aux données informatiques

4.1 Modèle de LAMPSON

Nous parlons du protocole AAA (les deux premières étapes sont fusionnées). Dans certaines situations, nous scinderons la dernière étape. Nous parlerons d'Accounting lorsque le fait de comptabiliser des faits sera demandé, et d'Audit lorsque des résultats plus globaux devront être étudiés. Notons également que l'authentification, visant à prouver l'identité d'un individu peut se faire de plusieurs manières :

- ☐ Ce que vous savez (mot de passe, code PIN, etc.) ;
- ☐ Ce que vous avez (carte magnétique, lecteur de carte, etc.) ;
- ✂ Ce que vous êtes (empreintes digitales, réseau rétinien, etc.).

L'authentification forte résultera de la combinaison de deux de ces facteurs.



Première partie : Sécurité Informatique

230

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Access List Control (ACL)

L'accès est déterminé par le propriétaire de l'objet. Celui-ci détermine qui (sujet) peut utiliser l'objet, et comment (action) il peut l'utiliser. On part du principe que tous les objets ont un propriétaire (qui sera souvent le sujet qui aura créé cet objet).

Quelques variantes de ce type d'accès permettent un transfert de propriété ou la délégation d'un droit entre utilisateurs non-propriétaires. Cette méthode d'accès est celle rencontrée la plupart du temps dans les systèmes d'exploitation courants (Linux, Windows). Le principe est d'associer une liste de contrôle d'accès à chaque fichier. Cette ACL renferme un

certain nombre d'entrées (Access Control Entry - ACE). Le détail des accès permis ou refusé est mentionné. Exemple d'ACL liée

à un objet T :

- ACE1 : L'utilisateur A peut le lire ;
- ACE2 : L'utilisateur B ne peut pas le modifier ;
- ACE3:



Première partie : Sécurité Informatique

231

Chapitre 4 : Administration d'accès aux données informatiques

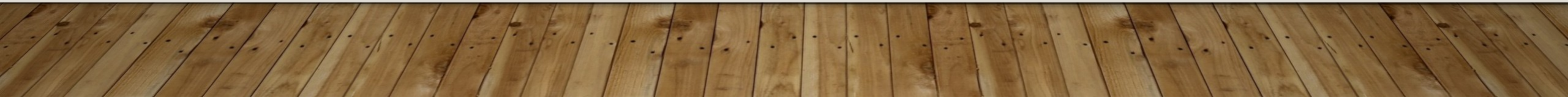
4.2 Méthodes d'accès aux données

Mandatory Access Control (MAC)

Il s'agit ici de contrôler l'accès en se concentrant sur les flux de données. L'accès est déterminé par le système :

- Ǻ Chaque sujet possède un label lui donnant un niveau de confiance ;
- Ǻ Chaque objet possède un label permettant d'identifier le niveau de confiance requis pour l'utiliser ;
- Ǻ Le sujet doit avoir un label supérieur ou égal à celui de l'objet.

Bref, cette méthode est beaucoup plus sûre, car elle ne dépend plus du propriétaire. Imaginez les pertes potentielles si le propriétaire d'un objet "sensible" venait à donner l'accès (volontairement ou non) à tous les utilisateurs. . . Un exemple concret est le modèle dérivé LBAC (Lattice-Based Access Control). Une lattice est une règle définissant un ensemble de niveaux de sécurité. Par exemple, la définition suivante, illustrée à la figure ci-dessous :



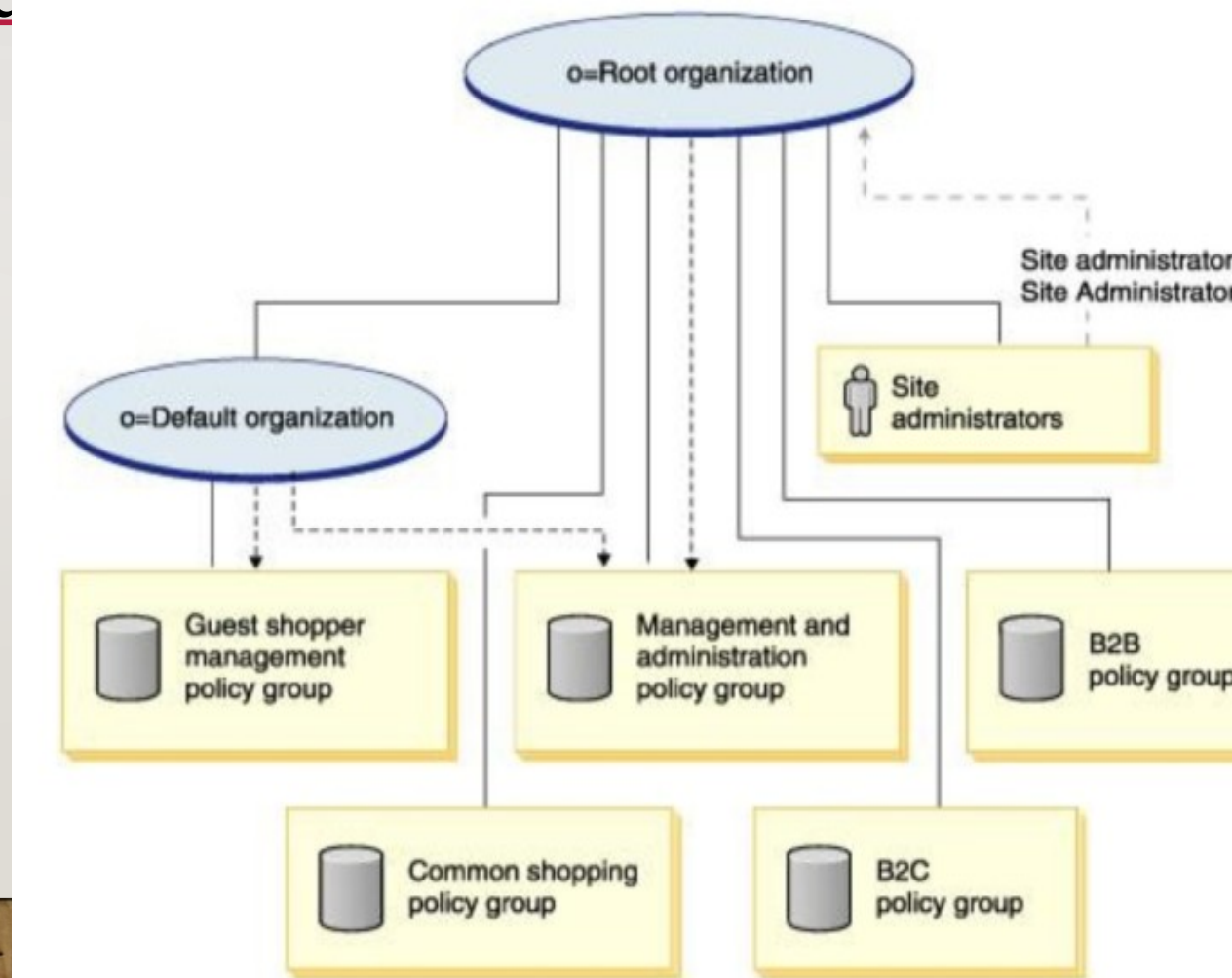
Première partie : Sécurité Informatique

232

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

- Les sujets avec un label L ne peuvent lire que des objets de label $L_0 \leq L$ (No ReadUp) ;
- Les sujets avec un label L ne peuvent écrire que des objets de label $L_0 \geq L$ (No Write-Down).



Première partie : Sécurité Informatique

Chapitre 4 : Administration d'accès aux données informatiques

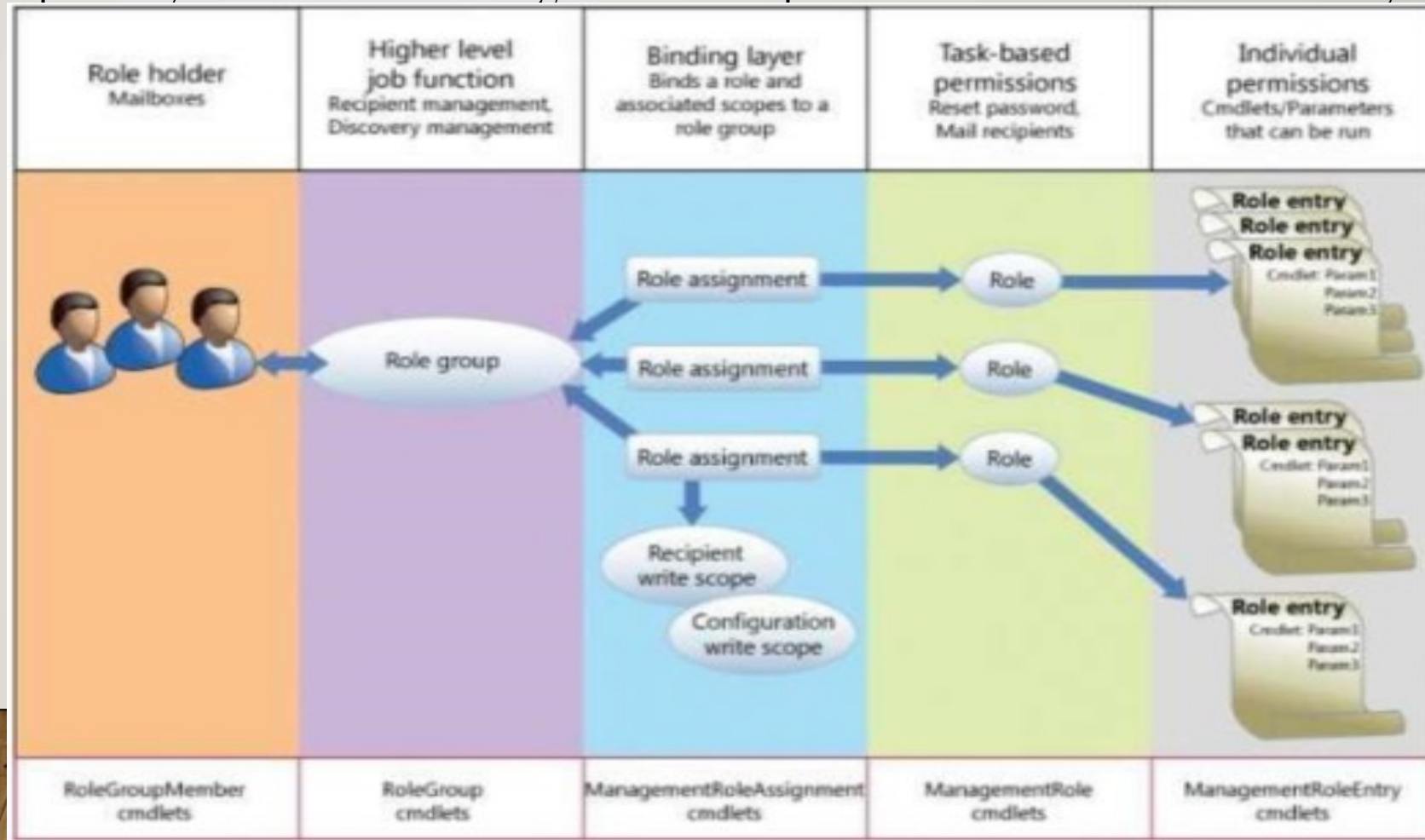
233

4.2 Méthodes d'accès aux données

Comme l'illustre l'image ci-dessous, on voit que ce système est très contraignant. Peu adapté à un environnement commercial, il est peu répandu dans les contextes non-militaires.

On le réserve à des lattices simples.

Bien que très sûr, il reste sensible aux attaques par canaux cachés (dialogue interprocessus à partir de l'utilisation du processeur par exemple).



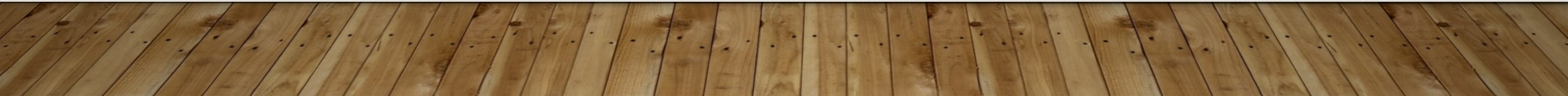
Première partie : Sécurité Informatique

234

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Dans le contexte grand public, ce type de contrôle d'accès est rarement utilisé pour garantir la confidentialité en tant que telle. Ainsi, les distributions Linux l'utilisent pour la vérification de l'intégrité des données. Son modèle porte le nom de "Biba Model", qui utilise une règle "no write-up". Cette technique est notamment utilisée pour empêcher la modification des données de l'OS à partir de logiciels indésirables circulant sur Internet.



Première partie : Sécurité Informatique

235

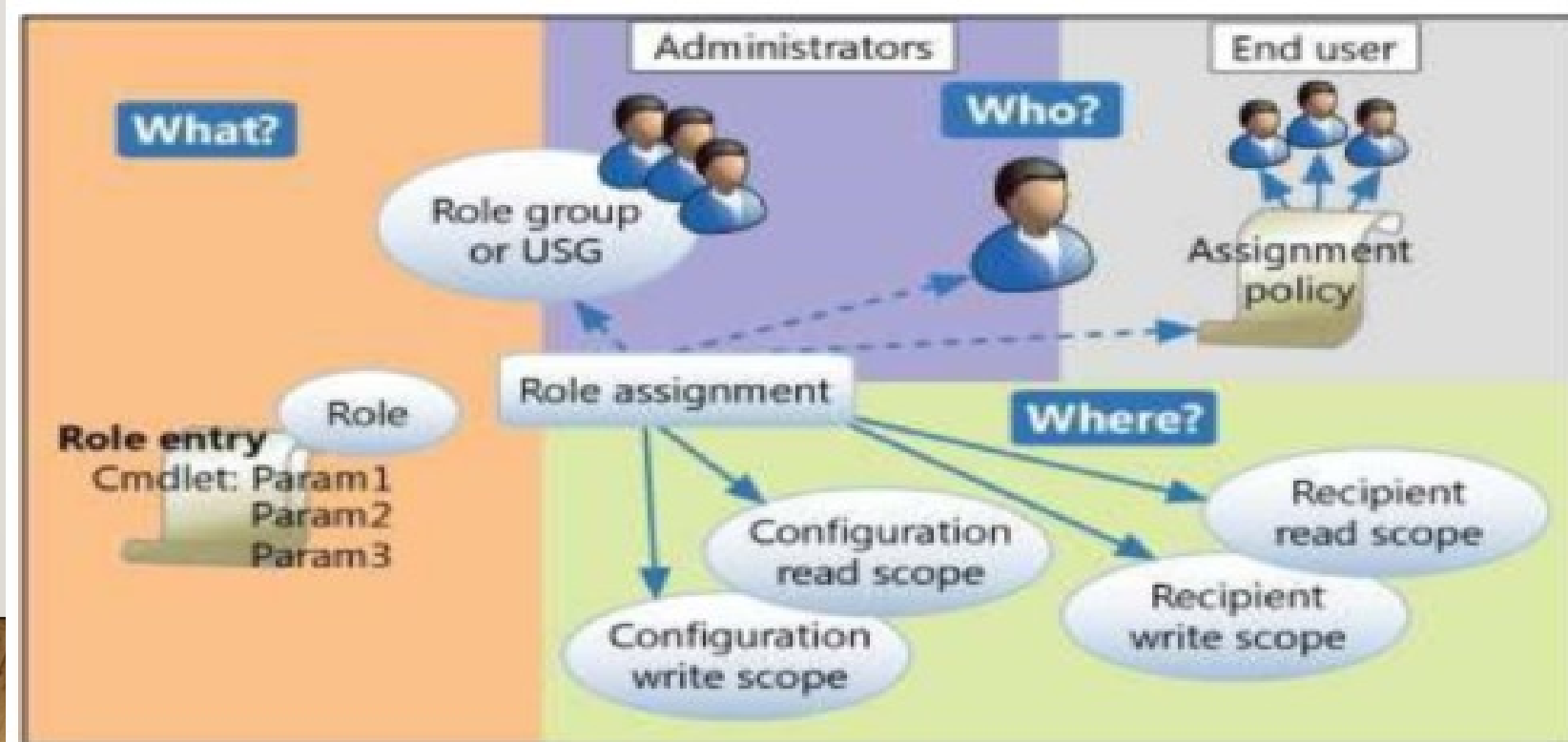
Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Role-Based Access Control (RBAC)

L'accès est ici aussi déterminé par le système. Cette méthode d'accès est régulièrement utilisée en entreprise, où chaque personne possède un rôle particulier qui lui donne accès à certaines informations. Le rôle va permettre d'attribuer un ensemble de permissions à un type d'utilisateurs :

- Plusieurs utilisateurs peuvent avoir le même rôle ;
- ✂ Un utilisateur peut avoir plusieurs rôles, qu'il pourra activer au besoin.



Première partie : Sécurité Informatique

236

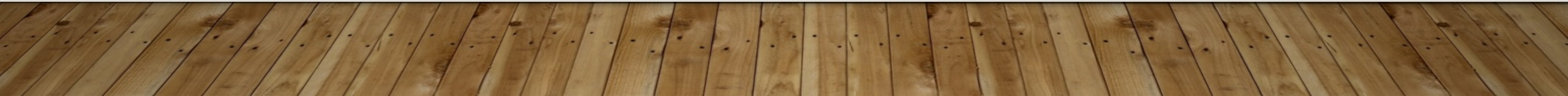
Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Cette méthode est plus facile à mettre en œuvre que le DAC pour la simple raison qu'il suffit de changer de rôle lorsque cela s'avère nécessaire (au lieu de modifier les accès pour chaque fichier). Il existe plusieurs variantes à cette méthode :

- ✂ Utilisation de rôles « hiérarchiques » : un rôle « hiérarchiquement supérieur » possède toutes les permissions des rôles « inférieurs » ;
- ✂ Contrôle des activations simultanées des rôles : plusieurs rôles peuvent selon les cas être autorisés simultanément pour un même utilisateur.

Ce type d'accès aux données apparaît très proche de ce que nous connaissons sous Windows notamment, par l'intermédiaire de la gestion des comptes utilisateurs. Cette filiation n'est pas anodine puisqu'il est en effet possible de simuler un système RBAC en utilisant la notion de « groupes utilisateurs ». En réalité, il s'agit d'un DAC caché.



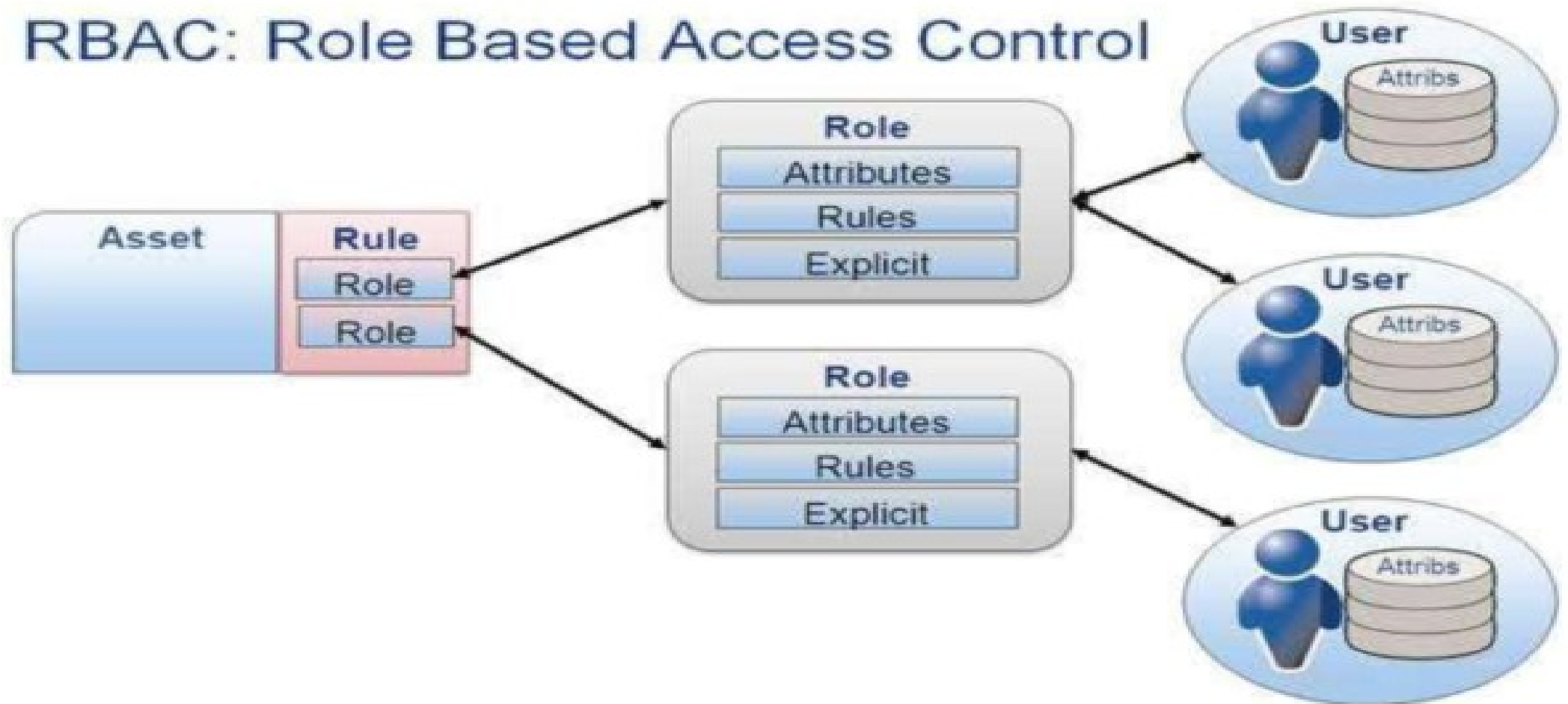
Première partie : Sécurité Informatique

Chapitre 4 : Administration d'accès aux données informatiques

237

4.2 Méthodes d'accès aux données

RBAC: Role Based Access Control



Première partie : Sécurité Informatique

238

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Windows utilise des ACL spécifiant les accès par groupe :

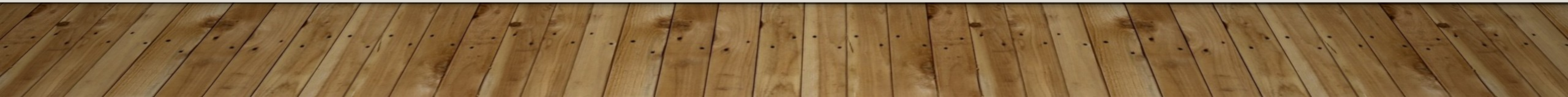
- ACE1 : Le groupe A ne peut pas lire le fichier ;
- ☞ ACE2 : Le groupe B peut modifier le fichier, ...

Avec la figure ci-haut, on voit que:

- ☞ A l'ouverture d'une session, l'utilisateur reçoit un jeton d'accès (Access Token). Ce jeton définira les actions qu'il peut effectuer.

SID - Security Identifier (unique) :

- SACL : System ACL utilisé pour l'Audit ;
- ☞ L'ordre établi dans la DACL est important : la première entrée correspondante est prise en compte ;
- ☞ Comme on le voit, la notion de groupe est présente, mais ce sont bel et bien les droits définis par le propriétaire qui détermine les actions possibles pour les autres utilisateurs.



Première partie : Sécurité Informatique

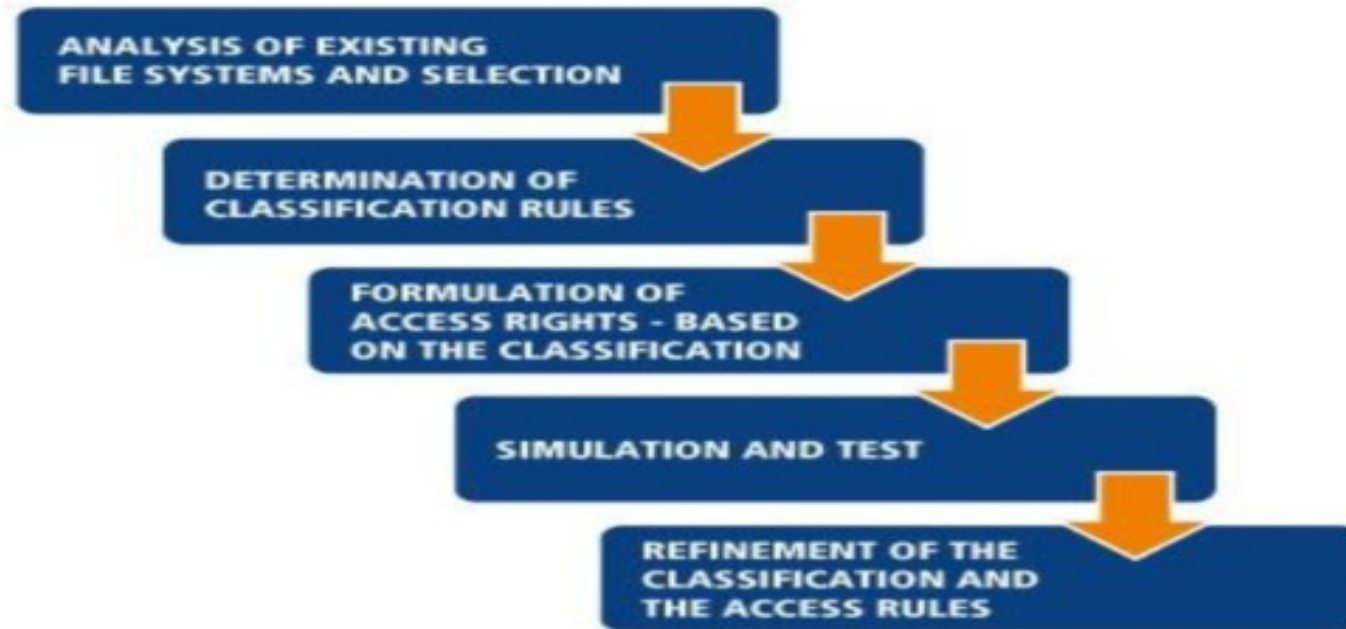
239

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Dynamic Access Control (DAC)

Le DAC est une solution de gouvernance de données, un ensemble de fonctionnalités qui permet aux entreprises d'organiser, de gérer, de distribuer et de sécuriser les dossiers et les fichiers au sein de l'infrastructure. L'enjeu principal du DAC est de pouvoir gérer le cycle de vie et l'intégrité de l'information au sein d'une organisation et de répondre finement aux besoins métier en termes d'autorisation d'accès, ce que ne permettent pas toujours les permissions NTFS afin d'assurer la sécurité des données.



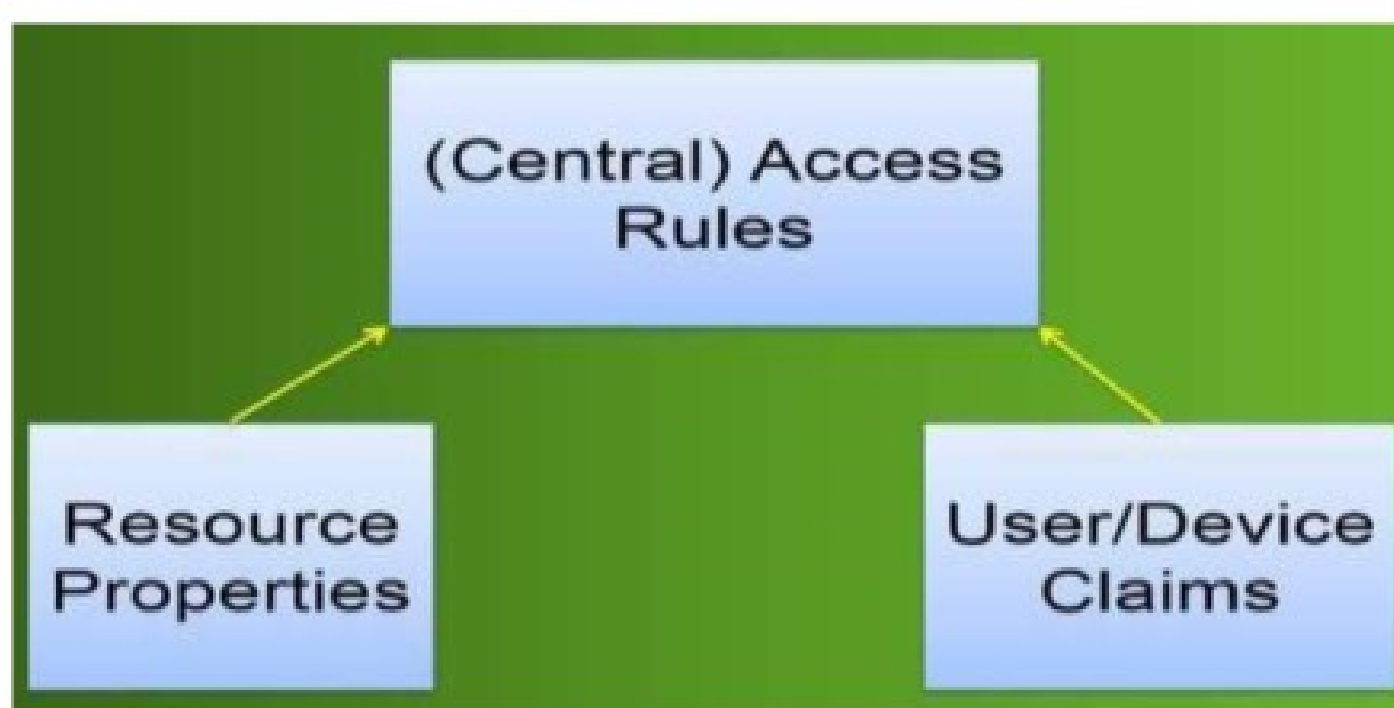
Première partie : Sécurité Informatique

240

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

Sur ce, le DAC fournit un contrôle d'accès non plus seulement basé sur des autorisations NTFS, mais également basé sur des expressions qui peuvent inclure des groupes de sécurités, des revendications, c'est-à-dire des propriétés propres à l'utilisateur, par exemple, ou à la machine qu'il utilise, des propriétés liées à la ressource, des propriétés de classification, celles que l'on retrouve plus classiquement dans le gestionnaire de ressources du serveur de fichiers de Windows. L'image ci-après illustre comment fonctionne le DAC.



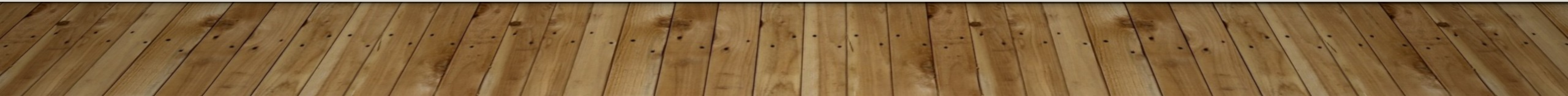
Première partie : Sécurité Informatique

241

Chapitre 4 : Administration d'accès aux données informatiques

4.2 Méthodes d'accès aux données

En sus, le DAC utilise une surcouche des listes de contrôle d'accès NTFS, on est bien au-dessus de la couche ACE, Access Control Entry, dans ma liste ACL, ensuite le DAC va donc récupérer et utiliser des stratégies d'accès centralisé qui sont stockées dans l'annuaire Active Directory; ce qui permet la mise en place des expressions conditionnelles, qui en fonction de ses expressions vont accorder ou pas l'accès à un utilisateur sur une ressource.



Première partie : Sécurité Informatique

242

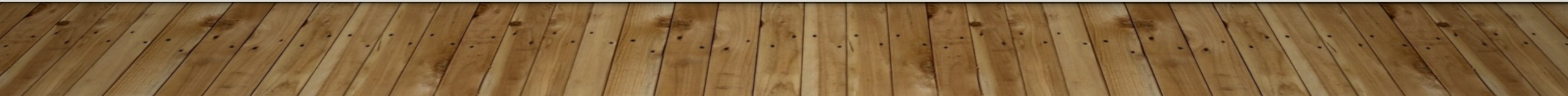
Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Définition

Un mot de passe est un mot ou une série de caractères utilisés comme moyen d'authentification pour prouver son identité lorsque l'on désire accéder à un lieu protégé, à une ressource (notamment informatique) ou à un service dont l'accès est limité et protégé. Le mot de passe doit être tenu secret pour éviter qu'un tiers non autorisé puisse accéder à la ressource ou au service. C'est une méthode parmi d'autres pour vérifier qu'une personne correspond bien à l'identité déclarée. Il s'agit d'une preuve que l'on possède et que l'on communique au service chargé d'autoriser l'accès.

C'est par exemple : Dans le conte « Ali Baba et les Quarante Voleurs des Mille et Une Nuits » figure l'un des plus célèbres mots de passe : « Sésame, ouvre-toi ! ».



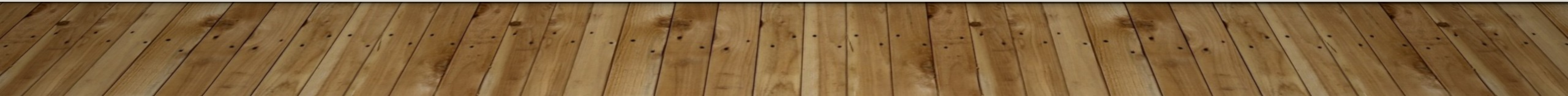
Première partie : Sécurité Informatique

243

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Le terme « mot de passe » est d'origine militaire. Les « mots d'ordres » comprennent le « mot de sommation » (c'est-à-dire la question convenue) et le « mot de passe » (c'est-à-dire la réponse correspondante)¹⁴. Il s'agit des signes verbaux qui permettent à deux unités ou deux militaires de se reconnaître mutuellement, par exemple lors d'une patrouille de nuit, au moment délicat du retour dans le dispositif ami. Dans ce cas, le mot de passe est donc partagé par un groupe de personnes de confiance. Quand il s'agit d'un code personnel, il vaut mieux utiliser l'expression « code confidentiel » pour mettre en évidence le caractère secret du code et responsabiliser son détenteur.



Première partie : Sécurité Informatique

244

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

PRINCIPE ET LIMITES

Une limite juridique existe, par exemple en France à la sécurisation par mot de passe : si des données chiffrées sont saisies par la justice, la loi sur la sécurité quotidienne oblige l'utilisateur à fournir la méthode de chiffrement et les clés ou mots de passe. L'utilisation de mots de passe est un compromis entre la sécurité et l'aspect pratique. Avec la multiplication de situations où il est nécessaire de disposer d'un mot de passe, chacun de nous possède un nombre de plus en plus important de mots de passe. S'il est légitime d'utiliser le même mot de passe pour l'ensemble des situations où celui-ci n'a pas grande importance, il reste néanmoins de nombreux cas où un mot de passe de qualité doit être utilisé. Ce mot de passe ne peut être le même partout, d'une part pour éviter que la compromission de celui-ci ne conduise à des situations malheureuses, d'autre part parce que certains sites et logiciels obligent à changer régulièrement son mot de passe et en limitent la réutilisation. La mémoire de l'utilisateur étant alors insuffisante pour mémoriser tous ces mots de passe, la tentation est grande de les lister. Il est indispensable que la liste de mots de passe ainsi constituée soit plus protégée encore.

Première partie : Sécurité Informatique

245

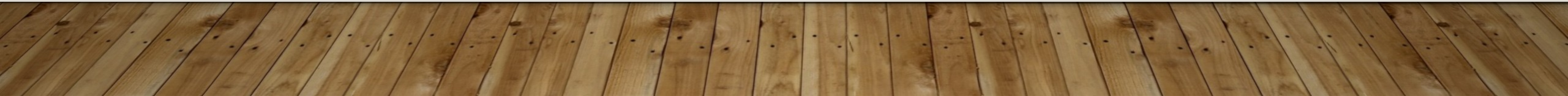
Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

On parle alors de « coffre-fort à mots de passe » :

→ **Capture d'un mot de passe « en clair »** - Un mot de passe est « en clair » lorsqu'il n'a pas été transformé via une fonction de hachage. Il existe plusieurs situations où le mot de passe peut être trouvé en clair :

- ↯ Espionnage direct du clavier de la personne qui saisit son mot de passe ;
- ↯ Mise en place d'un enregistreur de frappes (keylogger), qui saisit tout texte tapé par un utilisateur à son insu ;
- ↯ Écoute du réseau. Si un attaquant arrive à écouter une communication non chiffrée où la cible doit s'identifier par un mot de passe, ce mot de passe apparaîtra en clair à l'attaquant.
- ↯ Vol d'un mot de passe manuscrit.



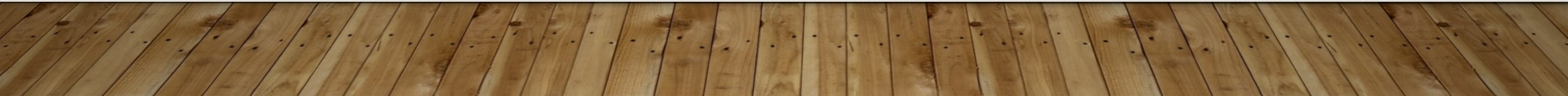
Première partie : Sécurité Informatique

246

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Certains logiciels permettent de rendre visibles les mots de passe des formulaires. Les caractères sont « cachés » par des ronds ou astérisques, qui sont là pour éviter qu'une personne derrière soi ne lise ce que l'on saisit. Dans le programme, à ce moment-là, le mot de passe est bien présent et encore non chiffré, le rendre visible consiste simplement à changer une option d'affichage.



Première partie : Sécurité Informatique

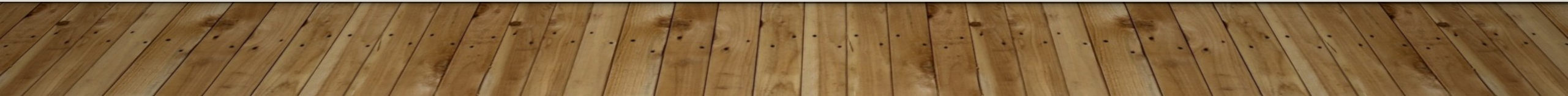
247

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

→ **Capture d'un mot de passe chiffré** - Dans le cas où un mot de passe chiffré est capturé, il n'est pas directement utilisable : la personne malintentionnée (l'attaquant) doit découvrir le clair correspondant, en le déchiffrant si c'est possible, ou avec d'autres techniques. On dit que l'attaquant casse ou « craque » le mot de passe. On distingue deux principaux cas de figure : le mot de passe fait partie d'une communication, ou c'est seulement le mot de passe chiffré qui est capturé :

↯ Toute la communication est chiffrée : Dans ce cas, il faut trouver un moyen de déchiffrer toute la communication pour trouver le mot de passe. Il faut donc trouver une faille dans l'algorithme de chiffrement ou dans une de ses implémentations. Si le chiffrement est cassé, peu importe la taille du mot de passe il sera trouvé dans le texte déchiffré.



Première partie : Sécurité Informatique

248

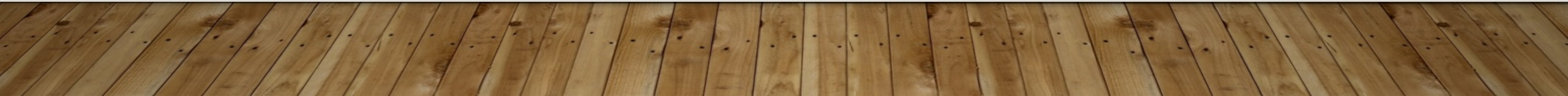
Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

➤ Seul le mot de passe chiffré est capturé : C'est généralement un condensat (ou hash) du mot de passe qui est capturé, c'est-à-dire le résultat d'un algorithme non réversible.

C'est une bonne pratique, utilisée dans de nombreux cas : sites web, comptes d'utilisateur de système d'exploitation, etc. Dans le cas où cet algorithme n'est pas vraiment irréversible (à cause d'erreurs de conception ou d'implémentation), il peut être possible de retrouver le clair correspondant à un condensat. Par exemple, la gestion des mots de passe pour protéger les fichiers Excel et Word d'Office 97 comporte des failles qui font qu'il est facile de trouver les mots de passe utilisés.

Mais en général pour casser un condensat, on utilise d'autres techniques. En connaissant la fonction de hachage, on peut imaginer différentes attaques



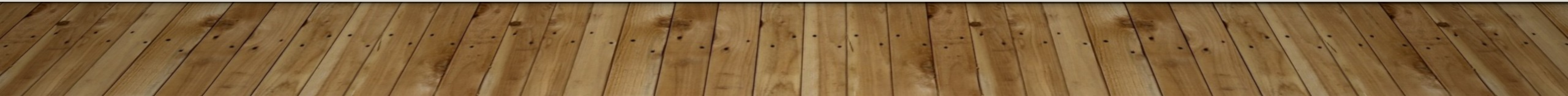
Première partie : Sécurité Informatique

249

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

→ **l'attaque par force brute** : on se donne un espace de mots de passe à explorer en se fixant une longueur et un ensemble de caractères ; on énumère tous les mots de passe possibles de cet espace ; pour chacun de ces mots de passe on calcule l'empreinte par la fonction de hachage, et on compare cette empreinte avec celle que l'on a capturée. Pour empêcher ces attaques, l'utilisation d'un mot de passe long et complexe est recommandée. Par mot de passe complexe, on entend mot de passe comprenant différents types de caractères : des lettres minuscules et majuscules, des chiffres, et des caractères non alphanumériques (comme !:/#@...). La longueur du mot de passe assurera qu'il n'est pas énuméré lors d'une attaque par force brute : plus l'espace à énumérer est grand et plus l'attaque ne prend de temps. Voir le graphique ci-contre (attention l'échelle est logarithmique).



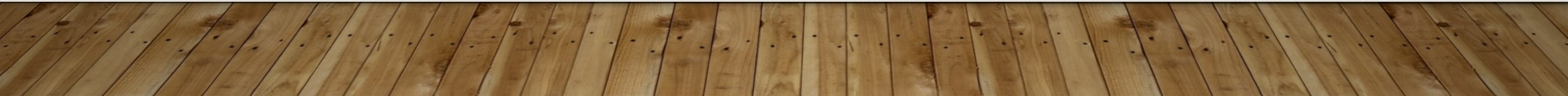
Première partie : Sécurité Informatique

250

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

→ **l'attaque par dictionnaire** : même chose que pour l'attaque par force brute, mais où les mots sont choisis dans un dictionnaire. L'utilisation de caractères différents des lettres et chiffres assurera généralement que le mot de passe n'appartient pas à un dictionnaire, et qu'il ne sera donc pas sensible à une attaque par dictionnaire.



Première partie : Sécurité Informatique

251

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

CHOIX DU MOT DE PASSE

□ S'il y a bien un domaine où la sécurité peut faire défaut, c'est dans la gestion des mots de passe utilisateur. En effet, la sécurité d'un système dépend aussi du niveau de sécurité du mot de passe mis sur pied pour son accès. Lors de la création du mot de passe, une attention particulière doit être portée sur certains points :

✂ Si un générateur de mots de passe est utilisé, il devra employer une grande variété de caractères (pour le rendre plus robuste à la force brute) ;

✂ Il peut être utile d'utiliser un vérificateur de mots de passe afin de tester la vulnérabilité aux attaques par dictionnaire. Dans le même temps, il pourra tester la taille des mots de passe face aux attaques par force brute ;

✂ Il est bon d'associer une durée de vie aux mots de passe. Un changement régulier permet une meilleure protection contre la force brute.

□ On peut aussi limiter le nombre d'essais.

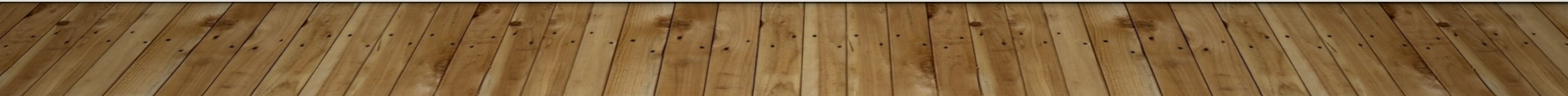
Première partie : Sécurité Informatique

252

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Des attaques plus complexes, issues de la cryptanalyse, comme l'utilisation de tables arc-en-ciel. L'utilisation d'un mot de passe complexe ne protège pas nécessairement de ce type d'attaque. La préparation d'une attaque de ce type est longue et gourmande en espace de stockage, mais elle est loin d'être inaccessible de nos jours.



Première partie : Sécurité Informatique

253

Chapitre 4 : Administration d'accès aux données informatiques

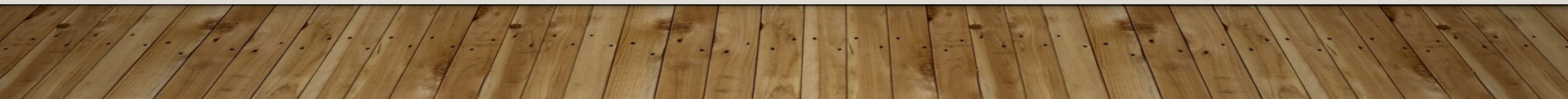
4.3 Notions sur le mot de passe

CRITÈRES DE ROBUSTESSE

La qualité et la longueur du mot de passe sont des éléments cruciaux pour la sécurité.

Un mot de passe trop court ou provenant d'un dictionnaire est susceptible d'être attaqué via une recherche dans une table contenant une liste de mots de passe. D'une manière plus systématique, une attaque par force brute tente toutes les possibilités et, avec suffisamment de temps, il est théoriquement possible de retrouver le mot de passe. Un compromis est la table arc-en-ciel, une amélioration du principe du compromis temps-mémoire. La robustesse d'un mot de passe dépend de plusieurs critères :

→ **Sa longueur** - qui est le critère le plus important. Il est conseillé d'utiliser des mots de passe d'une longueur suffisante pour que celui-ci soit protégé des attaques de force brute (cette longueur augmente au fil du temps avec la puissance des outils utilisés par les attaquants - pour un mot de passe à usage local, on recommande dans les années 2010 au moins 12 caractères, voire 16 caractères pour des mots de passe plus sûrs)



Première partie : Sécurité Informatique

254

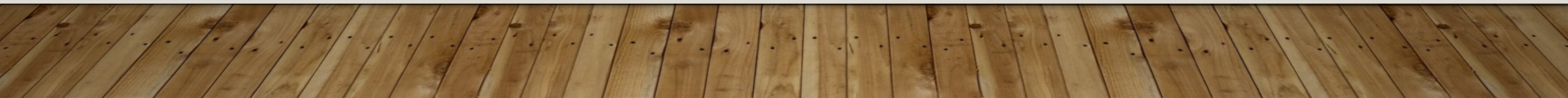
Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

→ **Sa non-simplicité** - 123456, www, 111111, Love, 0000, azerty... sont à proscrire, de même que les dates de naissance, le nom du chien ou toutes autres informations ayant un rapport direct avec la vie privée. De même, les slogans et les citations sont facilement attaquables via une attaque par dictionnaire. Plus généralement, le contenu du mot de passe ne devrait suivre aucune logique, mais être une simple succession de caractères choisis aléatoirement.

→ **Son unicité** - la réutilisation du même mot de passe pour des services différents est à proscrire, afin d'éviter des dégâts en cascade.

→ **La variation des caractères utilisés**- le mot de passe est plus fort lorsqu'il mélange des majuscules, des minuscules, des chiffres, des signes de ponctuation et des caractères spéciaux. Notons par ailleurs qu'il est toujours plus sécurisé de chercher à augmenter la longueur d'un mot de passe que de chercher à utiliser le plus possible des caractères différents.



Première partie : Sécurité Informatique

255

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Par ailleurs, le choix d'un mot de passe doit se faire suivant la criticité de ce dernier (par exemple, un mot de passe permettant d'accéder à l'interface d'administration d'une application ou d'un équipement sera considéré comme étant très critique).

Dans la pratique, une étude portant sur 32 millions de mots de passe du site RockYou.com, obtenus en 2009 à la suite d'une attaque du site, a montré que 30 % de ces mots de passe comportaient six caractères ou moins, et que le plus fréquent (un peu moins d'un sur cent) est « 123456 ». Tous les ans, Splash-Data, fournisseur de solutions de sécurité publique également une liste des mots de passe les plus utilisés, et désignés comme étant « les pires mots de passe, à ne pas utiliser ». Les 5 mots de passe les plus utilisés par les utilisateurs du monde entier en 2015 sont :

- ☐ 123456 ;
- ☐ Password ;
- ☐ 12345678 ;
- ☐ Qwerty.

Première partie : Sécurité Informatique

256

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

LES “MAUVAIS” MOTS DE PASSE

- ☐ Par défaut : password, mdp, default, admin, . . .
- ☐ Mots : bonjour, test, voiture, silence, . . .
- ☐ Mots numérotés : clavier12, merci154, armoire98, . . .
- ☐ Egaux au login : Albert84, . . .
- ☐ Mots doubles : crabcrab, stopstop, treetree,...
- ☐ Séquences : qwerty, 12345678, bhunji,...
- ☐ Personnels : prénom, numéro d'imatriculation,...
- ✂ Noms propres : Anaël, Yende ,...

Première partie : Sécurité Informatique

257

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

Certes, les besoins en sécurité étant ce qu'ils sont, la difficulté majeure aujourd'hui est que le nombre de mots de passe ne cesse de croître. Leur mémorisation reste donc problématique. Toutefois, quelques solutions existent :

✂ **Hardware** - Utiliser des clés usb comme accès aux données. Le problème est que c'est alors la clé qui authentifie, et non l'individu. De plus, que faire en cas de perte de la clé ?

✂ **Software** - utiliser un logiciel de gestion de mots de passe : un seul mot de passe (ou une phrase de passe) pour stocker tous les autres. Mais que faire en cas d'oubli du mot de passe maître ?

✂ **utiliser la saisie semi-automatique ;**

✂ **Au niveau de l'OS** - Une solution avancée est connue sous le nom de SSO (Single Sign On). Le fait de se « logger » sur une machine permet d'accéder à toutes les données. Une seule phase d'authentification a donc lieu, et si elle réussit, l'utilisateur est libre d'agir avec les données et logiciels correspondant à ses droits, sans avoir à donner son mot de passe à chaque accès. Une application connue basée sur un principe similaire porte le nom de Kerberos (authentification d'utilisateurs sur les machines d'un réseau).

Première partie : Sécurité Informatique

258

Chapitre 4 : Administration d'accès aux données informatiques

4.3 Notions sur le mot de passe

LES AUTRES CATEGORIES DE MOTS DE PASSE

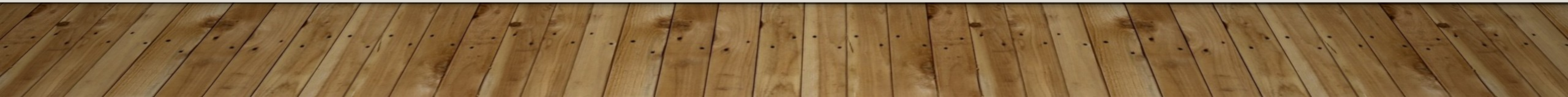
Il existe une autre possibilité, mais qui n'est pas utilisable dans toutes les conditions, porte le nom de One Time Password (OTP) et Mot de passe sous contrainte :

✂ **Mot de passe sous contrainte** - Certaines sociétés de télésurveillance utilisent 2 mots de passe : le mot de passe normal et le mot de passe sous contrainte. En cas de déclenchement de l'alarme, la société de télésurveillance appelle le client, et demande son mot de passe pour s'assurer de son identité, si celui-ci donne le mot de passe sous contrainte, alors l'agent de télésurveillance sait que la personne qui le dit est menacée et déclenche une intervention.

✂ **One Time Password** - Le mot de passe ici généré ne reste valable que pour une durée déterminée. Deux méthodes coexistent :

- *Méthode synchrone : Fonction du temps (Time-synchronous) ;

- *Méthode asynchrone : En réponse à un "challenge" (Challenge-response).



Première partie : Sécurité Informatique

259

Chapitre 4 : Administration d'accès aux données informatiques

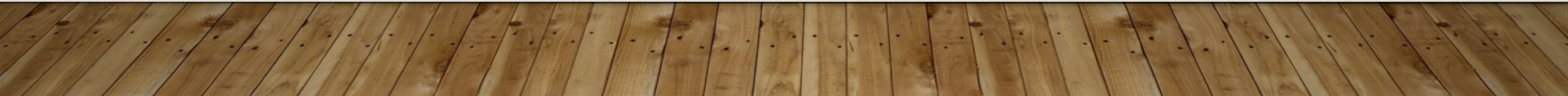
4.3 Notions sur le mot de passe

Signalons qu'un bon mot de passe doit notamment (et principalement) être à la fois facile à retenir (pas besoin de le noter), et utiliser des caractères spéciaux, de casse différente (ce qui rend la force brute plus fastidieuse et l'attaque par dictionnaire presque impossible). Les conseils proposés par la Commission européenne devraient être appliqués lorsque l'on veut créer un mot de passe afin de le protéger contre les attaques. En fait, un bon mot de passe doit:

Etre long ; Etre unique ; Etre complexe ;

Modifié régulièrement ; Pas contenir n'importe quelle partie du nom du compte utilisateur ;

Avoir un minimum de huit caractères ; Contenir des caractères d'au moins trois des catégories suivantes ; Symboles non alphanumériques (\$,;, "%@#!); Chiffres; Lettres majuscules et Lettres minuscules.



Deuxième partie : Techniques cryptographiques

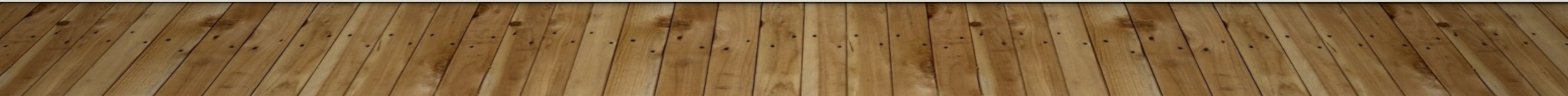
260

Introduction

L'homme a toujours ressenti le besoin de dissimuler des informations, avant même l'apparition des premiers ordinateurs et de machines à calculer.

Depuis sa création, le réseau Internet a tellement évolué qu'il est devenu un outil essentiel de communication. Cependant cette communication met de plus en plus en jeu des flux financiers pour les entreprises présentes sur le Web. Les transactions faites à travers le réseau peuvent être interceptées, d'autant plus que les lois ont du mal à se mettre en place sur Internet, il faut donc garantir la sécurité de ces informations : c'est la cryptographie qui s'en charge.

Le mot **cryptographie** est un terme générique désignant l'ensemble des techniques permettant de chiffrer des messages, c'est-à-dire permettant de les rendre inintelligibles sans une action spécifique. Le verbe **crypter** est parfois utilisé mais on lui préférera le verbe **chiffrer**.



Deuxième partie : Techniques cryptographiques

261

Introduction

Cryptologie : Ensemble de techniques permettant d'assurer la sécurité des systèmes d'information.

→ Science nouvelle : recherche académique/universitaire depuis les années 1970.

→ Regroupe la cryptographie et la cryptanalyse.

La cryptologie est essentiellement basée sur l'arithmétique. Il s'agit dans le cas d'un texte de transformer les lettres qui composent le message en une succession de chiffres (sous forme de bits dans le cas de l'informatique car le fonctionnement des ordinateurs est basé sur le binaire), puis ensuite de faire des calculs sur ces chiffres pour :

- d'une part les modifier de telle façon à les rendre incompréhensibles. Le résultat de cette modification (le message chiffré) est appelé cryptogramme (ciphertext) par opposition au message initial, appelé message en clair (plaintext) ;
- faire en sorte que le destinataire saura les déchiffrer.

Le fait de coder un message de telle façon à le rendre secret s'appelle chiffrement. La méthode inverse, consistant à retrouver le message original, est appelée déchiffrement

Deuxième partie : Techniques cryptographiques

262

Introduction

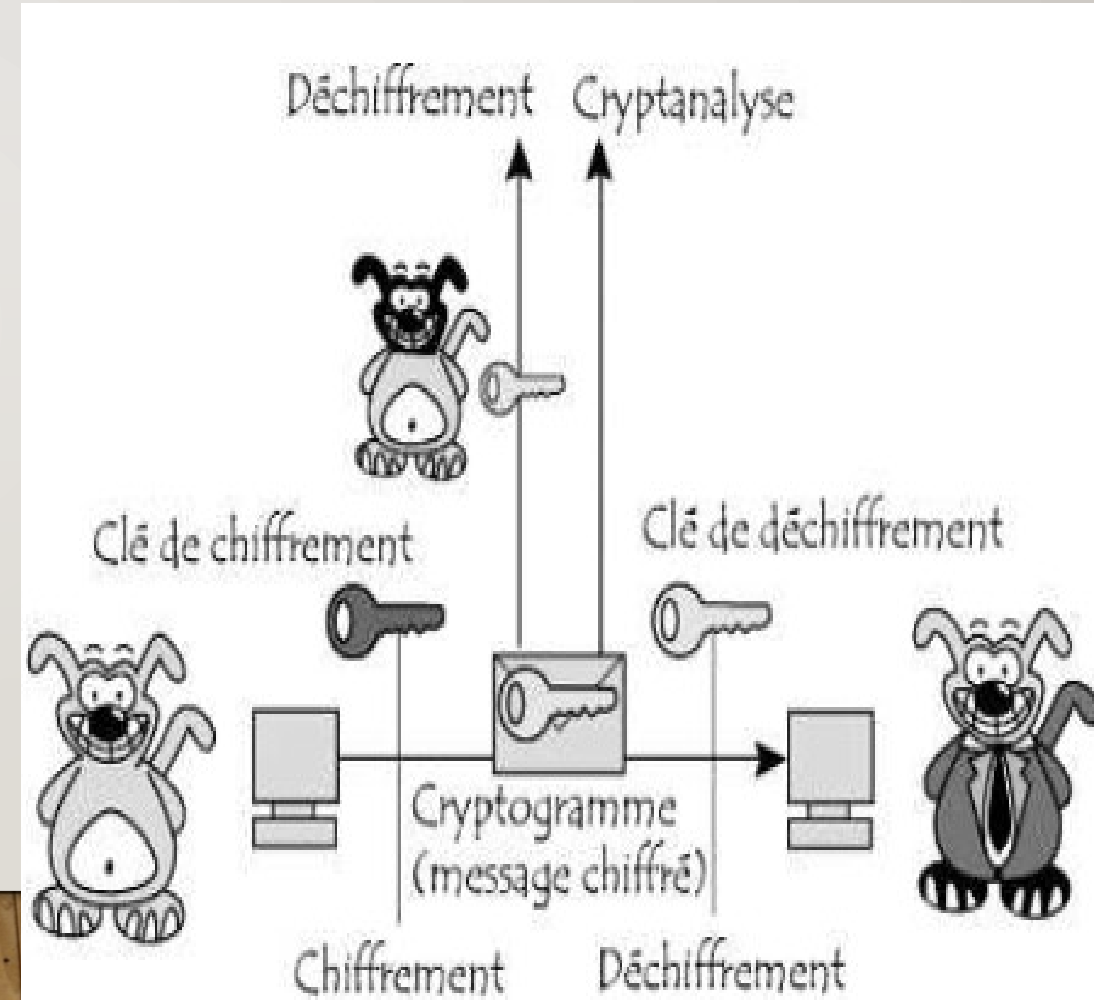
Le chiffrement se fait généralement à l'aide d'une clé de chiffrement, le déchiffrement nécessite quant à lui une clé de déchiffrement.

On distingue généralement deux types de clés :

- Les clés symétriques : il s'agit de clés utilisées pour le chiffrement ainsi que pour le déchiffrement. On parle alors de chiffrement symétrique ou de chiffrement à clé secrète.

- Les clés asymétriques : il s'agit de clés utilisées dans le cas du chiffrement asymétrique (aussi appelé chiffrement à clé publique).

Dans ce cas, une clé différente est utilisée pour le chiffement et pour le déchiffrement.



Deuxième partie : Techniques cryptographiques

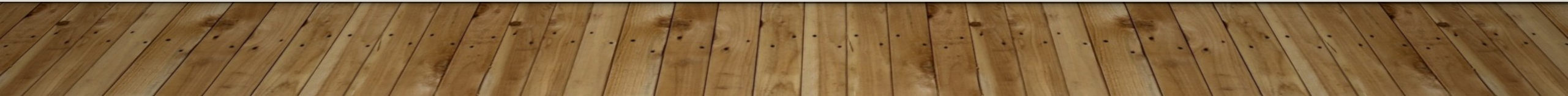
263

Introduction

On appelle **décryptement** (le terme de décryptage peut être utilisé également) le fait d'essayer de déchiffrer illégitimement le message (que la clé de déchiffrement soit connue ou non de l'attaquant).

Lorsque la clé de déchiffrement n'est pas connue de l'attaquant on parle alors de **cryptanalyse** ou **cryptoanalyse** (on entend souvent aussi le terme plus familier de cassage).

La cryptologie est la science qui étudie les aspects scientifiques de ces techniques, c'est-à-dire qu'elle englobe la cryptographie et la cryptanalyse.



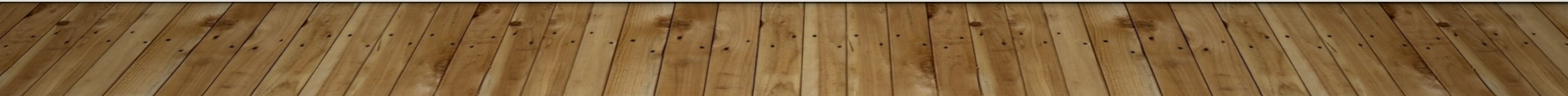
Deuxième partie : Techniques cryptographiques

264

Introduction

Objectifs de la cryptographie

La cryptographie est traditionnellement utilisée pour dissimuler des messages aux yeux de certains utilisateurs. Cette utilisation a aujourd'hui un intérêt d'autant plus grand que les communications via Internet circulent dans des infrastructures dont on ne peut garantir la fiabilité et la confidentialité. Désormais, la cryptographie sert non seulement à préserver la confidentialité des données mais aussi à garantir leur intégrité et leur authenticité.



Deuxième partie : Techniques cryptographiques

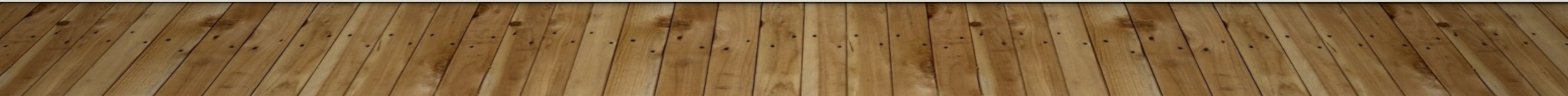
265

Introduction

Cryptanalyse

On appelle **cryptanalyse** la reconstruction d'un message chiffré en clair à l'aide de méthodes mathématiques. Ainsi, tout **cryptosystème** doit nécessairement être résistant aux méthodes de cryptanalyse.

Lorsqu'une méthode de cryptanalyse permet de déchiffrer un message chiffré à l'aide d'un cryptosystème, on dit alors que l'algorithme de chiffrement a été « cassé ».



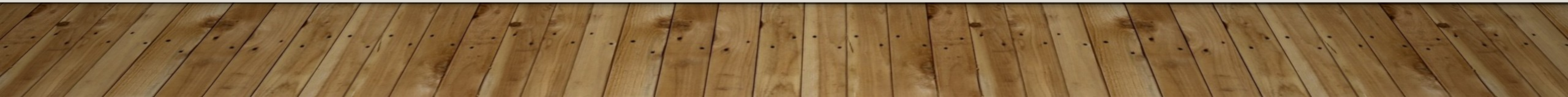
Deuxième partie : Techniques cryptographiques

266

Introduction

On distingue habituellement quatre méthodes de cryptanalyse :

- Une **attaque sur texte chiffré seulement** consiste à retrouver la clé de déchiffrement à partir d'un ou plusieurs textes chiffrés.
- Une **attaque sur texte clair connu** consiste à retrouver la clé de déchiffrement à partir d'un ou plusieurs textes chiffrés, connaissant le texte en clair correspondant.
- Une **attaque sur texte clair choisi** consiste à retrouver la clé de déchiffrement à partir d'un ou plusieurs textes chiffrés, l'attaquant ayant la possibilité de les générer à partir de textes en clair.
- Une **attaque sur texte chiffré choisi** consiste à retrouver la clé de déchiffrement à partir d'un ou plusieurs textes chiffrés, l'attaquant ayant la possibilité de les générer à partir de textes en clair.



Deuxième partie : Techniques cryptographiques

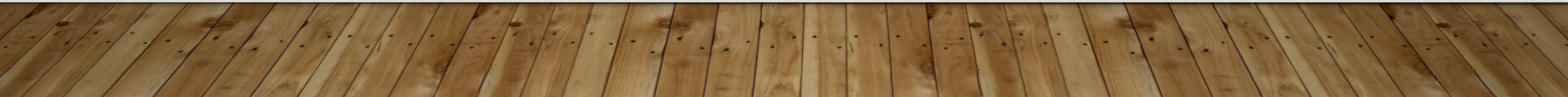
267 Chapitre 1: Chiffrement basique

I. Chiffrement par substitution

Le chiffrement par substitution consiste à remplacer dans un message une ou plusieurs entités (généralement des lettres) par une ou plusieurs autres entités.

On distingue généralement plusieurs types de cryptosystèmes par substitution :

- La **substitution monoalphabétique** consiste à remplacer chaque lettre du message par une autre lettre de l'alphabet.
- La **substitution polyalphabétique** consiste à utiliser une suite de chiffres monoalphabétique réutilisée périodiquement.
- La **substitution homophonique** permet de faire correspondre à chaque lettre du message en clair un ensemble possible d'autres caractères.
- La **substitution de polygrammes** consiste à substituer un groupe de caractères (polygramme) dans le message par un autre groupe de caractères.



Deuxième partie : Techniques cryptographiques

268 Chapitre 1: Chiffrement basique

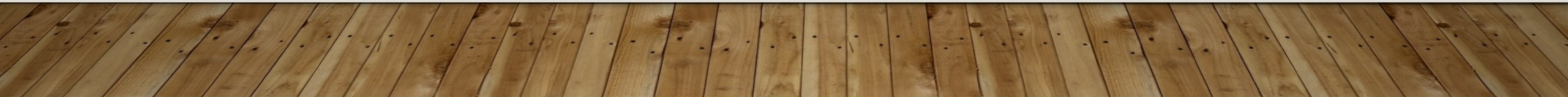
I. Chiffrement par substitution

□ Le chiffrement de César

Ce code de chiffrement est un des plus anciens, dans la mesure où Jules César l'aurait utilisé. Le principe de codage repose sur l'ajout d'une valeur constante à l'ensemble des caractères du message, ou plus exactement à leur code ASCII (pour un usage informatique de ce codage).

Il s'agit donc simplement de décaler l'ensemble des valeurs des caractères du message d'un certain nombre de positions, c'est-à-dire en quelque sorte de substituer chaque lettre par une autre. Par exemple, en décalant le message « COMMENT CA MARCHE » de trois positions, on obtient « FRPPHQW FD PDUFKH ». Lorsque l'ajout de la valeur donne une lettre dépassant la lettre Z, il suffit de continuer en partant de A, ce qui revient à effectuer un modulo 26.

Exemple: Dans le film 2001, l'odyssée de l'espace (S. Kubrick, 1968), l'ordinateur porte le nom de HAL. Ce surnom est en fait IBM décalé de 1 position vers le bas...



Deuxième partie : Techniques cryptographiques

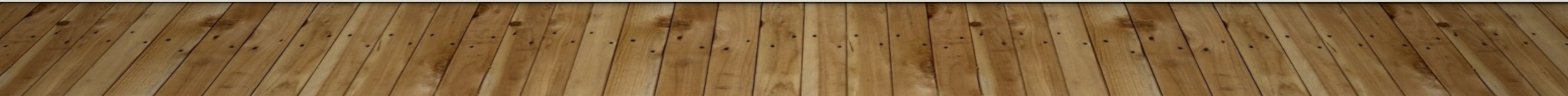
269 Chapitre 1: Chiffrement basique

I. Chiffrement par substitution

On appelle clé le caractère correspondant à la valeur que l'on ajoute au message pour effectuer le cryptage. Dans notre cas la clé est C, car c'est la 3e lettre de l'alphabet.

Ce système de cryptage est certes simple à mettre en œuvre, mais il a pour inconvénient d'être totalement symétrique, cela signifie qu'il suffit de faire une soustraction pour connaître le message initial. Une méthode primaire peut consister à une bête soustraction des nombres 1 à 26 pour voir si l'un de ces nombres donne un message compréhensible.

Une méthode plus évoluée consiste à calculer les fréquences d'apparition des lettres dans le message codé (cela est d'autant plus facile à faire que le message est long). Effectivement, selon la langue, certaines lettres reviennent plus couramment que d'autres (en français, par exemple, la lettre la plus utilisée est la lettre E), ainsi la lettre apparaissant le plus souvent dans un texte crypté par le **chiffre de César** correspondra vraisemblablement à la lettre E, une simple soustraction donne alors la clé de cryptage...



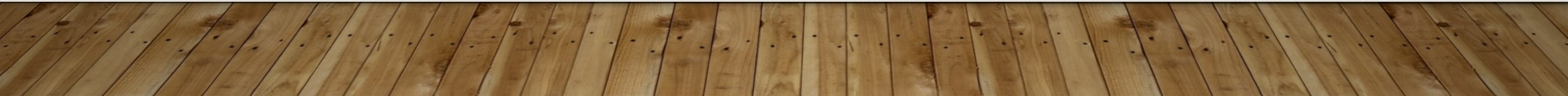
Deuxième partie : Techniques cryptographiques

270 Chapitre 1: Chiffrement basique

I. Chiffrement par substitution

□ Le chiffrement ROT13

Dans le cas spécifique du chiffrement de César où la clé de cryptage est N (13e lettre de l'alphabet), on appelle ce cryptage ROT13 (le nombre 13, la moitié de 26) a été choisi pour pouvoir crypter et décrypter facilement les messages...).



Deuxième partie : Techniques cryptographiques

271 Chapitre 1: Chiffrement basique

II. Chiffrement par transposition

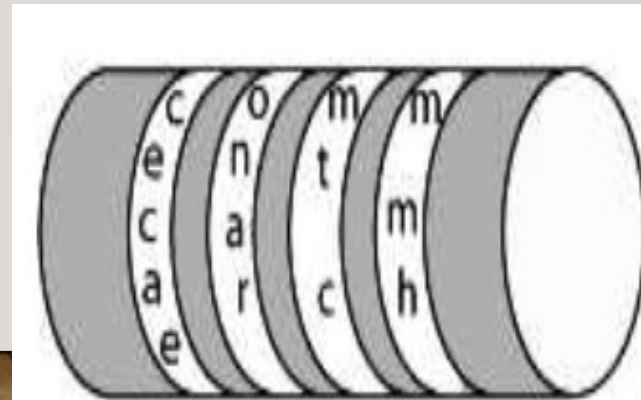
Les méthodes de **chiffrement par transposition** consistent à réarranger les données à chiffrer de façon à les rendre incompréhensibles. Il s'agit par exemple de réordonner géométriquement les données pour les rendre visuellement inexploitable.

□ La technique de chiffrement assyrienne

La **technique de chiffrement assyrienne** est vraisemblablement la première preuve de l'utilisation de moyens de chiffrement en Grèce dès 600 av. J.-C., afin de dissimuler des messages écrits sur des bandes de papyrus.

La technique consistait à :

- enrouler une bande de papyrus sur un cylindre appelé scytale ;
- écrire le texte longitudinalement sur la bandelette ainsi enroulée (le message dans l'exemple ci-dessus est « comment ça marche »).

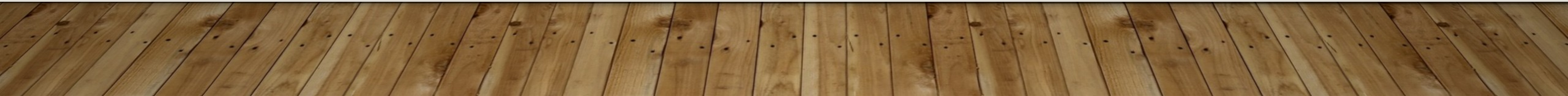


Deuxième partie : Techniques cryptographiques

272 Chapitre 1: Chiffrement basique

II. Chiffrement par transposition

Le message, une fois déroulé, n'est plus compréhensible (« cecaeonar mt c m mh »). Il suffit au destinataire d'avoir un cylindre de même diamètre pour pouvoir déchiffrer le message. En réalité un casseur (il existait des casseurs à l'époque !) peut déchiffrer le message en essayant des cylindres de diamètre successifs différents, ce qui revient à dire que la méthode peut être cassée statistiquement (il suffit de prendre les caractères un à un, éloignés d'une certaine distance).



Deuxième partie : Techniques cryptographiques

273 Chapitre 1I: Chiffrement symétrique

Le chiffrement symétrique (aussi appelé chiffrement à clé privée ou chiffrement à clé secrète) consiste à utiliser la même clé pour le chiffrement et le déchiffrement.

Le chiffrement consiste à appliquer une opération (algorithme) sur les données à chiffrer à l'aide de la clé privée, afin de les rendre inintelligibles. Ainsi, le moindre algorithme (tel qu'un OU exclusif) peut rendre le système quasiment inviolable (la sécurité absolue n'existant pas).

Toutefois, dans les années 1940, Claude Shannon démontra que pour être totalement sûr, les systèmes à clés privées doivent utiliser des clés d'une longueur au moins égale à celle du message à chiffrer.

De plus, le chiffrement symétrique impose d'avoir un canal sécurisé pour l'échange de la clé, ce qui dégrade sérieusement l'intérêt d'un tel système de chiffrement.

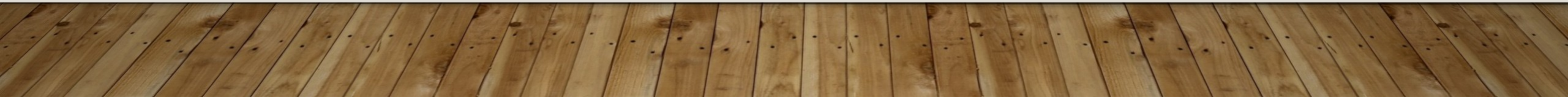


Deuxième partie : Techniques cryptographiques

274 Chapitre 1I: Chiffrement symétrique

Le principal inconvénient d'un cryptosystème à clé secrète (appelé aussi cryptosystème symétrique) provient de l'échange des clés. En effet, le chiffrement symétrique repose sur l'échange d'un secret (les clés) et pose le problème de la distribution des clés. D'autre part, un utilisateur souhaitant communiquer avec plusieurs personnes en assurant de niveaux de confidentialité distincts doit utiliser autant de clés privées qu'il a d'interlocuteurs. Pour un groupe de N personnes utilisant un cryptosystème à clés secrètes, il est nécessaire de distribuer un nombre de clés égal à $N * (N-1) / 2$.

Ainsi, dans les années 1920, Gilbert Vernam et Joseph Mauborgne mirent au point la méthode du One Time Pad (méthode du masque jetable, parfois appelée One Time Password, OTP), basée sur une clé privée, générée aléatoirement, utilisée une et une seule fois, puis détruite. À cette même époque par exemple, le Kremlin et la Maison Blanche étaient reliés par le fameux téléphone rouge, c'est-à-dire un téléphone dont les communications étaient cryptées grâce à une clé privée selon la méthode du masque jetable. La clé privée était alors échangée grâce à la valise diplomatique (jouant le rôle de canal sécurisé).



Deuxième partie : Techniques cryptographiques

275 Chapitre 1II: Chiffrement asymétrique

Le principe de chiffrement asymétrique (appelé aussi chiffrement à clés publiques) est apparu en 1976, avec la publication d'un ouvrage sur la cryptographie par Whitfield Diffie et Martin Hellman.

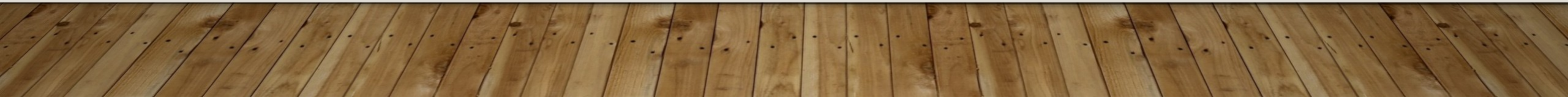
Dans un cryptosystème asymétrique (ou cryptosystème à clés publiques), les clés existent par paires (le terme de bi-clés est généralement employé) :

- une clé publique pour le chiffrement ;
- une clé secrète pour le déchiffrement.

Ainsi, dans un système de chiffrement à clé publique, les utilisateurs choisissent une clé aléatoire qu'ils sont seuls à connaître (il s'agit de la clé privée).

À partir de cette clé, ils déduisent chacun automatiquement un algorithme (il s'agit de la clé publique).

Les utilisateurs s'échangent cette clé publique au travers d'un canal non sécurisé.



Deuxième partie : Techniques cryptographiques

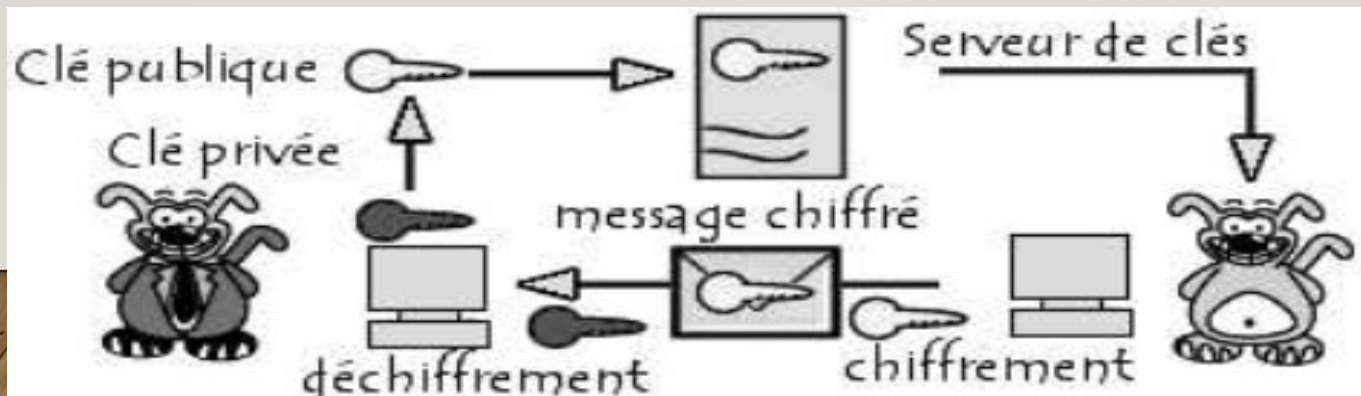
276 Chapitre 1II: Chiffrement asymétrique

Lorsqu'un utilisateur désire envoyer un message à un autre utilisateur, il lui suffit de chiffrer le message à envoyer au moyen de la clé publique du destinataire (qu'il trouvera par exemple dans un serveur de clés tel qu'un annuaire LDAP).

Le destinataire sera en mesure de déchiffrer le message à l'aide de sa clé privée (qu'il est seul à connaître).

Ce système est basé sur une fonction facile à calculer dans un sens (appelée fonction à trappe à sens unique ou one-way trapdoor function) et mathématiquement très difficile à inverser sans la clé privée (appelée trappe).

À titre d'image, il s'agit pour un utilisateur de créer aléatoirement une petite clé en métal (la clé privée), puis de fabriquer un grand nombre de cadenas (clé publique) qu'il dispose dans un casier accessible à tous (le casier joue le rôle de canal non sécurisé).



Deuxième partie : Techniques cryptographiques

277 Chapitre 1II: Chiffrement asymétrique

Pour lui faire parvenir un document, chaque utilisateur peut prendre un cadenas (ouvert), fermer une valisette contenant le document grâce à ce cadenas, puis envoyer la valisette au propriétaire de la clé publique (le propriétaire du cadenas).

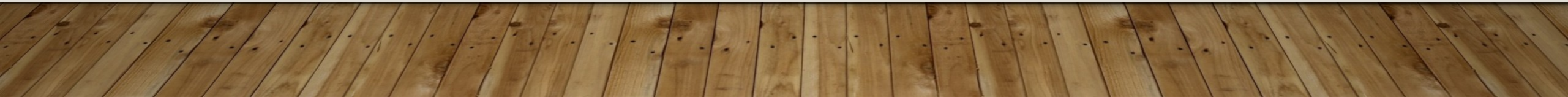
Seul le propriétaire sera alors en mesure d'ouvrir la valisette avec sa clé privée.

Avantages et inconvénients

Le problème consistant à se communiquer la clé de déchiffrement n'existe plus, dans la mesure où les clés publiques peuvent être envoyées librement.

Le chiffrement par clés publiques permet donc à des personnes d'échanger des messages chiffrés sans pour autant posséder de secret en commun.

En contrepartie, tout le challenge consiste à (s')assurer que la clé publique que l'on récupère est bien celle de la personne à qui l'on souhaite faire parvenir l'information chiffrée !



Deuxième partie : Techniques cryptographiques

278 Chapitre 1II: Chiffrement asymétrique

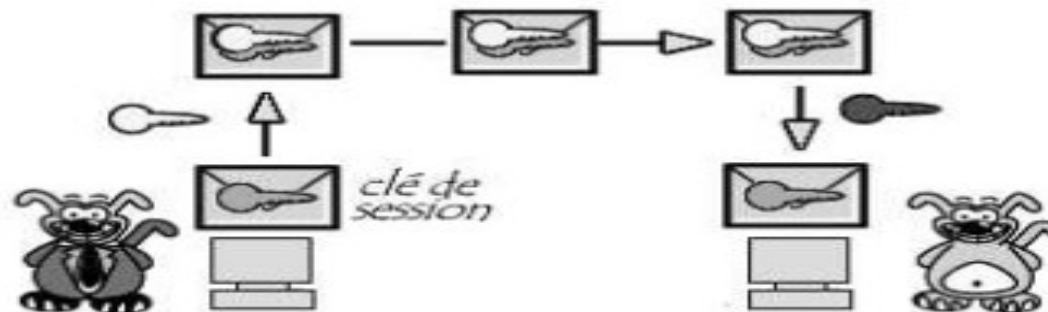
Notion de clé de session

Les algorithmes asymétriques (entrant en jeu dans les cryptosystèmes à clé publique) permettent de s'affranchir de problèmes liés à l'échange de clé via un canal sécurisé.

Toutefois, ces derniers restent beaucoup moins efficaces (en termes de temps de calcul) que les algorithmes symétriques.

Ainsi, la notion de clé de session est un compromis entre le chiffrement symétrique et asymétrique permettant de combiner les deux techniques.

Le principe de la clé de session est simple : il consiste à générer aléatoirement une clé de session de taille raisonnable, et de chiffrer celle-ci à l'aide d'un algorithme de chiffrement à clé publique (plus exactement à l'aide de la clé publique du destinataire).



Deuxième partie : Techniques cryptographiques

279 Chapitre 1II: Chiffrement asymétrique

Le destinataire est en mesure de déchiffrer la clé de session à l'aide de sa clé privée.

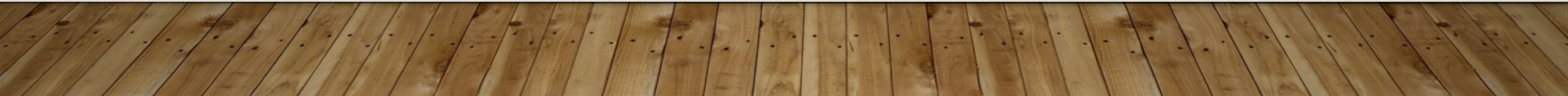
Ainsi, expéditeur et destinataires sont en possession d'une clé commune dont ils sont seuls connaisseurs. Il leur est alors possible de s'envoyer des documents chiffrés à l'aide d'un algorithme de chiffrement symétrique.

Algorithme d'échange de clés

L'algorithme de Diffie-Hellman (du nom de ses inventeurs) a été mis au point en 1976 afin de permettre l'échange de clés à travers un canal non sécurisé.

Il repose sur la difficulté du calcul du logarithme discret dans un corps fini.

L'algorithme de Diffie-Hellman est cependant sensible à l'attaque man in the middle (traduit parfois en attaque de l'intercepteur ou attaque par le milieu).



Deuxième partie : Techniques cryptographiques

280 Chapitre 1 V: Signature électronique

Le paradigme de **signature électronique** (appelé aussi signature numérique) est un procédé permettant de garantir l'authenticité de l'expéditeur (fonction d'authentification) et de vérifier l'intégrité du message reçu.

La signature électronique assure également **une fonction de non-répudiation**, c'est-à-dire qu'elle permet d'assurer que l'expéditeur a bien envoyé le message (autrement dit elle empêche l'expéditeur de nier avoir expédié le message).

Fonction de hachage

Une fonction de hachage (parfois appelée fonction de condensation) est une fonction permettant d'obtenir un condensé (appelé aussi condensat ou haché, message digest) d'un texte, c'est-à-dire une suite de caractères assez courte représentant le texte qu'il condense. La fonction de hachage doit être telle qu'elle associe un et un seul haché à un texte en clair (cela signifie que la moindre modification du document entraîne la modification de son haché). D'autre part, il doit s'agir d'une fonction à sens unique (one-way function) afin qu'il soit impossible de retrouver le message original à partir du condensé. S'il existe un moyen de retrouver le message en clair à partir du haché, la fonction de hachage est dite « à brèche secrète ».

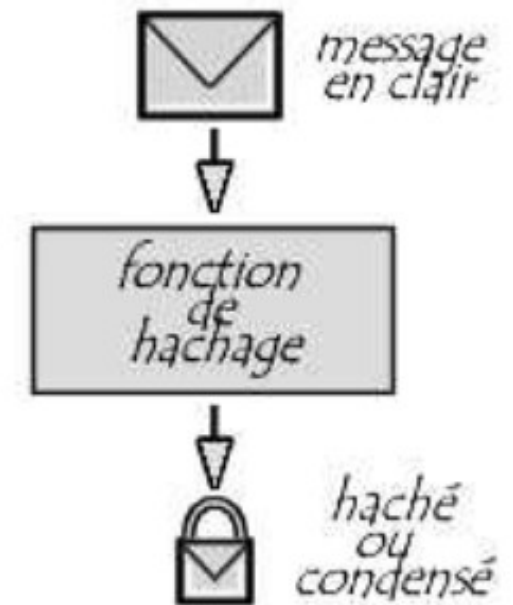
Deuxième partie : Techniques cryptographiques

281 Chapitre 1 V: Signature électronique

Ainsi, le haché représente en quelque sorte l'empreinte digitale (finger print) du document.

Les algorithmes de hachage les plus utilisés actuellement sont :

- MD5 (MD signifiant Message Digest). Développé par Rivest en 1991, MD5 crée une empreinte digitale de 128 bits à partir d'un texte de taille arbitraire en le traitant par blocs de 51 bits. Il est courant de voir des documents en téléchargement sur Internet accompagnés d'un fichier MD5, il s'agit du condensé du document permettant de vérifier l'intégrité de ce dernier) :
- SHA (Secure Hash Algorithm, pouvant être traduit par algorithme de hachage sécurisé) crée des empreintes d'une longueur de 160 bits. SHA-1 est une version améliorée de SHA datant de 1994 et produisant une empreinte de 160 bits à partir d'un message d'une longueur maximale de 264 bits en le traitant par blocs de 512 bits.



Deuxième partie : Techniques cryptographiques

282 Chapitre 1 V: Signature électronique

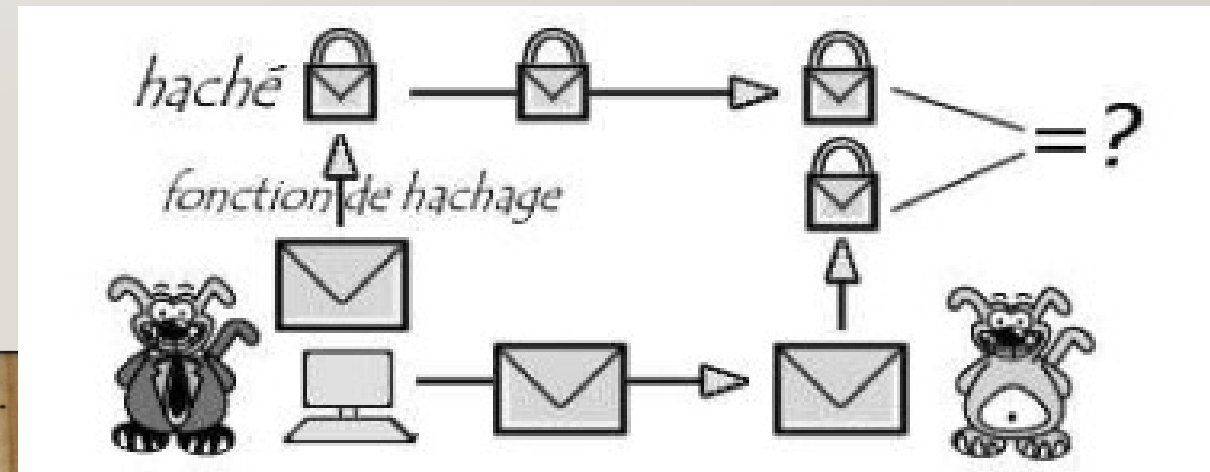
Vérification de l'intégrité d'un message

En expédiant un message accompagné de son haché, il est possible de garantir l'intégrité d'un message, c'est-à-dire que le destinataire peut vérifier que le message n'a pas été altéré (intentionnellement ou de manière fortuite) durant la communication.

Lors de la réception du message, il suffit au destinataire de calculer le haché du message reçu et de le comparer avec le haché accompagnant le document. Si le message (ou le haché) a été falsifié durant la communication, les deux empreintes ne correspondront pas.

Scellement des données

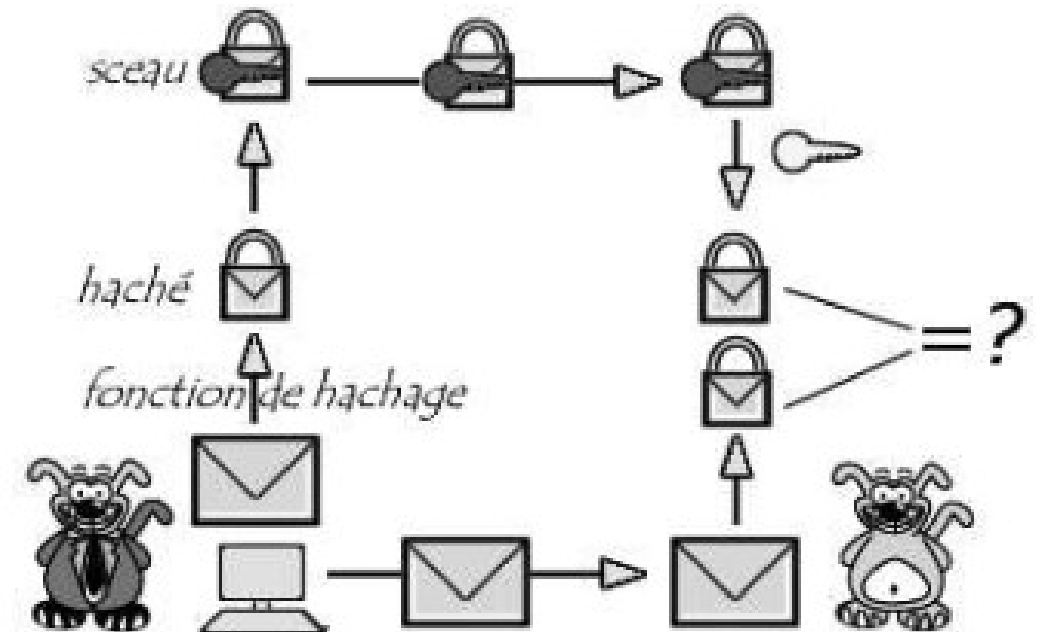
L'utilisation d'une fonction de hachage permet de vérifier que l'empreinte correspond bien au message reçu, mais rien ne prouve que le message a bien été envoyé par celui que l'on croit être l'expéditeur.



Deuxième partie : Techniques cryptographiques

283 Chapitre 1 V: Signature électronique

Ainsi, pour garantir l'authentification du message, il suffit à l'expéditeur de chiffrer (on dit généralement signer) le condensé à l'aide de sa clé privée (le haché signé est appelé sceau) et d'envoyer le sceau au destinataire. À réception du message, il suffit au destinataire de déchiffrer le sceau avec la clé publique de l'expéditeur, puis de comparer le haché obtenu avec la fonction de hachage au haché reçu en pièce jointe. Ce mécanisme de création de sceau est appelé scellement.



Deuxième partie : Techniques cryptographiques

284 Chapitre 1 V: Signature électronique

Certificats

Les algorithmes de chiffrement asymétrique sont basés sur le partage entre les différents utilisateurs d'une clé publique. Généralement le partage de cette clé se fait au travers d'un annuaire électronique (généralement au format LDAP) ou bien d'un site web.

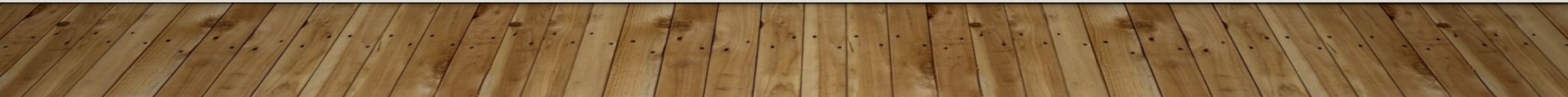
Toutefois ce mode de partage a une grande lacune : rien ne garantit que la clé est bien celle de l'utilisateur à qui elle est associée.

En effet un pirate peut corrompre la clé publique présente dans l'annuaire en la remplaçant par sa clé publique.

Ainsi, le pirate sera en mesure de déchiffrer tous les messages qui auront été chiffrés avec la clé présente dans l'annuaire.

Ainsi un certificat permet d'associer une clé publique à une entité (une personne, une machine...) afin d'en assurer la validité.

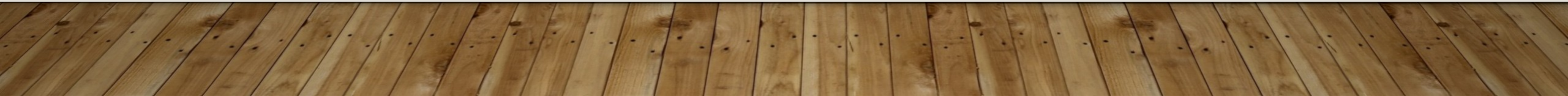
Le certificat est en quelque sorte la carte d'identité de la clé publique, délivré par un organisme appelé autorité de certification (souvent notée CA, Certification Authority).



Deuxième partie : Techniques cryptographiques

285 Chapitre 1 V: Signature électronique

L'autorité de certification est chargée de délivrer les certificats, de leur assigner une date de validité (équivalent à la date limite de péremption des produits alimentaires), ainsi que de révoquer éventuellement des certificats avant cette date en cas de compromission de la clé (ou du propriétaire)



Deuxième partie : Techniques cryptographiques

286 Chapitre 1 V: Signature électronique

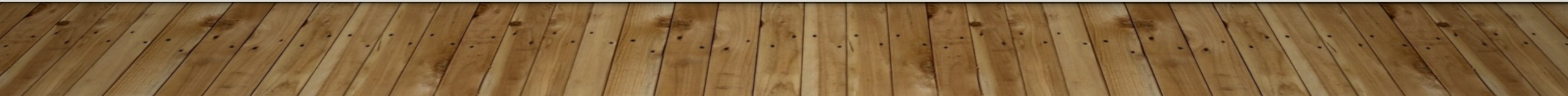
Structure d'un certificat

Les certificats sont des petits fichiers divisés en deux parties :

- La partie contenant les informations.
- La partie contenant la signature de l'autorité de certification.

La structure des certificats est normalisée par le standard X.509 de l'UIT (plus exactement X.509v3), qui définit les informations contenues dans le certificat :

- La version de X.509 à laquelle le certificat correspond.
- Le numéro de série du certificat.
- L'algorithme de chiffrement utilisé pour signer le certificat.



Deuxième partie : Techniques cryptographiques

287 Chapitre 1 V: Signature électronique

- Le nom (DN, Distinguished Name) de l'autorité de certification émettrice.
- La date de début de validité du certificat.
- La date de fin de validité du certificat.
- L'objet de l'utilisation de la clé publique
- La clé publique du propriétaire du certificat
- La signature de l'émetteur du certificat (thumbprint)

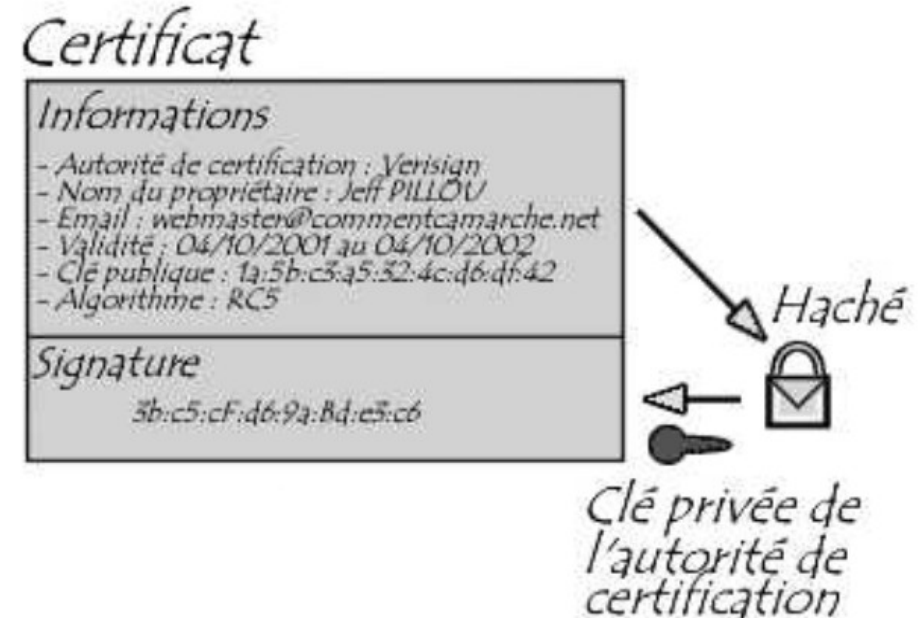
Deuxième partie : Techniques cryptographiques

288 Chapitre 1 V: Signature électronique

L'ensemble de ces informations (informations + clé publique du demandeur) est signé par l'autorité de certification, cela signifie qu'une fonction de hachage crée une empreinte de ces informations, puis ce condensé est chiffré à l'aide de la clé privée de l'autorité de certification ; la clé publique ayant été préalablement largement diffusée afin de permettre aux utilisateurs de vérifier la signature avec la clé publique de l'autorité de certification.

Lorsqu'un utilisateur désire communiquer avec une autre personne, il lui suffit de se procurer le certificat du destinataire.

Ce certificat contient le nom du destinataire, ainsi que sa clé publique et est signé par l'autorité de certification. Il est donc possible de vérifier la validité du message en appliquant d'une part la fonction de hachage aux informations contenues dans le certificat, en déchiffrant d'autre part la signature de l'autorité de certification avec la clé publique de cette dernière et en comparant ces deux résultats.



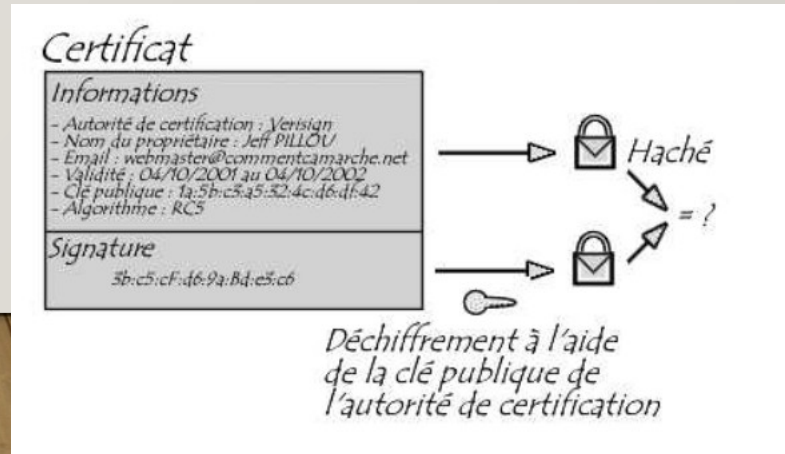
Deuxième partie : Techniques cryptographiques

289 Chapitre 1 V: Signature électronique

Niveau de signature

On distingue différents types de certificats selon le niveau de signature :

- Les certificats autosignés sont des certificats à usage interne. Signés par un serveur local, ce type de certificat permet de garantir la confidentialité des échanges au sein d'une organisation, par exemple pour le besoin d'un intranet. Il est ainsi possible d'effectuer une authentification des utilisateurs grâce à des certificats autosignés.
- Les certificats signés par un organisme de certification sont nécessaires lorsqu'il s'agit d'assurer la sécurité des échanges avec des utilisateurs anonymes, par exemple dans le cas d'un site web sécurisé accessible au grand public. Le certificateur tiers permet d'assurer à l'utilisateur que le certificat appartient bien à l'organisation à laquelle il est déclaré appartenir.



Deuxième partie : Techniques cryptographiques

290 Chapitre 1 V: Signature électronique

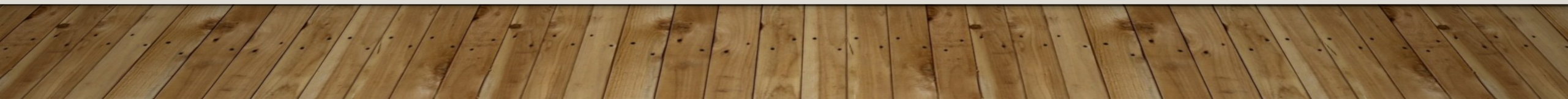
Types d'usages

Les certificats servent principalement dans trois types de contextes :

► **Le certificat client**, stocké sur le poste de travail de l'utilisateur ou embarqué dans un conteneur tel qu'une carte à puce, permet d'identifier un utilisateur et de lui associer des droits. Dans la plupart des scénarios il est transmis au serveur lors d'une connexion, qui affecte des droits en fonction de l'accréditation de l'utilisateur. Il s'agit d'une véritable carte d'identité numérique utilisant une paire de clés asymétriques d'une longueur de 512 à 1 024 bits.

► **Le certificat serveur** installé sur un serveur web permet d'assurer le lien entre le service et le propriétaire du service.

Dans le cas d'un site web, il permet de garantir que l'adresse (URL) et en particulier le domaine de la page web appartiennent bien à telle ou telle entreprise. Par ailleurs il permet de sécuriser les transactions avec les utilisateurs grâce au protocole SSL.



Deuxième partie : Techniques cryptographiques

291 Chapitre 1 V: Signature électronique

► **Le certificat VPN** est un type de certificat installé dans les équipements réseaux, permettant de chiffrer les flux de communication de bout en bout entre deux points (par exemple deux sites d'une entreprise). Dans ce type de scénario, les utilisateurs possèdent un certificat client, les serveurs mettent en œuvre un certificat serveur et les équipements de communication utilisent un certificat particulier (généralement un certificat IPSec).

Deuxième partie : Techniques cryptographiques

292 Chapitre V: Quelques exemples de cryptosystèmes

A-Chiffre de Vigenère

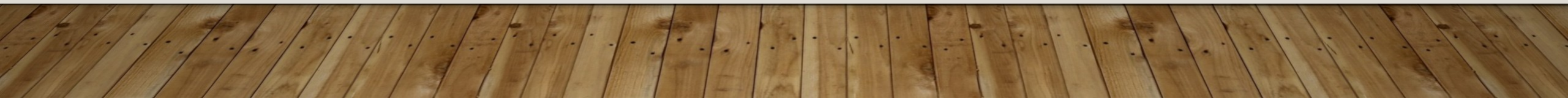
Le chiffre de Vigenère est un cryptosystème symétrique, ce qui signifie qu'il utilise la même clé pour le chiffrement et le déchiffrement.

Le chiffrement de Vigenère ressemble beaucoup au chiffrement de César, à la différence près qu'il utilise une clé plus longue afin de pallier le principal problème du chiffrement de César : le fait qu'une lettre puisse être codée d'une seule façon. Pour cela on utilise un mot-clé au lieu d'un simple caractère.

Il consiste à coder un texte avec un mot en ajoutant à chacune de ses lettres la lettre d'un autre mot appelé clé. La clé est ajoutée indéfiniment en vis-à-vis avec le texte à chiffrer, puis le code ASCII de chacune des lettres de la clé est ajouté au texte à crypter.

Par exemple le texte « rendezvousamidi » avec la clé bonjour sera codé de la manière suivante.

On associe dans un premier temps à chaque lettre un chiffre correspondant



Deuxième partie : Techniques cryptographiques

293 Chapitre V: Quelques exemples de cryptosystèmes

A-Chiffre de Vigenère

Par exemple le texte « rendezvousamidi » avec la clé bonjour sera codé de la manière suivante.

On associe dans un premier temps à chaque lettre un chiffre correspondant

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26

Texte original :

r	e	n	d	e	z	v	o	u	s	a	m	i	d	i
114	101	110	100	101	122	118	111	117	115	97	109	105	100	105

Clé :

b	o	n	j	o	u	r
98	111	110	106	111	117	114

Texte chiffré :

r+b	e+o	n+n	d+j	e+o	z+u	v+r	o+b	u+o	s+n	a+j	m+o	i+u	d+r	i+b
114	101	110	100	101	122	118	111	117	115	97	109	105	100	105
+	+	+	+	+	+	+	+	+	+	+	+	+	+	+
98	111	110	106	111	117	114	98	111	110	106	111	117	114	98

Deuxième partie : Techniques cryptographiques

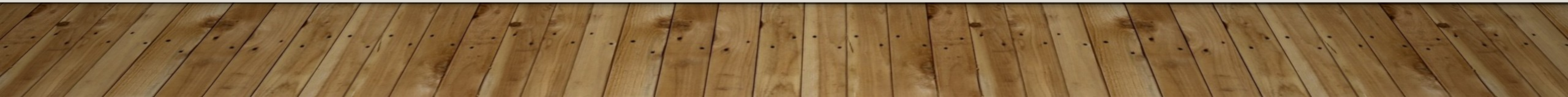
294 Chapitre V: Quelques exemples de cryptosystèmes

A-Chiffre de Vigenère

Pour déchiffrer ce message il suffit de posséder la clé secrète et faire le déchiffrement inverse, à l'aide d'une soustraction.

Bien que ce chiffrement soit beaucoup plus sûr que le chiffrement de César, il peut encore être facilement cassé. En effet, lorsque les messages sont beaucoup plus longs que la clé, il est possible de repérer la longueur de la clé et d'utiliser pour chaque séquence de la longueur de la clé la méthode consistant à calculer la fréquence d'apparition des lettres, permettant de déterminer un à un les caractères de la clé...

Pour éviter ce problème, une solution consiste à utiliser une clé dont la taille est proche de celle du texte afin de rendre impossible une étude statistique du texte crypté. Ce type de système de chiffrement est appelé système à clé jetable. Le problème de ce type de méthode est la longueur de la clé de cryptage (plus le texte à crypter est long, plus la clé doit être volumineuse), qui empêche sa mémorisation et implique une probabilité d'erreur dans la clé beaucoup plus grande (une seule erreur rend le texte indéchiffrable...).



Deuxième partie : Techniques cryptographiques

295 Chapitre V: Quelques exemples de cryptosystèmes

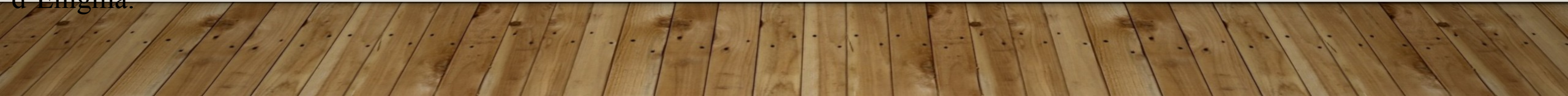
B-Cryptosystème Enigma

□ Histoire d'Enigma

C'est à la fin de la première guerre mondiale qu'est apparue la nécessité de crypter les messages (bien que les techniques de chiffrement existaient déjà depuis fort longtemps). C'est un Hollandais résidant en Allemagne, le Dr Arthur Scherbius qui mit au point à des fins commerciales la machine Enigma, servant à encoder des messages.

Le modèle A de la machine (Chiffriermaschinen Aktien Gesellschaft) fut présenté en 1923 au Congrès Postal International de Berne. Le prix de cette machine à l'époque (équivalent à 30 000 euros aujourd'hui) en fit un échec cuisant. La marine de guerre allemande reprit le projet en 1925 et en confia son évolution au service de chiffrement (Chiffrierstelle) du ministère de la guerre allemand. Le modèle Enigma M3 fut finalement adopté par la Wehrmacht (armée allemande) le 12 janvier 1937.

À la même époque, les services de contre-espionnage français et polonais travaillaient également depuis 1930 sur une méthode de déchiffrement. Si bien que lorsque la seconde guerre mondiale éclata en 1939, les alliés savaient décrypter les messages d'Enigma.



Deuxième partie : Techniques cryptographiques

296 Chapitre V: Quelques exemples de cryptosystèmes

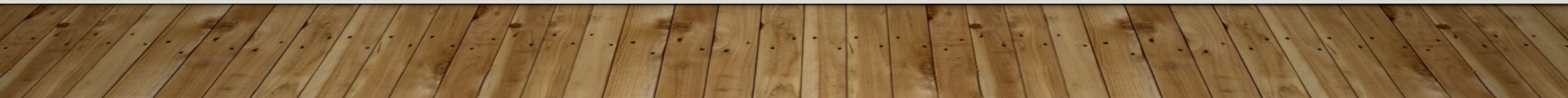
B-Cryptosystème Enigma

La guerre s'est ensuite intensifiée et la cadence de déchiffrement augmenta. Ainsi, entre les mois d'octobre et juin 1939, plus de 4 000 messages chiffrés furent décodés par les services secrets français.

En août 1939, les Anglais installèrent à Bletchley Park (80 km de Londres) les services du Code et du Chiffre, pas moins de 12 000

scientifiques et mathématiciens anglais, polonais et français qui travaillaient à casser le code d'Enigma. Parmi ces mathématiciens, on retrouve l'un des inventeurs de l'informatique moderne : Alan Turing, qui dirigeait tous ces travaux.

Les Anglais réussirent ainsi à déchiffrer ces messages codés. Seulement, la Kriegsmarine (marine de guerre allemande), utilisant des mesures de cryptage différentes, le déchiffrement s'avéra plus difficile. La capture sur le U-110 d'une Enigma et surtout de ses instructions permit une avancée importante. Ceci permettant de connaître les positions de sous-marins et de réduire le tonnage coulé par les U-Boot (cf. le film U-571)



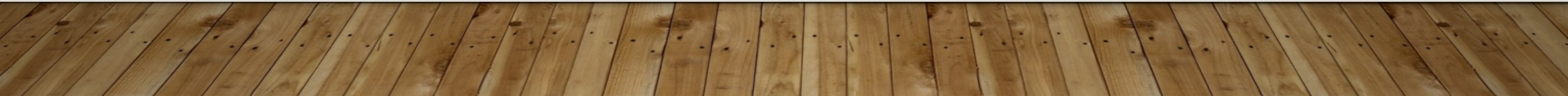
Deuxième partie : Techniques cryptographiques

297 Chapitre V: Quelques exemples de cryptosystèmes

B-Cryptosystème Enigma

Le 1er février 1942, le modèle Enigma M4 fut mis en service. Pendant onze mois, les alliés ne réussirent pas à décrypter ces messages.

Durant toute la guerre, plus de 18 000 messages par jours furent décryptés, et permirent aux forces de l'alliance de connaître les intentions de l'Allemagne. Le dernier message chiffré fut trouvé en Norvège, signé par l'amiral Doenitz : « Le Führer est mort. Le combat continue. » Les Allemands ne se sont jamais doutés que leur précieuse machine pouvait être décryptée.



Deuxième partie : Techniques cryptographiques

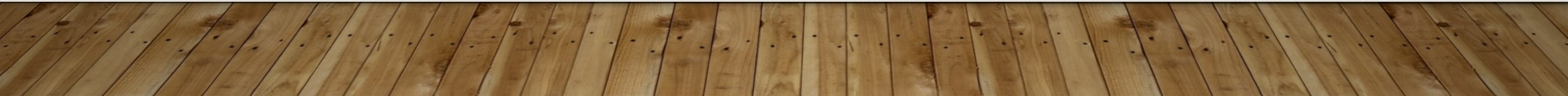
298 Chapitre V: Quelques exemples de cryptosystèmes

B-Cryptosystème Enigma

☐ Principe de fonctionnement

Enigma possédait un fonctionnement particulièrement simple : l'objet était équipé d'un clavier pour la saisie du message, de différentes roues pour le codage, et enfin d'un tableau lumineux pour le résultat.

À chaque pression d'une touche du clavier, une lettre du panneau lumineux s'illuminait. Il y avait ainsi trois roues de codage, appelées brouilleur rotor, qui reliaient le clavier au panneau lumineux.



Deuxième partie : Techniques cryptographiques

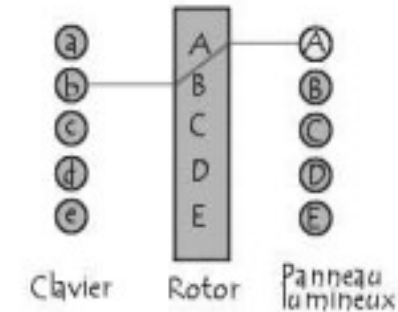
299 Chapitre V: Quelques exemples de cryptosystèmes

B-Cryptosystème Enigma

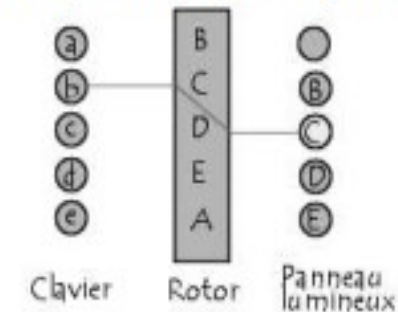
Suivant les modèles (M3 ou M4), le système était muni de trois ou quatre rotors. Les deuxième et troisième rotors avançaient d'un cran quand le premier avait fait un tour complet. Il y avait aussi un tableau de connexion qui mélangeait les lettres de l'alphabet et un réflecteur qui faisait repasser le courant dans les rotors avant l'affichage.

Au final, pour des machines Enigma équipées pour 26 lettres, il y avait 17 576 combinaisons ($26 \times 26 \times 26$) liées à l'orientation de chacun des trois rotors, 6 combinaisons possibles liées à l'ordre dans lequel étaient disposés les rotors, soient 100 391 791 500 branchements possibles quand on relie les six paires de lettres dans le tableau de connexions : 12 lettres choisies parmi 26 ($26!/(12!14!)$), puis 6 lettres parmi 12 ($12!/6!$), et puisque certaines paires sont équivalentes

Par exemple, avec un seul rotor, lorsque l'on appuie sur B le courant passe par le rotor et allume A sur le panneau lumineux :



Pour complexifier la machine, à chaque pression sur une touche, le rotor tourne d'un cran. Après la première pression on obtient donc :



Deuxième partie : Techniques cryptographiques

300 Chapitre V: Quelques exemples de cryptosystèmes

B-Cryptosystème Enigma

Les machines Enigma peuvent donc chiffrer un texte selon 10^{16} ($17\,576 \times 6 \times 100\,391\,791\,500$) combinaisons différentes !

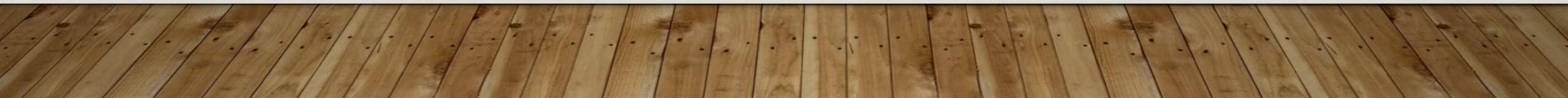
□ Cassage du code d'Enigma

Les Polonais inventèrent « la Bombe » (rebaptisée plus tard « Ultra ») qui permettait de connaître les réglages Enigma. Seulement, à partir de 1938, c'est l'opérateur lui-même qui établissait le réglage. Pour remédier à ce problème, les Polonais trouvèrent la solution : chaque message contenait soit une répétition de mots soit des mots récurrents (appelés « femelles »).

Ceci était un indice quant au noyau (réglage de base des rotors). Pour découvrir ce réglage, les Polonais utilisaient ensuite la « Grille » (cartes perforées correspondant à toutes les permutations du noyau).

Ces cartes étaient empilées les unes sur les autres par rapport à la position des « femelles ».

Ensuite, il s'agissait de chercher le point où une série de perforations se recouvrait du haut en bas de la pile.



Deuxième partie : Techniques cryptographiques

301 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

Le 15 mai 1973 le NBS (National Bureau of Standards, aujourd'hui appelé NIST, National Institute of Standards and Technology) a lancé un appel dans le Federal Register (l'équivalent aux États-Unis du Journal Officiel en France) pour la création d'un algorithme de chiffrement répondant aux critères suivants :

- posséder un haut niveau de sécurité lié à une clé de petite taille servant au chiffrement et au déchiffrement ;
- être compréhensible ;
- ne pas dépendre de la confidentialité de l'algorithme ;
- être adaptable et économique ;
- être efficace et exportable.

Fin 1974, IBM propose « Lucifer », qui, grâce à la NSA (National Security Agency), est modifié le 23 novembre 1976 pour donner le DES (Data Encryption Standard). Le DES a finalement été approuvé en 1978 par le NBS. Le DES fut normalisé par l'ANSI (American National Standard Institute) sous le nom de ANSI X3.92, plus connu sous la dénomination DEA (Data Encryption Algorithm).

Deuxième partie : Techniques cryptographiques

302 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

□ Principe du DES

Il s'agit d'un système de chiffrement symétrique par blocs de 64 bits, dont 8 bits (un octet) servent de test de parité (pour vérifier l'intégrité de la clé).

Chaque bit de parité de la clé (1 tous les 8 bits) sert à tester un des octets de la clé par parité impaire, c'est-à-dire que chacun des bits de parité est ajusté de façon à avoir un nombre impair de « 1 » dans l'octet à qui il appartient.

La clé possède donc une longueur « utile » de 56 bits, ce qui signifie que seuls 56 bits servent réellement dans l'algorithme.

L'algorithme consiste à effectuer des combinaisons, des substitutions et des permutations entre le texte à chiffrer et la clé, en faisant en sorte que les opérations puissent se faire dans les deux sens (pour le déchiffrement).

La combinaison entre substitutions et permutations est appelée code produit.

La clé est codée sur 64 bits et formée de 16 blocs de 4 bits, généralement notés k_1 à k_{16} . Étant donné que « seuls » 56 bits servent effectivement à chiffrer, il peut exister 2^{56} (soit $7,2 \times 10^{16}$) clés différentes !

Deuxième partie : Techniques cryptographiques

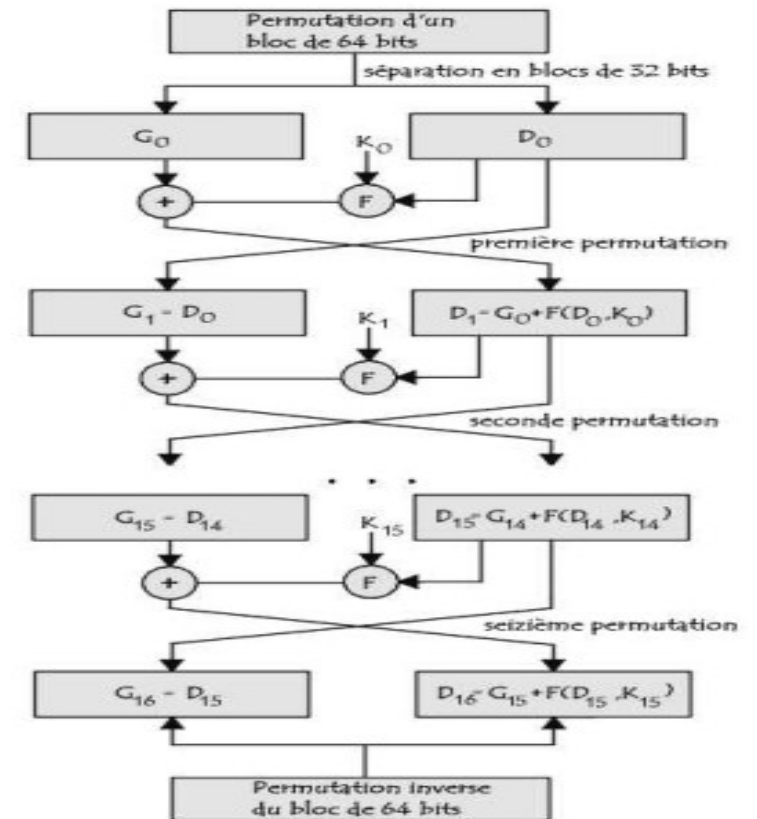
303 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

□ Algorithme du DES

Les grandes lignes de l'algorithme sont les suivantes :

- Fractionnement du texte en blocs de 64 bits (8 octets).
- Permutation initiale des blocs.
- Découpage des blocs en deux parties : gauche et droite, nommées G et D.
- Étapes de permutation et de substitution répétées 16 fois (appelées rondes).
- Recollement des parties gauche et droite puis permutation initiale inverse.



Deuxième partie : Techniques cryptographiques

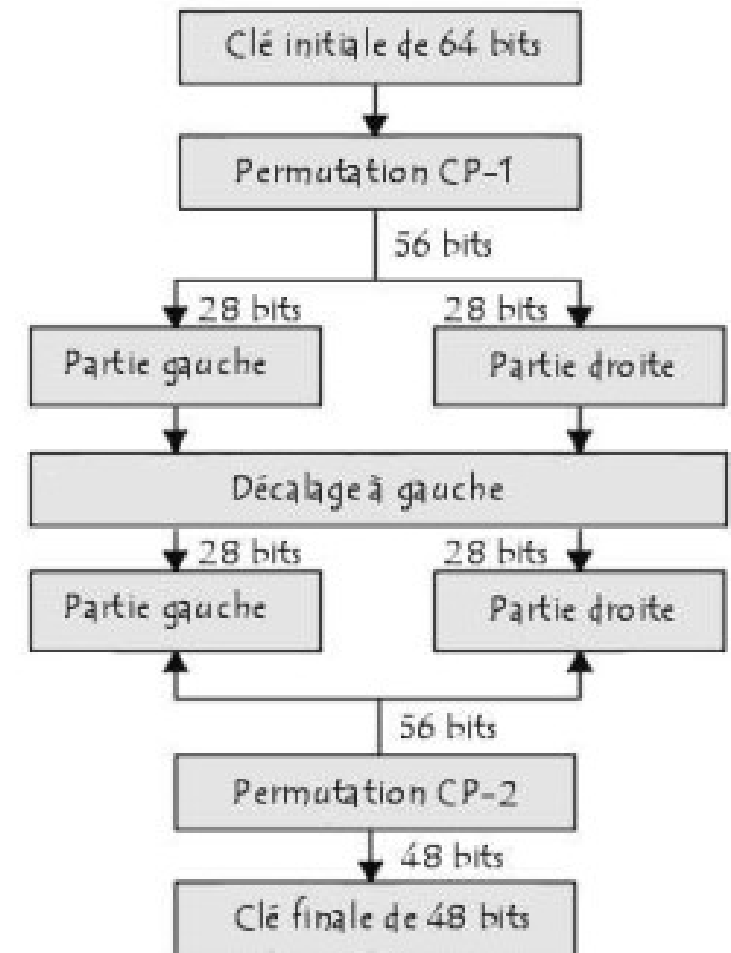
304 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

□ Génération de clés

Étant donné que l'algorithme du DES présenté ci-dessus est public, toute la sécurité repose sur la complexité des clés de chiffrement.

L'algorithme ci-dessous montre comment obtenir à partir d'une clé de 64 bits (composé de 64 caractères alphanumériques quelconques) 8 clés diversifiées de 48 bits chacune servant dans l'algorithme du DES :



Deuxième partie : Techniques cryptographiques

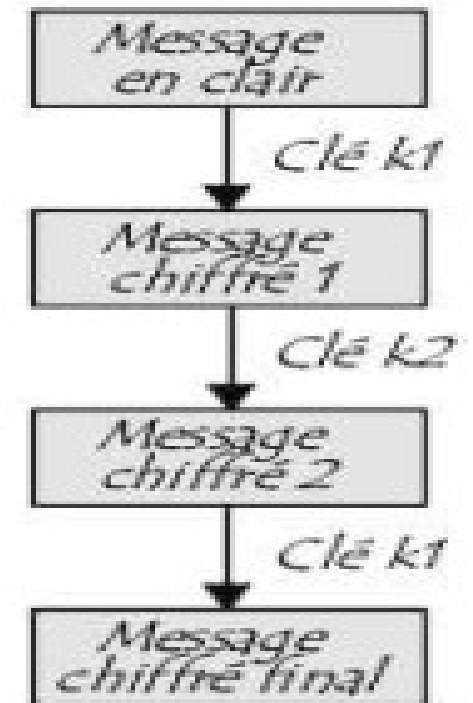
305 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

□ Triple DES

Une clé d'une longueur de 56 bits donne un nombre énorme de possibilités. Néanmoins, de nos jours, de nombreux processeurs permettent de calculer plus de 10^6 clés par seconde, ainsi, utilisés parallèlement sur un très grand nombre de machines, il devient possible pour un grand organisme (un État par exemple) de trouver la bonne clé.

Une solution à court terme consiste à chaîner trois chiffrements DES à l'aide de deux clés de 56 bits (ce qui équivaut à une clé de 112 bits). Ce procédé est appelé triple DES, noté TDES (parfois 3DES ou 3-DES).



Deuxième partie : Techniques cryptographiques

306 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème DES

Le TDES permet d'augmenter significativement la sécurité du DES, toutefois il a l'inconvénient majeur de demander également plus de ressources pour les chiffrements et les déchiffrements.

On distingue habituellement plusieurs types de chiffrement triple DES :

- DES-EEE3 : trois chiffrements DES avec trois clés différentes ;
- DES-EDE3 : une clé différente pour chacune des trois opérations DES (chiffrement, déchiffrement, chiffrement) ;
- DES-EEE2 et DES-EDE2 : une clé différente pour la seconde opération (déchiffrement).

En 1997 le NIST lança un nouvel appel à projet pour élaborer l'AES (Advanced Encryption Standard), un algorithme de chiffrement destiné à remplacer le DES. Le système de chiffrement DES fut réactualisé tous les 5 ans. En 2000 lors de la dernière révision, après un processus d'évaluation qui a duré trois années, l'algorithme conçu conjointement par deux candidats belges, Vincent Rijmen et Joan Daemen fut choisi comme nouveau standard par le NIST. Ce nouvel algorithme baptisé Rijndael par ses inventeurs, remplacera dorénavant le DES.

Deuxième partie : Techniques cryptographiques

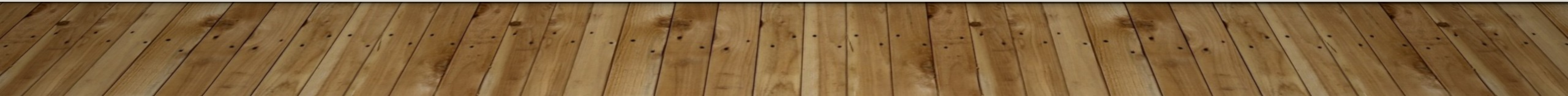
307 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème RSA

Le premier algorithme de chiffrement à clé publique (chiffrement asymétrique) a été développé par R. Merckle et M. Hellman en 1977.

Il fut vite rendu obsolète grâce aux travaux de Shamir, Zippel et Herlestman, de célèbres cryptanalistes.

En 1978, l'algorithme à clé publique de Rivest, Shamir, et Adelman (d'où son nom RSA) apparaît. Cet algorithme servait encore en 2002 à protéger les codes nucléaires des armées américaine et russe.



Deuxième partie : Techniques cryptographiques

308 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème RSA

□ Fonctionnement de RSA

Le fonctionnement du cryptosystème RSA est basé sur la difficulté de factoriser de grands entiers.

Soit deux nombres premiers p et q , et d un entier tel que d soit premier avec $(p - 1) * (q - 1)$. Le triplet (p, q, d) constitue ainsi la clé privée.

La clé publique est alors le doublet (n, e) créé à l'aide de la clé privée par les transformations suivantes :

$$n = p * q$$

$$e = 1/d \bmod ((p - 1)(q - 1))$$

Soit M , le message à envoyer. Il faut que le message M soit premier avec la clé n . En effet, le déchiffrement repose sur le théorème d'Euler stipulant que si M et n sont premiers entre eux, alors :

$$M^{\phi(n)} = 1 \bmod(n)$$

$\phi(n)$ étant l'indicateur d'Euler, et valant dans le cas présent $(p - 1) * (q - 1)$.

Deuxième partie : Techniques cryptographiques

309 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème RSA

Il est donc nécessaire que M ne soit pas un multiple de p , de q , ou de n . Une solution consiste à découper le message M en morceaux M_i tels que le nombre de chiffres de chaque M_i soit strictement inférieur à celui de p et de q . Cela suppose donc que p et q soient grands, ce qui est le cas en pratique puisque tout le principe de RSA réside dans la difficulté à trouver dans un temps raisonnable p et q connaissant n , ce qui suppose p et q grands.

Supposons qu'un utilisateur (nommé Bob) désire envoyer un message M à une personne (nommons-la Alice), il lui suffit de se procurer la clé publique (n, e) de cette dernière puis de calculer le message chiffré c :

$$c = M^e \bmod(n)$$

Bob envoie ensuite le message chiffré c à Alice, qui est capable de le déchiffrer à l'aide de sa clé privée (p, q, d) :

$$M = M^{e \cdot d} \bmod(n) = c^d \bmod(n)$$

Deuxième partie : Techniques cryptographiques

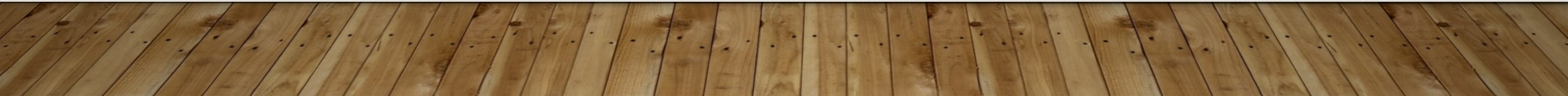
310 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

PGP (Pretty Good Privacy) est un cryptosystème (système de chiffrement) inventé par Philip Zimmermann, un analyste informaticien.

Philip Zimmermann a travaillé de 1984 à 1991 sur un programme permettant de faire fonctionner RSA sur des ordinateurs personnels.

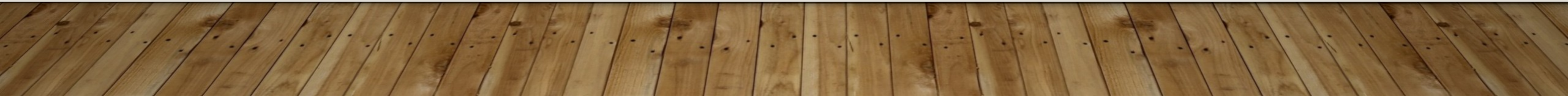
Cependant, étant donné que son système utilisait RSA sans l'accord de ses auteurs, cela lui a valu des procès pendant 3 ans. Il est donc vendu environ 150 \$ depuis 1993. Il est très rapide et sûr ce qui le rend quasiment impossible à cryptanalyser.



Deuxième partie : Techniques cryptographiques

311 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP



Deuxième partie : Techniques cryptographiques

312 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

□ Principe

PGP est un système de **cryptographie hybride**, utilisant une combinaison des fonctionnalités de la cryptographie à clé publique et de la cryptographie symétrique.

Lorsqu'un utilisateur chiffre un texte avec PGP, les données sont d'abord compressées. Cette compression des données permet de réduire le temps de transmission par tout moyen de communication, d'économiser l'espace disque et, surtout, de renforcer la sécurité cryptographique.

La plupart des cryptanalystes exploitent les modèles trouvés dans le texte en clair pour casser le chiffrement. La compression réduit ces modèles dans le texte en clair, améliorant par conséquent considérablement la résistance à la cryptanalyse.

Ensuite, l'opération de chiffrement se fait principalement en deux étapes :

- PGP crée une clé secrète IDEA de manière aléatoire, et chiffre les données avec cette clé.
- PGP crypte la clé secrète IDEA et la transmet au moyen de la clé RSA publique du destinataire.

Deuxième partie : Techniques cryptographiques

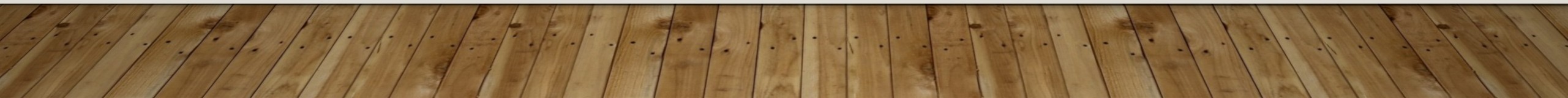
313 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

L'opération de décryptage se fait également en deux étapes :

- PGP déchiffre la clé secrète IDEA au moyen de la clé RSA privée.
- PGP déchiffre les données avec la clé secrète IDEA précédemment obtenue.

Cette méthode de chiffrement associe la facilité d'utilisation du cryptage de clé publique à la vitesse du cryptage conventionnel. Le chiffrement conventionnel est environ 1 000 fois plus rapide que les algorithmes de chiffrement à clé publique. Le chiffrement à clé publique résout le problème de la distribution des clés. Utilisées conjointement, ces deux méthodes améliorent la performance et la gestion des clés, sans pour autant compromettre la sécurité.



Deuxième partie : Techniques cryptographiques

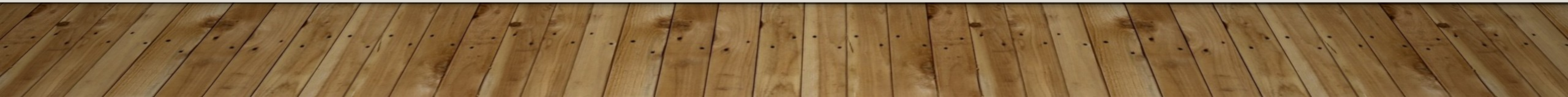
314 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

□ Fonctionnalités de PGP

PGP offre les fonctionnalités suivantes :

- Signature électronique et vérification d'intégrité de messages : fonction basée sur l'emploi simultané d'une fonction de hachage (MD5) et du système RSA. MD5 hache le message et fournit un résultat de 128 bits qui est ensuite chiffré, grâce à RSA, par la clé privée de l'expéditeur.
- Chiffrement des fichiers locaux : fonction utilisant IDEA.
- Génération de clés publiques et privées : chaque utilisateur chiffre ses messages à l'aide de clés privées IDEA. Le transfert de clés électroniques IDEA utilise le système RSA ; PGP offre donc des mécanismes de génération de clés adaptés à ce système. La taille des clés RSA est proposée suivant plusieurs niveaux de sécurité : 512, 768, 1 024 ou 1 280 bits.

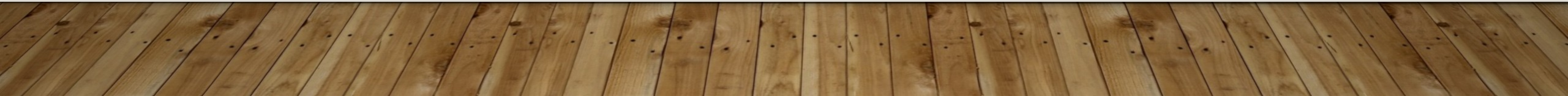


Deuxième partie : Techniques cryptographiques

315 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

- Gestion des clés : fonction assurant la distribution de la clé publique de l'utilisateur aux correspondants qui souhaiteraient lui envoyer des messages chiffrés.
- Certification de clés : cette fonction permet d'ajouter un sceau numérique garantissant l'authenticité des clés publiques. Il s'agit d'une originalité de PGP, qui base sa confiance sur une notion de proximité sociale plutôt que sur celle d'autorité centrale de certification.
- Révocation, désactivation, enregistrement de clés : fonction qui permet de produire des certificats de révocation.



Deuxième partie : Techniques cryptographiques

316 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

□ Format des certificats PGP

Un certificat PGP comprend entre autres les informations suivantes :

- Le numéro de version de PGP : identifie la version de PGP utilisée pour créer la clé associée au certificat.
- La clé publique du détenteur du certificat : partie publique de votre paire de clés associée à l'algorithme de la clé, qu'il soit RSA, DH (Diffie-Hellman) ou DSA (algorithme de signature numérique).
- Les informations du détenteur du certificat : il s'agit des informations portant sur l'« identité » de l'utilisateur, telles que son nom, son ID utilisateur, sa photographie, etc.
- La signature numérique du détenteur du certificat : également appelée autosignature, il s'agit de la signature effectuée avec la clé privée correspondant à la clé publique associée au certificat.
- La période de validité du certificat : dates/heures de début et d'expiration du certificat. Indique la date d'expiration du certificat.

Deuxième partie : Techniques cryptographiques

317 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

► L'algorithme de chiffrement symétrique préféré pour la clé : indique l'algorithme de chiffrement que le détenteur du certificat préfère appliquer au cryptage des informations. Les algorithmes pris en charge sont CAST, IDEA ou DES triple.

Le fait qu'un seul certificat puisse contenir plusieurs signatures est l'un des aspects uniques du format du certificat PGP. Plusieurs personnes peuvent signer la paire de clés/d'identification pour attester en toute certitude de l'appartenance de la clé publique au détenteur spécifié. Certains certificats PGP sont composés d'une clé publique avec plusieurs libellés, chacun offrant un mode d'identification du détenteur de la clé différent (par exemple, le nom et le compte de messagerie d'entreprise du détenteur, l'alias et le compte de messagerie personnel du détenteur, sa photographie, et ce, dans un seul certificat).

Dans un certificat, une personne doit affirmer qu'une clé publique et le nom du détenteur de la clé sont associés. Quiconque peut valider les certificats PGP. Les certificats X.509 doivent toujours être validés par une autorité de certification ou une personne désignée par la CA. Les certificats PGP prennent également en charge une structure hiérarchique à l'aide d'une CA pour la validation des certificats.

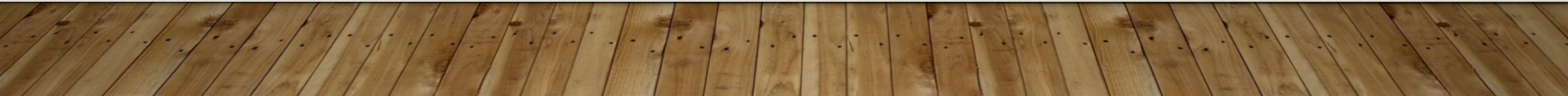
Deuxième partie : Techniques cryptographiques

318 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

Plusieurs différences existent entre un certificat X.509 et un certificat PGP. Les plus importantes sont indiquées ci-dessous :

- Les certificats X.509 prennent en charge un seul nom pour le détenteur de la clé.
- Les certificats X.509 prennent en charge une seule signature numérique pour attester de la validité de la clé.
- La création d'un certificat PGP doit faire l'objet d'une obtention préalable d'un certificat X.509 auprès d'une autorité de certification.



Deuxième partie : Techniques cryptographiques

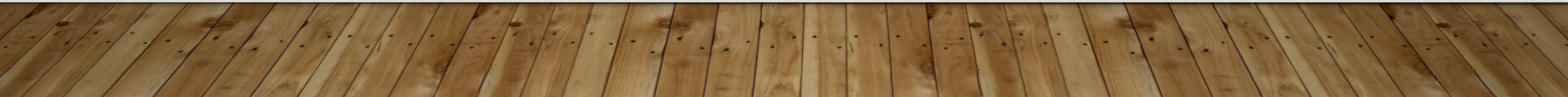
319 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

☐ Modèles de fiabilité

En règle générale, la CA (Certification Authority, autorité de certification) inspire une confiance totale pour établir la validité des certificats et effectuer tout le processus de validation manuelle. Mais, il est difficile d'établir une ligne de confiance avec les personnes n'ayant pas été explicitement considérées comme fiables par votre CA.

Dans un environnement PGP, tout utilisateur peut agir en tant qu'autorité de certification. Il peut donc valider le certificat de clé publique d'un autre utilisateur PGP. Cependant, un tel certificat peut être considéré comme valide par un autre utilisateur uniquement si un tiers reconnaît celui qui a validé ce certificat comme un correspondant fiable. C'est-à-dire, si l'on respecte par exemple mon opinion selon laquelle les clés des autres sont correctes uniquement si je suis considéré comme un correspondant fiable. Dans le cas contraire, mon opinion sur la validité d'autres clés est controversée.

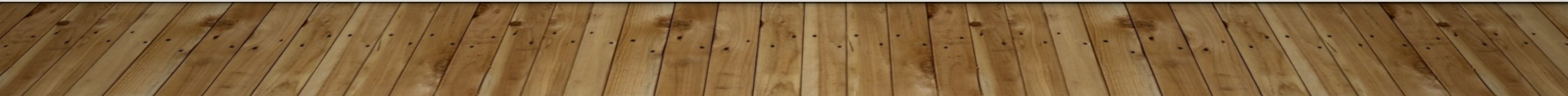


Deuxième partie : Techniques cryptographiques

320 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

Supposons, par exemple, que votre trousseau de clés contient la clé d'Alice. Vous l'avez validée et, pour l'indiquer, vous la signez. En outre, vous savez qu'Alice est très pointilleuse en ce qui concerne la validation des clés d'autres utilisateurs. Par conséquent, vous affectez une fiabilité complète à sa clé. Alice devient ainsi une autorité de certification. Si elle signe la clé d'un autre utilisateur, cette clé apparaît comme valide sur votre trousseau de clés



Deuxième partie : Techniques cryptographiques

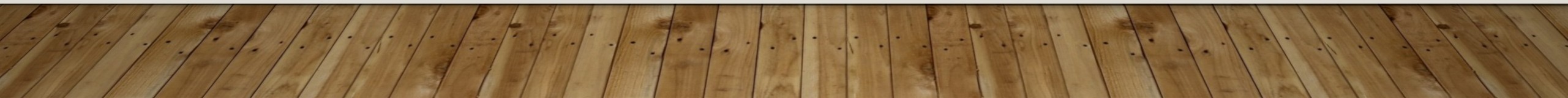
321 Chapitre V: Quelques exemples de cryptosystèmes

C-Cryptosystème PGP

☐ Révocation d'un certificat PGP

Seul le détenteur du certificat (le détenteur de sa clé privée correspondante) ou un autre utilisateur, désigné comme autorité de révocation par le détenteur du certificat, a la possibilité de révoquer un certificat PGP. La désignation d'une autorité de révocation est utile, car la révocation, par un utilisateur PGP, de son certificat est souvent due à la perte du mot de passe complexe de la clé privée correspondante. Or, cette procédure peut uniquement être effectuée s'il est possible d'accéder à la clé privée. Un certificat X.509 peut uniquement être révoqué par son émetteur.

Lorsqu'un certificat est révoqué, il est important d'en avertir ses utilisateurs potentiels. Pour informer de la révocation des certificats PGP, la méthode habituelle consiste à placer cette information sur un serveur de certificats. Ainsi, les utilisateurs souhaitant communiquer avec vous sont avertis de ne pas utiliser cette clé publique.



322 TD + TP

Fiche des exercices

TP 1: Audit d'un AD

TP2: Durcissement d'un AD

TP 3: Mise en place des mesures de sécurité sur les switch et routeurs